

# **A Trusted Authorisation Framework for Multi-Party Patient Consent in Healthcare Data Sharing**

Principal Supervisor: Professor Farookh Hussain

Co-Supervisor: Dr. Firas Al-Doghman

Presenter: Yasir Dhaifallah O Alyoubi

Student ID: 24724078

August 2026

## Abstract

Healthcare data sharing increasingly requires authorisation decisions in which the patient, a guardian set  $G$ , the authorised doctor  $D$  and institutional authorities participate without belonging to a single administrative domain. Existing blockchain-based consent systems establish the conditions of such a decision individually, and several combine three or four of them. However, no reviewed system evaluates, in every access decision, the identity and authority of the participants, the required collective approval, the requested purpose and data scope, and the temporal validity of the consent together, and none assures that conjunction formally.

This research proposes HALAH, a trust-oriented authorisation framework in which patient consent is represented as an evaluable consent object  $C = (I, A, P, T, L, E)$  rather than as a static permission record. Six research objectives are addressed. RO1 is a trust-centric consent model, and RO2 is decentralised identity and authority trust using decentralised identifiers and verifiable credentials. RO3 is trustworthy multi-party authorisation through a threshold  $N$  over the guardian set  $G$ , and RO4 is policy- and context-aware access control. RO5 is temporal and lifecycle trust with expiry and revocation, and RO6 is formal security assurance with empirical validation. A systematic literature review of 25 primary studies, structured by six requirements, shows that no reviewed study satisfies all six requirements together and that the strongest multi-party and policy mechanisms provide no formal assurance of the authorisation decision. The framework is realised through a Model-View-Controller architecture, six procedures with their algorithms, and a prototype deployed on the Ethereum Sepolia testnet. In the prototype, consent activation and revocation are anchored as verifiable transactions. Every access decision is the conjunction of the five trust predicates  $V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ . The current stage delivers RO1 to RO5 in operational form together with the empirical component of RO6, evidenced by 23 automated tests, a live jurisdiction-based denial, an on-chain revocation followed by refusal and an independent verification of every recorded transaction. The formal component of RO6, together with consent modification, delegation and a performance study, constitutes the next stage of the research.



# Contents

|                                                                               |    |
|-------------------------------------------------------------------------------|----|
| <b>1 Introduction</b>                                                         | 7  |
| 1.1 Research Context                                                          | 7  |
| 1.2 Problem Statement                                                         | 8  |
| 1.3 Research Motivation                                                       | 10 |
| <b>2 Systematic Literature Review</b>                                         | 14 |
| 2.1 Overview                                                                  | 14 |
| 2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation        | 15 |
| 2.2.1 Representation of consent as an evaluable authorisation object (Req: 1) | 15 |
| 2.2.2 Decentralised verification of identity and authority (Req: 2)           | 15 |
| 2.2.3 Multi-party authorisation through a verifiable threshold (Req: 3)       | 15 |
| 2.2.4 Policy- and context-aware enforcement at the time of access (Req: 4)    | 16 |
| 2.2.5 Temporal validity and lifecycle control of consent (Req: 5)             | 16 |
| 2.2.6 Verifiable auditability and security assurance (Req: 6)                 | 16 |
| 2.3 Systematic Literature Review Methodology                                  | 17 |
| 2.3.1 Review Design and Reporting Framework                                   | 17 |
| 2.3.2 Questions for Review                                                    | 18 |
| 2.3.3 Search Databases and Search Strategy                                    | 19 |
| 2.3.4 Search Period and Search Execution                                      | 21 |
| 2.3.5 Eligibility Criteria                                                    | 22 |
| 2.3.6 Screening and Study Selection                                           | 23 |
| 2.3.7 Data Extraction, Quality Assessment and Synthesis                       | 27 |
| 2.3.8 Shortlisted Studies and Their Categorisation                            | 30 |
| 2.4 Review                                                                    | 32 |
| 2.4.1 Consent Representation and Blockchain-Based Consent Governance          | 34 |
| 2.4.2 Decentralised Identity and Authority Trust                              | 36 |
| 2.4.3 Multi-Party Authorisation and Collaborative Consent                     | 39 |
| 2.4.4 Policy- and Context-Aware Access Control                                | 45 |
| 2.4.5 Temporal Validity and Consent Lifecycle                                 | 49 |
| 2.4.6 Formal Security Assurance and Empirical Validation                      | 52 |
| 2.4.7 Comparative Analysis of Existing Approaches                             | 56 |
| 2.5 Synthesis and Research Gap                                                | 60 |
| 2.5.1 Research Gaps in the Existing Studies from the Requirement Perspective  | 63 |
| 2.6 Conclusion                                                                | 66 |
| <b>3 Research Gaps and Questions</b>                                          | 69 |
| 3.1 Research Gap                                                              | 69 |
| 3.2 Main Research Question                                                    | 71 |
| 3.3 Sub-Research Questions                                                    | 72 |
| 3.3.1 SRQ1: Trust-Centric Consent Modelling                                   | 72 |
| 3.3.2 SRQ2: Decentralised Identity and Authority Trust                        | 73 |
| 3.3.3 SRQ3: Trustworthy Multi-Party Authorisation                             | 73 |
| 3.3.4 SRQ4: Policy- and Context-Aware Access Control                          | 74 |
| 3.3.5 SRQ5: Temporal and Lifecycle Trust                                      | 75 |
| 3.3.6 SRQ6: Formal Security Assurance and Empirical Validation                | 76 |
| 3.4 Research Questions as an Integrated Research Problem                      | 78 |
| <b>4 Research Objectives</b>                                                  | 80 |

|                                                                         |            |
|-------------------------------------------------------------------------|------------|
| 4.1 RO1 - Trust-Centric Consent Model.....                              | 80         |
| 4.2 RO2 - Decentralised Identity and Authority Trust.....               | 80         |
| 4.3 RO3 - Trustworthy Multi-Party Authorisation.....                    | 80         |
| 4.4 RO4 - Policy- and Context-Aware Access Control.....                 | 81         |
| 4.5 RO5 - Temporal and Lifecycle Trust.....                             | 81         |
| 4.6 RO6 - Formal Security Assurance and Empirical Validation.....       | 82         |
| 4.7 Relationship Between Research Questions and Objectives.....         | 82         |
| <b>5 Research Architecture: MVC.....</b>                                | <b>86</b>  |
| 5.1 MVC Layered Architecture and Component Decomposition.....           | 86         |
| 5.1.1 MVC Component Decomposition.....                                  | 89         |
| 5.1.2 Trust Evaluation Across the MVC Layers.....                       | 90         |
| 5.1.3 Relationship Between MVC Layers and Research Questions.....       | 91         |
| 5.1.4 Architectural Boundary and Trust Assumptions.....                 | 92         |
| 5.2 Trust-Oriented Consent Authorisation Workflow.....                  | 93         |
| 5.3 Model: Trust-Aware Consent and Authorisation Representation.....    | 96         |
| 5.4 View: Controlled Interaction Among Independent Participants.....    | 98         |
| 5.5 Controller: Trusted Multi-Party Authorisation Enforcement.....      | 98         |
| 5.6 Multi-Party Consent as Distributed Trust Establishment.....         | 99         |
| 5.7 Policy-Aware Consent Enforcement.....                               | 100        |
| 5.8 Authorisation Evidence and Auditability.....                        | 101        |
| 5.9 Architectural Security Properties.....                              | 102        |
| 5.10 MVC Architecture and the Research Objectives.....                  | 102        |
| 5.11 Architectural Contribution and Scope.....                          | 103        |
| <b>6 Proposed Solution.....</b>                                         | <b>106</b> |
| 6.1 Trust-Centric Consent Model for RO1.....                            | 106        |
| 6.1.1 RO1 Consent Creation Workflow.....                                | 106        |
| 6.1.2 Procedure for Trust-Aware Consent Creation.....                   | 108        |
| 6.1.3 Algorithm 1: Trust-Aware Consent Creation.....                    | 111        |
| 6.2 Decentralised Identity and Authority Trust for RO2.....             | 111        |
| 6.2.1 RO2 Identity and Authority Verification Workflow.....             | 112        |
| 6.2.2 Procedure for DID and VC Identity and Authority Verification..... | 112        |
| 6.2.3 Algorithm 2: DID and VC Identity and Authority Verification.....  | 115        |
| 6.3 Trustworthy Multi-Party Authorisation for RO3.....                  | 116        |
| 6.3.1 RO3 Multi-Party Authorisation Workflow.....                       | 116        |
| 6.3.2 Procedure for Threshold-Based Multi-Party Authorisation.....      | 117        |
| 6.3.3 Algorithm 3: Threshold-Based Multi-Party Authorisation.....       | 120        |
| 6.4 Policy- and Context-Aware Access Control for RO4.....               | 121        |
| 6.4.1 RO4 Policy-Aware Access Workflow.....                             | 122        |
| 6.4.2 Algorithm 4: Policy-Aware Access Decision.....                    | 123        |
| 6.4.3 Procedure for Policy-Aware Access Decision.....                   | 124        |
| 6.5 Temporal and Lifecycle Trust for RO5.....                           | 128        |
| 6.5.1 RO5 Temporal and Lifecycle Workflow.....                          | 129        |
| 6.5.2 Procedure for Temporal and Lifecycle Validation.....              | 129        |
| 6.5.3 Algorithm 5: Temporal and Lifecycle Validation.....               | 131        |
| 6.6 Formal Security Assurance and Empirical Validation for RO6.....     | 133        |
| 6.6.1 RO6 Assurance and Validation Workflow.....                        | 134        |

|                                                                                  |            |
|----------------------------------------------------------------------------------|------------|
| 6.6.2 Procedure for Formal and Empirical Authorisation Validation.....           | 135        |
| 6.6.3 Algorithm 6: Formal and Empirical Authorisation Validation.....            | 139        |
| 6.7 Algorithms and the Research Objectives.....                                  | 140        |
| 6.8 Implementation and Live Demonstration of the Proposed Solution.....          | 142        |
| 6.8.1 The HALAH System.....                                                      | 142        |
| 6.8.2 Create Smart Consent Contract: Patient Subsystem.....                      | 146        |
| 6.8.3 Guardian Cryptographic Approval.....                                       | 148        |
| 6.8.4 Secure Patient Data Access for the Doctor.....                             | 151        |
| 6.8.5 Negative Demonstration: Jurisdiction Violation.....                        | 156        |
| 6.8.6 Consent Revocation.....                                                    | 157        |
| 6.8.7 Blockchain Audit and Consent Lifecycle for the Auditor.....                | 161        |
| 6.8.8 Detailed Audit Records.....                                                | 163        |
| 6.8.9 Complete Audit Ledger and Independent Verification.....                    | 163        |
| 6.8.10 Correspondence Between the Subsystems and the Framework.....              | 165        |
| 6.8.11 Overall System Demonstration.....                                         | 166        |
| 6.8.12 Verification Links.....                                                   | 167        |
| <b>7 Current Progress Status.....</b>                                            | <b>168</b> |
| 7.1 Progress of RO1: Trust-Centric Consent Model.....                            | 168        |
| 7.2 Progress of RO2: Decentralised Identity and Authority Trust.....             | 168        |
| 7.3 Progress of RO3: Trustworthy Multi-Party Authorisation.....                  | 169        |
| 7.4 Progress of RO4: Policy- and Context-Aware Access Control.....               | 169        |
| 7.5 Progress of RO5: Temporal and Lifecycle Trust.....                           | 170        |
| 7.6 Progress of RO6: Formal Security Assurance and Empirical Validation<br>..... | 171        |
| <b>8 Publications Summary.....</b>                                               | <b>173</b> |
| <b>9 Research Plan.....</b>                                                      | <b>174</b> |
| 9.1 Current Stage: Completed and Current Work.....                               | 174        |
| 9.2 Next Stage: Planned Work.....                                                | 174        |
| <b>Appendix A — Traceability to the Implemented System.....</b>                  | <b>178</b> |
| <b>References.....</b>                                                           | <b>179</b> |

# 1 Introduction

## 1.1 Research Context

The rapid digitalisation of contemporary society has created an increasing demand for secure, interoperable, and trustworthy data sharing across organisational and institutional boundaries. Modern digital ecosystems frequently involve multiple independent stakeholders, including individuals, healthcare providers, service organisations, regulatory authorities, researchers, and third-party data processors, who may need to exchange information while maintaining privacy, accountability, and control over how that information is used [6, 19, 26]. Although digital transformation creates significant opportunities for collaboration and service innovation, it also introduces a fundamental governance challenge: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain?

Healthcare represents a particularly important and challenging example of this broader problem. The increasing digitisation and decentralisation of healthcare information enables patients, healthcare professionals, guardians, researchers, healthcare organisations, and other authorised entities to participate in data-sharing processes [31, 21]. At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control [24, 22, 12, 25].

Traditional access-control architectures are commonly based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms [28, 25]. These approaches can provide effective access control within a well-defined organisational boundary, but they become increasingly difficult to apply when authorisation decisions involve multiple independent entities operating across decentralised or cross-organisational environments. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain.

This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, institutional authorities, and other authorised stakeholders [31, 9]. Similar challenges also arise in enterprise, financial, and other cross-organisational data-sharing environments, where a decision may depend on the joint approval of customers, service providers, compliance entities, or regulatory authorities. These scenarios demonstrate that authorisation is increasingly a distributed governance problem rather than simply a process of authenticating a user and checking a static permission.

Several emerging technologies provide important building blocks for addressing these challenges. Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability, while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles, attributes, qualifications, or authority [20, 5], and cryptographic and policy-based access-control mechanisms can restrict access to authorised resources [2, 28, 25]. More broadly, blockchain-based approaches have demonstrated the potential to improve the integrity, transparency, and traceability of decentralised data-management processes [1, 26].

However, the availability of these technologies does not, by itself, establish trustworthy authorisation. Blockchain can preserve evidence that a consent event or transaction has occurred. However, the existence of an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, or that all necessary parties participated in the decision. It also does not demonstrate that a subsequent data-access request remains consistent with the conditions originally authorised. Similarly, a decentralised identity may establish who an entity is, while a verifiable credential may provide evidence concerning the entity's role or attributes, but neither mechanism independently determines whether access to a particular patient's data should be granted.

The fundamental challenge is therefore not simply how to record consent in a decentralised system. Rather, it is how to coordinate identity verification, authority evaluation, collective decision-making, policy enforcement, and auditable evidence so that a data-access decision can be regarded as trustworthy. This requires a transition from viewing consent as a static record of permission towards understanding consent as an active and evaluable component of a broader authorisation process, extending the dynamic consent perspective [13, 24].

## **1.2 Problem Statement**

Existing consent-management and decentralised access-control approaches commonly represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability. However, in most systems consent remains a passive artefact indicating that a permission or approval has been created. The relationship between the consent record, the identity of the participants, their authority to act, the required authorisation conditions, the applicable policy constraints, and the resulting access decision is frequently treated as a collection of separate technical concerns.

This creates a fundamental distinction between consent representation and trustworthy authorisation enforcement. A consent record can



demonstrate that a decision has been created or recorded, but it does not necessarily establish why that decision should be trusted when it is subsequently exercised. Immutability protects the integrity of recorded information, but immutability alone does not verify the legitimacy of the entities that participated in the decision. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information.

The problem becomes more complex when healthcare data sharing requires the coordinated authorisation of multiple independent participants. A patient may initiate consent, while guardians, healthcare professionals, or institutional authorities may also need to participate in the authorisation process. In such circumstances, a valid access decision should not necessarily be generated by a single participant acting independently. Instead, the authorisation process may need to establish whether the required set of independently verified participants has satisfied a defined collective approval condition.

Even where identity and collective approval requirements have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. For example, a healthcare professional may possess a valid identity and participate in a valid consent process while subsequently requesting information that was not included in the patient's original authorisation. Consequently, identity verification and multi-party approval alone are insufficient to guarantee trustworthy access. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of a particular mechanism. In that mechanism, identity, authority, multi-party approval, policy, temporal and lifecycle conditions would be conjoined in every access decision. That conjunction would also be assured both formally and empirically. The review in Chapter 2 shows that the individual conditions already exist, and that several partial combinations of them exist as well [58, 61, 45]. Existing approaches provide important technological components. These include decentralised identity and verifiable credentials [58, 76], blockchain-based consent records [53, 71], multi-party approval mechanisms of several kinds [53, 61, 69, 43] and policy-based access control [44, 57, 63, 15], as reviewed in Chapter 2. However, these mechanisms are usually investigated separately.

Accordingly, the problem is not primarily whether consent can be stored securely or whether a blockchain transaction can be made immutable. The more fundamental problem is whether a system can determine that a particular data-access request has been generated under sufficient and verifiable trust conditions. This requires a framework capable of evaluating the legitimacy and authority of participating entities, determining whether the required collective authorisation has been

established, and verifying that the requested operation remains consistent with the policy constraints defined by the consent.

The proposed research therefore addresses trustworthy authorisation as a coordinated security problem. The objective is to move beyond a model in which consent is primarily represented as a static permission and towards a model in which consent functions as a security-bearing authorisation object whose associated trust conditions can be explicitly represented and evaluated.

In this context, the overarching research question is how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints. This question is decomposed into six sub-research questions in Chapter 3 and mapped to the research objectives RO1 to RO6 in Chapter 4.

### **1.3 Research Motivation**

The purpose of this section is to explain why a trust-oriented authorisation framework is required and to introduce its dimensions. It should be noted at the outset that, in addition to the four foundational dimensions RO1 to RO4 that are introduced below, the proposed framework has been extended to incorporate temporal validity and lifecycle trust (RO5), which was originally planned for the next stage. In particular, validity periods and expiration are enforced at the point of evaluation and mirrored on-chain, revocation is executed as a verifiable blockchain transaction, and consent progresses through controlled state transitions. This is important because trust cannot be regarded as permanently established at the moment a consent is created.

Adversarial and negative testing has been undertaken using the HALAH prototype, which is the Patient Consent Management Platform for History Access by Authorised Healthcare Providers described in Section 6.8. This testing covers per-dimension denial scenarios, guardian signature-rejection tests and tests of tampered and expired zero-knowledge proofs. It also includes a live negative evaluation on the Ethereum Sepolia testnet. Formal security analysis has not yet been undertaken and remains the subject of the next research stage.

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied.

The term Trust Computing is used in this report to denote the evaluation of trust as a computable outcome of explicitly verified conditions on identity, authority, collective approval, policy and lifecycle. It should be distinguished from trusted computing in the hardware sense, such as trusted execution environments and attestation. Trusted computing in that sense lies outside the scope of the review in Chapter 2.

This perspective requires a clear separation between several concepts that are often implicitly combined within conventional access-control systems. Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role, capability, or permission to participate in a particular decision. Multi-party authorisation concerns whether the required threshold of independently verified participants has jointly established the authorisation condition. Together, these conditions provide the foundation for determining whether the resulting authorisation decision has a sufficient basis to be trusted, and not merely whether access has been requested.

The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object that connects the relevant participants, authority requirements, policy constraints, and evidence associated with an authorisation decision. This conceptualisation makes it possible to evaluate the relationship between the consent itself and a subsequent data-access request rather than assuming that the existence of a recorded consent automatically justifies future access.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient.

These four dimensions (RO1 to RO4) collectively define the foundational scope of the proposed framework, which is then extended by temporal and lifecycle trust (RO5) and by formal security assurance and empirical validation (RO6). Their significance lies in the fact that they address different but interdependent aspects of the same authorisation problem. A

trustworthy consent model cannot operate effectively without reliable evidence concerning the identity and authority of its participants. Similarly, verified identities and collective approval do not guarantee trustworthy access unless the resulting request remains within the policy constraints associated with the consent. The Multi-Party Patient Consent research therefore investigates these mechanisms as coordinated conditions of a unified authorisation model rather than as independent security features.

In addition, trust cannot be regarded as static over time. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state, and this temporal dimension is addressed by RO5.

Formal analysis will be used to define the security properties expected from the proposed trust-oriented authorisation model and to reason about whether unauthorised entities or invalid authorisation conditions can produce an apparently valid access decision under defined assumptions.

The distinction between the empirical validation delivered at the current stage and the formal analysis planned for the next stage establishes a clear progression between the two stages of the research. The current research is concerned primarily with establishing the conceptual and technical foundations through which trustworthy multi-party authorisation can be constructed.

In this report, the current stage denotes the work delivered at the CA2 milestone, and the next stage, referred to as CA3, denotes the subsequent research stage in which the remaining objectives are completed.

Ultimately, the research is motivated by the argument that trustworthy healthcare data sharing cannot be guaranteed by a single technological mechanism. Blockchain can provide tamper-resistant evidence, decentralised identity can establish participant identity, verifiable credentials can provide evidence of authority, and policy mechanisms can constrain access. However, the security value of these mechanisms depends on how they are coordinated within the authorisation process. The proposed research therefore seeks to provide a trust-oriented authorisation framework in which these independently verifiable conditions contribute collectively to a defensible and explainable decision about whether a particular healthcare data-access request should be permitted.

The remainder of this report is organised as follows. Chapter 2 presents the systematic literature review and derives six requirements for trustworthy multi-party consent authorisation. Chapter 3 formulates the research gap and the research questions. Chapter 4 states the research objectives. Chapter 5 describes the MVC-based research architecture. Chapter 6 presents the proposed solution, its algorithms and the live HALAH demonstration. Chapters 7 to 9 report the current progress, the

publications and the research plan for the next stage. Appendix A traces the framework to the implemented system.

It should be noted that the scope of the current stage is bounded. The HALAH prototype is deployed on the Ethereum Sepolia testnet with synthetic healthcare records. The guardian approval rule is currently implemented as N-of-N over the guardian set  $G$ . The security properties of the framework are demonstrated through scenario-based, negative and adversarial testing rather than through formal proof, which is deferred to the next stage.

Table 1 summarises the scope of the research and the progression of the six objectives from the current stage to the next stage.

**Table 1:** Research Scope and Progression

| Stage                               | Research Dimension                                      | Purpose and Core Objective                                                                                                                                                                                                                    |
|-------------------------------------|---------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Current                             | RO1: Trust-Centric Consent Model                        | Develop a structured and evaluable representation of patient consent as a trust-aware authorisation object that explicitly connects identity, authority requirements, policy constraints, and authorisation evidence.                         |
| Current                             | RO2: Decentralised Identity and Authority Trust         | Establish trustworthy participants using decentralised identifiers and verifiable credentials while explicitly separating identity authentication from authorisation authority.                                                               |
| Current                             | RO3: Trustworthy Multi-Party Authorisation              | Establish collective trust by requiring multiple independently verified participants to satisfy predefined authorisation conditions before sensitive healthcare data access can be granted.                                                   |
| Current                             | RO4: Policy- and Context-Aware Access Control           | Ensure that authorised access remains consistent with the purpose, policy, and healthcare data scope specified by the consent, preventing valid identities and approvals from being used to obtain data beyond the authorised constraints.    |
| Current                             | RO5: Temporal and Lifecycle Trust                       | Extend the authorisation model with validity periods, expiration, revocation, and controlled consent-state transitions to support dynamic and lifecycle-aware trust evaluation.                                                               |
| Current (empirical) / Next (formal) | RO6: Formal Security Assurance and Empirical Validation | Formally define and analyse the security and authorisation properties of the proposed framework and empirically evaluate the complete HALAH implementation using representative healthcare data-sharing, negative, and adversarial scenarios. |

Table 1 summarises the research dimensions, distinguishing those realised in the implemented HALAH prototype from the formal security assurance that remains for the subsequent research.

## **2 Systematic Literature Review**

### **2.1 Overview**

The systematic literature review examines the current state of research on trustworthy and decentralised data sharing. Particular attention is given to healthcare consent management, blockchain-based consent governance, decentralised identity and authority, and multi-party authorisation. The review also covers policy- and context-aware access control, temporal validity and consent lifecycle, and formal security assurance and empirical validation. The purpose of the review is to examine how the existing approaches address the different conditions that are required for a trustworthy authorisation decision, and to identify where conceptual or architectural gaps remain. The review is therefore not limited to identifying technologies that can be applied to healthcare data sharing.

The reviewed literature demonstrates that substantial progress has been made in individual areas. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing [31, 14, 24, 22, 12]. Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised trust [2, 7, 3, 30, 26]. Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication [20, 33, 4, 16, 5, 27]. Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information [32, 11, 28, 25].

However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. In this context, the availability of a security mechanism is not the same as the ability to construct a unified and trustworthy authorisation decision from several mechanisms. The following sections analyse these research areas and identify the gap that is addressed by the proposed framework.

The structure of this chapter is as follows. Section 2.2 presents the six key requirements that a trustworthy multi-party consent authorisation framework should satisfy, which serve as the basis of comparison throughout the review. Section 2.3 describes the process that was adopted to search, shortlist and categorise the studies, including the review questions, the databases, the search string, the eligibility criteria and the PRISMA-based selection. Section 2.4 reviews the shortlisted studies in six thematic streams and assesses each study against the six requirements. Section 2.5 synthesises the review and identifies the research gap from the requirement perspective, and Section 2.6 concludes the chapter.

## **2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation**

This section discusses the requirements that a trustworthy authorisation framework for multi-party patient consent should satisfy. These requirements form the basis on which the existing studies are compared in this SLR. They are derived from the research problem introduced in Chapter 1, and each of them corresponds to one of the six sub-research questions that are formulated in Chapter 3. A consent decision in healthcare is not a single event. It passes through three phases: the phase in which the consent is specified and approved, the phase in which it is enforced at the time of a data-access request, and the phase in which its validity is maintained or withdrawn over time. The six requirements below cover these three phases.

### **2.2.1 Representation of consent as an evaluable authorisation object (Req: 1)**

Patient consent is commonly stored as a permission record, a consent receipt, or a transaction on a ledger. Such a record establishes that a consent decision occurred, but it does not by itself state the conditions under which a later access request should be trusted. A trustworthy framework therefore requires that consent is represented as a structured object. The components of this object are the participating identities, the authority requirements, the permitted purpose and data scope, the temporal validity, the jurisdiction and the supporting evidence. Each component can then be evaluated independently at the time of each request. This is important because the same consent may be valid for one request and invalid for another request. The validity depends on the requesting party, the requested purpose and the time of the request.

### **2.2.2 Decentralised verification of identity and authority (Req: 2)**

The participants in a consent decision, including the patient, the guardians, the healthcare professional and the institution, must be identifiable without relying on a single central identity provider. Decentralised identifiers and verifiable credentials provide this capability. A framework should, however, distinguish between establishing who a participant is and establishing what that participant is permitted to do. A verified identity does not imply authority over a patient's data. Consequently, a trustworthy framework requires that identity verification and authority verification are treated as separate conditions, each with its own evidence.

### **2.2.3 Multi-party authorisation through a verifiable threshold (Req: 3)**

In many healthcare situations, a single party cannot lawfully authorise access on its own. Access to the records of a minor, for example, may

require the approval of more than one guardian. A framework should therefore support collective approval in which a predefined number of designated parties must each provide an independently verifiable approval before the consent becomes active. This requirement is not satisfied by a workflow in which several participants simply record an approval in the system. The approval condition must be represented within the consent object and must be checkable by any party at a later time.

#### **2.2.4 Policy- and context-aware enforcement at the time of access (Req: 4)**

Valid identities and the required approvals are not sufficient on their own. An access request should be granted only if it conforms to the purpose and the data scope that the patient authorised. It should also satisfy the contextual constraints that apply to the request, such as the jurisdiction in which the data may be used. A framework should evaluate every request against these constraints rather than relying on the existence of a valid consent record. This is important because many unauthorised disclosures in practice are not caused by unknown requesters. They are caused by legitimate requesters who exceed the scope of what was permitted. This is the insider risk that risk-aware and usage-control models seek to address [11].

#### **2.2.5 Temporal validity and lifecycle control of consent (Req: 5)**

Trust in a consent decision is not permanent. A consent may expire, may be revoked by the patient, or may pass through intermediate states before it becomes active. A framework should enforce the validity interval of a consent at every request, should make revocation effective immediately and verifiably, and should permit only controlled transitions between lifecycle states. Without this requirement, a consent that was valid when it was granted continues to authorise access long after the patient has withdrawn it.

#### **2.2.6 Verifiable auditability and security assurance (Req: 6)**

Finally, every consent decision and every access decision should leave evidence that can be verified independently of the application that produced it. A tamper-evident ledger provides such evidence for the events themselves. In addition, the security properties of the framework, such as the impossibility of access after revocation or without sufficient approvals, should be validated, either formally or through systematic adversarial testing. A framework that only demonstrates the successful cases does not establish that the unsuccessful cases are correctly refused.

These six requirements form the basis of the investigation into the existing approaches in the literature. Therefore, the question of whether each reviewed study assists in addressing these requirements is answered in the study tables of Section 2.4 and in the gap analysis of Section 2.5. The



next section details the process that was adopted to identify and shortlist the studies reviewed in this SLR.

## **2.3 Systematic Literature Review Methodology**

The review corpus comprises the 25 primary studies that were identified, screened, coded and included through the process described in the remainder of this section. A further 19 reports passed the same screen and were coded in full, but they are not part of the corpus. They are retained as supporting references and are cited in the supporting-evidence paragraph of each review stream in Section 2.4. Together, the two groups are numbered [35]–[78] in the reference list. Three secondary studies [79, 80, 81] were also retained, but for background only. These three studies are not counted as primary evidence. All 25 included studies were published between 2020 and 2026, which is the publication period fixed in the review protocol. Of the 25 studies, 13 were retrieved through Scopus, 10 through IEEE Xplore and two through ProQuest, after the duplicate records that these databases share with SpringerLink, ScienceDirect and Web of Science had been removed. In the remainder of this chapter, each included study is referred to by the label Sn (S1 to S25) together with its reference number, so that the reader can move between the tables, the text and the reference list without ambiguity. The rule by which the 25 included studies were separated from the 19 supporting references is explained in Section 2.3.7.

### **2.3.1 Review Design and Reporting Framework**

A systematic literature review (SLR) was conducted to identify, classify and critically evaluate existing research on trustworthy multi-party authorisation for patient consent in healthcare data sharing. The review was designed to establish the conceptual and technical foundations of the proposed framework, and to determine, for each of the key requirements defined in Section 2.2, the extent to which the existing approaches already satisfy that requirement. In particular, the review considered whether a study addresses consent representation, identity, multi-party approval, policy enforcement, temporal validity or security assurance. It also considered whether these mechanisms are integrated into a single authorisation decision that can be trusted.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA 2020) statement [34]. PRISMA 2020 was adopted to improve the transparency, reproducibility and traceability of the identification, screening, eligibility assessment and inclusion stages. The review was governed by a written protocol (Protocol v1.1), which fixed the review questions, the databases, the master search query, the inclusion and exclusion criteria, the data extraction codebook and the quality assessment items before any screening took place. All records, decisions and counts were maintained in

a single PRISMA 2020 master workbook so that every number reported in this section can be traced to a record and to a decision.

Screening and coding were organised as six review roles, and each role was responsible for one perspective of the review. Five of the roles covered review methodology, trust modelling, identity and multi-party authorisation, policy and temporal enforcement, and formal and empirical assurance. The sixth role was a chair who issued the final decision on each record. Every exclusion carries a reason code (EC1 to EC9, defined in Section 2.3.5) and every inclusion carries the page reference on which the positive coding is based. Where a panel member disagreed with the chair, the dissent was recorded against the record and retained in the log rather than being overwritten. All panel decisions were entered in a decision log (D-001 to D-166). The log records the date, the subject, the position of each panel member, the evidence cited and the outcome. The author retained the right to ratify, veto or reopen any decision by its identifier. The counts reported in this chapter are those of the checkpoint of 10 September 2026 (decision D-166).

### **2.3.2 Questions for Review**

This systematic literature review is guided by the following seven questions, which correspond to the six sub-research questions and the six research objectives of this study, the sixth of which is addressed by two review questions:

1. How do existing systems represent patient consent, that is, as a static record of a decision that has occurred or as a dynamic authorisation object that can be evaluated at the time of access?
2. What mechanisms are used to establish the identity and the authority of the participants in a consent decision, and is authentication distinguished from authorisation?
3. How do existing systems support joint or multi-party patient authorisation, and what prevents a single party from authorising access unilaterally?
4. How are policy, purpose, role, data scope and context enforced within the authorisation decision, rather than merely recorded alongside it?
5. How are temporal validity, consent states, expiration, withdrawal, revocation and renewal managed after a consent has been granted?
6. How are the security properties of existing consent and access-control systems defined and validated against identity, authorisation, policy, replay, expiry and state attacks?
7. How are the proposed approaches implemented and empirically evaluated in terms of authorisation correctness, security behaviour, audit evidence, interoperability and performance?

Questions 1 to 5 correspond to Req 1 to Req 5 of Section 2.2 respectively, while Questions 6 and 7 together correspond to Req 6, which combines formal security assurance with empirical validation. In addition to these seven questions, the synthesis in Section 2.5 addresses an unnumbered gap-testing question, namely the extent to which any single study integrates all of the dimensions above in one validated authorisation mechanism. This question is not a review question in its own right. It expresses the research gap rather than a separate objective, and it is answered only after the seven questions have been answered for every included study. Therefore, the review focused on the relationship between the individual security mechanisms rather than treating identity, consent, multi-party approval, policy and lifecycle control as isolated technologies.

### **2.3.3 Search Databases and Search Strategy**

The literature search was conducted using the following seven academic databases: 1) IEEE Xplore, 2) SpringerLink, 3) ProQuest Science and Technology, 4) ScienceDirect, 5) Scopus, 6) Web of Science, and 7) ACM Digital Library. In addition, Google Scholar was used as a discovery arm for snowballing and for testing the sensitivity of the search, but not as a structured retrieval source. Its results are reported under the PRISMA 2020 heading of records identified through other methods. They are not summed into the database total.

These databases were selected because they provide complementary coverage of computer science, cybersecurity, distributed systems, healthcare informatics and information management research. IEEE Xplore and the ACM Digital Library were used to identify studies on multi-party trust architectures, cryptographic mechanisms, decentralised identity and access control. SpringerLink and ScienceDirect were used to identify research on healthcare information systems, privacy and data governance. ProQuest was included to capture peer-reviewed journal literature that is not indexed by the publisher databases. Scopus and Web of Science were used to improve the coverage of multidisciplinary and medical-informatics venues, which the sentinel test described in Section 2.3.4 confirmed to be necessary for the healthcare-oriented consent studies.

A single master query was defined and executed on every database, adapted only to the field syntax of each platform. The query consists of three concept blocks joined by the AND operator. The first block captures the healthcare data domain (healthcare, health care, health data, medical data, patient data, electronic health record, electronic medical record, EHR and EMR). The second block captures the consent and authorisation concepts (patient consent, consent management, dynamic consent, authorization, authorisation and access control). The third block captures the trust and multi-party concepts (trust, trustworthy, trusted, multi-party, multiparty, joint consent, guardian, threshold, decentralized, decentralised, blockchain, smart contract, decentralized identifier,

verifiable credential and self-sovereign identity). Within each block the terms are joined by the OR operator, and both British and American spellings are included. The master query, as executed in the command search of IEEE Xplore over all metadata fields, is shown in Figure 1 and reads as follows:

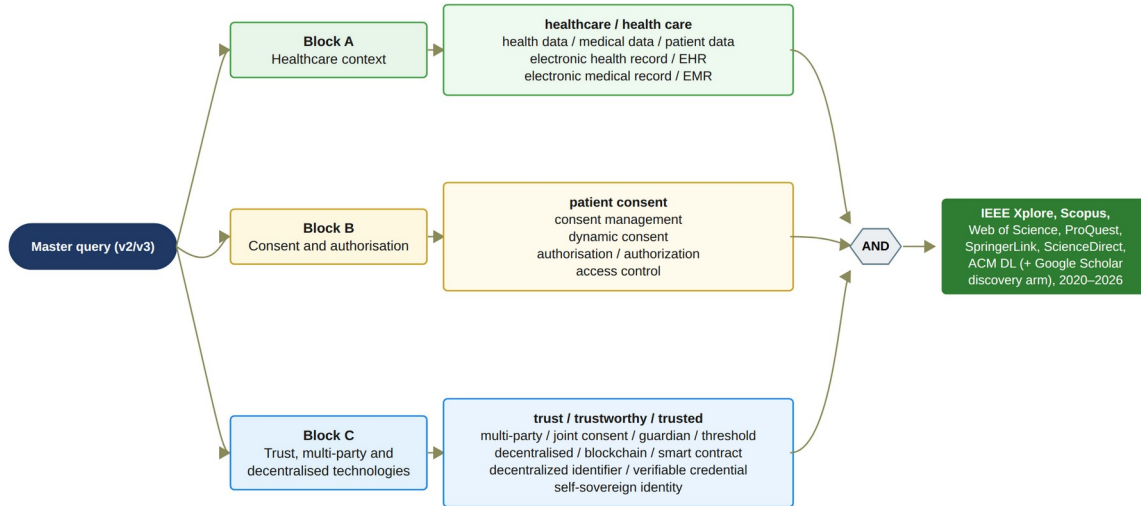


Figure 1: SLR search string definition: the three concept blocks of the master query and their combination across the seven databases

"("healthcare" OR "health care" OR "health data" OR "medical data" OR "patient data" OR "electronic health record" OR "electronic medical record" OR EHR OR EMR) AND ("patient consent" OR "consent management" OR "dynamic consent" OR "authorization" OR "authorisation" OR "access control") AND ("trust" OR "trustworthy" OR "trusted" OR "multi-party" OR "multiparty" OR "joint consent" OR "guardian" OR "threshold" OR "decentralized" OR "decentralised" OR "blockchain" OR "smart contract" OR "decentralized identifier" OR "verifiable credential" OR "self-sovereign identity")"

The same three blocks were entered in the TITLE-ABS-KEY field of Scopus, in the Topic field of Web of Science, in the NOFT (all fields except full text) field of ProQuest, and in the Title, Abstract and Keyword fields of the ACM Digital Library. It should be noted that two platforms could not accept the full Boolean expression. SpringerLink rejected long nested queries, and the master query was therefore executed as five short sub-queries that pair the consent, access-control and verifiable-credential terms with the healthcare and blockchain terms. ScienceDirect limits the number of Boolean connectors, and the master query was likewise executed as five sub-queries in the title, abstract and keyword field, with residual term compressions documented. In both cases the within-source overlap between sub-queries was removed at merge, and the low marginal yield of ScienceDirect was expected because Scopus already indexes the same

publisher content. For Google Scholar the query was compressed to the platform character limit. It should also be noted that the review protocol originally listed eight family-specific sensitivity queries for IEEE Xplore. These queries were superseded by the single master query and were never executed. This is declared as a documented deviation from the protocol rather than as an unexecuted step.

#### **2.3.4 Search Period and Search Execution**

The search was restricted to studies published between January 2020 and the search date in 2026. This period was selected to capture the development of blockchain-based consent management, decentralised identity and consent-aware access control from the first fully decentralised multi-party consent proposals in 2020 onwards, while maintaining a contemporary evidence base. Earlier seminal studies, such as the 2016 MedRec proposal, fall outside this period by design and could enter the review only through snowballing, and this date-range decision is recorded in the protocol.

The searches were executed on 24 and 25 August 2026 for IEEE Xplore, Scopus, Web of Science, ProQuest, ScienceDirect, SpringerLink and Google Scholar. The ACM Digital Library was searched on 5 September 2026, as a late arm added after the six other database searches had been frozen. This late addition is declared as a limitation of the search strategy. Each query was frozen with a search identifier and a version number before its export was accepted. The frozen identifiers were IEEE-M v2, SCOPUS-M v3, WOS-M v2, PROQ-M v2, SD-M v2, SPR-M v3, GS-M v2 and ACM-M v1. A changed query was always recorded as a new version rather than overwriting the previous one. Superseded versions were archived together with the cause of their rejection. For example, the first two Scopus versions were rejected because a subject-area limit had removed the medical-venue records. An initial ProQuest run over the full text was rejected because its scope was inconsistent with the title, abstract and keyword scope of the other databases. The document-type filters (journal articles and conference papers) and the English-language filter were applied within each platform where available.

The exported records were merged into a single screening register. IEEE Xplore returned 1,806 records, of which 1,805 were captured in two export batches merged by DOI. SpringerLink returned 2,895 records across the five sub-queries, exported in seven batches without abstracts because of a platform limitation, and reduced to 2,515 records after within-source deduplication. ProQuest returned 1,180 records and ScienceDirect returned 65 records, which were reduced to 23 after within-source deduplication. Scopus returned 2,133 records. Web of Science returned 1,137 records, which had to be exported by e-mail because the direct download was blocked by the library proxy. The ACM Digital Library returned 40 records. Google Scholar returned approximately 8,160 results, of which the first 100 by relevance were screened manually under

a pre-declared stopping rule and recorded by screenshot. Duplicate records across databases were identified first by DOI and then by normalised title, and the most complete bibliographic record was retained.

The purpose of the sentinel test was to validate the recall of the master query before it was frozen. Twelve sentinel papers that were already known to be relevant to the review questions were defined in advance, each chosen for one review dimension or for one protocol decision such as the date range. The frozen query was then tested for whether it retrieved each of them. The four healthcare-scoped sentinels, namely Madine et al. [53], Jaiman and Urovi [49], Tith et al. [71] and Albalwy et al. [37], were retrieved by the master query. The first two were retrieved through IEEE Xplore, and all four were retrieved through Scopus, Web of Science and ProQuest and were present in the merged register. The eight sentinels that were not retrieved were diagnosed individually. In five cases the paper is not healthcare-scoped in its title, abstract and keywords, or it is an identity-generic study in which healthcare is only an application domain, so that the healthcare block of the query correctly excludes it. One sentinel lacks the trust and multi-party terms of the third block. One sentinel is the 2016 MedRec proposal, which lies outside the date range by design. For one sentinel the cause of the miss had not been established at the checkpoint, and it is recorded as an open item. These misses were therefore attributed to venue or scope and not to a defect of the query. The protocol rule that no query is tuned to rescue a single paper was observed, and such papers can enter the review only through snowballing. Therefore, the sentinel test provides the recall evidence for the master query in place of the family-specific sensitivity searches that were not executed.

### **2.3.5 Eligibility Criteria**

The eligibility criteria were defined in the review protocol before the screening process began, to ensure consistency in the selection of studies across the title, abstract and full-text stages. The criteria were designed to identify research that is directly relevant to the review questions, and each exclusion decision in the screening register carries the code of the criterion under which it was made.

A study was included if it satisfied all of the following criteria:

1. IC1: Addresses healthcare, health/patient/clinical/medical data, EHR/EMR or closely related healthcare information systems.
2. IC2: Addresses patient consent, authorization, access control, trust, authority, permission or governance relevant to data access.
3. IC3: Contributes a mechanism, architecture, model, protocol, algorithm, formal model, implemented system or empirical evaluation relevant to at least one SLR review question.
4. IC4: Peer-reviewed journal or conference paper.

5. IC5: Available in English.
6. IC6: Full text available for final inclusion.
7. IC7: Within the protocol publication period (2020–2026) except separately documented seminal/snowball studies.

A study was excluded if it satisfied one or more of the following criteria:

1. EC1: Outside healthcare.
2. EC2: General blockchain/identity/security/privacy with no meaningful authorization/access-control/consent relevance.
3. EC3: Blockchain consensus but not authorization trust.
4. EC4: Identity authentication only; no meaningful healthcare authorization relevance.
5. EC5: Editorial, poster, presentation, magazine, news, tutorial or non-peer-reviewed item.
6. EC6: Duplicate publication.
7. EC7: Secondary review (kept separately for background/snowballing).
8. EC8: Full text unobtainable after reasonable attempts.
9. EC9: Superficial mention of healthcare or consent; no evidence for SLR questions.

Two rules governed the application of these criteria. First, a study was never excluded because it does not support the proposed research gap. The criteria concern relevance, document type and availability only. A study whose findings contradict or weaken the gap was therefore retained and coded in the same way as any other study. Second, any record whose eligibility was uncertain at a given stage was advanced to the next stage rather than excluded. In this context, it should be noted that several word-sense traps were identified during calibration and were frozen as screening rules. Regulatory or insurance authorisation is not data authorisation, blockchain consensus is not consent, encryption is not authorisation, and informed consent to a clinical procedure without a data-access dimension falls under EC9. Secondary reviews excluded under EC7 were kept in a separate list for backward snowballing, and three of them [79, 80, 81] are cited as background in this chapter.

### **2.3.6 Screening and Study Selection**

The screening process consisted of four sequential stages: deduplication, title screening, abstract screening and full-text eligibility assessment. The counts reported below are those recorded in the PRISMA 2020 master workbook at the checkpoint of 10 September 2026 (decision D-166), and the arithmetic of each stage was verified against the screening register.

In the identification stage, the seven database searches returned 9,256 records (IEEE Xplore 1,806; SpringerLink 2,895; ProQuest 1,180; ScienceDirect 65; Scopus 2,133; Web of Science 1,137; ACM Digital Library 40). It should be noted that this raw yield reflects the breadth of the master query and the indexing mode of the databases rather than the size of the relevant literature. The two full-record searches, SpringerLink and IEEE Xplore, account for 4,701 of the 9,256 records, whereas the four field-restricted searches on title, abstract and keywords (Scopus, Web of Science, ScienceDirect and ACM Digital Library) returned 3,375 between them. The protocol accepted this over-retrieval deliberately, since a broad query was preferred to a query tuned to the sentinel papers, and the screening stages reduce the set to 1,800 full texts and 25 included studies. The Google Scholar discovery arm returned approximately 8,160 results, of which the first 100 were screened; the candidates identified in this way were checked by DOI against the merged register and are reported separately as records identified through other methods. Before screening, 422 within-source duplicates from the SpringerLink and ScienceDirect sub-queries, together with the one IEEE Xplore record that was not captured at the export boundary (423 records in total), and 2,794 cross-database duplicates were removed by DOI and normalised-title matching, leaving 6,039 unique records.

In the title stage, the panel first calibrated the screening rules on a set of 48 records, adjudicated the contested cases and froze the ruleset before the bulk screen was executed. Of the 6,039 titles screened, 2,910 were excluded, namely 1,396 under EC9 (clinical or health studies with no authorisation signal), 1,268 under EC1 (outside healthcare), 199 under EC7 (secondary reviews, moved to the snowballing list) and 47 under EC5 (front matter and non-peer-reviewed items). Every title exclusion was delivered with its reason code for a veto window, during which an adversarial rescue sweep returned 125 records to the uncertain category. The remaining 3,129 records advanced to the abstract stage.

In the abstract stage, the ruleset was frozen after three audit passes, which added a centrality test (the consent or authorisation concept must be central to the contribution and not mentioned in passing) and the word-sense traps noted in Section 2.3.5. Of the 3,129 records, 2,541 abstracts were screened and 741 were excluded, in the majority of cases under EC2 (no consent or authorisation relevance), with smaller groups under EC7 and EC9. The remaining 588 records, 575 of them from SpringerLink, could not be screened at this stage because the SpringerLink export does not contain abstracts. These records were marked as pending and were not advanced. They are reported as pending in the flow diagram rather than being counted as screened or excluded. Therefore, 1,800 records advanced to full-text retrieval.

The full-text pool of 1,800 records was too large to be read exhaustively within the study period. It was therefore prioritised by signal detectors applied to the title and abstract of each record. The detectors covered the



seven trust dimensions T1 to T7, the consent-core terms, formal-verification terms and evaluation terms. Tier A (39 records) comprises the records that combine a consent-core signal with at least three trust dimensions, or a multi-party signal with a consent-core signal, or a formal-verification signal with a consent-core signal. Tier B (1,066 records) comprises the records that carry a consent-core, multi-party or formal signal, or at least two trust-dimension signals, and Tier C (695 records) comprises the remainder. All 39 Tier A records were processed at full text, 38 of which were assessed, while one could not be retrieved, as reported below. Tier B and Tier C records were then read in a targeted order under a dimension-level saturation rule. Under this rule, saturation of a dimension is declared when eight consecutively coded studies that carry a positive signal for that dimension yield no new mechanism class for it. Saturation is declared for each dimension separately and never for the corpus as a whole. It should be noted that this prioritised full-text coding of Tiers B and C continues after the checkpoint under the same rule, and that the counts reported here are therefore those of the checkpoint of 10 September 2026.

Therefore, 1,735 of the 1,800 records sought at full text had not been assessed at the checkpoint, in addition to the 588 pending-abstract records that had not been screened. The completeness of the corpus is consequently bounded by the dimension-level saturation rule rather than by exhaustive reading, and this is declared as a limitation of the review that is carried into the interpretation of the synthesis in Section 2.5.

At the checkpoint, one full text could not be retrieved after five documented retrieval routes (EC8), and 64 full texts had been assessed for eligibility. Of these, 17 were excluded with reasons. Nine were excluded under EC9 for superficial healthcare or consent relevance, and several of these studies treated consent only as a clinical procedure or a machine-learning metric. The other eight were excluded under EC1 (outside healthcare, three), EC5 (non-peer-reviewed items, two), EC2 (no authorisation relevance, two) and EC4 (identity authentication only, one). Three studies were classified as secondary reviews under EC7 and retained for background [79, 80, 81]. The remaining 44 reports were coded in full. Of these, 23 are classified as core studies and 21 as supporting studies under the synthesis rule described in Section 2.3.7. Every one of the 44 reports also passed the quality gate described in Section 2.3.7, and the studies that fell exactly on the boundary of the gate were retained and tested in a sensitivity analysis rather than being excluded. The 23 core studies, together with the two highest-quality supporting studies, Albalwy et al. [37] and Li et al. [51], each with a quality score of 7.0, form the 25 primary studies included in the review. The remaining 19 supporting studies are retained as supporting references outside the corpus and are cited in the supporting-evidence paragraph of each review stream. This bound was adopted so that the review concentrates on the studies that

bear most directly on the research gap, while every retained report remains traceable in the reference list.

Figure 2 presents the PRISMA 2020 flow diagram for this review. The diagram summarises the identification, screening, eligibility and inclusion stages described above. It also shows the records identified through the Google Scholar discovery arm, the pending-abstract records that were not advanced, the full text that could not be retrieved, and the reasons for exclusion at the full-text stage. The chain of counts in the diagram is internally consistent. The 9,256 identified records minus the 2,794 cross-database duplicates and the 423 within-source records give the 6,039 titles screened. The 6,039 titles minus the 2,910 title exclusions give the 3,129 records advanced to the abstract stage. The 3,129 records minus the 741 abstract exclusions and the 588 pending records give the 1,800 full texts sought. The 39 Tier A, 1,066 Tier B and 695 Tier C records add up to the same 1,800. The 64 full texts assessed comprise the 25 included primary studies, the 19 supporting references, the three secondary studies and the 17 excluded reports.

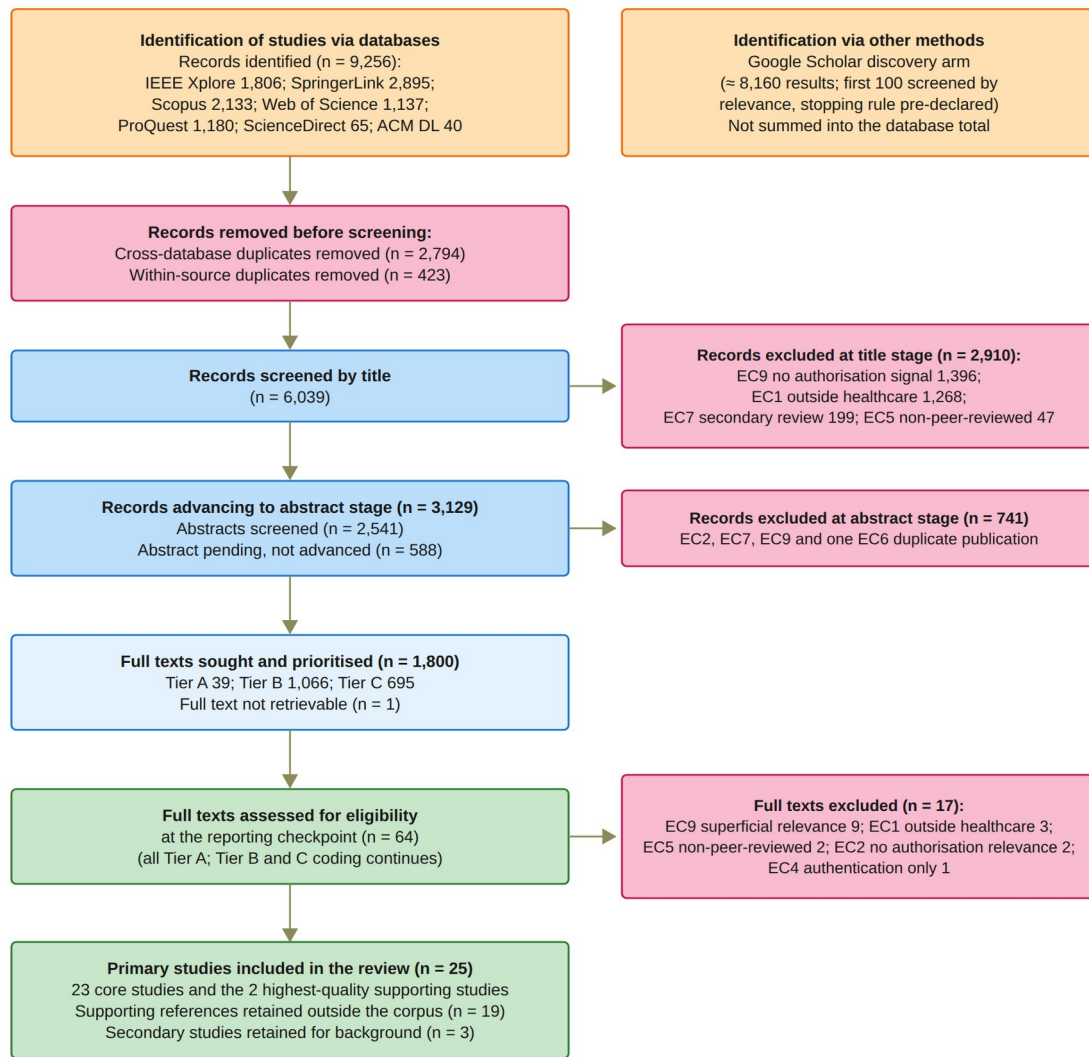


Figure 2: PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages, with the audited counts at the reporting checkpoint

### 2.3.7 Data Extraction, Quality Assessment and Synthesis

The included studies were analysed using a predefined data extraction form that was implemented as the screening register of the workbook. For every study, the extracted information included the bibliographic record, the document type, and the coding of the seven trust dimensions and the seven requirements defined below. It also included the page reference and evidence note on which each positive coding rests. The technology flags were blockchain, decentralised identifier, verifiable credential, threshold mechanism, policy model, revocation mechanism, formal method, prototype and dataset. In addition, the eight quality assessment items, the evidence tier, the gap-impact verdict, the reviewer and any recorded dissent were extracted. Extraction was performed only from the complete full text; a study whose full text was incomplete was not coded until the missing pages had been obtained.

Each study was coded against seven trust dimensions using the values Yes, Partial or No. T1 (identity) records whether the identity of a participant is established by a decentralised identifier, verifiable credential, public-key certificate or equivalent, noting that a DID string alone is not a verified identity. T2 (authority) records whether the case-specific authority of a participant is verified separately from authentication, because identity is not authorisation. T3 (multi-party) records whether at least two distinct and independent participants must approve, as in k-of-n thresholds, guardian co-consent or multi-signature. Blockchain consensus, endorsement policies, multi-authority attribute-based encryption and the mere presence of multiple organisations do not qualify. T4 (policy) records whether purpose, role, data scope or context influences the decision, noting that a policy described in prose is not enforcement. T5 (temporal) records whether time influences the decision through a start, end or expiry, noting that a timestamp in a log is not temporal authorisation. T6 (lifecycle) records whether consent states and transitions such as active, revoked and expired are enforced, noting that mentioning revocation is not implementing it. T7 (audit) records whether verifiable evidence of the decision is produced, noting that an immutable record is not by itself a trustworthy decision.

Each study was further coded against the seven workbook requirements Req1 to Req7, which correspond to the seven review questions. Req1 is awarded only when consent is represented as an evaluable authorisation object with states, predicates, policy, lifecycle and evidence, and not for the mere existence of a consent record. Req2 requires that both identity and authority are verified, with Partial awarded when only one of them is. Req3 requires that authorisation depends on at least two independent participants. Req4 requires that purpose, scope, role or context is evaluated before access is granted, with Partial awarded when the policy is stored but does not influence the decision. Req5 requires that time or lifecycle state is technically enforced in the authorisation decision, with Partial awarded when it is recorded but not enforced. Req6 requires that security properties are formally defined and demonstrated by verification, model checking, a security proof, an attack model or a theorem, with Partial awarded for a threat discussion only. The statement that a system is secure is not evidence. Req7 requires working evidence in the form of a prototype, simulation, dataset, allow and deny test cases, attack cases or audit logs, noting that architecture diagrams alone are not empirical validation. Every positive coding required a page reference. Because Req 6 of this report combines formal security assurance with empirical validation, the workbook values of Req6 and Req7 are mapped to a single Req 6 column in the study tables of Section 2.4: a study is marked as satisfying Req 6 if either workbook value is Yes, as partially satisfying it if either value is Partial, and as not satisfying it otherwise.

Each study that passed the relevance criteria at the full-text stage was additionally evaluated against eight quality assessment items scored 1 for

Yes, 0.5 for Partial and 0 for No. The first four items form the quality gate. QA1 asks whether the study deals with patient consent or consent-governed data access at the healthcare level. QA2 asks whether it deals with an authorisation or access-decision mechanism rather than storage or recording only. QA3 asks whether it introduces a proper framework, model, protocol or architecture to address its aim. QA4 asks whether the proposed methodology is validated by a proof of concept or an implementation. A study was included when the sum of QA1 to QA4 was at least 3.0. The remaining four items, QA5 to QA8, do not affect inclusion but inform the evidence tier assigned to each study. Evidence Tier A denotes strong direct evidence, and evidence Tier B denotes direct evidence with limitations. Evidence Tier C denotes a supporting mechanism, and Background is assigned to the secondary studies. It should be noted that these evidence tiers are distinct from the full-text priority tiers of Section 2.3.6, which use the same letters but rank records for reading order only. It should be noted that a low quality score was never treated as evidence for or against the research gap. Studies with low scores were retained, and their influence was tested in a sensitivity analysis. Quality items were scored for every included study and for exclusions in which the relevance gate corroborated the decision. They were not scored for studies excluded as outside healthcare (EC1) or on document type, duplication, secondary status or unavailability (EC5 to EC8). These criteria precede quality assessment in the protocol.

After the seven review questions had been answered for a study, the chair recorded a gap-impact verdict stating whether the study contradicts, weakens, narrows or supports the proposed research gap, or has no effect on it, followed by a rationale organised by the deficits identified in Section 2.5. On the basis of this verdict, the 44 eligible reports were divided into core and supporting studies. The distinction was adopted at decision D-164 and tightened at decision D-166 to the following rule: a study is a core study if, and only if, its gap-impact verdict is contradicts, weakens or narrows, or its T3 coding is Yes or Partial. Under this rule, 23 of the 44 eligible reports are core studies and 21 are supporting studies. The 23 core studies and the two supporting studies with the highest quality score, Albalwy et al. [37] and Li et al. [51], are the 25 primary studies included in the review, and they carry the argument of Sections 2.4 and 2.5. The other 19 supporting studies are retained as supporting references, and they are cited only as corroboration in Section 2.4.

Coding and synthesis followed the six-role review procedure described in Section 2.3.1. For each full text, the panel executed a fixed review template. The first member verified the completeness of the full text and the bibliographic identity of the record and applied the eligibility and quality gates. The second member coded consent representation and trust modelling, and the third member coded identity, authority and multi-party authorisation. The fourth member coded policy, temporal and lifecycle enforcement, and the fifth member coded formal assurance and empirical

validation. The chair issued the final decision and the gap-impact verdict. Where a member disagreed with the final decision, the dissent was recorded in the register against the study together with the reason. The chair's decision stood subject to the author's ratification. A dissent was never removed from the log, so that the boundary cases remain visible in the sensitivity analysis. For full texts whose abstract already suggested a positive coding on a contested dimension, the tests that would decide that coding were pre-registered in the decision log before the full text was read, so that the outcome could not be adjusted after reading. The matrix of T1 to T7 and Req1 to Req7 values was re-derived from the register at every checkpoint, and the synthesis in Section 2.5 is based on the values held in the register at decision D-166.

### 2.3.8 Shortlisted Studies and Their Categorisation

Each of the 25 included studies was analysed according to its scope, topic, authors, year of publication and its contribution to the review questions. Based on this analysis, each study was assigned to one of six review streams, which correspond to the six key requirements of Section 2.2: consent representation and blockchain-based consent governance (Req 1); decentralised identity and authority (Req 2); multi-party authorisation (Req 3); policy- and context-aware access control (Req 4); temporal validity and consent lifecycle (Req 5); and formal security assurance and empirical validation (Req 6). A study was placed in the stream of the requirement on which it is coded most strongly, even though most studies touch on more than one requirement, and the extent to which each study addresses every requirement is recorded in the study tables of Section 2.4. The studies are listed in Table 2 in the order of their labels S1 to S25, together with their reference numbers. The studies in each stream are reviewed in the next section, and their issues and limitations with respect to the key requirements defined in Section 2.2 are discussed.

Figure 3 profiles the 25 included studies by publication year and by review stream.

**Table 2:** Listing of the studies identified after the shortlisting process

| Study | Authors (Year)        | Ref. | Title                                                                                                                                          | Review stream                                    |
|-------|-----------------------|------|------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------|
| S1    | Abbasi et al. (2026)  | [35] | Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains | Multi-party authorisation (Req 3)                |
| S2    | Albalwy et al. (2021) | [37] | A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study                | Policy- and context-aware access control (Req 4) |
| S3    | Al Amin et al. (2023) | [38] | Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach                                | Multi-party authorisation (Req 3)                |
| S4    | Ekholm et al. (2025)  | [43] | Implementing electronic informed consent in rare disease genomics                                                                              | Multi-party authorisation (Req 3)                |
| S5    | Eneh et al. (2026)    | [44] | Demo: EdgeConsent: On-Chain Attribute-                                                                                                         | Temporal validity                                |

| Study | Authors (Year)               | Ref. | Title                                                                                                                                                     | Review stream                                                          |
|-------|------------------------------|------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------|
|       |                              |      | Based Access Control for Data Consent Management                                                                                                          | and consent lifecycle (Req 5)                                          |
| S6    | Hagström et al. (2024)       | [47] | Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland                         | Multi-party authorisation (Req 3)                                      |
| S7    | Jaiman and Urovi (2020)      | [49] | A Consent Model for Blockchain-Based Health Data Sharing Platforms                                                                                        | Policy- and context-aware access control (Req 4)                       |
| S8    | Zhao and Su (2024)           | [50] | A threshold traceable delegation authorization scheme for data sharing in healthcare                                                                      | Formal security assurance and empirical validation (Req 6)             |
| S9    | Li et al. (2026)             | [51] | Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization                       | Temporal validity and consent lifecycle (Req 5)                        |
| S10   | Madine et al. (2020)         | [53] | Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records                                                           | Multi-party authorisation (Req 3)                                      |
| S11   | Maruthi and Singh (2025)     | [54] | Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain                                                                       | Formal security assurance and empirical validation (Req 6)             |
| S12   | Mei et al. (2026)            | [55] | Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT                                                                         | Formal security assurance and empirical validation (Req 6)             |
| S13   | Panagoulis et al. (2026)     | [57] | Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage                                      | Temporal validity and consent lifecycle (Req 5)                        |
| S14   | Phuyal et al. (2026)         | [58] | Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR-FHIR Translation                                    | Decentralised identity and authority (Req 2)                           |
| S15   | Phuyal et al. (2026)         | [59] | A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data                                                 | Decentralised identity and authority (Req 2)                           |
| S16   | Punia et al. (2025)          | [61] | An access control system for cloud-based healthcare systems driven by blockchain                                                                          | Multi-party authorisation (Req 3)                                      |
| S17   | Román-Martínez et al. (2023) | [63] | Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing                                                       | Policy- and context-aware access control (Req 4)                       |
| S18   | Hema et al. (2026)           | [64] | Patient Centric Cryptographic Protection of Cloud Electronic Health Records                                                                               | Temporal validity and consent lifecycle (Req 5)                        |
| S19   | Soohoo et al. (2026)         | [67] | Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems | Consent representation and blockchain-based consent governance (Req 1) |
| S20   | Tan et al. (2024)            | [69] | Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification                                          | Multi-party authorisation (Req 3)                                      |
| S21   | Tith et al. (2020)           | [71] | Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology                                   | Policy- and context-aware access control (Req 4)                       |
| S22   | Tremper et al. (2026)        | [72] | Mainzelliste: Ten years of pseudonymization, record linkage, and                                                                                          | Consent representation and                                             |

| Study | Authors (Year)      | Ref. | Title                                                                                                                     | Review stream                                              |
|-------|---------------------|------|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
|       |                     |      | informed consent management                                                                                               | blockchain-based consent governance (Req 1)                |
| S23   | Tseng et al. (2025) | [73] | EMR-Chain: Decentralized Electronic Medical Record Exchange System                                                        | Decentralised identity and authority (Req 2)               |
| S24   | Wu et al. (2023)    | [75] | Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data | Multi-party authorisation (Req 3)                          |
| S25   | Wu and Zhang (2025) | [76] | HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID                   | Formal security assurance and empirical validation (Req 6) |

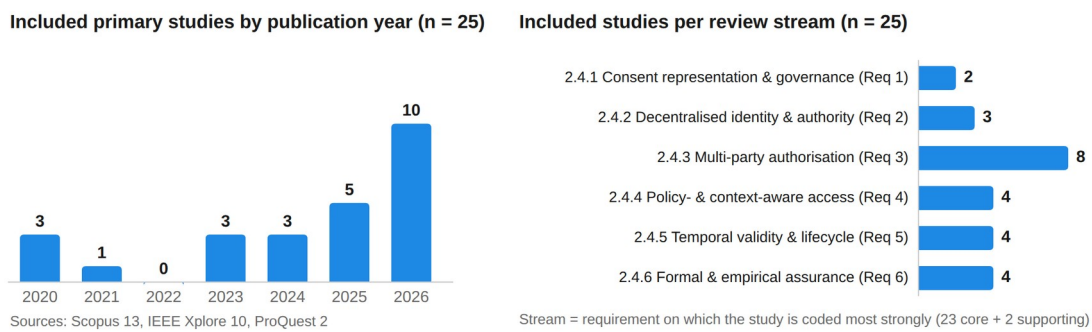


Figure 3: Profile of the 25 included primary studies: distribution by publication year and by review stream. Each study is assigned to the stream of its strongest coded requirement.

## 2.4 Review

This section reviews the 25 primary studies that were included in Section 2.3.8. The review is organised by the six key requirements of Section 2.2, so that Sections 2.4.1 to 2.4.6 correspond to Req 1 to Req 6 respectively. It should be noted how the 25 studies were selected from the 44 reports that passed the full-text screen. Following the synthesis rule ratified by the coding panel (D-166), 23 reports were classified as core and the remaining 21 as supporting. A study was classified as core when its full-text evidence contradicts, weakens or narrows the research gap. A study was also classified as core when it involves more than one authorising party (T3 graded Yes or Partial). The review corpus therefore consists of the 23 core studies together with the two supporting studies with the highest quality-assessment score, Albalwy et al. [37] and Li et al. [51], each scored 7.0 of 8. The other 19 supporting reports are retained as supporting references. They are cited only in a short closing paragraph of the stream to which they were assigned, which states in general terms what they corroborate, and they do not appear in Table 2 or in the study tables. Each subsection reviews the included studies that were assigned to that stream and states their issues and limitations with respect to the requirement in question. Each subsection ends with a table that summarises the included studies



and records their commitment to all six requirements. In the tables, ✓ denotes that the requirement is satisfied, ~ denotes that it is partially satisfied and × denotes that it is not satisfied, as coded from the full texts using the codebook described in Section 2.3. Each study is assigned to one stream only, according to the requirement to which its main contribution relates; a study assigned to one stream may nevertheless be discussed briefly in another subsection when its coding is relevant to that requirement. The background surveys and position papers [1]–[34] are used only for context and do not appear in the tables, which list the 25 included studies only. In addition, a small number of studies outside the healthcare consent domain, concerning archival record-keeping [8], attested sensing with blockchain coordination [17], ledger immutability [18], attested execution environments [23] and decentralised decision-making [29], were consulted as background and are not part of the review corpus.

Figure 4 shows the correspondence between the seven review questions of Section 2.3.2 and the sections of this review in which each of them is answered.

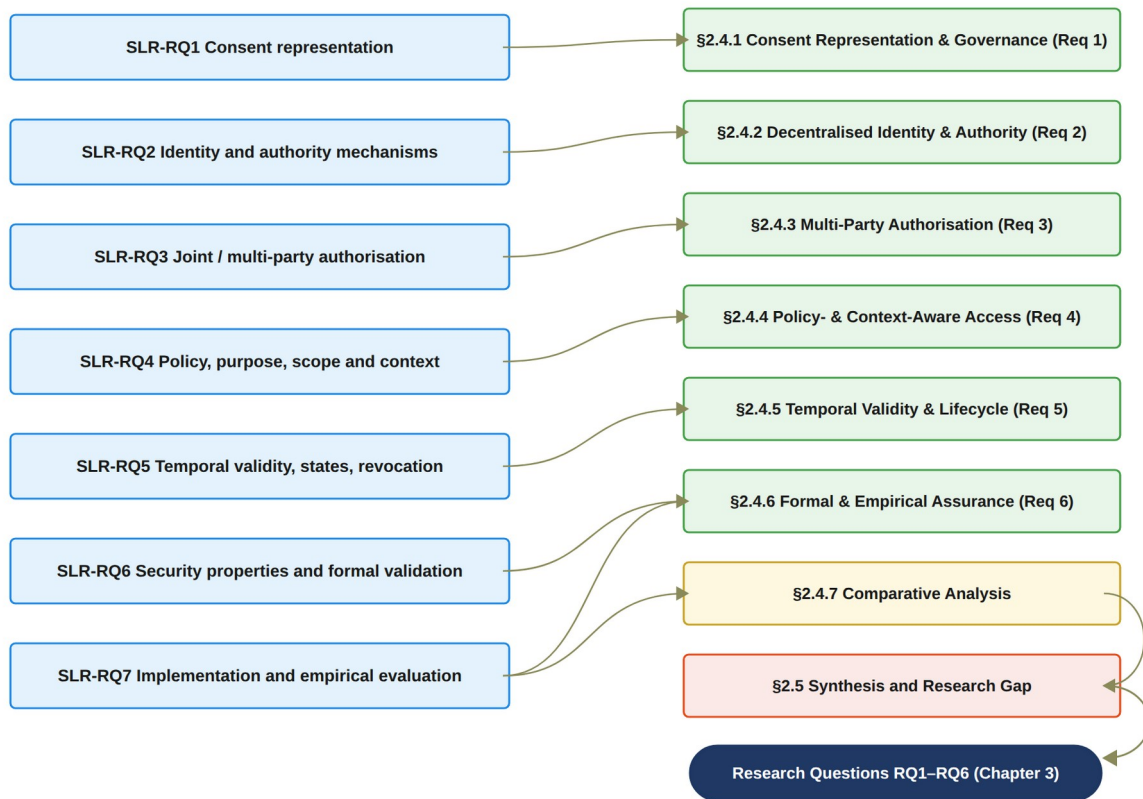


Figure 4: Correspondence between the seven review questions of Section 2.3.2 and the sections of the review in which they are addressed, ending in the synthesis that leads to the research questions of Chapter 3.

### **2.4.1 Consent Representation and Blockchain-Based Consent Governance**

This section reviews the two included studies whose main contribution is the representation and governance of patient consent. Both are deployed platforms rather than research prototypes. The ten supporting references assigned to this stream, most of which govern consent on a blockchain, are cited at the end of the section. Req 1 requires that consent is represented as a structured object whose components, namely the participating identities, the authority requirements, the permitted purpose and data scope, the temporal validity, the jurisdiction and the supporting evidence, can be evaluated at the time of each request. Earlier consent-management research represented consent as a permission indicating whether a party may perform an operation, and dynamic consent and consent receipts added the possibility of changing preferences over time and of retaining evidence of how consent was obtained [13, 10]. The question examined in this stream is whether the reviewed systems go beyond a stored consent record and make the consent itself an object that the access decision evaluates. The full-text coding shows that both included studies of this stream, and all ten supporting references assigned to it, were graded Partial on Req 1 and that none was graded Yes. In this context, three situations recur across the stream. In the first, consent is represented but absent from the decision. In the second, consent is present in the decision but reduced to a boolean flag. In the third, consent is held in a registry whose status is displayed or queried but never enforced. The two included studies illustrate the first and the third of these situations in production settings.

Soohoo et al. [67] describe the authentication and authorisation module of the iAgree patient-controlled data-sharing portal, deployed across three United States health systems, with OAuth2, SMART on FHIR and one-time-password identity that was tested with matched and unmatched accounts, and with a permissioned Ethereum audit contract. Consent is a preference matrix of data category by recipient type whose enforcement is outside the scope of the paper, so that the consent object is represented but absent from the access decision that the paper describes. A single patient decides, and the involvement of several institutions does not make the decision multi-party. Authorisation is OAuth2 delegation with no separate authority evidence for researchers, the one-hour window is a session token rather than a consent validity period, and revocation is append-only and untested. The evaluation consists of functional tests of identity matching and contains no formal method and no allow or deny correctness case for the preference matrix itself.

Tremper et al. [72] report ten years of the Mainzelliste pseudonymisation, record-linkage and consent-management service, an open-source production tool in use since 2015, with multi-tenant role-based access control, per-request token validation, modular FHIR consent directives scoped by use type and an automated consent-check capability. The

consent object is the richest in this stream. However, the paper specifies no check semantics, no term list and no allow or deny protocol. Therefore, the way in which a directive is evaluated at the time of a request cannot be established from the publication. Consent withdrawal is implemented at the registry level through an API delete, with no downstream enforcement shown, and no temporal validity is evaluated. The reason for each request is captured for audit but not adjudicated. It should be noted that the secure multi-party computation parties of the service perform record linkage rather than authorisation, and that the security evidence is an independent penetration test and a secure development process rather than a formal analysis.

The two included studies show that the representation of consent and the evaluation of consent have been developed separately, even in production systems. In both studies the consent object is comparatively rich. In iAgree [67] it is a preference matrix of data category by recipient type, and in Mainzelliste [72] it is a set of FHIR consent directives scoped by use type. However, neither paper specifies the semantics by which an access decision evaluates that object. Enforcement is out of scope in the first study and unspecified in the second. In addition, neither study verifies its own authorisation decisions. The functional tests of Soohoo et al. [67] and the penetration test of Tremper et al. [72] contain no allow or deny correctness case, and Req 6 is graded Partial for both. Neither study involves more than one authorising party, and Req 3 is graded No for both, as it is for all twelve studies assigned to this stream. The closest single-party analogues of the consent object  $C = (I, A, P, T, L, E)$  required by the proposed framework are not found in this stream. They are found in the on-chain consent object of Phuyal et al. [58] in Section 2.4.2 and in the patient-driven policy of Al Amin et al. [38] in Section 2.4.3. Therefore, Req 1 is partially addressed in this stream. However, consent as an object that is evaluated on every request against identity, authority, purpose, scope, time and jurisdiction is not provided by either of the reviewed consent-governance platforms. Table 3 presents a summary of the included studies in this stream and their commitment to the key requirements.

Supporting references. Ten further reports were assigned to this stream and coded, but they are not part of the review corpus [36], [39], [41], [42], [60], [65], [68], [70], [74], [78]. They corroborate the pattern described above. Where consent enters the access decision, it enters as a per-record boolean grant [36], [60]. Where consent is bound to cryptographic operations, the conditions are fixed at encryption or key-issuance time and cannot be re-evaluated at the time of the request [70], [78]. Where the consent object is rich, as in the gICS directives integrated into REDCap [74], its state is displayed and queried but no access decision depends on it. Consent is absent from the formalised decision function of the largest measurement campaign in the stream [65] and is reduced to a logged event with a gas cost in [42]. The zero-knowledge and homomorphic-encryption workflow of [68] evaluates a free-text reason rather than a

purpose term. The two conceptual designs [39], [41] remain unimplemented. All ten supporting references were graded Partial on Req 1 and No on Req 3, and none of them provides a formal security analysis, the closest being the threat model and simulated attacks of [65].

**Table 3:** Descriptions, issues and limitations of existing studies on consent representation and blockchain-based consent governance

| Study    | Description                                                                                                                                                                                                                                                                                                                        | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                          | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S19 [67] | The authentication and authorisation module of the iAgree patient-controlled data-sharing portal, deployed at three health systems, with OAuth2, SMART on FHIR and one-time-password identity, a patient preference matrix of data category by recipient type, and a permissioned Ethereum audit contract.                         | A single patient decides and multi-institution is not multi-party; authorisation is OAuth2 delegation with no separate authority evidence for researchers; enforcement of the preference matrix is out of scope; the one-hour window is a session token, not consent validity; revocation is append-only and untested; no formal methods; functional tests only.                              | ~     | ~     | ×     | ~     | ~     | ~     |
| S22 [72] | Mainzelliste, an open-source pseudonymisation, record-linkage and consent-management service in production since 2015, with multi-tenant role-based access control, per-request token validation, modular FHIR consent directives scoped by use type, an automated consent-check capability and registry-level consent withdrawal. | The consent-check semantics, term list and allow or deny protocol are not specified in the paper; withdrawal is a registry operation whose downstream enforcement is not shown; no temporal validity; the secure multi-party computation parties perform record linkage, not authorisation; security evidence is a penetration test without formal analysis; no consent decision is verified. | ~     | ~     | ×     | ~     | ~     | ~     |

## 2.4.2 Decentralised Identity and Authority Trust

This section reviews the three included studies whose main contribution is the decentralised verification of the participants in a consent decision. The two supporting references assigned to this stream are cited at the end of the section. Req 2 requires that the patient, the guardians, the healthcare professional and the institution can be identified without a single central identity provider. It also requires that establishing who a participant is (identity) is treated separately from establishing what that participant may do (authority). Each of the two is supported by its own evidence. Decentralised identifiers and verifiable credentials provide the first capability [20, 33, 4, 16], and the reviewed studies apply them, or national equivalents, to healthcare data exchange. It should be noted that the coding distinguishes T1 (identity established by DID, VC, PKI or

certificate) from T2 (case-specific authority verified separately from authentication). Across the 25 included studies, T2 was graded Yes in only 10 studies and Partial in 15. That is, in three fifths of the corpus, authority over a particular patient's data is not established directly. A verified identity, a platform role or an administratively assigned attribute stands in for it instead.

Phuyal et al. [58] present the most integrated system in the corpus. It is a simulated Norwegian cross-institution exchange in which patients and professionals hold EUDI-compatible wallets with W3C decentralised identifiers and verifiable credentials. Consent is an executable on-chain object on a Hyperledger Besu ledger that carries the patient identifier, the requester identifier, the data scope and an expiry, together with an ACTIVE or REVOKED state. Access proofs are generated with Groth16 circuits. Identity verification checks the issuer registry, the signature and the credential expiry. With respect to Req 2, a licensing-body credential asserts the professional's role, specialisation and scope of practice, and the system verifies this credential separately from authentication. This is the strongest Req 2 evidence in the corpus. Revocation is enforced at run time in 1.45 seconds and subsequent access returns an error, and allow and deny cases are tested over 100 runs per workflow. The limitations should also be noted. A single patient grants a bilateral data-sharing agreement, and there is no multi-party approval. The expiry field is stored on the ledger, but the access algorithm checks only the state and the proof. Purpose exists only at the user-interface level. There is no threat model, formal verification or adversarial test. The companion architecture of Phuyal et al. [59] extends the design to secondary use with a FHIR Consent resource carrying purpose, scope, actors and validity period, and specifies validation of these constraints at decision time. However, the authors state that nothing is implemented or evaluated, so every dimension is capped at Partial. In addition, the proxy or guardian delegation mentioned as an option is substitution rather than joint approval.

Tseng et al. [73] present EMR-Chain, an open-source decentralised medical record exchange that combines an Ethereum identity chain with a Hyperledger Fabric record chain. The identifier is a government-endorsed hashed national identity bound to a wallet, which the authors call a DID although it is not a W3C decentralised identifier; professional identities are X.509 certificates issued by the ministry certificate authority, and roles are granted by the health authority, so that authority is verified separately from authentication. The system is benchmarked against national exchange statistics and the code is public. Its limitations with respect to the later requirements are as follows. The patient and requester co-signature on a request is bilateral authentication rather than independent approval. Purpose is logged in the transaction record but never evaluated, and scope is at the hospital level. The token expiry enforced at the validator is a session bound rather than a consent validity window, and

revocation of the access list does not invalidate tokens already issued. The security discussion is narrative.

Identity is the strongest dimension of this stream. T1 is graded Yes in two of the three included studies and Partial in the design-only architecture of Phuyal et al. [59]. Authority verified with its own evidence is found in Phuyal et al. [58], through licensing-body credentials, and in Tseng et al. [73], through authority-issued roles. The remaining eight Yes gradings for T2 among the 25 included studies belong to other streams, and several of them do not use decentralised identifiers at all. Ekholm et al. [43] and Hagström et al. [47] verify legal guardianship against a national population register, Madine et al. [53] rely on a regulatory agency, and Punia et al. [61] bind roles, attributes and access tokens to their owners independently of the sender address. In addition, the included study that comes closest to an evaluable consent object, Phuyal et al. [58], is a single-party design and is not formally assured. It is also the only one of the three included studies that verifies allow and deny outcomes. Therefore, the literature provides mature mechanisms for decentralised identity and, increasingly, for credential-based authority. However, it does not yet combine separated identity and authority evidence with multi-party approval, policy evaluation and formal assurance in one decision. Table 4 presents a summary of the included studies in this stream and their commitment to the key requirements.

Supporting references. Two further reports were assigned to this stream and coded. They are not part of the review corpus, but they corroborate these findings without altering them [45], [66]. Ferreira et al. [45] design the widest authorisation predicate in the corpus, in which a single call conjoins the subject, the purpose, the scope and the time over the current consent state. Shanmugham and Senthilkumar [66] propose a consent token carrying an identifier, a role, a scope, a validity interval and a three-state lifecycle. This token is the closest single-party structural analogue of the consent object required by the proposed framework. In both, however, case-specific authority reduces to a credential together with the consent state, and the guardians named in [45] are a key-recovery mechanism rather than co-authorisers. No denial after revocation or expiry is tested, and neither study is formally assured. Consequently, both were graded Partial on Req 2 and No on Req 3.

**Table 4:** Descriptions, issues and limitations of existing studies on decentralised identity and authority trust

| Study    | Description                                                                                                                                                                                  | Issues / Limitations                                                                                                                                                                                                          | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S14 [58] | A simulated Norwegian cross-institution exchange with EUDI-compatible wallets, W3C DIDs and VCs, an executable on-chain consent object (patient DID, requester DID, scope, expiry, state) on | A single patient grants a bilateral agreement with no multi-party approval; the expiry field is stored but the access algorithm checks only state and proof; purpose is at the user-interface level with no policy engine; no | ✓     | ✓     | ×     | ~     | ~     | ✓     |

| Study    | Description                                                                                                                                                                                                                                                                                                                                                                                                                            | Issues / Limitations                                                                                                                                                                                                                                                                                                                                        | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
|          | Hyperledger Besu, Groth16 access proofs, licensing-body credentials asserting role and scope of practice, run-time revocation (1.45 s) and an openEHR to FHIR bridge; allow and deny outcomes tested over 100 runs.                                                                                                                                                                                                                    | threat model, formal verification or adversarial test; simulation only with a node-count inconsistency.                                                                                                                                                                                                                                                     |       |       |       |       |       |       |
| S15 [59] | A design-only architecture for dynamic and auditable consent in secondary use in which a FHIR Consent resource carrying purpose, scope, actors and validity period is anchored on an Ethereum-compatible ledger, requester credentials are validated in three steps at a gateway, and validation of purpose, scope and duration at decision time is specified.                                                                         | Explicitly not implemented and not evaluated, so no dimension is enforced; proxy or guardian delegation is a substitution option rather than joint approval; revocation is specified but not implemented; the STRIDE-style threat table is declared non-exhaustive with no proof or verification; same author group as [58].                                | ~     | ~     | ×     | ~     | ~     | ~     |
| S23 [73] | EMR-Chain, an open-source decentralised record exchange combining an Ethereum identity chain, on which a government-endorsed hashed national identity is bound to a wallet, with a Hyperledger Fabric record chain using X.509 identities from the ministry certificate authority, health-authority-granted roles, a patient-adjustable per-hospital access list and JWT validation, benchmarked against national exchange statistics. | The identifier is not a W3C DID; the patient and requester co-signature is bilateral authentication, not independent approval; purpose is logged but never evaluated and scope is hospital-level; JWT expiry is a session bound rather than consent validity; access-list revocation does not invalidate issued tokens; narrative security discussion only. | ~     | ✓     | ×     | ~     | ~     | ~     |

### 2.4.3 Multi-Party Authorisation and Collaborative Consent

This section reviews the eight included studies of stream 3, whose main contribution involves the participation of more than one party in a consent or access decision. Req 3 applies where a single party cannot lawfully authorise access on its own. In that case, a predefined number of designated parties must each provide an independently verifiable approval. This threshold condition must be represented within the consent object, and it must be possible for any party to check it at a later time. The background surveys and position papers [1]–[34] reviewed in Section 2.3 give the impression that multi-party joint authorisation of patient data

access has not been realised in the literature. The full-text coding of the included studies does not support that impression. Across the 25 included studies, T3 (at least two distinct independent participants must approve) was graded Yes in 6 studies, Partial in 4 and No in 15, and the coding panel ratified six distinct mechanism classes of multi-party authorisation. It should be noted that the coding applied a strict word-sense discipline. Blockchain consensus, endorsement policies, multi-authority attribute-based encryption, secure multi-party computation parties, requester co-signatures and social key-recovery guardians were not counted as multi-party authorisation, because none of them adds an independent authoriser to the decision. The purpose of this section is therefore to state precisely which forms of multi-party authorisation exist and which form does not.

The first class is joint approval on a contingency path. Madine et al. [53] propose a fully decentralised multi-party consent scheme on Ethereum in which an access request on the incapacitated path requires the approvals of a regulatory agency and of at least the minimum of  $\text{ceil}(0.7g)$  and five guardians on the same request, and an emergency request requires the agency's approval together with a hospital admission confirmation. This is a genuine N-of-M condition over independent parties, combined with expiry enforced inside the decision predicate, since stale attestations stop counting, and with explicit revocation of claims and removal of guardians. However, on the normal path a single patient key authorises access. Joint approval is therefore a fallback that applies only when the principal is absent, and it is not a condition of every decision. In addition, the guardians hold no key shares: the decryption key is split between the patient and the regulatory agency, which can decrypt with its own shares, so the joint guarantee holds at the smart-contract layer only. The paper contains no formal analysis, no dataset and no allow or deny correctness matrix. A related design is threshold key custody. Abbasi et al. [35] present Nexa, a public-blockchain record system in which a Shamir (5, 3) threshold protects each record key. A clinical access combines the requester's own share with two automated oracle shares released on the basis of the current on-chain role. There is therefore a single authorisation locus and no human co-approval, and the patient's share is not required. The institutional multi-signature for bulk access is proposed but outside the prototype. The prototype is public and measured, but no authorisation decision is verified. The threshold over patient-designated relatives of Maruthi and Singh [54], reviewed in Section 2.4.6, belongs to the same custody class.

The second class places the threshold on the institution side. Wu et al. [75] present Soteria, a clinical-trial data platform on Hyperledger Fabric with trusted-execution chaincode in which a  $(t, n)$  threshold signature runs over named investigators. The threshold does not apply to all operations in the same way. The admission of a trial record to the ledger requires a majority of investigators and the revocation of a consent requires half of them, whereas the consent grant itself is submitted unilaterally by the patient. In



addition, each investigator's vote consists of recomputing and confirming the hash of the message, so the threshold is a threshold of integrity verifiers rather than of authorisers, and the voters act for the institution rather than for the patient. The third class is institutional custodian approval conjoined with a policy engine. Punia et al. [61] implement MedXBlock, a permissioned Ethereum access-control system. In this system, an M-of-N multi-signature contract over registered doctors and administrators, for example two of three, governs high-sensitivity and cross-departmental requests. An implemented hybrid attribute- and role-based policy engine evaluates a conjunctive grant predicate with deny-by-default over a stateful policy store. This is the only study among the 25 included studies in which multi-party approval and an enforced policy predicate co-occur. Even so, the threshold applies only to high-sensitivity and cross-departmental requests, since ordinary access is token-only, and it can be bypassed by a single emergency officer. In addition, it is implemented outside the grant predicate as a separate layer. The patient enters the predicate as a boolean consent attribute rather than as an authoriser, and no purpose term exists. The assurance is a threat table and an asserted safety property, and the 100 measured transactions include no executed authorisation test.

The fourth class appoints witnesses. Tan et al. [69] propose a personal health record sharing scheme with multi-party pre-authorisation verification, in which the patient fixes  $n$  verifiers and a threshold  $t$ . Each verifier evaluates the patient-issued grant, its expiry and the revocation list before releasing its share of the decryption key. Without  $t$  shares, no key and no plaintext exist. This is the first threshold in the corpus whose authorisers are appointed by the patient for the patient's own access decision, and expiry is checked at the point of approval. The joint approval is nevertheless a pre-delegated contingency for the case in which the patient is unable to act. The verifiers evaluate identity, grant, time and revocation but not purpose or data scope, since attribute-based policy is explicitly future work. Only the secure multi-party computation layer is implemented, while the identity, wallet and ledger layers are not. The security argument is a STRIDE and LINDDUN enumeration with no proof over the authorisation protocol. The fifth class, reviewed in Section 2.4.6, is the consumer-side delegated threshold of Zhao and Su [50], in which  $l$  of  $d$  already-authorized clinicians jointly authorise an out-of-policy requester; the delegates are consumer-side rather than patient-side parties, and the scheme has no time, lifecycle or purpose term.

The sixth class is register-verified guardian co-consent at consent registration, and it is the only class found in deployed systems. Ekholm et al. [43] report the implementation of electronic informed consent in rare disease genomics on a commercial platform used by three genomic medicine centres in Sweden. The consent of a minor is valid only when all legal guardians, one or two, have signed. Guardianship is verified in real time against the national Population Register, and 61 paediatric trio

consents were obtained under this rule. This is a deployed n-of-n guardian condition with authority verified separately from the national electronic identity used for authentication, and it is the cleanest separation of identity and authority in the corpus. However, the condition applies at the registration of consent and not at the access decision. The only decision-time touchpoint is an interface that answers whether a valid consent exists, without purpose, scope or time parameters. The platform is centralised, and the paper provides no formal or authorisation-correctness evidence. Hagström et al. [47] examine the national patient portals of Sweden and Finland in a retrospective comparative case study. In both portals, guardian proxy access to a minor's record is gated jointly by a healthcare professional's assessment of the minor's capacity and by the minor's own consent, and guardianship is verified against a population register. Age windows are also enforced, and their enforcement is demonstrated by the absence of use within blocked windows and by the consent of 95.8 per cent of capable minors to disclosure. This is a second deployed instance of collective, consent-gated proxy governance, but it is documentation-time governance in centralised national systems with no formal assurance. Finally, Al Amin et al. [38] represent informed consent as a patient-driven policy  $IC = (U, O, OP, CON)$ , an evaluable object whose contextual conditions include time, date, day, location, network address and access frequency, and whose enforcement conjoins the patient's consent with organisational and regulatory policies. The only multi-party element is a two-of-two multi-signature wallet in the experimental harness, in which every member must sign to store a consent. The members are not named, the mechanism gates registration rather than access, and it is absent from the model. No purpose term exists, and the Goerli deployment reports no measured result or allow or deny case. The panel recorded it as a candidate class only.

The position of the literature with respect to Req 3 can therefore be stated precisely. What exists is multi-party authorisation in six forms. The first two are joint approval on a contingency path when the principal is absent [53, 69], and guardian or bilateral co-consent at the time of consent registration [43, 47, 38]. The next two are institution-side thresholds over record admission and consent revocation [75], and custodial M-of-N approval around, but not inside, a policy predicate [61]. The last two are a patient-appointed witness threshold welded to key release [69], and threshold key custody or delegation among custodians, relatives or clinicians [35, 54, 50]. In this context, the sentence that multi-party authorisation does not exist in the literature is no longer defensible and is not made in this review. What does not exist in any of the 25 included studies is a threshold predicate over the guardian set  $G$  with threshold  $N$  that is constitutive of the access decision. Such a predicate would be evaluated on every access request in a decentralised exchange. It would be a conjunct of the same predicate that evaluates the policy conditions of purpose and data scope, the temporal validity and the jurisdiction of the

consent object C. It would also be supported by allow and deny correctness evidence and by formal assurance of the conjunction. The coding supports each element of this statement. Only Punia et al. [61] combine T3 = Yes with an enforced policy predicate, and there the threshold is outside the predicate, the patient is an attribute and purpose is absent. Every T3-positive study in this stream is graded No or Partial on Req 6, except the observational study of Hagström et al. [47], whose Req 6 tick rests on empirical evidence alone. The two T3-positive studies elsewhere that carry a proof [50, 54] prove the threshold gate or confidentiality in isolation. Therefore, the broadest multi-party systems carry the weakest assurance. In addition, the deployed guardian mechanisms [43, 47] establish guardian authority through a state register, which is the attestation pattern against which the guardian credentials of the proposed framework must be compared. Table 5 presents a summary of the eight included studies in this stream and their commitment to the key requirements.

**Table 5:** Descriptions, issues and limitations of existing studies on multi-party authorisation and collaborative consent

| Study   | Description                                                                                                                                                                                                                                                                                                                                                                                                                  | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                        | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S1 [35] | Nexa, a public Avalanche blockchain record system with a public prototype and a Synthea-derived dataset, in which each record key is protected by a Shamir (5, 3) threshold; clinical access combines the requester's share with two automated oracle shares released on the current on-chain role, revocation of roles is checked at each request, and an institutional M-of-N multi-signature for bulk access is proposed. | The threshold is over key custodians, not authorisers: a single authorisation locus with no human co-approval and the patient's share not required; the institutional multi-signature is outside the prototype; role-based only with no purpose, context or temporal term; no formal proof or tool; performance measured with no allow or deny or attack test; estimated competitor values. | ~     | ~     | ~     | ~     | ~     | ~     |
| S3 [38] | Informed consent represented as a patient-driven policy IC = (U, O, OP, CON) with hash integrity and contextual conditions (time, date, day, location, network address, frequency) that an authorisation module conjoins with organisational and regulatory policies; a Solidity consent-management contract is deployed on the Goerli testnet.                                                                              | The only multi-party element is a two-of-two multi-signature wallet in the test harness that gates consent registration, with unnamed members and no place in the model; no purpose term; lifecycle operations described but not specified; enforcement mechanisms explicitly not included; no measured result or allow or deny case; assumptions only, no security analysis.               | ✓     | ~     | ~     | ~     | ~     | ~     |
| S4 [43] | Deployed electronic informed consent for rare disease genomics at three Swedish genomic                                                                                                                                                                                                                                                                                                                                      | The guardian condition applies at consent registration, not to the access decision; the only                                                                                                                                                                                                                                                                                                | ~     | ✓     | ✓     | ×     | ~     | ~     |

| Study    | Description                                                                                                                                                                                                                                                                                                                                                                                                                                   | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                             | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
|          | medicine centres on a commercial platform: a minor's consent is valid only when all legal guardians sign, guardianship is verified in real time against the national Population Register, authentication uses the national electronic identity, and adoption is reported for 2,244 invited participants.                                                                                                                                      | decision-time touchpoint answers whether a valid consent exists, without purpose, scope or time; study-level broad consent with no policy; withdrawal effect not described; centralised research platform described in little technical detail; no formal or authorisation-correctness evidence; vendor conflict of interest declared.                                           |       |       |       |       |       |       |
| S6 [47]  | A retrospective comparative case study of the Swedish and Finnish national patient portals in which guardian proxy access to a minor's record is gated jointly by a healthcare professional's capacity assessment and the minor's own consent, with register-verified guardianship and age windows whose enforcement is evidenced by no use within blocked windows and 95.8 per cent of capable minors consenting to disclosure.              | The collective condition is documentation-time governance in centralised national systems rather than a decision-time predicate in a decentralised exchange; consent is not an evaluable object with its own scope or purpose; the study is observational and offers no security analysis or formal assurance.                                                                   | ~     | ✓     | ~     | ~     | ✓     | ✓     |
| S10 [53] | A fully decentralised multi-party consent scheme on Ethereum in which incapacitated-path access requires regulatory-agency approvals and at least $\min(\text{ceil}(0.7g), 5)$ guardian approvals on one request, emergency access requires agency approval and hospital admission confirmation, attestation expiry is enforced inside the decision, and claims and guardians can be revoked; a testnet prototype with gas costs is reported. | On the normal path a single patient key authorises, so joint approval is a contingency fallback rather than a condition of every decision; guardians hold no key shares and the regulatory agency can decrypt alone, so the joint guarantee is contract-level only; no policy, purpose or data-category model; no formal analysis, dataset, attack test or allow or deny matrix. | ✓     | ✓     | ✓     | ~     | ✓     | ~     |
| S16 [61] | MedXBlock, a permissioned Ethereum access-control system with an implemented hybrid attribute- and role-based policy engine evaluating a conjunctive deny-by-default predicate over a stateful policy store, an M-of-N multi-signature contract over registered doctors                                                                                                                                                                       | The threshold is institution-side, scoped to sensitive requests, bypassable by a single emergency officer and outside the grant predicate; patient consent is a boolean attribute, not an evaluable object with its own scope, validity or lifecycle; no purpose                                                                                                                 | ~     | ~     | ✓     | ✓     | ✓     | ~     |

| Study    | Description                                                                                                                                                                                                                                                                                                                                                                                                                           | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                                                   | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
|          | and administrators for high-sensitivity and cross-departmental requests, token expiry checked at access, and 100 instrumented transactions.                                                                                                                                                                                                                                                                                           | term; a threat table and an asserted safety property only; systems metrics with no executed authorisation, denial or attack test; gas figures internally inconsistent.                                                                                                                                                                                                                                                 |       |       |       |       |       |       |
| S20 [69] | Personal health record sharing with multi-party pre-authorisation verification in which the patient appoints n verifiers and a threshold t; each verifier checks the patient-issued grant, its expiry and the revocation list before releasing a share of the decryption key, so that t validated shares are needed to obtain the record; the secure multi-party computation layer is implemented in Go on ten machines.              | The joint approval is a pre-delegated contingency for an incapable patient; verifiers evaluate identity, grant, time and revocation but not purpose or data scope (attribute policy is future work); the identity, wallet, credential and ledger layers are not implemented; no authorisation test, no expired or revoked credential rejection test; STRIDE and LINDDUN enumeration with no proof over the protocol.   | ✓     | ✓     | ✓     | ×     | ~     | ~     |
| S24 [75] | Soteria, a multi-site clinical-trial data platform on Hyperledger Fabric with trusted-execution chaincode in which a (t, n) threshold signature over named investigators gates the admission of trial records to the ledger and the revocation of a consent, consents carry enumerated states with start and end times and a study-number binding validated at an endpoint, and fourteen endpoints are timed on a managed deployment. | The consent grant is unilateral and the threshold governs record admission and revocation rather than the patient's access decision; each vote is a hash-integrity check by institution-side investigators; time is a stored attribute not shown to gate the decision; no policy engine; no theorem, proof or adversary model; performance only with borrowed latency figures and no correctness or attack evaluation. | ~     | ~     | ~     | ~     | ~     | ~     |

#### 2.4.4 Policy- and Context-Aware Access Control

Healthcare access-control research has developed a broad range of mechanisms for restricting access according to roles, attributes, risk conditions and usage constraints. Attribute-based encryption and decentralised key management protect healthcare data through cryptographic access policies [32], risk-aware usage-control models incorporate dynamic conditions beyond role-based permissions [11], and recent surveys of blockchain-based and IoT healthcare access control emphasise fine-grained, dynamic and privacy-preserving enforcement [28, 25]. This section reviews the four included studies of stream 4 against Req 4. The question asked of each study is not whether a policy exists. It is whether purpose, data scope, requester role and contextual constraints

influence the decision at the time of access. It is also whether the evaluated policy is bound to the consent object rather than to the requester alone. It should be noted that, under the coding rules of Section 2.3, a policy that is described in prose or stored on a ledger without being consulted by the decision does not satisfy Req 4.

Tith et al. [71] proposed one of the earliest purpose-based consent models for electronic health records on a Hyperledger Fabric consortium. Consent is represented as an evaluable four-tuple of role, doctor identifiers, action and intended purpose, in which the intended purpose is expressed through a purpose tree with allowed and prohibited purposes, and the tuple is matched by chaincode at request time with per-datum scope. The model therefore satisfies Req 1 and Req 4. However, the consent tuple carries no temporal element. Withdrawal is implemented in chaincode, but its effect on subsequent access is not tested. Identity rests on the Fabric membership service without decentralised identifiers or authority credentials. The prototype on four nodes reports functional targets without quantitative results, attack cases or a formal argument. Jaiman and Urovi [49] developed a consent model for blockchain-based health data sharing platforms. In this model, the purpose of a request is matched inside the smart contract against the patient's consent. The matching uses the Data Use Ontology and the Automatable Discovery and Access Matrix ontology, and denial is tested across several requester profiles. This is one of the few studies in the corpus in which purpose is evaluated in the decision and the denial path is exercised. Security assurance is explicitly placed outside the scope of the paper, the consent is granted by a single patient, and temporal validity and lifecycle transitions are not enforced in the decision.

Albalwy et al. [37] presented ConsentChain, a dynamic consent architecture for clinical genomic data sharing on a permissioned Ethereum network. Consent is a machine-readable object of data type, role and purpose, combined into an access-policy tree that is hashed and evaluated by a checkConsent function, so that purpose, role and data type are jointly required. The evaluation is a rigid exact-match of hashes rather than a policy engine, and the requester role is self-submitted and not verified against a credential. The consent tuple has no validity interval, and time is applied only at the data-delivery layer through short-lived download links. Revocation is a binary active or cancelled status, and the security analysis is qualitative. The proof of concept is deployed in a production environment with measured throughput and open source code, but no adversarial or systematic allow-and-deny tests are reported. Román-Martínez et al. [63] proposed a blockchain-based service-oriented architecture for consent management, access control and auditing in which FHIR Consent purpose-of-use limits are evaluated per resource by an XACML policy decision point operating over Hyperledger Fabric. This is the most standards-native purpose enforcement in the corpus, and the architecture includes supervisory auditing. Nevertheless, no withdrawal or expiry path exists anywhere in the architecture, and the authors state

that their experiments validate the blockchain component only, so the authorisation decision itself is not verified.

Across the 25 included studies, T4 is coded Yes in 11, Partial in 10 and No in 4. A policy or attribute condition therefore influences the access decision in a substantial share of the reviewed systems, and the requirement cannot be described as unaddressed. However, the nature of the policy is narrower than Req 4 demands. In most of the T4-positive studies the evaluated policy is bound to the requester, that is, to a role, a department, an institution or an attribute set. This is the case in Punia et al. [61], in Li et al. [51], in the attribute-based access control of Ghosh et al. [46] and in the attribute-based encryption schemes of stream 6. Purpose-of-use enters the evaluated decision in only six of the 25 included studies [37, 44, 49, 57, 63, 71], and in one supporting reference [45]. Purpose and data scope are jointly present in the decision by design in fewer still, in Albalwy et al. [37], Eneh et al. [44], Tith et al. [71] and the supporting reference [45]. Jurisdiction appears as a rule field only in Eneh et al. [44]; other contextual conditions are limited to the duty-hours term of Punia et al. [61] and the location and network-address conditions specified but not enforced by Al Amin et al. [38]. The gap verdicts recorded by the coding panel repeatedly note the absence of a purpose or data-category policy from the decision. Madine et al. [53] contain no purpose or policy term in the body of the paper, Tan et al. [69] defer attribute-based scope to future work, Punia et al. [61] evaluate role, department, record type and duty hours but no purpose, and Hema et al. [64] scope keys by role and workflow but carry no purpose-of-use term in the consent token. It should also be noted that every purpose-bearing study is coded T3 No. The single study which conjoins an implemented policy engine with a threshold approval, Punia et al. [61], consumes patient consent as a boolean attribute rather than as a consent object with its own scope. Therefore, the residual deficit for Req 4 is not the absence of a policy engine. The deficit is that purpose-of-use and data-scope constraints are not carried by the consent object C itself and evaluated together with the identity, authority and multi-party conditions, with evidence that requests outside the authorised scope are refused. Table 6 presents a summary of the four included studies of stream 4 and their commitment to the key requirements.

Supporting reference. One further report of stream 4 was coded and retained outside the corpus. The quantum-safe attribute-based access control scheme of Ghosh et al. [46] corroborates the finding that an attribute policy can operate inside the access decision and be enforced cryptographically, with attribute revocation checked at every access. It also confirms the residual deficit. The policy carries no purpose-of-use or data-scope term, one fully trusted authority issues and verifies both identity and authority, and the security analysis is argued without a theorem or tool.

**Table 6:** Descriptions, issues and limitations of existing studies on policy- and context-aware access control

| Study    | Description                                                                                                                                                                                                                                                                                                              | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                                                                    | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S2 [37]  | ConsentChain represents genomic-data consent as a machine-readable object of data type, role and purpose combined into an access-policy tree that is hashed and evaluated by a checkConsent function on a permissioned Ethereum network; the proof of concept is deployed with measured throughput and open source code. | Policy evaluation is a rigid hash exact-match rather than a policy engine; the requester role is self-submitted without credential verification; the consent tuple has no validity interval and time is enforced only at the delivery layer; revocation is a binary status; a single patient consents; the security analysis is qualitative and no adversarial or allow-and-deny suite is reported.                                     | ✓     | ~     | ×     | ✓     | ~     | ✓     |
| S7 [49]  | A consent model for blockchain-based health data sharing platforms in which the requester's purpose is matched inside the smart contract against the patient's consent through DUO and ADA-M ontology terms, with denial tested across several requester profiles.                                                       | Security assurance is explicitly outside the scope of the paper; the consent is granted by a single patient without guardian or threshold approval; temporal validity and lifecycle states are not enforced in the decision; identity and authority verification is only partially addressed.                                                                                                                                           | ✓     | ~     | ×     | ✓     | ~     | ✓     |
| S17 [63] | A blockchain-based service-oriented architecture for consent management, access control and auditing in which FHIR Consent purpose-of-use limits are evaluated per resource by an XACML policy decision point over Hyperledger Fabric, with supervisory audit services.                                                  | No withdrawal or expiry path exists anywhere in the architecture; the authors state that the experiments validate the blockchain component only, so the authorisation decision is not verified; no multi-party approval, identity and authority only partially verified, and no formal security argument.                                                                                                                               | ✓     | ~     | ×     | ✓     | ×     | ~     |
| S21 [71] | A purpose-based consent model for EHRs on Hyperledger Fabric in which consent is an evaluable tuple of role, doctor identifiers, action and intended purpose, matched by chaincode at request time against a purpose tree of allowed and prohibited purposes with per-datum scope.                                       | The consent tuple has no temporal element; withdrawal is implemented but its effect on later access is untested and there is no state machine; identity relies on Fabric membership certificates without DIDs, VCs or authority credentials; consensus endorsement is not multi-party consent; no formal verification or threat model; the four-node prototype reports functional targets without quantitative results or attack cases. | ✓     | ~     | ×     | ✓     | ~     | ~     |



### 2.4.5 Temporal Validity and Consent Lifecycle

Req 5 requires that the validity interval of a consent and its lifecycle state are technically enforced inside the authorisation decision. Two distinctions from the codebook of Section 2.3 govern the reading of this stream. First, a timestamp that is written to a log or stored in a consent record is not temporal authorisation; the decision itself must read the clock. Second, a mention of revocation, or an operation that changes a status field, is not an implemented lifecycle unless the state is consulted by the decision and the transitions are constrained. This section reviews the four included studies of stream 5, namely Eneh et al. [44], Li et al. [51], Panagoulas et al. [57] and Hema et al. [64], and draws on the lifecycle evidence recorded for the included studies of the other streams.

Eneh et al. [44] presented EdgeConsent, an on-chain attribute-based access control engine for data consent management, demonstrated on a healthcare scenario. Consent rules carry not-before and not-after bounds together with roles, organisations, jurisdictions, data categories, sensitivity levels, purposes and actions, and the `checkAccess` function evaluates the requester attributes, the resource, the purpose and the current timestamp against these bounds with deny-by-default and deny-overrides semantics. Expiry therefore takes effect at decision time, and the demonstration shows that a request is denied again once its rule is revoked. This is the first study in the corpus in which temporal validity is enforced inside the decision predicate. The lifecycle is nevertheless limited to an active flag and the temporal bounds, without pending, suspended or renewed states. Identity is a wallet address with an attribute registry whose issuance governance is unspecified, and a single patient authors the rules. There is no threat model. The evaluation is a two-page demonstration on a local network with gas measurements and an integration test suite. Hema et al. [64] take a different approach in a patient-centric cryptographic protection scheme for cloud EHRs. In this scheme the patient's signed consent token, the requester role and the expiry time are inputs to the key derivation function. Once the expiry has passed, the decryption key cannot be reconstructed, and revocation likewise causes derivation to fail without re-encryption. Therefore, the expiry is enforced by the key derivation itself rather than by an explicit comparison in a decision function, and authority is separated from identity through role-scoped keys. However, there is no lifecycle state machine, and the consent is issued by a single patient key. Identity relies on a commercial authentication service without credentials. The security argument is an adversary model with a probabilistic statement rather than a proof, and only operation latency is measured. Panagoulas et al. [57] proposed a blockchain-enabled governance overlay for clinical artificial intelligence pipelines. In this overlay, a formal policy object carries identifiers, roles, purposes, a validity window and a revoked flag with a

version number. Access is allowed only if the policy is valid at time  $t$  and the role and purpose conditions hold. Revocation is enforced mid-stream at decision time and is verified through a consent-drift metric over 43,500 simulated attempts across nine scenarios, with denials recorded as ledger events. The temporal conjunct is implemented, but interval-bound denials are not separately exercised, and the lifecycle is a binary active or revoked state. The ledger is a single-node hash chain without consensus, and identity is inherited from an existing clinical identity provider. The authors explicitly declare that no formal verification was performed.

The fourth included study illustrates a pattern that the coding panel describes as displacement, in which time is enforced on an artefact issued to the requester rather than on the consent itself. Li et al. [51] presented a hybrid role-based and smart-contract scheme with attribute-based authorisation for IoMT records. The expiry of a signed credential is compared with the current time at every sharing interaction, and a grant ledger records authorisations. The credential window is therefore enforced. However, the consent or authorisation object itself carries no enforced validity window, and there is no consent state machine. The same displacement is observed in the short-lived tokens of Tseng et al. [73] in stream 2, whose expiry is checked by the token validator while revocation of the access-control list does not invalidate tokens already issued. In both cases the enforced time belongs to a credential or a token, and the consent object is left without a validity interval of its own.

Across the 25 included studies, T5 is coded Yes in 8 and T6 in 7. Req 5, which requires enforcement in the decision, is Yes in 8. The distinction between recorded and enforced time explains most of the Partial codes. Albalwy et al. [37], for example, store a struct timestamp in the consent record and apply time only to the download link, so that the consent tuple itself has no validity interval. A parallel distinction separates named state machines from ad hoc revocation flags. Named states with constrained transitions appear in Phuyal et al. [58] (active and revoked with an audited emergency override), Wu et al. [75] (approved, pending, completed and revoked with investigator-verified transitions) and Punia et al. [61], although in the last case the states belong to policies and tokens rather than to the consent. By contrast, Abbasi et al. [35] enforce a role status without consent states, and even Madine et al. [53], with four transitions that affect the decision, define no named state set. Where revocation is enforced at scheme level, as in the immediate ciphertext update of Mei et al. [55], its cost is measured but its effect on a revoked requester is not exercised; among the included studies a post-revocation denial is actually demonstrated only by Phuyal et al. [58], Panagoulas et al. [57] and Eneh et al. [44]. In this context, the residual deficit for Req 5 is not the absence of decision-time temporal enforcement, which Eneh et al. [44], Hema et al. [64] and Panagoulas et al. [57] each achieve in isolation. The deficit is that temporal and lifecycle enforcement at the level of the consent object has not been verified in a deployed multi-institution exchange. In addition, the

three stream-5 systems which enforce time inside the decision are all single-party. Of the eight included studies coded Yes on Req 5, including the multi-party designs of Madine et al. [53] and Punia et al. [61], only the encryption scheme of Mei et al. [55] carries a formal proof. That proof concerns the static encryption predicate rather than the consent decision. Table 7 presents a summary of the included stream-5 studies and their commitment to the key requirements.

Supporting reference. One further report of stream 5 was coded and retained outside the corpus. The revocable attribute-based encryption scheme of Xu et al. [77], organised in key epochs for hospital-to-hospital sharing, corroborates the displacement pattern. Revocation is realised by key rollover, so that a revoked user retains access until the epoch ends. The word consent does not appear, and keyword matching is a discovery mechanism rather than an approval. The distinction between recorded and enforced time is likewise corroborated by the supporting references of the other streams. In several of them a timestamp is stored, logged or used only as a replay window without being read by the decision [46], [60], [62], [78]. In others, automatic expiry is claimed without specifying where the clock is read [68], [70]. Among the supporting references, a post-revocation denial is reported only in results captioned as illustrative [45] or in a single narrated scenario [68]. Named consent states gating the decision appear in one further supporting reference [66].

**Table 7:** Descriptions, issues and limitations of existing studies on temporal validity and consent lifecycle

| Study   | Description                                                                                                                                                                                                                                                                                                                                                                                 | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                         | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S5 [44] | EdgeConsent implements an on-chain attribute-based access control engine in which consent rules with not-before and not-after bounds, purposes, data categories, sensitivity levels and jurisdictions are evaluated by checkAccess against the requester attributes and the current timestamp, with deny-by-default; revocation is enforced at the next block and every decision is logged. | Lifecycle limited to an active flag and temporal bounds without pending, suspended or renewed states; wallet-address identity with unspecified attribute issuance and no DIDs or VCs; single-patient rules with no threshold; no threat model or formal properties; two-page demonstration on a local network with gas measurements but no adversarial or correctness suite. | ✓     | ~     | ×     | ✓     | ✓     | ~     |
| S9 [51] | A hybrid RBAC and smart-contract scheme with attribute-based authorisation for IoMT records in which the expiry of a signed credential is checked against the current time at every sharing interaction and authorisations are recorded on a grant ledger.                                                                                                                                  | Time is enforced on the requester's credential rather than on the consent or authorisation object, which carries no validity window; no consent state machine; no multi-party approval; neither a formal proof of the authorisation decision nor decision-level correctness evidence is reported                                                                             | ~     | ~     | ×     | ✓     | ✓     | ~     |

| Study    | Description                                                                                                                                                                                                                                                                                                                                                                                                              | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                                                            | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
|          |                                                                                                                                                                                                                                                                                                                                                                                                                          | (both coded Partial).                                                                                                                                                                                                                                                                                                                                                                                                           |       |       |       |       |       |       |
| S13 [57] | A blockchain-enabled governance overlay for clinical AI pipelines in which a formal policy object with roles, purposes, a validity window, a revoked flag and a version is evaluated so that access is allowed only if the policy is valid at time t and the role and purpose hold; mid-stream revocation is verified at scale through a consent-drift metric, with denials ledgered and the artefact publicly archived. | Interval-bound denials are not separately exercised and the lifecycle is a binary active or revoked state; single-node hash-chain ledger without consensus; identity inherited from an existing clinical identity provider; single policy administrator with no multi-party approval; purpose is requester-declared set membership without attestation or scope; the authors declare that no formal verification was performed. | ✓     | ~     | ×     | ✓     | ✓     | ✓     |
| S18 [64] | A patient-centric cryptographic protection scheme for cloud EHRs in which the patient's signed consent token, the requester role, the expiry time and delegation are inputs to key derivation, so that an expired or revoked consent makes the decryption key unreachable without re-encryption and role-scoped keys separate authority from identity.                                                                   | No explicit lifecycle state machine; consent issued by a single patient key although the construction could accept a threshold; identity relies on a commercial authentication service and device keys without credentials; adversary model with a probabilistic statement but no proof or tool; only operation latency is measured, with literature values as baselines.                                                       | ✓     | ~     | ×     | ✓     | ✓     | ~     |

#### 2.4.6 Formal Security Assurance and Empirical Validation

Req 6 has two components. The first is that the security properties of the authorisation mechanism are formally defined and demonstrated. This may be done through a security proof, a model, a verification tool or an explicit adversary model with a theorem. Under the codebook, the statement that a system is secure is not evidence, and a threat discussion alone is coded Partial. The second is that the mechanism is validated empirically, through a prototype, a dataset, allow-and-deny test cases, attack cases or audit evidence; architecture diagrams alone are not empirical validation. In the workbook these two components are coded separately as Req6 and Req7, and they are combined into the report's Req 6 in the tables of this chapter. Stream 6 gathers the four included studies in which formal argument is a principal contribution, namely Zhao and Su [50], Maruthi and Singh [54], Mei et al. [55] and Wu and Zhang [76], all of them cryptographic constructions published in security and network journals.

Wu and Zhang [76] presented HealthDID, an authorisable multi-party privacy-preserving EMR sharing system based on decentralised identifiers. The authorisation proof is a non-interactive zero-knowledge proof that binds the data subject's commitment to the public key of a specific querier, so that a verifier can check that this subject authorised this requester without learning the subject's identity; authorisation is therefore separated from the DID challenge-response authentication. The paper states three game-based security definitions and proves three theorems by reduction, namely anonymity from the hiding property of Pedersen commitments, unforgeability of the authorisation proof from the discrete logarithm assumption through the forking lemma, and search privacy from the decisional Diffie-Hellman assumption. This is the first complete formal assurance in the corpus. However, what is proven concerns the identity and authority fragment only. There is no theorem of the form that access is granted only under stated conditions. The proofs cannot cover policy, temporal or lifecycle conjuncts because the system has none. Access is all-or-nothing per authorising owner, the only time values are index and document fields that no algorithm reads, and there is no revocation, withdrawal or state. The term multi-party denotes several stakeholders whose privacy requirements are satisfied simultaneously, not several parties authorising one decision. The evaluation is a reproducible performance study with a public repository, but it includes no allow-and-deny tests, executed attacks or dataset. Zhao and Su [50] proposed a threshold traceable delegation authorisation scheme in which the data owner delegates to  $l$  of  $d$  already-authorised users. Each of these users must run an authorisation algorithm bound to a private key before an out-of-policy requester can restore the data. Unforgeability below the threshold rests on the bilinear Diffie-Hellman assumption, and confidentiality is proven under an IND-CPA game with reduction. The proof covers the threshold gate in isolation, the delegates are consumer-side clinicians rather than patient-side stakeholders, there is no time, expiry, revocation or state, and the Java benchmark measures performance only. Maruthi and Singh [54] addressed the unconscious patient with a threshold proxy re-encryption scheme. In this scheme  $t$  of  $n$  patient-designated relatives contribute to re-encryption without the key ever being reassembled at a single point. The hospital and the relatives are authenticated on chain through non-interactive zero-knowledge proofs, and IND-CCA security is proven. A Solidity implementation is reported. The collective mechanism is genuine and decision-time, but policy and temporal conditions are both absent, so the proof again covers a narrow predicate. Mei et al. [55] proposed a dual-revocation ciphertext-policy attribute-based encryption scheme for IoMT in which a direct mode terminates access immediately through a ciphertext update. The authors motivate this construction by patient consent withdrawal. The scheme offers user-level and attribute-level granularity and an IND-CPA reduction under the  $q$ -BDHE assumption. It has no audit element and no multi-party approval, and the proof concerns the static encryption predicate.

Two observations follow at corpus level. The first concerns formal assurance in the sense of the workbook's Req6. It is coded Yes in only 4 of the 25 included studies, all of them in this stream. Two supporting references of this stream, both encryption schemes, also carry a proof. In every case the proven property attaches to a narrow predicate. It is an identity-and-authority fragment in HealthDID [76], a threshold gate in Zhao and Su [50] and Maruthi and Singh [54], and a static attribute policy in the encryption scheme of Mei et al. [55]. By contrast, the studies with the broadest decision predicates carry the weakest assurance. Punia et al. [61], with six of seven dimensions positive, offer a threat table and an asserted safety property. Madine et al. [53], the strongest multi-party system, contain no adversary model, property statement or proof. Panagoulas et al. [57], whose decision is the best verified in the corpus, state that no formal method was applied. The coding panel records this as an inverse relation between predicate breadth and assurance strength, and the quadrant in which a broad conjunctive predicate is also formally assured is empty. Structured threat models in the STRIDE or LINDDUN style, as in Tan et al. [69], Phuyal et al. [59] and Panagoulas et al. [57], are useful, but they were coded Partial because they enumerate threats without demonstrating properties.

The second observation concerns empirical validation in the sense of the workbook's Req7. It is coded Yes in only 5 of the 25 included studies, Partial in 19 and No in 1. In the large majority of the Partial cases, evaluation means throughput, latency, gas cost, block time or encryption timing. Abbasi et al. [35] measure hundreds to a thousand transactions per operation on a public test network with a published repository and a Synthea-generated dataset, but execute no allow-or-deny test. Punia et al. [61] instrument 100 transactions and describe, but do not run, the single denial scenario. The four cryptographic studies of this stream report benchmarks of their primitives without exercising a single denial. The coding panel describes this pattern as built and measured but never validated as an authorisation decision, and it is the dominant form of evidence in the corpus. Negative validation of the decision, that is, evidence that requests without sufficient authority, outside the authorised scope or after revocation are refused, is found in a small minority. Panagoulas et al. [57] report a blocked rate of 1.000 for unauthorised attempts and zero post-revocation drift across 43,500 attempts, in a single-node simulation. Phuyal et al. [58] test allow and deny paths over 100 runs per workflow and show that revocation yields a refused access within about 1.5 seconds, in a simulated hospital without adversarial tests. Jaiman and Urovi [49] test denial across requester profiles, Albalwy et al. [37] deploy a proof of concept with open code but without adversarial tests, and Hagström et al. [47] show that age windows in a national portal are enforced in practice. No study executes an adversarial campaign against the authorisation decision itself. Where adversarial testing exists, it targets ledger integrity, as in Panagoulas et al. [57], or the software

surface through penetration testing, as in Tremper et al. [72]. Therefore, the residual deficit for Req 6 is the combination, within one system, of a formal argument over the conjoined identity, authority, multi-party, policy and temporal conditions and an audited set of allow and deny cases that includes the negative cases. Table 8 presents a summary of the included stream-6 studies and their commitment to the key requirements.

Supporting references. Five further reports of stream 6 were coded and retained outside the corpus. Two of them are coded Yes on formal assurance. These are the revocable attribute-based searchable encryption scheme of Gao et al. [48] and the bilateral proxy re-encryption scheme of Luo et al. [52]. They corroborate the first observation, since each proof concerns a static encryption predicate. The threshold among authorisation nodes in [48] is key-management resilience rather than approval, and the bilateral matching in [52] is policy symmetry rather than co-approval. The private set intersection protocol of Cao et al. [40], the lightweight multi-authority CP-ABE scheme of Qiao et al. [62] and the policy-hiding encryption scheme of Zhang et al. [56] were coded Partial on formal assurance because their proofs do not reach the authorisation decision, and all five corroborate the second observation, since their evaluations are timing benchmarks or simulations without allow-and-deny or attack tests.

**Table 8:** Descriptions, issues and limitations of existing studies on formal security assurance and empirical validation

| Study    | Description                                                                                                                                                                                                                                                                                                                                                  | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                                                                                                                               | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
| S8 [50]  | A threshold traceable delegation authorisation scheme in which the data owner delegates to 1 of d already-authorised users, each running a private-key-bound authorisation algorithm before an out-of-policy requester can restore the data, with IND-CPA security reduced to the bilinear Diffie-Hellman assumption and unforgeability argued by reference. | Delegates are consumer-side clinicians rather than patient-side stakeholders and the owner's own decision is unilateral; identity is an escrowed identity-based key without authentication protocol or credentials; no purpose term and out-of-policy requesters bypass the policy by delegation; no time, expiry, revocation or states; accountability signature verifiable by the owner only; Java benchmark against the authors' own baseline with no system prototype or allow-and-deny tests. | ~     | ~     | ✓     | ~     | ×     | ✓     |
| S11 [54] | A blockchain scheme for IoMT data of unconscious patients in which t of n patient-designated relatives contribute to threshold proxy re-encryption without the key being reassembled at any single point, the hospital and relatives are                                                                                                                     | No policy, purpose or data-scope condition and no temporal validity in the decision; lifecycle limited to the emergency path without consent states; the proof covers the threshold and encryption predicate only; empirical validation is limited to an in-paper                                                                                                                                                                                                                                  | ~     | ~     | ✓     | ×     | ×     | ✓     |

| Study    | Description                                                                                                                                                                                                                                                                                                                                                                                        | Issues / Limitations                                                                                                                                                                                                                                                                                                                                                                                                      | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|-------|-------|-------|-------|-------|
|          | authenticated on chain through non-interactive zero-knowledge proofs, IND-CCA security is proven and a Solidity implementation is reported.                                                                                                                                                                                                                                                        | implementation (Req7 Partial) without a verified allow-and-deny suite.                                                                                                                                                                                                                                                                                                                                                    |       |       |       |       |       |       |
| S12 [55] | A dual-revocation ciphertext-policy attribute-based encryption scheme for IoMT in which a direct mode terminates access immediately through a ciphertext update, motivated by patient consent withdrawal, with user-level and attribute-level granularity and an IND-CPA reduction under the q-BDHE assumption.                                                                                    | No audit element; attribute policy without a consent object; no multi-party approval; identity and authority only partially established; the proof concerns the static encryption predicate; scheme-level revocation is measured for cost, and enforcement at the consent object in a multi-institution exchange is not shown.                                                                                            | ~     | ~     | ×     | ✓     | ✓     | ✓     |
| S25 [76] | HealthDID, a DID-based EMR sharing system in which a zero-knowledge authorisation proof binds the data subject's commitment to a specific querier's public key, separating authorisation from authentication, with three game-based definitions and three reduction theorems for anonymity, unforgeability and search privacy, and a reproducible performance evaluation with a public repository. | The theorems cover the identity and authority fragment only and no theorem states the conditions under which access is granted; no purpose, role or data-category policy; no time value is read by any algorithm; no revocation, withdrawal or states; multi-party denotes multiple stakeholders' privacy, not joint authorisation; no allow-and-deny suite, executed attacks or dataset, and self-scored feature tables. | ✓     | ✓     | ×     | ×     | ×     | ✓     |

#### 2.4.7 Comparative Analysis of Existing Approaches

The reviewed literature demonstrates that existing approaches provide strong solutions for individual dimensions of trustworthy consent authorisation. Evaluable consent objects that are consulted at the time of a request have existed since 2020 in the purpose-based models of Tith et al. [71] and Jaiman and Urovi [49]. They are now realised with richer attributes in Eneh et al. [44], Panagoulas et al. [57] and Phuyal et al. [58]. The separation of identity from authority is achieved through licensing-body credentials in Phuyal et al. [58], through a national population register in Ekholm et al. [43], through a requester-bound zero-knowledge authorisation proof in HealthDID [76] and through role-scoped key derivation in Hema et al. [64]. Multi-party mechanisms exist in six distinct classes. These include the guardian and agency approvals of Madine et al. [53], the patient-appointed verifiers of Tan et al. [69], the delegated threshold of Zhao and Su [50], the institutional multi-signature of Punia et



al. [61], the kin threshold of Maruthi and Singh [54] and the deployed guardian co-consent of Ekholm et al. [43]. Policy engines operate inside the decision in Punia et al. [61] and Román-Martínez et al. [63]. Temporal validity is enforced inside the decision by Eneh et al. [44], Hema et al. [64] and Madine et al. [53]. Formal proofs are given for the identity fragment of HealthDID [76] and for several threshold and encryption schemes. Verified allow-and-deny behaviour is reported by Panagoulas et al. [57] and Phuyal et al. [58].

However, these contributions address different layers of the same problem, and the strength of each study on one requirement coincides with an absence on another. The systems that enforce purpose and time inside the decision are authored by a single patient and provide no formal argument. The systems that provide multi-party approval carry no purpose or data-scope condition and no formal argument. The schemes that prove security properties do so for predicates that contain no policy, no temporal validity and no lifecycle. A blockchain record does not establish participant authority, a valid identifier does not establish permission, an approval threshold does not guarantee that the request lies within the authorised scope, and a proof of unforgeability does not state the conditions under which access is granted. Consequently, no reviewed study establishes that a healthcare data-access decision is trustworthy in the conjunctive sense required by Section 2.2. In that sense, the identity, authority, multi-party, policy and temporal conditions must hold together, and this conjunction must be both formally argued and empirically tested.

Table 9 summarises the position of the 25 included studies against the six key requirements and positions the proposed framework relative to the existing literature. The included studies are the 23 core studies ratified by the coding panel, together with the two highest-quality supporting studies, Albalwy et al. [37] and Li et al. [51]. The core studies are those whose coding narrows, weakens or contradicts one of the deficits of the gap statement. Studies that carry a multi-party signal (T3 Yes or Partial) are also core studies. The 19 supporting references are cited in the supporting-reference paragraphs of Sections 2.4.1 to 2.4.6 and are outside the corpus, so that the comparison rests on the studies closest to the research problem. The ticks are taken from the coding of Section 2.3, with Req 6 combining the coding scheme's formal-assurance and empirical-validation codes as explained in Section 2.4.6.

**Table 9:** Comparison of the included studies and the proposed framework against the key requirements

| Study                         | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|-------------------------------|-------|-------|-------|-------|-------|-------|
| S1 [35] Abbasi et al. (2026)  | ~     | ~     | ~     | ~     | ~     | ~     |
| S2 [37] Albalwy et al. (2021) | ✓     | ~     | ×     | ✓     | ~     | ✓     |
| S3 [38] Al Amin et al. (2023) | ✓     | ~     | ~     | ~     | ~     | ~     |

| Study                                 | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---------------------------------------|-------|-------|-------|-------|-------|-------|
| S4 [43] Ekholm et al. (2025)          | ~     | ✓     | ✓     | ×     | ~     | ~     |
| S5 [44] Eneh et al. (2026)            | ✓     | ~     | ×     | ✓     | ✓     | ~     |
| S6 [47] Hagström et al. (2024)        | ~     | ✓     | ~     | ~     | ✓     | ✓     |
| S7 [49] Jaiman and Urovi (2020)       | ✓     | ~     | ×     | ✓     | ~     | ✓     |
| S8 [50] Zhao and Su (2024)            | ~     | ~     | ✓     | ~     | ×     | ✓     |
| S9 [51] Li et al. (2026)              | ~     | ~     | ×     | ✓     | ✓     | ~     |
| S10 [53] Madine et al. (2020)         | ✓     | ✓     | ✓     | ~     | ✓     | ~     |
| S11 [54] Maruthi and Singh (2025)     | ~     | ~     | ✓     | ×     | ×     | ✓     |
| S12 [55] Mei et al. (2026)            | ~     | ~     | ×     | ✓     | ✓     | ✓     |
| S13 [57] Panagoulas et al. (2026)     | ✓     | ~     | ×     | ✓     | ✓     | ✓     |
| S14 [58] Phuyal et al. (2026)         | ✓     | ✓     | ×     | ~     | ~     | ✓     |
| S15 [59] Phuyal et al. (2026)         | ~     | ~     | ×     | ~     | ~     | ~     |
| S16 [61] Punia et al. (2025)          | ~     | ~     | ✓     | ✓     | ✓     | ~     |
| S17 [63] Román-Martínez et al. (2023) | ✓     | ~     | ×     | ✓     | ×     | ~     |
| S18 [64] Hema et al. (2026)           | ✓     | ~     | ×     | ✓     | ✓     | ~     |
| S19 [67] Soohoo et al. (2026)         | ~     | ~     | ×     | ~     | ~     | ~     |
| S20 [69] Tan et al. (2024)            | ✓     | ✓     | ✓     | ×     | ~     | ~     |
| S21 [71] Tith et al. (2020)           | ✓     | ~     | ×     | ✓     | ~     | ~     |
| S22 [72] Tremper et al. (2026)        | ~     | ~     | ×     | ~     | ~     | ~     |
| S23 [73] Tseng et al. (2025)          | ~     | ✓     | ×     | ~     | ~     | ~     |
| S24 [75] Wu et al. (2023)             | ~     | ~     | ~     | ~     | ~     | ~     |
| S25 [76] Wu and Zhang (2025)          | ✓     | ✓     | ×     | ×     | ×     | ✓     |
| Proposed framework (HALAH)            | ✓     | ✓     | ✓     | ✓     | ✓     | ✓     |

The matrix supports four observations. First, counting only full satisfaction, Req 1 is met by 12 of the 25 included studies, Req 2 by 7, Req 3 by 6, Req 4 by 10, Req 5 by 8 and Req 6 by 9. No requirement is unaddressed. However, none is met by a majority of the included studies, and Req 1, at 12 of 25, comes closest. Second, no study satisfies all six requirements together. The largest number of requirements fully satisfied by a single study is four. This number is reached by Madine et al. [53] on

Req 1, Req 2, Req 3 and Req 5 and by Panagoulas et al. [57] on Req 1, Req 4, Req 5 and Req 6. Six studies, namely Abbasi et al. [35], Al Amin et al. [38], Hagström et al. [47], Madine et al. [53], Punia et al. [61] and Wu et al. [75], carry no cross in any column, but each of them relies on Partial codes for at least two requirements. Five studies, namely Abbasi et al. [35], Phuyal et al. [59], Soohoo et al. [67], Tremper et al. [72] and Wu et al. [75], fully satisfy no requirement at all. Third, the pair of requirements that co-occurs most often is Req 1 with Req 4, which is found in seven studies (Albalwy et al. [37], Eneh et al. [44], Jaiman and Urovi [49], Panagoulas et al. [57], Román-Martínez et al. [63], Hema et al. [64] and Tith et al. [71]). The next most frequent pair is Req 4 with Req 5, which is found in six studies (Eneh et al. [44], Li et al. [51], Mei et al. [55], Panagoulas et al. [57], Punia et al. [61] and Hema et al. [64]). These two pairs reflect the maturity of single-party consent objects with purpose and time conditions. In contrast, Req 2 and Req 4 never co-occur in full. Req 3 co-occurs with Req 4 only in Punia et al. [61]. Req 3 co-occurs with Req 6 only in the two cryptographic threshold schemes of Zhao and Su [50] and Maruthi and Singh [54], neither of which has policy or temporal enforcement. Two triples are the most frequent, and each is found in three studies. The first is Req 1 with Req 4 and Req 5, in Eneh et al. [44], Panagoulas et al. [57] and Hema et al. [64], all of them single-party systems. The second is Req 1 with Req 4 and Req 6, in Albalwy et al. [37], Jaiman and Urovi [49] and Panagoulas et al. [57], all of them single-party systems whose Req 6 tick rests on empirical validation rather than a formal proof. The triples that include Req 3 are fewer. Req 1, Req 2 and Req 3 co-occur in Madine et al. [53] and in Tan et al. [69], neither of which enforces purpose or data scope or provides a formal argument; the quadruple of Madine et al. [53] also yields Req 1 or Req 2 with Req 3 and Req 5. Req 3, Req 4 and Req 5 co-occur in Punia et al. [61], where the threshold lies outside the policy predicate and no purpose term exists. Fourth, the two quadruples among the included studies share only Req 1 and Req 5 and are otherwise complementary in the way that the gap predicts. Madine et al. [53] combine multi-party approval with identity, consent representation and time, but not with policy or assurance. Panagoulas et al. [57] combine consent representation, policy, time and validation, but not with multi-party approval or identity depth.

The comparison therefore indicates that the principal contribution of the proposed framework is not the replacement of existing technologies, each of which the literature has developed to a high standard in isolation. The contribution lies in establishing an explicit and verifiable relationship among them. In the proposed framework the consent object *C* carries the identity, authority, multi-party threshold, purpose and data-scope, temporal and lifecycle conditions together. The authorisation decision is the conjunction of their independent verification, and this conjunction is both formally argued and validated through positive and negative test cases. No reviewed study occupies this integrated position, which is

represented by the final row of Table 9. The next section states the resulting research gap requirement by requirement.

## 2.5 Synthesis and Research Gap

This section synthesises the review of Section 2.4 against the six requirements defined in Section 2.2. The counts stated in this section refer to the 25 included studies. Across the corpus, the requirement that is most often satisfied is the representation of consent as an evaluable authorisation object (Req 1), which 12 studies satisfy fully and 13 satisfy in part. Policy- and context-aware enforcement (Req 4) is satisfied fully by 10 studies, in part by 11 and not at all by 4. Temporal validity and lifecycle control (Req 5) is satisfied fully by 8 studies, in part by 13 and not at all by 4. Decentralised verification of identity and authority (Req 2) is satisfied fully by 7 studies and in part by 18, and no included study is without an identity mechanism. Multi-party authorisation through a verifiable threshold (Req 3) is the least satisfied requirement: 6 studies satisfy it fully, 4 satisfy it in part and 15 do not address it. With respect to Req 6, formal security assurance of the authorisation decision is provided by 4 studies and argued informally by 9, while 12 studies offer no security analysis beyond assertion; empirical validation is complete in 5 studies, partial in 19 and absent in 1. It should be noted that these proportions are consistent with the signal prevalence in the wider full-text pool of 1,800 records described in Section 2.3.6, as recorded by the signal detectors of the screening workbook, in which only 8% of the records carry a multi-party signal, 2% a temporal-validity signal and 1% a formal-verification signal, compared with 74% for audit or evidence and 69% for a prototype or experiment. The scarcity observed among the included studies is therefore a property of the field and not an artefact of the selection.

It should be noted that the most important correction which the review makes to the framing of this research concerns multi-party authorisation. Read on their own, the background surveys [1]-[34] suggest that multi-party authorisation of patient consent does not exist in the literature. The full-text coding does not support that suggestion. That statement is withdrawn. The coding panel identified six distinct mechanism classes in which more than one party participates in an authorisation-related decision. Madine et al. [53] require regulator and guardian approvals on a single access request, but only on the incapacitated and emergency paths; on the normal path a single patient key authorises, so that joint approval is a contingency rather than a standing condition. Wu et al. [75] apply a (t, n) threshold of investigators, but the threshold governs the admission of a trial record to the ledger and the revocation of a consent rather than the grant, and the vote itself reduces to a hash-integrity check. Zhao and Su [50] place the threshold among consumer-side delegates who are already within the access policy, and Tan et al. [69] place it among patient-appointed witnesses who act for a patient who is unable to act. Punia et al. [61] conjoin an institutional M-of-N signature with an attribute policy, but

the signature is reserved for high-sensitivity and cross-departmental requests, lies outside the decision predicate and can be bypassed by a single emergency officer. Ekholm et al. [43] report a deployed platform in which all legal guardians must co-sign at consent registration, and Hagström et al. [47] report national patient portals in which guardian proxy access is gated by register-verified guardianship, a professional's capacity assessment and the minor's own consent. In addition, Maruthi and Singh [54] distribute a threshold key among patient-designated relatives, and Abbasi et al. [35] among automated oracles, so that the threshold protects key custody rather than expressing an authorisation judgement. Therefore, multi-party approval exists in the reviewed literature in six forms. The first three are joint approval on a contingency path with key-share reconstruction, an institution-side admission gate and a consumer-side delegated threshold. The other three are a patient-appointed witness threshold, a custodial M-of-N around a policy engine and a guardian co-consent at consent registration. No reviewed study treats it as a constitutive predicate that every access decision must satisfy together with the identity, policy and temporal conditions. In addition, no study defines the approving set through the patient and evaluates it on every request.

A similar qualification applies to Req 4 and Req 5. Purpose of use is evaluated inside the decision in several studies. Tith et al. [71] and Albalwy et al. [37] match a purpose tree or a purpose tuple, Jaiman and Urovi [49] match ontology terms, Román-Martínez et al. [63] evaluate the FHIR purpose-of-use through an XACML decision point, Eneh et al. [44] evaluate purpose, data category and jurisdiction in an on-chain rule set, and Panagoulas et al. [57] verify a purpose conjunct at scale. However, every one of these studies is single-party, and the one study that conjoins a policy engine with a multi-party signature, Punia et al. [61], carries no purpose term and consumes consent as a Boolean attribute. In the cryptographic schemes the policy is bound to the ciphertext or to the requester's attributes rather than to the consent [78, 46, 56], and in the deployed research infrastructures the purpose is displayed or logged rather than evaluated [72, 74, 73]. Purpose and data-scope policy that is bound to the consent object and conjoined with multi-party approval is therefore largely absent. Temporal enforcement inside the decision is rare. Eneh et al. [44] evaluate the validity bounds of a rule at request time, the key-derivation scheme in [64] binds the expiry into the key so that decryption after expiry is unreachable, Madine et al. [53] discount stale attestations, and Punia et al. [61] check token expiry on access. In most other studies the time element takes one of four forms. It is a stored timestamp [37, 71] or an expiry field that the decision algorithm never reads [58]. Otherwise it is a session or token lifetime rather than a consent validity window [73, 67, 51], or a claimed auto-expiry with no enforcement locus [68, 70]. Verified revocation with an observed denial is reported by Panagoulas et al. [57] and Phuyal et al. [58], in a demonstration by Eneh et al. [44], and in a single

narrated scenario in [68]; elsewhere revocation is specified and its cost measured, but its effect on a subsequent request is not exercised [61, 62, 60]. Therefore, the gap under Req 5 is not the absence of temporal mechanisms. The gap is that the validity interval, revocation and state transitions are not enforced at the consent object itself and verified at decision time in a multi-institution exchange.

Formal assurance of the authorisation decision is almost absent, and where it exists it is narrow. The four included studies with a formal proof, Wu and Zhang [76], Zhao and Su [50], Maruthi and Singh [54] and Mei et al. [55], together with the two supporting references that carry a proof, Gao et al. [48] and Luo et al. [52], prove anonymity, unforgeability, confidentiality or revocation properties of a cryptographic gate over one or two conditions. None of them contains a theorem stating that access is granted only if a conjunction of identity, authority, policy, temporal and lifecycle conditions holds, because none of them implements such a conjunction. Conversely, the studies with the broadest decision predicates, Punia et al. [61], Madine et al. [53], Ferreira et al. [45], Phuyal et al. [58], Shanmugham and Senthilkumar [66] and Panagoulas et al. [57], provide at most a threat table or a structured adversary model. Across the corpus, therefore, the breadth of the decision predicate and the strength of its assurance vary inversely, and no study occupies the position in which a broad predicate is formally proved. The empirical evidence shows the same pattern from the other side. Five studies report a complete empirical evaluation [37, 47, 49, 57, 58], and only Panagoulas et al. [57] and Phuyal et al. [58] verify ALLOW and DENY outcomes systematically, the former in a single-node simulation and the latter without adversarial tests. A larger group of studies builds and measures a decision path without verifying a single authorisation decision [61, 35, 65, 72, 78, 36]. Sawant and Gomes [65] run the broadest measurement campaign in the corpus. They report no outcome for the access-control function that they formalise. When the formal and empirical halves of Req 6 are combined, nine of the 25 included studies would reach a tick in the combined Req 6 column of the tables of Section 2.4, but no study combines a formal proof of its decision with a systematic empirical test of that decision.

Therefore, the review establishes two gaps rather than one. The first is a conjunction gap. Identity and authority verification, collective approval, purpose and data-scope policy, temporal validity and lifecycle control each exist in the literature. Several of them exist in mature form. A number of studies combine three or four of them in one design [58, 61, 45, 66, 57]. However, no study conjoins identity, authority, threshold, policy, temporal, jurisdictional and lifecycle conditions in one decision predicate in which multi-party approval is a standing condition of every access decision and in which the patient, rather than an institution, defines the approving set. The second is an assurance gap. Where the conditions do co-exist, they are neither proved nor tested as an authorisation decision, and where a proof exists it covers a fragment of the predicate. The proposed framework is

positioned against these two gaps. The consent object C carries the guardian set G and the threshold N together with the identity, policy, temporal, jurisdictional and lifecycle components. The access decision is the conjunction of the corresponding predicates, and the conjunction, rather than any single component, is the object of both formal and empirical assurance. It should be noted that the framework is not positioned on the idea of an evaluable consent object, which the literature has provided since 2020 [71, 37], nor on the existence of a threshold mechanism, which the six classes above provide. It is positioned on the conjunction of the conditions and on the assurance of that conjunction.

### **2.5.1 Research Gaps in the Existing Studies from the Requirement Perspective**

Gap 1 (Req 1): The strongest evaluable consent objects in the reviewed studies are the purpose-based tuple of Tith et al. [71], the ontology object of Albalwy et al. [37], the on-chain consent object of Phuyal et al. [58], the consent token of Shanmugham and Senthilkumar [66], the rule structure of Eneh et al. [44] and the policy object of Panagoulas et al. [57]. Each of them carries a subset of the required components: Tith et al. [71] and Albalwy et al. [37] carry no temporal component, Eneh et al. [44] and Shanmugham and Senthilkumar [66] carry no authority requirement beyond the single patient, and Phuyal et al. [58] store an expiry that the decision algorithm does not read. In the 13 included studies coded as partial, and in the supporting references, the consent is a Boolean flag, a logged event or a status that is displayed rather than evaluated [36, 60, 65, 74], and in Punia et al. [61] the object that carries a lifecycle is the policy rather than the consent. What remains open is a consent object that represents the participating identities, the authority requirement including the guardian set and the threshold, the purpose and data scope, the validity interval, the jurisdiction, the lifecycle state and the evidence as separately evaluable components. This gap corresponds to research question RQ1 of Chapter 3.

Gap 2 (Req 2): The clearest separations of identity from authority are found in five places. In Ekholm et al. [43] and Hagström et al. [47] guardianship is verified against a national population register independently of the eID login. In Phuyal et al. [58] a licensing-body credential asserts role and scope of practice separately from the wallet identity. In Wu and Zhang [76] a zero-knowledge proof binds the owner's authorisation to a specific requester key. Separate authority evidence is also found in Tan et al. [69], Madine et al. [53] and Tseng et al. [73]. In the 18 included studies coded as partial the identity is a wallet address or a platform certificate, the role is administratively assigned or self-selected at login [36, 44], and the authority to act on behalf of a patient is not evidenced at all. The register-based guardian verification of [43, 47] is centralised, and the DID and VC designs [58, 45, 66] carry no guardian credential. What remains open is decentralised evidence of both identity and authority for every participant

in a consent, including the guardians, with the two conditions evaluated separately. This gap corresponds to research question RQ2 of Chapter 3.

Gap 3 (Req 3): The strongest multi-party mechanisms are those of Madine et al. [53], Tan et al. [69], Punia et al. [61], Zhao and Su [50], Maruthi and Singh [54] and Ekholm et al. [43], with partial mechanisms in Wu et al. [75], Hagström et al. [47], Al Amin et al. [38] and Abbasi et al. [35]. As set out above, the joint approval in these studies is limited in one of four ways. In some studies it is contingent on the absence of the patient [53, 69, 54], or it is reserved for particular request classes and bypassable in an emergency [61]. In others it is placed among consumer-side delegates or institution-side investigators rather than patient-side parties [50, 75], or it is applied at consent registration rather than at each access decision [43, 47, 38]. None of the six mechanism classes is conjoined with a purpose or data-scope condition, and the two threshold gates that are formally proved [50, 54] are proved in isolation from any policy, temporal or lifecycle condition. What remains open is a verifiable threshold over a patient-defined approving set that is a standing component of the access-decision predicate and is evaluated on every request. This gap corresponds to research question RQ3 of Chapter 3.

Gap 4 (Req 4): The strongest policy enforcement is found in Eneh et al. [44], whose on-chain rules evaluate purpose, data category, sensitivity, jurisdiction and action with deny-by-default, and in Panagoulas et al. [57], who verify a purpose conjunct over thousands of requests. Román-Martínez et al. [63], Tith et al. [71], Albalwy et al. [37] and Jaiman and Urovi [49] evaluate purpose against the consent. The key-derivation scheme of [64] binds role and consent into the key, and the attribute policy of Punia et al. [61] is evaluated in a conjunctive predicate. In the remaining studies the policy is bound to the requester's role or attributes or to the ciphertext rather than to what the patient authorised [46, 56, 78, 36]. Alternatively, the purpose is captured for audit but not adjudicated [72, 73]. In other cases the policy is described but not enforced [39, 41, 59]. Jurisdiction appears as a rule attribute only in Eneh et al. [44], and the declared purpose is never attested. What remains open is a purpose and data-scope policy that is bound to the consent object, evaluated together with the jurisdiction on every request, and conjoined with the multi-party approval condition. This gap corresponds to research question RQ4 of Chapter 3.

Gap 5 (Req 5): Temporal validity is enforced inside the decision by Eneh et al. [44], the scheme in [64], Madine et al. [53], Punia et al. [61] and Panagoulas et al. [57], credential or attribute expiry is enforced by Li et al. [51] and Mei et al. [55], and age windows are demonstrably enforced in the national portal studied by Hagström et al. [47]. Explicit lifecycle state machines are found in Phuyal et al. [58], Wu et al. [75] and Shanmugham and Senthilkumar [66], and verified revocation in Panagoulas et al. [57] and Phuyal et al. [58]. However, the enforced window is usually attached to a token, a key or a credential rather than to the consent [73, 51, 77]. The



stored expiry of the consent is not read by the decision [58], and revocation does not invalidate tokens already issued [73]. No study verifies expiry, revocation and state transition together at the consent level in a multi-institution exchange. What remains open is the enforcement of the validity interval, immediate and verifiable revocation, and controlled transitions between lifecycle states of the consent object itself at every access decision. This gap corresponds to research question RQ5 of Chapter 3.

Gap 6 (Req 6): Formal proofs are provided by Wu and Zhang [76], Zhao and Su [50], Maruthi and Singh [54], Mei et al. [55], Gao et al. [48] and Luo et al. [52], in each case for a cryptographic property of a narrow predicate. Complete empirical evaluations are provided by Panagoulas et al. [57], Phuyal et al. [58], Albalwy et al. [37], Jaiman and Urovi [49] and Hagström et al. [47], and systematic adversarial testing without formal content by Tremper et al. [72] and Sawant and Gomes [65]. No study provides both. The studies with the broadest predicates [61, 53, 45, 66] provide neither a proof nor an ALLOW and DENY test of the decision, and Phuyal et al. [58], which does test both outcomes, provides no formal argument. What remains open is the formal definition and proof of the properties of the conjoined predicate, namely identity correctness, authorisation integrity, threshold security, temporal safety and lifecycle safety, together with an empirical evaluation that demonstrates the refusal of the negative cases. This gap corresponds to research question RQ6 of Chapter 3.

The proposed research addresses this gap by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object rather than simply as a database entry, consent receipt, or blockchain transaction. Decentralised identifiers and verifiable credentials are used to establish trusted identity and authority inputs. Multi-party authorisation mechanisms determine whether the required independent participants have collectively satisfied the authorisation condition. Policy-aware access control evaluates whether a requested operation remains within the authorised purpose and data scope.

The foundational authorisation decision investigated in the current stage of the research can therefore be represented as

$$\begin{aligned} Decision(C, R, t) = ALLOW &\Leftrightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L \\ Decision(C, R) = ALLOW &\Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R), \end{aligned} \tag{1}$$

where  $V_I(u)$  represents the validity of the identity and relevant authority evidence associated with participant  $u$ ,  $V_A(C)$  represents the satisfaction of the required multi-party authorisation condition for consent  $C$ , and  $V_P(C, R)$  represents compliance between the consent and the requested operation  $R$ .

$V_T(C, t)$  represents the temporal validity of the request instant and  $V_L(C)$  represents the jurisdictional constraint. This is the rule enforced by the implemented Consent Engine, in which every access request is evaluated

over the complete tuple. All five predicates are enforced in the implemented Consent Engine and are evaluated empirically in the later chapters of this report.

This formulation represents the principal conceptual contribution of the current research stage. It shifts the focus from determining whether consent has merely been recorded towards determining whether a data-access decision has been generated under sufficient and independently verifiable trust conditions.

In this context, the principal research opportunity identified by the literature is not the development of another isolated blockchain consent mechanism or identity-management system. Instead, the opportunity lies in constructing a coherent trust-oriented authorisation model in which the different security mechanisms contribute to a common and explainable authorisation decision. Trustworthy healthcare data sharing can then be evaluated not simply according to whether a consent record exists, but according to whether the combined identity, authority, collective authorisation, policy, temporal and jurisdictional conditions required for access have been satisfied.

## **2.6 Conclusion**

This chapter has presented a systematic literature review, conducted and reported in accordance with PRISMA 2020, of the studies that address the authorisation of patient consent in decentralised healthcare data sharing. Six requirements for a trustworthy multi-party consent authorisation framework were defined in Section 2.2 and used as the basis of comparison throughout the chapter. Seven frozen database searches, supplemented by a Google Scholar discovery arm, identified 9,256 records, of which 6,039 unique records were screened by title. After abstract screening, full-text assessment and quality appraisal, 25 primary studies published between 2020 and 2026 were included, together with 19 supporting references retained outside the corpus and three secondary studies that were used as background only. The studies were reviewed in six streams corresponding to the six requirements, and each study was assessed against all six requirements in the tables of Section 2.4.

It should be noted that the review has limitations. The 588 pending-abstract records described in Section 2.3.6 were not screened, the full-text pool of 1,800 records was read in a prioritised order under the saturation rule rather than exhaustively, and the coding was performed by a single panel, so that a small number of relevant studies may have been missed. The consistency between the coding of the included studies and the signal prevalence of the wider pool, reported in Section 2.5, limits but does not remove this risk.

The review found that the individual conditions of a trustworthy authorisation decision are each represented in the literature. Evaluable consent objects have existed since 2020. Purpose-based and attribute-

based policy engines operate inside the decision in a number of systems, and temporal validity and revocation are enforced at decision time in a few. Identity and authority are separated most clearly where guardianship or professional licensing is verified against an external register or credential. Multi-party approval exists in six mechanism classes. The review also found that these conditions are not conjoined. Multi-party approval does not appear as a standing condition of every access decision. It appears instead as joint approval on a contingency path with key-share reconstruction, an institution-side gate or a consumer-side delegated threshold. In other studies it appears as a patient-appointed witness threshold, a custodial M-of-N around a policy engine, or a guardian co-consent at consent registration. The purpose and data-scope policy is never conjoined with multi-party approval. Temporal and lifecycle enforcement at the consent level is rarely verified. Formal assurance, where it exists, covers a narrow cryptographic predicate, while the broadest predicates are neither proved nor tested. The research gap is therefore a conjunction gap and an assurance gap, as stated in Section 2.5 and decomposed by requirement in Section 2.5.1.

These two gaps define the research undertaken in the remainder of this report. The conjunction gap motivates a consent object whose components are evaluated as separate predicates. These components are the participating identities, the guardian set  $G$  and the threshold  $N$ , the purpose and data scope, and the validity interval. They also include the jurisdiction, the lifecycle state and the evidence, and the conjunction of these predicates determines every access decision. The assurance gap motivates the formal definition of the security properties of that conjunction and their empirical validation in the HALAH prototype. In this context, the six requirements of Section 2.2 and the six gaps of Section 2.5.1 correspond one to one to the six sub-research questions and the six research objectives that follow. Chapter 3 defines the key terms and states the research questions.

Figure 5 summarises this synthesis, showing that each requirement is satisfied by some of the 25 studies while no study conjoins all six conditions in one assured access decision.

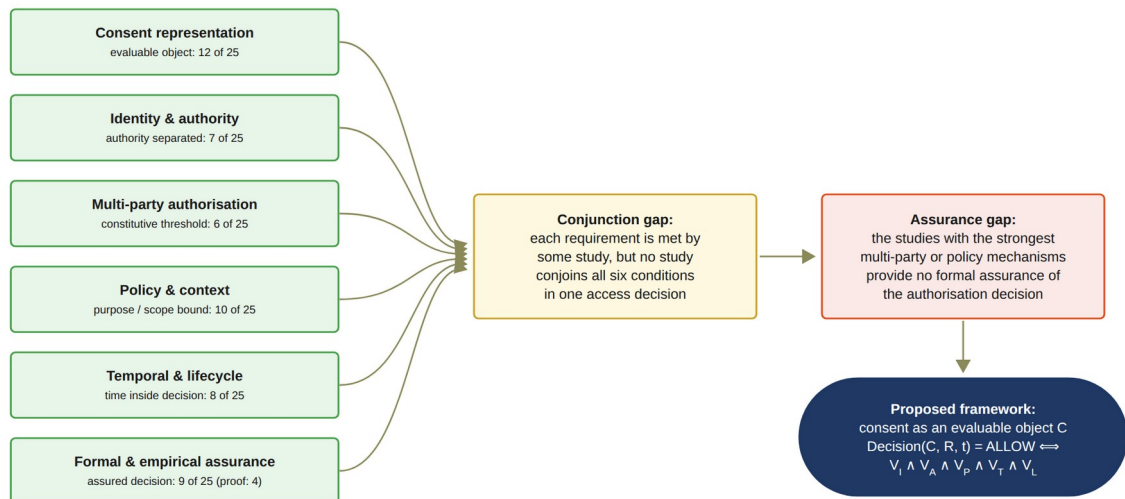


Figure 5: Synthesis of the review: each of the six requirements is satisfied by some of the 25 studies, but no study conjoins all six conditions in one access decision (conjunction gap) and the strongest mechanisms lack formal assurance (assurance gap); the proposed framework addresses both by treating consent as an evaluable authorisation object.

### 3 Research Gaps and Questions

#### 3.1 Research Gap

The systematic literature review of 25 primary studies presented in Chapter 2 (Section 2.5) indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. Representative examples are the blockchain EHR review of [1] and the dynamic consent model of [13], the DID and VC survey of [20], the attribute-based encryption scheme of [32], the access-control survey of [25] and the multi-party mechanisms of [53, 61, 69]. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions. The few studies that coordinate several of them in one decision [58, 61, 45, 66, 57] do not make multi-party approval a standing condition of that decision and do not assure the conjunction formally or empirically.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, many consent-oriented approaches still treat consent primarily as a record or a Boolean flag [36, 60, 65], and even the evaluable consent objects reported since 2020 [71, 37, 44, 58, 66] carry only a subset of the conditions and are issued by a single party, as established in Section 2.5. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred. It does not necessarily establish that the requester possesses the required authority, or that all required parties have independently approved the access. It also does not establish that the requested operation is consistent with the purpose and data scope originally authorised by the patient.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event [2, 28], but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is [20], but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but in the reviewed studies it is never conjoined with a purpose or data-scope condition [61, 53, 69], and

approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as the outcome of several independent conditions that are each verified and that are all satisfied together. The relevant conditions are the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of the required collective approval and the compliance of the requested operation with the policy defined by the consent. In this context, the research does not treat trust as a static attribute of a particular entity or technology. It treats trust as a property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows. Existing healthcare consent and access-control research provides many of the necessary technological building blocks. However, there remains a need for an authorisation framework in which the consent object carries identity, authority, threshold, policy, temporal, jurisdictional and lifecycle conditions. In this framework, multi-party approval must be a standing condition of every access decision, and the conjunction of these conditions must be formally and empirically assured. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent.

In the terms of Section 2.5, these two requirements correspond to the conjunction gap and the assurance gap respectively. It should be noted that the approving set must be defined by the patient rather than by an institution. In the reviewed studies, the approving set is either defined on the institutional or delegate side [61, 50, 75], or it is appointed by the patient [69, 54]. In the latter case, it is evaluated only as a contingency path or as a key-custody threshold rather than on every access request.

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular

access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

For clarity, the following terms are used throughout the remaining chapters. The patient is the data subject who creates the consent object C. The guardian set G is the set of designated participants whose independent approval is required, and the threshold N is the number of valid guardian approvals needed for activation. The authorised doctor D is the requester whose access request R is evaluated against C.

### **3.2 Main Research Question**

Before the question is stated, the scope of the current stage should be noted. Temporal and lifecycle trust has been operationalised in the current prototype, and empirical validation has been partially completed through automated and live negative testing. The formal component of security assurance therefore forms the remaining research scope and is developed in the next stage of the research (Section 9.2).

Based on the identified research gap, the overarching research question is formulated as follows:

*How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?*

The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

The main research question therefore encompasses both the conceptual and technical dimensions of the research. At the conceptual level, it investigates how trust should be represented and reasoned about within a multi-party consent environment. At the technical level, it investigates how these trust conditions can be operationalised through decentralised identities, verifiable credentials, multi-party authorisation, and policy-aware access control. The question consequently provides the basis for both the proposed framework and its subsequent implementation and evaluation.

For the current stage, the investigation is deliberately focused on the foundational conditions required to establish trustworthy authorisation. These conditions are represented through the first four of the six interconnected sub-research questions presented in Section 3.3,

concerning consent modelling, identity and authority trust, multi-party authorisation, and policy-aware access control. The remaining two sub-questions, addressing temporal and lifecycle trust and formal security assurance, complete the six-question structure; the fifth is operationalised in the current prototype, and the formal component of the sixth is carried into the next stage of the research.

### 3.3 Sub-Research Questions

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework, while the six questions collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation.

Each sub-research question corresponds to one of the six requirements defined in Section 2.2 (Req 1 to Req 6) and to the associated gap identified in Section 2.5, so that SRQ1 to SRQ6 address, respectively, the representation, identity, threshold, policy, lifecycle and assurance requirements that no reviewed study satisfies together. For brevity, the sub-research questions SRQ1 to SRQ6 are referred to as RQ1 to RQ6 in Chapter 4 and in the remaining chapters, except in Section 5.1, where the full label SRQ is retained in the mapping of each sub-research question to the MVC layers.

#### 3.3.1 SRQ1: Trust-Centric Consent Modelling

The first sub-research question is:

*How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?*

The purpose of this question is to establish the conceptual foundation of the framework. Rather than representing consent as a simple association between a patient, a requester, and a permission, the proposed model represents consent as a structured and evaluable authorisation object such that

$$C = (I, A, P, E), \quad (2)$$

where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence.

This formulation changes the role of consent from a passive record into an evaluable authorisation object. The security significance of the consent is not determined merely by the existence of a consent record. It is



determined by whether the associated trust, authority, policy and evidence conditions remain valid when an access request is evaluated.

SRQ1 therefore establishes the conceptual representation required by the subsequent identity, multi-party authorisation, policy, and security-assurance mechanisms.

### 3.3.2 SRQ2: Decentralised Identity and Authority Trust

The second sub-research question is:

*How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?*

A fundamental principle of the proposed framework is that identity and authorisation should not be treated as equivalent. A valid decentralised identifier establishes the identity of a participant, while a verifiable credential provides evidence concerning the participant's role or authority [20, 16]. Therefore, Identity  $\neq$  Authorisation. The identity and authority validity condition is represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (3)$$

This separation prevents successful authentication from being interpreted as automatic authorisation. For example, authenticating a healthcare professional identified by a DID does not by itself establish that the professional is authorised to access a particular patient's data. Identity and authority verification instead provide trusted inputs to the subsequent authorisation evaluation process.

SRQ2 therefore addresses how trustworthy participants can be established before their participation in collective authorisation decisions.

### 3.3.3 SRQ3: Trustworthy Multi-Party Authorisation

The third sub-research question is:

*How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?*

This question addresses the collaborative authorisation problem. Let  $A_v$  denote the set of independently verified authorisation participants and let  $N$  denote the required authorisation threshold. In this context,  $A_v$  is the subset of the guardian set  $G$  whose approvals have been independently verified, so that  $A_v \subseteq G$  and  $1 \leq N \leq |G|$ . Multi-party authorisation is defined as

$$V_A(C) = \{ 1, |A_v| \geq N; 0, |A_v| < N. \} \quad (4)$$

Consequently,

$$|A_v| < N \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (5)$$

In the implemented framework,  $N$  is instantiated as  $|G|$ , the number of designated guardians, so that activation requires the approval of every listed guardian. Configurable  $k$ -of- $n$  thresholds are identified as future work (Section 9.2), and the evaluated configuration is 2-of-2.

This formulation allows the framework to distinguish explicitly between sufficient and insufficient collective participation. It also reduces reliance on a single authorising participant where a predefined threshold of independent approvals is required.

In this context, SRQ3 changes the interpretation of trust. Trust is no longer an assumption about a single trusted entity. It is a property that is established when several independently verified participants have jointly satisfied the authorisation requirement.

### 3.3.4 SRQ4: Policy- and Context-Aware Access Control

The fourth sub-research question is

*How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?*

Multi-party approval alone does not guarantee that a data-access request is legitimate. A requester may possess a valid identity and the required approvals while requesting information beyond the authorised scope. The framework therefore introduces an explicit policy predicate

$$V_P(C, R) = \text{Policy}(C, R), \quad (6)$$

which evaluates whether the requested operation satisfies the purpose and data-scope constraints defined by the consent object.

The consent object against which this predicate is evaluated is the six-component object

$$C = (I, A, P, T, L, E) \quad (7)$$

where  $I$  represents the participating identities,  $A$  represents the authority requirements, namely the guardian set  $G$  and the approval threshold  $N$ ,  $P$  represents the purpose and data-scope constraints,  $T$  represents the temporal validity window,  $L$  represents the jurisdictional constraint, and  $E$  represents the authorisation evidence, including the record of whether the consent remains active or has been revoked. It should be noted that the question of SRQ1 and Equation (2) name four dimensions, namely identity, authority requirements, policy constraints and authorisation evidence, whereas the consent object contains six components. The temporal component  $T$  and the jurisdictional component  $L$  are required by Gap 1 of Section 2.5.1 and were made explicit during implementation as constraints of the policy dimension; the jurisdictional constraint is motivated by Gap 4

and the temporal constraint by Gap 5 of Section 2.5.1, and both are evaluated as the separate predicates  $V_L$  and  $V_T$  defined in Section 6.5 rather than as an additional sub-research question. For example, if a consent authorises access to the data scope  $S_C = \{\text{Observation}, \text{Medication}\}$  and the access request declares the scope

$$S_R = \{\text{Observation}, \text{Medication}, \text{Procedure}\}, \quad (8)$$

the request must be rejected when

$$S_R \not\subseteq S_C. \quad (9)$$

Similarly, a request may be rejected when its declared purpose is inconsistent with the purpose specified in the consent.

Therefore, trustworthy authorisation requires trusted participants and sufficient approvals, and in addition it requires compliance between the requested operation and the authorisation policy.

SRQ4 therefore completes the foundational access-control mechanisms by connecting participant trust and collective authorisation with the actual operation being requested.

### 3.3.5 SRQ5: Temporal and Lifecycle Trust

The fifth sub-research question is

*How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?*

Trustworthy authorisation is inherently dynamic. A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely, as recognised in the dynamic consent literature [24, 13]. Let the validity interval of a consent object be  $[t_s, t_e]$ . Temporal validity is defined as

$$V_T(C, t) = 1, t_s \leq t \leq t_e; 0, \text{ otherwise.} \quad (10)$$

Consequently,

$$t < t_s \vee t > t_e \Rightarrow \text{Decision}(C, R, t) = \text{DENY}. \quad (11)$$

Temporal validity must also be evaluated together with the lifecycle state of the consent. The lifecycle can be represented as

$$\text{Specification} \rightarrow \text{Verification} \rightarrow \text{Approval} \rightarrow \text{Active} \rightarrow \text{Expiration/Revocation}. \quad (12)$$

The lifecycle validity predicate  $V_S$  can therefore be represented as

$$V_S(C) = \text{ValidState}(C) \wedge \text{ValidTransition}(C). \quad (13)$$

An authorisation decision consequently requires both temporal and lifecycle validity. A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even

when its original identity, authority, and approval conditions were valid. In the implemented framework, the state and revocation conditions of  $V_S$  are evaluated as part of the collective authorisation predicate  $V_A$ , whereas Section 6.5 additionally evaluates  $V_S$  as a composite temporal and lifecycle predicate  $V_S(C, t, q)$  that includes the temporal condition of  $V_T$ . This is important because only a consent in the ACTIVE state can satisfy the authorisation condition. It should also be noted that the symbol  $V_L$  is reserved for the jurisdictional predicate, which corresponds to the component L of the consent object.

It should be noted that Section 6.4 also writes the data-scope condition of Equation (9) as  $V_S(C, R)$ ; for this reason the lifecycle predicate is written with three arguments,  $V_S(C, t, q)$ , wherever the two could be confused.

SRQ5 therefore extends the foundational authorisation model into a dynamic consent environment in which trust is continuously evaluated according to both temporal conditions and lifecycle state.

### 3.3.6 SRQ6: Formal Security Assurance and Empirical Validation

The sixth sub-research question is

*How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?*

This question integrates the formal security analysis and empirical validation of the proposed framework. The purpose is to determine whether the prototype can execute valid consent workflows. In addition, the purpose is to establish whether the implemented mechanism conforms to the security properties defined by the conceptual model.

The overall authorisation decision is defined as a conjunction of independently evaluated predicates

$$Decision(C, R, t) = \{ ALLOW, V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L; DENY, otherwise. \} \quad (14)$$

The corresponding security properties include identity correctness, which can be formulated as

$$u \in A_v \Rightarrow V_I(u) = I, \quad (15)$$

authorisation integrity

$$\neg (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow Decision(C, R, t) = DENY, \quad (16)$$

threshold security, formulated as

$$|A_v| < N \Rightarrow Decision(C, R) = DENY, \quad (17)$$

and temporal safety, formulated as

$$t \notin [t_s, t_e] \Rightarrow Decision(C, R, t) = DENY. \quad (18)$$

Lifecycle safety additionally requires that unauthorised state transitions be rejected

$$\text{IllegalTransition}(C) \Rightarrow \text{Reject}. \quad (19)$$

The formal analysis provides a theoretical assurance layer that is independent of the empirical execution of the prototype. Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable.

The empirical component evaluates whether the implemented HALAH framework realises these defined properties in representative decentralised healthcare data-sharing scenarios. Synthetic demonstration records, containing no real patient data, are used to construct representative consent workflows. The evaluation considers both successful and unsuccessful authorisation scenarios, including valid identity and credential verification, invalid identity or credential submission, insufficient multi-party approval, valid threshold-based approval, unauthorised data-scope requests, purpose violations, expired consent, revoked consent, and invalid lifecycle transitions.

For a representative multi-party consent scenario, if two authorised participants are required, then it yields

$$|A_v| = 2 \Rightarrow V_A = 1, \quad (20)$$

whereas

$$|A_v| = 1 \Rightarrow V_A = 0. \quad (21)$$

The prototype evaluation therefore examines whether the implemented framework correctly transitions a consent from an unapproved state to an active authorisation state only when all required conditions are satisfied, and whether subsequent access requests are rejected when any required trust condition is violated.

Audit records are generated throughout the workflow to provide evidence of consent creation, participant verification, approval events, authorisation-state evaluation, data-access decisions, and relevant lifecycle transitions.

The empirical evaluation is therefore not primarily intended as a high-throughput performance benchmark. Instead, it assesses functional security correctness and consistency between the conceptual model, formal security properties, and implemented authorisation behaviour.

SRQ6 therefore represents the final assurance stage of the research programme. It connects formal security reasoning with evidence from the implementation. Together, these two forms of analysis provide evidence that the proposed framework is conceptually defined and that it can also

enforce the intended trust-oriented authorisation properties in representative healthcare data-sharing scenarios.

### 3.4 Research Questions as an Integrated Research Problem

The six sub-research questions are not independent technical questions. They represent successive and interdependent trust conditions within a single healthcare data authorisation problem. Collectively, they investigate how patient consent can be transformed from a static permission record into a trustworthy, evaluable, and enforceable authorisation mechanism.

SRQ1 establishes the conceptual object against which trust and authorisation can be evaluated by modelling patient consent as a structured authorisation object. SRQ2 establishes the trustworthiness of the participants by verifying their decentralised identities and authority evidence while explicitly separating identity from authorisation. SRQ3 then extends this participant-level trust into a collective decision by requiring independently verified participants to satisfy a predefined authorisation threshold. SRQ4 determines whether the resulting authorisation is applicable to the specific data-access request by evaluating purpose and data-scope constraints. SRQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, SRQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly.

The integrated authorisation condition can therefore be expressed as

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (22)$$

where  $V_I$  represents identity and authority validity,  $V_A$  represents collective authorisation validity,  $V_P$  represents policy and contextual compliance,  $V_T$  represents temporal validity, and  $V_L$  represents jurisdictional compliance, while lifecycle validity  $V_S$  is evaluated within  $V_A$ . This five-predicate conjunction constitutes the decision rule of the implemented Consent Engine; the three-predicate formulation of Equation (24) represents the foundational core of RO1 to RO4, which the implemented rule extends with the temporal and jurisdictional predicates.

The jurisdictional predicate  $V_L$  is satisfied when the jurisdiction declared in the access request  $R$  matches the jurisdiction  $L$  recorded in the consent object, or when no jurisdiction is recorded; its formal definition is given in Equation (59) in Section 6.5.

This formulation provides the central logical relationship among SRQ1–SRQ5. A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial, such that

$$\neg (V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow Decision(C, R, t) = DENY. \quad (23)$$

The formulation also clarifies the role of SRQ6. Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Empirical validation subsequently examines whether the implemented system realises these properties under representative valid, invalid, and adversarial healthcare data-sharing scenarios. Thus, SRQ6 operates as an assurance layer over the mechanisms established by SRQ1–SRQ5 rather than as an additional access-control predicate.

The research questions are ordered so that each one builds on the previous one. SRQ1 establishes the consent representation. SRQ2 establishes participant trust on that representation. SRQ3 uses trusted participants to establish collective authorisation, and SRQ4 adds policy enforcement to the resulting decision. SRQ5 adds temporal and lifecycle control over the decision, and SRQ6 provides security assurance and validation of the whole. In this way the questions connect the interaction of the participants with the authorisation checks that the system performs.

The first four objectives are realised in full, while the fifth objective is realised operationally in the current prototype and the sixth objective is addressed empirically at this stage, with its formal component reserved for the next research programme.

This progression provides a research pathway from the representation of consent to the enforcement and assurance of trustworthy data access. It also clarifies that decentralised identifiers, verifiable credentials, threshold authorisation, policy enforcement and lifecycle controls are not independent blockchain or security features. In the proposed framework they are complementary mechanisms within a single trust-oriented authorisation model.

Accordingly, the contribution of the research is not simply the implementation of a blockchain-based consent prototype. The research investigates how multiple trust conditions can be represented explicitly, evaluated independently and enforced jointly in a decentralised healthcare data-sharing environment, and how the resulting decision can be reasoned about formally and validated empirically. The six research questions therefore define the integrated research problem together, and they correspond directly to the six research objectives.

## **4 Research Objectives**

The research objectives are derived from the research questions and translate the identified research gap into concrete research and development activities. The objectives are intentionally broader than individual implementation tasks. Each objective represents a research contribution that can be examined conceptually, technically, and, where appropriate, empirically. The complete research programme consists of six research objectives, corresponding to six research questions. The first four objectives establish the foundational trust-oriented authorisation mechanisms investigated during the current stage, RO5 has been operationalised in the current prototype. The empirical component of RO6 has been partially delivered, so that the formal component of RO6 and the remaining empirical work are carried into the next stage.

### **4.1 RO1 - Trust-Centric Consent Model**

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model will incorporate identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. In particular, it defines the information that must be represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

### **4.2 RO2 - Decentralised Identity and Authority Trust**

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority.

RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. Instead, identity and authority must be verified as distinct but related conditions of trustworthy authorisation.

### **4.3 RO3 - Trustworthy Multi-Party Authorisation**

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants can jointly establish a trustworthy consent decision.



In the implemented framework, the designated guardians are defined at consent creation, each EIP-712 approval is verified through signature recovery, and a valid signature is required from every listed guardian. Consequently, the threshold equals  $|G|$ , an N-of-N condition demonstrated in the 2-of-2 configuration.

The objective is to prevent unilateral authorisation where collective approval is required and to provide an explicit mechanism for distinguishing sufficient from insufficient participation.

RO3 directly addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

#### **4.4 RO4 - Policy- and Context-Aware Access Control**

In the implemented framework, the policy mechanism evaluates whether the requested purpose is consistent with the consent and rejects any request whose data scope is not a non-empty subset of the authorised EMR modules.

The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope.

RO4 directly addresses RQ4 and completes the foundational authorisation model investigated during the current stage. Together, RO1-RO4 establish the representation, verification, collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

#### **4.5 RO5 - Temporal and Lifecycle Trust**

This objective has been substantially realised in the current implementation. In particular, the prototype enforces the temporal validity window at every access decision through the predicate  $V_T$ , and records notBefore and expiry on-chain within the consent token. It also implements end-to-end revocation, including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. The remaining work therefore concerns hardening these controls and extending them to consent modification, delegation and guardian-set changes (Section 9.2), rather than introducing them.

RO5 addresses RQ5 and extends the foundational current stage authorisation model into a dynamic consent environment. Whereas the current stage establishes whether an authorisation can be considered valid under the defined identity, approval, and policy conditions, RO5 investigates whether that authorisation remains valid as time passes and as the consent state changes.

## **4.6 RO6 - Formal Security Assurance and Empirical Validation**

The empirical component of this objective has been partially delivered in the current stage, as reported in Section 7.6 and summarised later in this section. The automated tests cover signature rejection and proof tampering. A live out-of-jurisdiction request was refused on the deployed Sepolia contract, and an independent tool re-verified every recorded transaction against the chain. Consequently, the complete formal analysis, whether through proofs or model checking of the stated properties, remains the subject of the next stage of the research.

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios.

RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The formal component, which is planned for the next stage, will specify and analyse the security properties, consistency requirements and soundness conditions of the trust-oriented authorisation mechanism. The empirical component evaluates the implementation through representative consent workflows, negative and adversarial scenarios and testing of the HALAH prototype.

The objective is to establish that the prototype can execute valid consent workflows. In addition, the objective is to establish that the prototype behaves correctly when one or more trust conditions are violated. For example, the evaluation should examine whether access is denied when identity verification fails, when the required authorisation threshold is not satisfied, or when the requested purpose or data scope violates the consent policy.

RO6 therefore represents the transition from establishing the authorisation model to providing evidence for its security and practical effectiveness.

## **4.7 Relationship Between Research Questions and Objectives**

The current stage delivers RO1-RO5 in operational form together with the empirical component of RO6, including negative and adversarial testing. Consequently, the principal remaining agenda for CA3 is the formal component of RO6, namely the formal specification and analysis of the security properties, together with the systematic performance study and the identified prototype hardening (Sections 7.6 and 9.2).

The relationship between the six research questions and the six research objectives is summarised in Table 10 and Table 11, in which the last column names the section of this report where each objective is realised. Because each research question corresponds to one requirement of Section 2.2 and to one gap of Section 2.5.1, each objective also

corresponds to the gap of the same number, so that RO1 addresses Gap 1, RO2 addresses Gap 2, and so on to RO6 and Gap 6.

The formal component of RO6 constitutes the principal research agenda for the next stage of the research, whereas RO5 has already been operationalised in the current prototype. RO5 extends the authorisation model with temporal and lifecycle trust, while RO6 provides formal security assurance and comprehensive empirical validation. The distinction between the current stage and the next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives. The current stage establishes the foundational mechanisms, their conceptual relationships and their operational lifecycle controls, whereas the next stage investigates whether these mechanisms satisfy the formally defined security properties and whether their security can be formally demonstrated, building on the empirical evidence already obtained.

**Table 10:** Research Questions, Research Objectives, and Report Sections (RQ1 to RQ3)

| RQ  | Research Objective                              | Research Focus and Scope                                                                                                                                                                                                              | Report Section                        |
|-----|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| RQ1 | RO1: Trust-Centric Consent Model                | Develop a structured and evaluable consent representation that treats patient consent as a policy-bound authorisation object containing identity information, authority requirements, policy constraints, and authorisation evidence. | Section 6.1 (progress in Section 7.1) |
| RQ2 | RO2: Decentralised Identity and Authority Trust | Establish trustworthy participants using DIDs and VCs while explicitly separating identity authentication from authorisation authority.                                                                                               | Section 6.2 (progress in Section 7.2) |
| RQ3 | RO3: Trustworthy Multi-Party Authorisation      | Establish collective authorisation through independently verified participants and threshold-based approval mechanisms, thereby preventing unilateral authorisation when collective approval is required.                             | Section 6.3 (progress in Section 7.3) |

**Table 11:** Research Questions, Research Objectives, and Report Sections (RQ4 to RQ6)

| RQ  | Research Objective                                      | Research Focus and Scope                                                                                                                                                                                   | Report Section                        |
|-----|---------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|
| RQ4 | RO4: Policy- and Context-Aware Access Control           | Enforce purpose and healthcare data-scope constraints as explicit and evaluable conditions of access, ensuring that valid identities and sufficient approvals cannot be used outside the authorised scope. | Section 6.4 (progress in Section 7.4) |
| RQ5 | RO5: Temporal and Lifecycle Trust                       | Temporal validity, expiration, revocation and controlled state transitions, enforced in the current prototype and anchored on-chain                                                                        | Section 6.5 (progress in Section 7.5) |
| RQ6 | RO6: Formal Security Assurance and Empirical Validation | Formal analysis of the security properties (next stage), building upon the empirical negative and adversarial testing already performed with the HALAH prototype                                           | Section 6.6 (progress in Section 7.6) |

The overall research argument is that trustworthy patient consent should not be understood as a single technological artefact or as the outcome of a single access-control operation. It should be understood as a security decision that results from a set of independently verifiable conditions. The contribution of the research is therefore a trust-oriented authorisation framework through which these conditions can be represented, evaluated, enforced and validated in a decentralised healthcare data-sharing environment. For the foundational current stage model, the authorisation decision is expressed as

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (24)$$

where  $V_I(u)$  represents the validity of the requesting participant's identity and authority evidence,  $V_A(C)$  represents satisfaction of the required multi-party authorisation threshold, and  $V_P(C, R)$  represents compliance between the access request and the consent policy. The implemented decision model incorporates the temporal and jurisdictional conditions as follows

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C), \quad (25)$$

where  $V_T(C, t)$  represents temporal validity and  $V_L(C)$  represents jurisdictional compliance, while the lifecycle state and its transitions are

evaluated within  $V_A$  (C), as stated in Section 3.4 and Section 6.5. This formulation provides a consistent connection between the foundational objectives RO1 to RO4, the operational lifecycle controls of RO5 and the assurance objective RO6, whose formal component is planned for the next stage of the research.

## **5 Research Architecture: MVC**

The proposed research architecture adopts a Model-View-Controller (MVC) design to provide a structured implementation foundation for the trusted multi-party consent management framework. However, the MVC architecture is not used merely as a conventional software engineering pattern for separating data, interfaces, and application logic. Within the proposed framework, MVC is extended to support a more fundamental separation between the representation of consent, the interaction of independent stakeholders, and the enforcement of security-critical authorisation decisions. This separation is particularly important in decentralised healthcare data-sharing environments. A healthcare consent decision may involve patients, guardians, healthcare professionals, auditors, and other authorised entities, each of whom may possess different identities, authorities, responsibilities, and interests. Consequently, the system cannot rely on a single user authentication event or a static permission entry to determine whether access should be granted. Instead, the authorisation decision must emerge from the coordinated evaluation of independently verifiable security conditions. The proposed architecture therefore distinguishes three complementary responsibilities. The Model represents the security and governance state of the system, including identities, credentials, consent objects, authorisation requirements, policies, approval evidence, and healthcare data scopes. The View provides controlled interaction mechanisms through which independent participants can create, inspect, approve, or exercise consent-related operations. The Controller acts as the trusted decision coordination layer responsible for validating identity,

evaluating authority, aggregating multi-party approval evidence, enforcing policy constraints, and determining whether a requested healthcare data operation should be permitted. The architectural significance of this design is that the View cannot directly modify the authorisation outcome, while the existence of a Model object does not automatically imply that access is permitted. Instead, every sensitive access decision must pass through the Controller, which evaluates the relevant trust predicates associated with the consent and the access request. This provides a clear separation between what consent represents, how stakeholders interact with it, and how trust is enforced.

### **5.1 MVC Layered Architecture and Component Decomposition**

The proposed HALAH framework adopts a layered Model-View-Controller (MVC) architecture to provide a clear separation between consent representation, stakeholder interaction, and security-critical authorisation enforcement. The purpose of this architectural decomposition is not simply to follow a conventional software engineering pattern. Its purpose is to establish explicit boundaries between the information that represents trust and the interfaces through which participants express their actions. It also separates both of these from the mechanisms that determine

whether those actions should result in an authorisation decision. At the highest level, the architecture consists of three complementary layers: the View Layer, the Controller Layer, and the Model Layer. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Sensitive healthcare data are treated as protected resources whose access is mediated by the Controller rather than directly exposed to the View. Figure 6 illustrates the conceptual relationship among these layers with the architectural separation between stakeholder interaction, trust enforcement, and persistent governance state. The View Layer contains role-specific interaction interfaces through which patients, guardians or other authorised participants, healthcare professionals, and auditors submit or inspect system operations. These interfaces are intentionally separated from the security decision mechanism: an action submitted through the View represents a request or claim rather than a trusted authorisation outcome. The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include request validation, decentralised identity verification, credential and authority verification, multi-party approval evaluation, policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed. The Model Layer maintains the persistent security and governance state required by these evaluations. It includes identity and DID information, credential and authority evidence, consent objects, approval evidence, policy and data-scope constraints, authorisation evidence, and lifecycle state. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted. The protected healthcare data are deliberately positioned outside the three MVC layers as a protected resource. This distinction is important because healthcare data should not be treated as ordinary application state that can be directly manipulated by the View; instead, access to the protected resource is mediated by the Controller after the relevant trust conditions have been evaluated.

MVC was selected in preference to a purely on-chain design for two reasons. First, the authorisation decision must combine the identity, threshold, policy, temporal and jurisdictional evaluation performed by the Controller with the anchoring of consent state on the blockchain. Second, the pattern allows each stakeholder interface to be replaced without altering the enforcement logic. This is necessary if the trust predicates are to be evaluated independently of any particular user interface. without

altering the enforcement logic, which is necessary for evaluating the trust predicates independently of any particular user interface.

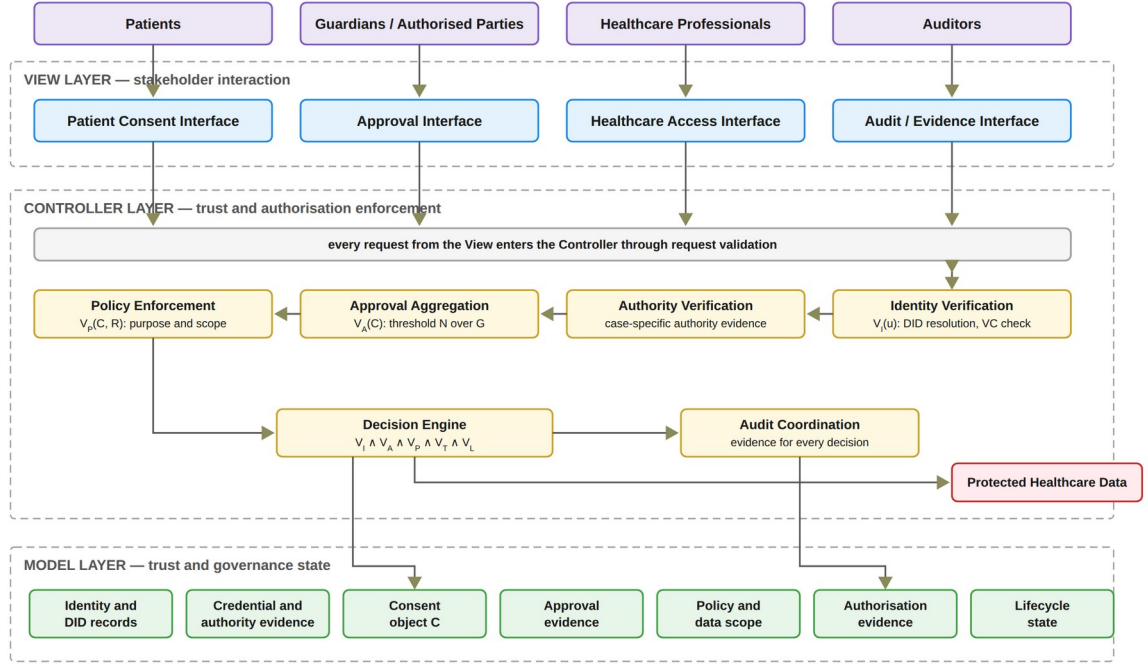


Figure 6: Layered MVC architecture and component decomposition of the HALAH framework

The Controller layer additionally incorporates two implementation components. The first is a ZK Proof Service, which generates and verifies the Groth16 proof and feeds its result directly into the Authorisation Decision. The second is an On-chain Anchor Service, which performs the minting and revocation transactions asynchronously. The Model layer correspondingly contains the ConsentSBTV3 contract deployed on Sepolia together with the application audit ledger. A revocation path flows from the Patient interface through the Controller to both the ledger and the contract. In addition, an external independent verification tool, described in Section 6.8.9, reads from both the audit ledger and the Sepolia chain.

It should be acknowledged that, in the present prototype, credential verification consists of a structural check that each DID is well formed, and that the requester's role and jurisdiction are declared in the interface rather than authenticated. Wallet-held signing keys and authenticated verifiable credentials are deferred to the production design and are therefore identified as future work. Guardian approvals are nevertheless verified cryptographically in the prototype. Each approval is an EIP-712 typed-data signature bound to the consent identifier. Consequently, the multi-party threshold of Section 5.6 is enforced over signed approvals rather than over interface actions, as described in Section 6.8.



### 5.1.1 MVC Component Decomposition

In the implemented prototype the Controller layer comprises eight principal functions rather than the six functions of the conceptual model described below. The two additional functions are Cryptographic Proof Generation and Verification, which is realised through the Groth16 proving system, and On-chain Anchoring and State Synchronisation, which performs the Sepolia mint and revoke operations as a background process. The Controller row of Figure 7 shows the six functions of the conceptual model; the two additional implementation components are described in Chapter 6.

The three architectural layers are further decomposed into functional components, each corresponding to a distinct responsibility within the trust-oriented authorisation process. Figure 7 presents this decomposition. The View is decomposed according to the principal stakeholder roles. The patient interface supports consent specification and consent-related actions. The guardian or other authorised-participant interface supports independent approval. The healthcare professional interface supports authorised data-access requests. The auditor interface supports inspection of authorisation evidence and audit history. These interfaces represent different interaction responsibilities but share the same architectural principle: none of them independently determines whether access should be granted. The Controller is decomposed into six principal security functions in the conceptual model, which the implemented prototype extends to the eight functions noted above. Identity Verification establishes whether a participant can be identified through the relevant decentralised identity mechanism. Authority Verification evaluates whether the participant possesses appropriate evidence concerning the required role or authority. Approval Aggregation determines whether independently verified approvals satisfy the predefined threshold. Policy Enforcement evaluates whether the requested purpose and data scope comply with the consent policy. Decision Engine combines the resulting predicates into the final authorisation decision. Finally, Audit Coordination records the relevant evidence and decision events. The Model is decomposed into seven principal state representations. The DID component represents decentralised identity information, and the VC component represents credential and authority evidence. The Consent component represents the structured patient authorisation object, the Approval component represents verified multi-party approval evidence, and the Policy component represents purpose and data-scope constraints. The Evidence component represents evidence generated throughout the authorisation process, and the Lifecycle component represents the current state of the consent object and its permissible transitions. This decomposition establishes an explicit distinction between state, interaction, and enforcement. The Model stores and represents security-relevant state, the

View expresses stakeholder actions, and the Controller determines whether those actions satisfy the required trust conditions.

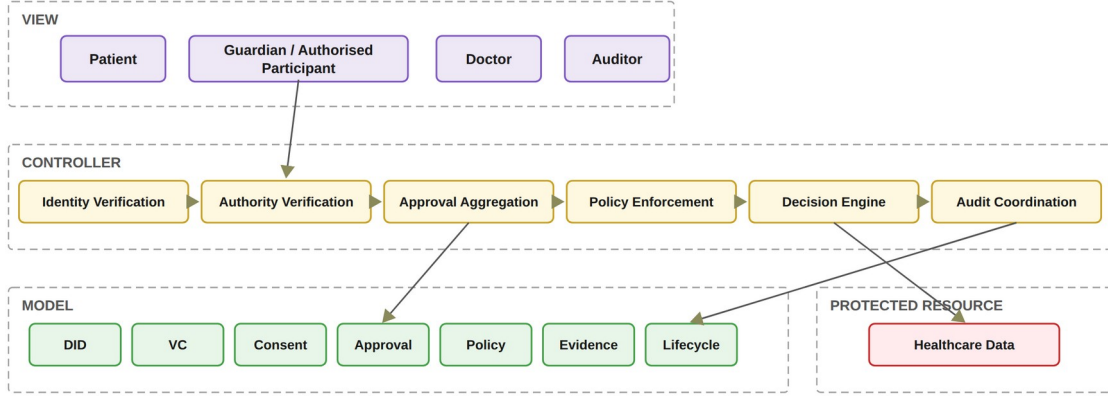


Figure 7: Functional decomposition of the MVC components

### 5.1.2 Trust Evaluation Across the MVC Layers

The architectural layers cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. The relationship between the MVC components and the trust predicates introduced by SRQ1-SRQ5 is illustrated in Figure 8. Figure 8 provides the logical relationship between the architectural components and the integrated trust model. A healthcare data-access request is not evaluated according to a single authentication event. Instead, the Controller coordinates a sequence of trust predicates representing the conditions established by SRQ1-SRQ5. The first condition,  $VI(u)$ , determines whether the requesting participant possesses valid identity and authority evidence. The second condition,  $VA(C)$ , determines whether the required independently verified participants have collectively satisfied the authorisation threshold. The third condition,  $VP(C, R)$ , determines whether the requested operation complies with the consent policy, including purpose and data-scope restrictions. The fourth condition,  $VT(C, t)$ , determines whether the consent remains valid at the time of the request. The fifth condition,  $V_L(C)$ , determines whether the jurisdictional constraint recorded in the consent is satisfied; lifecycle validity and revocation are evaluated within  $V_A$ . The integrated decision can therefore be expressed as Eq. (26).

This distinction is important because revocation and lifecycle state are not enforced by this function but within  $V_A$ . In Figure 8 the corresponding component is labelled  $V_L(C, j)$ , the jurisdiction verification function, where  $j = \text{Jur}(R)$  is the jurisdiction declared in the request. This is the same predicate that is written as  $V_L(C, R)$  in Eq. (59) and abbreviated as  $V_L(C)$  in Eq. (26).

$$\text{Decision}(C, R, t) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (26)$$

The Controller does not itself create these trust conditions. Instead, it evaluates evidence represented by the Model and coordinates the resulting decision. This distinction is important for the interpretation of the architecture: the Controller is a decision-enforcement mechanism, whereas the Model is a representation of trust and governance state. If any required predicate evaluates to false, the decision is

$$\neg(V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L) \Rightarrow \text{Decision}(C, R, t) = \text{DENY}. \quad (27)$$

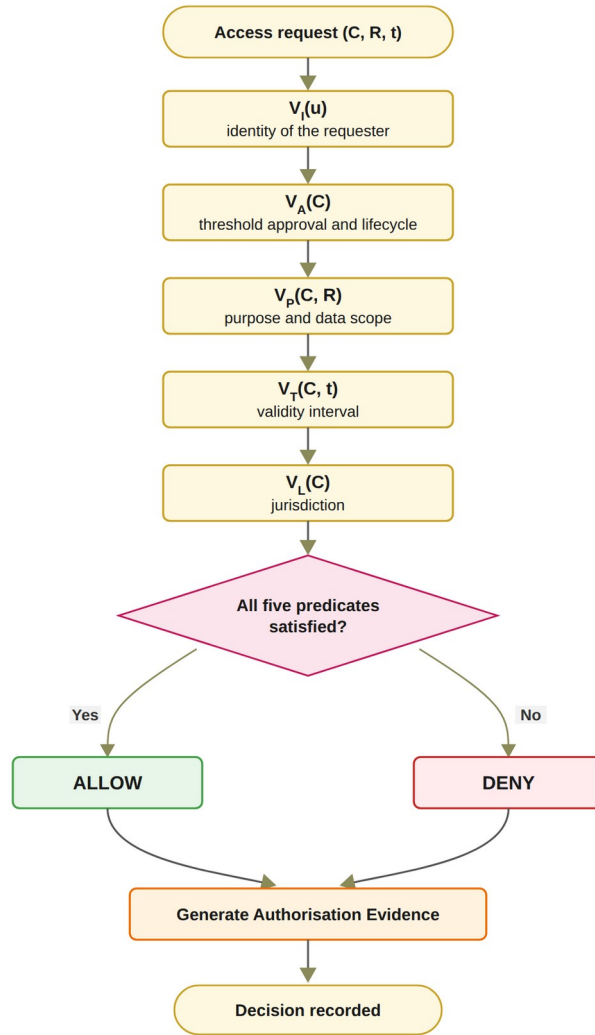


Figure 8: Trust predicate evaluation and authorisation decision flow

Both successful and unsuccessful decisions are subsequently associated with authorisation evidence. This ensures that the architecture supports accountability and subsequent verification in addition to access enforcement.

### 5.1.3 Relationship Between MVC Layers and Research Questions

The MVC decomposition provides an implementation-oriented mapping of the six sub-research questions. SRQ1 is primarily represented by the Model through the trust-aware consent object. SRQ2 is implemented

through the interaction between the Model and Controller, where decentralised identities and verifiable credentials are represented and verified. SRQ3 is primarily enforced by the Controller through verified multi-party approval and threshold evaluation. SRQ4 is implemented through the interaction between the consent and policy representations in the Model and the policy-enforcement functions of the Controller. SRQ5 extends the Model and Controller with temporal and lifecycle information. Temporal conditions and lifecycle state are represented in the Model, while their validity is evaluated by the Controller before an access decision is produced. SRQ6 operates across the complete architecture rather than being confined to a single MVC layer. Formal security assurance evaluates the logical properties of the integrated model, while empirical validation evaluates whether the implementation consistently realises those properties. The relationship can therefore be summarised as follows

*SRQ1 → Model; SRQ2 → Model + Controller; SRQ3 → Controller; SRQ4 → Model + Controller;  
SRQ5 → Model + Controller; SRQ6 → Model + View + Controller.*

This mapping demonstrates that MVC functions as the implementation architecture through which the conceptual research questions are operationalised. It does not replace the trust model; rather, it provides the structural boundaries through which the trust model can be implemented, evaluated, and validated.

#### **5.1.4 Architectural Boundary and Trust Assumptions**

The layered architecture also establishes explicit trust boundaries. The View is considered an interaction boundary and therefore cannot be treated as a trusted source of authorisation decisions. Participant actions originating from the View must be independently verified by the Controller. The Controller represents the security enforcement boundary. It is responsible for applying the authorisation rules consistently and for preventing direct access to protected healthcare data when the required trust conditions are not satisfied. The Model represents the security-state boundary. Its records provide the evidence and state required for authorisation evaluation, but stored state alone does not constitute permission. In particular, the presence of a consent record, credential, or approval record cannot independently produce an access decision.

The protected healthcare data represent the final resource boundary. Access is permitted only through the authorisation path enforced by the Controller. This separation reduces the possibility that presentation-layer operations or stored records can bypass the security decision mechanism. These boundaries are important for interpreting the security contribution of the architecture. The proposed framework does not claim that MVC itself provides security. Instead, security arises from the explicit placement of trust-sensitive operations within the Controller, the structured representation of security state within the Model, and the prevention of direct security decisions at the View layer. Accordingly, the

MVC architecture provides the structural foundation for implementing the trust-oriented authorisation model. The subsequent sections describe each layer in greater detail, beginning with the Model representation of trust-aware consent and authorisation state, followed by the View interaction mechanisms and Controller-based enforcement mechanisms.

It should also be noted that, in the present prototype, the Controller is realised as a single trusted server that both evaluates the predicates and writes the audit ledger. Therefore, the on-chain anchoring of consent state and the independent verification tool described in Section 6.8.9 provide the external evidence against which the Controller's own records can be checked.

## **5.2 Trust-Oriented Consent Authorisation Workflow**

Figure 9 presents the end-to-end workflow of the proposed trust-oriented patient consent authorisation framework. The workflow operationalises the central premise of this research that trustworthy healthcare data access cannot be established by a single mechanism, such as a blockchain record or an authenticated identity. Instead, an access decision should be established through the coordinated verification of consent specifications, participant identity and authority, multi-party authorisation, and policy compliance. Accordingly, the proposed workflow transforms a patient's consent from a static permission record into an evaluable authorisation object that can be verified before healthcare data are released. The workflow begins when the patient creates a consent request and specifies the conditions under which healthcare data may be accessed. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorise and provides the policy context against which subsequent access requests can be evaluated. Therefore, consent is not represented merely as an approval flag, but as a structured object containing the information required for subsequent authorisation decisions. The next stage performs decentralised identity and authority verification using Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) [20]. The purpose of this stage is to establish both the identity of the participant and the evidence supporting the participant's claimed role or authority. It should be noted that the framework explicitly separates identity authentication from authorisation. A successfully verified DID or VC demonstrates that a participant can be identified and that relevant credentials are valid; it does not, by itself, grant permission to access patient data. This distinction is fundamental to the proposed trust model because an authenticated participant should not automatically be considered an authorised participant. After identity and authority verification, the framework identifies the participants required to establish the consent decision. The authorisation requirement may involve multiple independent participants, such as a patient together with one or more guardians or other authorised parties. The framework then collects their

independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let  $A_v$  denote the set of successfully verified approvals and let  $N$  denote the required authorisation threshold. Multi-party authorisation is satisfied when the threshold condition of Eq. (28) holds.

$$V_A(C) = 1, |A_v| \geq N; 0, |A_v| < N. \quad (28)$$

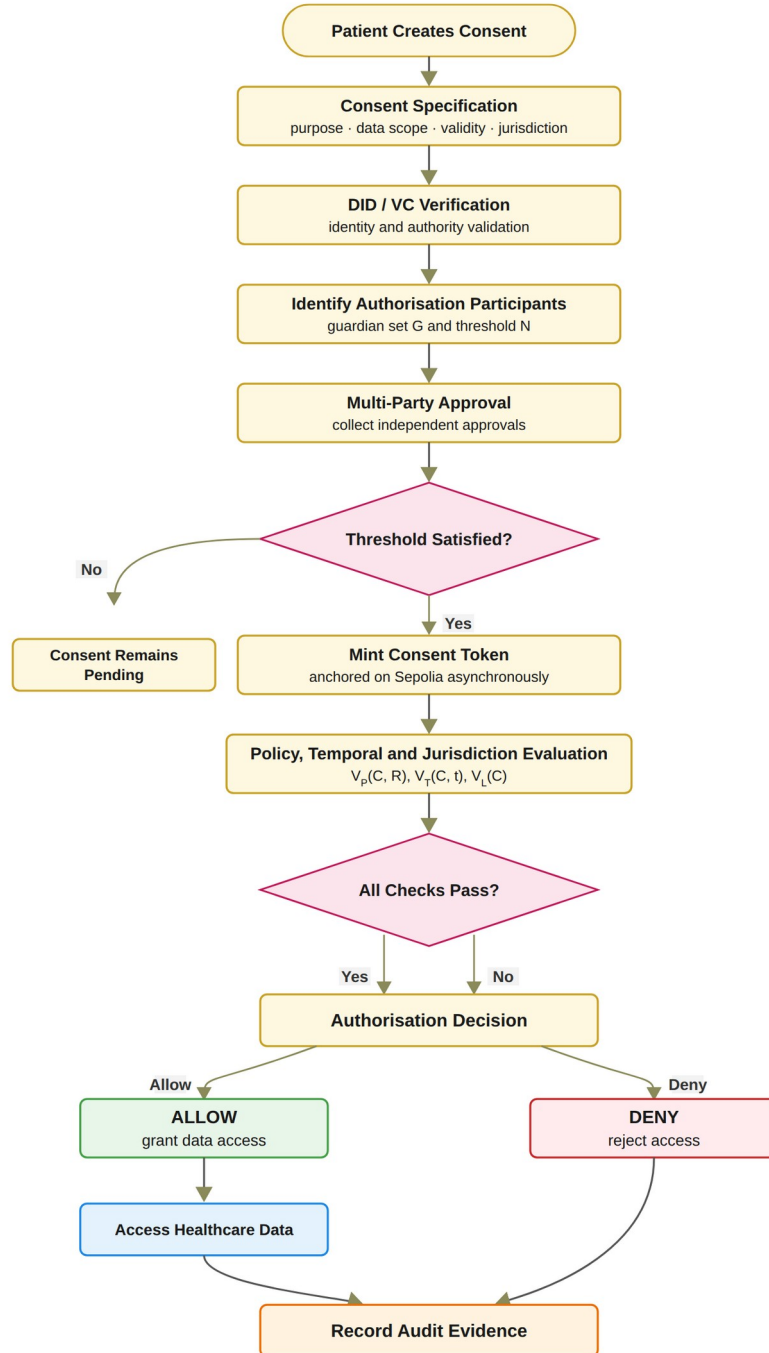


Figure 9: End-to-end workflow of the trust-oriented consent authorisation framework

In the implemented prototype the threshold is fixed at  $N = |G|$ , so that every listed guardian must provide a valid approval before activation; the

evaluated configuration is therefore 2-of-2. Configurable k-of-n thresholds constitute a direct generalisation that is deferred to future work.

Figure 9 further shows the steps that follow the threshold check. Once all  $|G|$  guardians have signed and the N-of-N condition of Eq. (28) is satisfied, the consent token is minted in the local ledger, and a background job anchors the mint on Sepolia asynchronously. The temporal check  $V_T$  and the jurisdictional check  $V_L$  are then evaluated before the Authorisation Decision. A Groth16 proof is generated and verified before access is granted, and the audit evidence is recorded. The flow then continues through patient-initiated revocation and the corresponding on-chain revoke transaction. Finally, the auditor reviews the record, and the verification tool of Section 6.8.9 performs an independent verification.

If the required threshold is not satisfied, the authorisation process terminates with a denial decision. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the workflow proceeds to policy evaluation. At this stage, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses an important limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent permits access to Observation, Medication, a request additionally containing Procedure should not be authorised because

$$S_R \not\subseteq S_C, \quad (29)$$

where  $S_R$  represents the requested data scope and  $S_C$  represents the consent-authorized scope. Similarly, the requested purpose must be consistent with the purpose specified in the consent. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. The final authorisation decision is therefore determined by the conjunction of identity and authority verification, multi-party authorisation, and policy compliance. For the foundational authorisation core established by RO1-RO4, the decision can be expressed, as in Equation (24), as

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R), \quad (30)$$

where  $V_I(u)$  represents the validity of the requesting participant's identity and authority evidence,  $V_A(C)$  represents satisfaction of the required multi-party authorisation threshold, and  $V_P(C, R)$  represents compliance between the access request and the consent policy. If any of these conditions is false, the request is denied. Only when all required conditions are satisfied is healthcare data access granted. Finally, the framework records the resulting authorisation evidence in the audit layer. It should be noted that both successful and denied decisions should be recorded. A trustworthy authorisation framework requires accountability for the data that were released and also for the access attempts that were rejected. The

audit evidence can therefore provide a traceable record of the authorisation decision, including the relevant consent, participants, policy evaluation, decision outcome, and associated evidence. In this manner, the workflow connects consent specification with identity trust, collective authorisation, policy enforcement, and accountability, providing the operational foundation of the proposed trust-oriented authorisation framework.

It should be noted that Eq. (30) expresses the foundational core only. In the complete model, the temporal predicate  $V_T(C, t)$  and the jurisdictional predicate  $V_L(C)$  introduced by RO5 are conjoined with these three conditions, as shown in Eq. (26), and the implemented Controller evaluates all five predicates at every access request.

### 5.3 Model: Trust-Aware Consent and Authorisation Representation

The Model layer represents the persistent security state of the proposed consent-management framework. Rather than treating consent as a simple binary permission, the framework models consent as a structured authorisation object that captures the security conditions under which healthcare data may be accessed. For the current stage scope, the core consent object is represented as

$$C = (I, A, P, T, L, E) \quad (31)$$

where T represents the temporal validity window of the consent and L represents the jurisdiction in which the consent may be exercised, both defined exactly as they are realised in the implementation.

In this representation, I represents identity-related information associated with the relevant participants, and A represents the authorisation requirements that must be satisfied before access can be granted. P represents the policy conditions governing purpose and healthcare data scope, and E represents the evidence generated throughout the authorisation process. The identity component I does not simply store a username or centrally issued account identifier. It represents decentralised identities and the associated evidence required to establish the legitimacy of participating entities. This allows patients, guardians, healthcare professionals, and other participants to be represented as independently identifiable actors rather than as entries controlled exclusively by a central authority. The authorisation component A defines the conditions under which a consent object may become operational. In particular, it specifies whether a single participant is sufficient or whether multiple independent entities are required to jointly authorise a sensitive healthcare data operation. Let  $A_v$  denote the set of approvals submitted by participants whose identities and authority have been successfully verified, and let N denote the minimum required approval threshold. The authorisation condition can then be represented, as in Eq. (28), as

$$V_A(C) = I, |A_v| \geq N; 0, |A_v| < N. \quad (32)$$



This mechanism differs from the reviewed systems. In those systems joint approval is a contingency path [53], a witness or notary threshold [69], a registration-time co-consent [43, 47], an institution-side admission gate [75], a custodial M-of-N signature [61] or a key-share reconstruction [35, 54]. In a single-owner model, the compromise, error or misuse of one privileged account may be sufficient to produce an authorisation decision. In the proposed framework, trust is instead distributed across multiple independently verified participants. A sensitive access decision becomes valid only when the defined collective authorisation condition has been satisfied.

The policy component  $P$  represents the contextual restrictions associated with the consent. These restrictions may include the intended purpose of access and the healthcare data categories that are permitted to be disclosed. Therefore, the existence of a valid identity and sufficient approval evidence does not automatically authorise unrestricted access to all patient information. Let  $S_C$  denote the healthcare data scope authorised by the consent object and  $S_R$  denote the scope requested by an entity. Policy compliance requires

$$S_R \subseteq S_C. \quad (33)$$

It should be noted that the lifecycle state of the consent,  $\text{State}(C)$ , is not an element of the tuple itself but is maintained by the Lifecycle component of the Model alongside  $C$ , and it is evaluated within  $V_A(C)$ , as stated in Section 6.5.

If the requested data exceeds the authorised scope, the request must be rejected even if the requester has successfully authenticated and the required number of participants has approved the consent. The evidence component  $E$  represents the verifiable information generated during the authorisation process. This may include identity-verification results, credential-verification results, approval records, policy-evaluation outcomes, access decisions, and audit events. The purpose of  $E$  is not merely to record that a decision occurred, but to provide evidence concerning why the decision was produced.

This distinction is particularly important for trustworthy consent governance. A conventional immutable record may demonstrate that a transaction was stored [2, 28], whereas the proposed model seeks to preserve evidence concerning the conditions that justified the resulting authorisation decision. Consequently, the Model acts as a security-bearing representation of the consent lifecycle rather than as a passive permission database.

The implemented prototype described in Section 6.8 realises the consent representation defined in this section in full, including temporal validity, expiration, on-chain revocation and an explicit lifecycle state machine. Formal verification of the associated security properties, however, remains a matter for future work.

## 5.4 View: Controlled Interaction Among Independent Participants

The View layer provides the interaction environment through which independent stakeholders participate in the consent-management process. In the HALAH prototype, these stakeholders may include patients, guardians, healthcare professionals, and auditors. Although these participants interact with different functions of the system, their interfaces do not directly determine the security outcome of an authorisation request. This separation is essential because user interaction and security enforcement should not be treated as equivalent. For example, a healthcare professional may successfully submit an access request through the interface, but this interaction alone does not establish the right to access patient information. Similarly, a guardian may submit an approval, but the approval does not become effective unless the corresponding identity and authority conditions have been verified and the required multi-party threshold has been satisfied. The View therefore functions as a controlled mechanism for expressing requests and authorisation intent. A patient may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. Guardians or other authorised participants may subsequently submit their approval. Healthcare professionals may submit data-access requests, while auditors may inspect the resulting evidence and authorisation history. The separation between interaction and enforcement prevents the user interface from becoming the source of trust. A request submitted through the View represents an input to the authorisation process, rather than an authorisation decision itself. The actual security decision remains the responsibility of the Controller. This distinction is particularly important in decentralised environments where different stakeholders may not fully trust one another. The proposed architecture therefore treats each user action as a claim that must be independently evaluated rather than as an automatically trusted system operation.

## 5.5 Controller: Trusted Multi-Party Authorisation Enforcement

The Controller represents the central decision coordination mechanism of the proposed framework. Its responsibility is to transform consent specifications, participant credentials, approval evidence, and access requests into a deterministic authorisation decision. The Controller first evaluates whether the requesting entity and relevant authorisation participants possess valid identities and credentials. Identity verification can be represented as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u), \quad (34)$$

where  $\text{VerifyDID}(u)$  determines whether the decentralised identity of participant  $u$  can be verified and  $\text{VerifyVC}(u)$  determines whether the associated credential provides valid evidence of the relevant authority or role. A central principle of the proposed architecture is that identity

verification and authorisation authority are not equivalent. A participant may possess a valid identity while lacking the authority required to access a particular patient's healthcare information. Therefore,

$$\text{Identity} \neq \text{Authorisation}. \quad (35)$$

This distinction prevents successful authentication from being incorrectly interpreted as unrestricted permission. After identity and authority conditions have been evaluated, the Controller determines whether the multi-party authorisation requirements associated with the consent object have been satisfied. Only independently verified participants can contribute to the authorisation evidence set  $A_v$ . If the number of valid approvals is below the required threshold  $N$ , the consent cannot produce an effective authorisation decision. The Controller then evaluates the relationship between the access request  $R$  and the policy conditions contained within the consent object. This process determines whether the requested healthcare data, operation, and intended purpose remain within the permitted authorisation boundary. The corresponding policy predicate can be represented as

$$V_P(C, R) = \text{Policy}(C, R). \quad (36)$$

The foundational authorisation decision for RO1-RO4 is therefore determined by the conjunction of the three core trust conditions, to which the temporal and jurisdictional predicates of Eq. (26) are added in the complete model. This is the rule of Eq. (30), restated here in the Controller context as

$$\text{Decision}(C, R) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (37)$$

Equivalently, the decision can be represented as

$$\text{Decision}(C, R) = \text{ALLOW}, V_I(u) = 1 \wedge V_A(C) = 1 \wedge V_P(C, R) = 1; \text{DENY, otherwise}. \quad (38)$$

The security significance of this formulation is that no individual condition is sufficient to produce an access decision. A valid identity without sufficient multi-party approval does not result in access. Similarly, sufficient approval without policy compliance cannot authorise disclosure beyond the permitted healthcare data scope. This creates a conjunctive trust model in which the failure of any required condition prevents the final authorisation decision. More importantly, the Controller provides a single security-enforcement point through which all sensitive operations must be evaluated. This reduces the risk that different components independently interpret consent conditions and produce inconsistent access decisions.

## 5.6 Multi-Party Consent as Distributed Trust Establishment

A central contribution of the proposed architecture is the treatment of multi-party consent as a distributed trust-establishment mechanism rather than as a simple collection of multiple signatures. In the reviewed approval mechanisms, multiple signatures may be appended at consent registration [38, 43] or collected as hash-integrity confirmations on a ledger

transaction [75]. However, the presence of multiple approvals does not necessarily establish that the approving entities were legitimate, possessed the appropriate authority, or approved the same policy conditions. The proposed framework therefore associates each approval with independently verifiable identity and authority information. An approval contributes to the effective authorisation condition only when the corresponding participant satisfies the identity and credential requirements defined by the framework. Let the set of submitted approvals be denoted by

$$A_s = \{a_1, a_2, \dots, a_m\}. \quad (39)$$

The verified approval set is then derived as

$$A_v = \{a_i \in A_s \mid V_i(a_i) = 1 \wedge \text{Authority}(a_i) = \text{Valid}\}. \quad (40)$$

Only the verified set  $A_v$  contributes to the threshold condition. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. This mechanism provides resistance against several classes of authorisation failure. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. Similarly, an invalid identity cannot increase the approval count merely by submitting an approval action through the user interface. The architectural contribution therefore lies in the combination of identity verification and collective decision making. Trust is not assumed to reside in a single privileged entity. Instead, it emerges from the coordinated satisfaction of independently verifiable requirements across multiple participants.

In Eq. (40),  $V_i(a_i)$  denotes the identity predicate  $V_i(u)$  of Eq. (34) evaluated for the participant  $u$  who submitted approval  $a_i$ , and  $\text{Authority}(a_i) = \text{Valid}$  denotes that the role of that participant matches the role required by the consent, corresponding to the  $\text{Authority}(u, C)$  condition of Section 6.2.

## 5.7 Policy-Aware Consent Enforcement

Another important feature of the architecture is the explicit separation between approval validity and access scope validity. Even when all required participants have approved a consent request, the resulting authorisation remains bounded by the policy encoded within the consent object. Suppose that a consent permits access to the following healthcare data categories:

$$S_C = \{\text{Observation}, \text{Medication}\}. \quad (41)$$

If a healthcare professional subsequently requests

$$S_R = \{\text{Observation}, \text{Medication}, \text{Procedure}\}, \quad (42)$$

the request exceeds the authorised data scope because

$$S_R \not\subseteq S_C. \quad (43)$$

The Controller must therefore return

$$Decision(C, R) = DENY. \quad (44)$$

This property is important because conventional authentication and role-based access control mechanisms may determine that an entity is generally authorised to access a category of healthcare information without adequately considering the specific policy conditions associated with an individual patient's consent [11, 25]. The proposed architecture instead binds the access decision to the consent policy itself. Consent therefore becomes an active authorisation constraint rather than a historical indication that a participant was once granted permission. This policy-centric approach also provides a basis for future extensions. While the current stage implementation focuses on purpose and healthcare data scope, the same mechanism can subsequently incorporate additional contextual conditions, including location, organisation, treatment relationship, emergency status, temporal restrictions, and other regulatory constraints.

### 5.8 Authorisation Evidence and Auditability

The proposed architecture further distinguishes between making an authorisation decision and demonstrating how that decision was made. For this reason, the Controller generates evidence associated with each relevant stage of the authorisation process. Conceptually, an authorisation evidence record can be represented as

$$E_R = \{ID, Credential, Approval, Policy, Decision, Audit\}. \quad (45)$$

where ID represents identity-verification evidence, Credential represents authority or role-verification evidence, Approval represents the verified multi-party approval state, Policy represents the result of policy evaluation, Decision represents the final access outcome, and Audit represents the associated event record. The resulting audit trail provides a stronger governance capability than a simple record of successful access. An auditor can examine whether access occurred. The auditor can also examine whether the requester possessed a valid identity, whether the required authorisation threshold was satisfied, whether the requested data complied with the authorised scope, and which conditions produced the final decision. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process [2, 28]. The trustworthiness of the access decision instead originates from the coordinated enforcement of identity, authority, multi-party approval, and policy conditions.

The record ER is the per-request instance of the evidence component E of the consent object C. In the implementation it corresponds to the event rows of the audit ledger. For on-chain events these rows additionally carry the Sepolia transaction hash and block number, as described in Section 6.8.8.

In the implementation, consent activation and revocation are anchored on the Sepolia blockchain through the ConsentSBTv3 soulbound contract. This anchoring is performed asynchronously, and the audit ledger records the transaction hash and block number of each anchoring operation, thereby providing tamper-resistant evidence of the consent state.

## **5.9 Architectural Security Properties**

The proposed MVC architecture provides several foundational security properties for the current stage. These properties emerge from the interaction between the Model, View, and Controller rather than from any single technology.

First, the architecture provides identity-dependent participation. A participant cannot contribute to the authorisation process solely by interacting with the system interface. The corresponding identity and credential must satisfy the verification requirements. Second, the architecture provides authority separation. Possession of a valid identity does not automatically result in permission to access patient data. Identity verification provides evidence concerning who an entity is, whereas authority verification determines whether that entity may perform a particular role within the authorisation process. Third, the architecture provides collective authorisation integrity. Sensitive healthcare data access can be configured to require multiple independently verified participants. Therefore, a single participant cannot unilaterally activate access when the defined authorisation threshold has not been reached. Fourth, the architecture provides policy-bounded access. A valid requester with sufficient approval evidence cannot access healthcare information beyond the purpose or data scope defined by the consent object. Finally, the architecture provides decision accountability. The system maintains evidence concerning the conditions that produced an authorisation decision, thereby supporting auditing and subsequent verification. These properties are summarised in Table 12 together with the separation of interaction and enforcement established in Section 5.1.4. In Table 12, collective authorisation integrity is listed as multi-party authorisation integrity and decision accountability is listed as authorisation evidence.

## **5.10 MVC Architecture and the Research Objectives**

The MVC architecture also provides a direct implementation structure for the research objectives. RO1 is primarily represented in the Model through the development of the trust-aware consent object. RO2 is implemented through the identity and authority verification mechanisms coordinated by the Controller. RO3 is realised through the multi-party approval and threshold evaluation process. RO4 is implemented through the policy evaluation mechanisms that constrain the authorised purpose and healthcare data scope. As shown in Table 13, the View provides the operational environment through which these mechanisms are exercised by independent participants. It should be noted that the View does not

determine whether an operation is authorised. Instead, it captures participant actions and forwards them to the Controller, which evaluates the security predicates defined by the Model.

RO5 is realised through the temporal and lifecycle state held in the Model and the corresponding predicates  $V_T$  and  $V_L$  evaluated by the Controller before any access decision is produced. RO6 operates across all three layers, since the evidence generated by the Controller and stored in the Model is what the empirical validation and the independent verifier examine.

### 5.11 Architectural Contribution and Scope

The principal contribution of the proposed architecture is not the use of MVC itself, but the way in which MVC is employed to operationalise a trust-oriented authorisation model. The Model provides a structured representation of the conditions that define valid consent. The View enables multiple independent stakeholders to express consent-related intentions without directly determining security outcomes. The Controller coordinates independently verifiable trust conditions and produces the final authorisation decision. This design transforms multi-party consent management from a conventional record-management problem into a distributed security-governance problem. The key innovation is not the evaluable consent object as such, since the literature already provides such an object [71, 37, 44, 58]. The innovation is the conjunction in which the effectiveness of the consent depends on the joint satisfaction of identity, authority, collective approval, policy, temporal and jurisdictional conditions. This conjunction is evaluated on every access decision, and the assurance of that conjunction is also part of the contribution. For the current stage, the architecture therefore establishes the mechanisms required to answer RQ1–RQ5, while RQ6 is addressed empirically through the prototype evaluation in Section 6.8 and formally in the next stage.

**Table 12:** Security Properties Supported by the Proposed MVC-Based Consent Architecture

| Security Property                   | Architectural Mechanism                                                                          | Security Significance                                                                                                                        |
|-------------------------------------|--------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| Identity-dependent participation    | DID and credential verification before a participant can contribute to the authorisation process | Designed to prevent unverified entities from being treated as legitimate participants.                                                       |
| Authority separation                | Independent evaluation of identity and role or authority evidence                                | Designed to prevent successful authentication from being interpreted as unrestricted authorisation.                                          |
| Multi-party authorisation integrity | Threshold evaluation over independently verified approval participants                           | Designed to prevent a single participant from unilaterally activating sensitive healthcare data access when collective approval is required. |
| Policy-bounded access               | Evaluation of purpose and                                                                        | Designed to prevent                                                                                                                          |

| Security Property                         | Architectural Mechanism                                                                       | Security Significance                                                                                         |
|-------------------------------------------|-----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
|                                           | requested data scope against consent policy                                                   | otherwise valid identities and approvals from being used to obtain data beyond the authorised scope.          |
| Authorisation evidence                    | Recording of verification results, approval evidence, policy evaluation, and final decisions  | Designed to provide traceability and support accountability, auditing, and future verification.               |
| Separation of interaction and enforcement | The View submits requests while the Controller independently determines the security decision | Designed to prevent user-interface actions from being interpreted directly as trusted authorisation outcomes. |

**Table 13:** Mapping Between Research Objectives and MVC Components

| Research Objective | Primary MVC Component       | Core Mechanism                                      | Expected Contribution                                                                                                                                                                             |
|--------------------|-----------------------------|-----------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RO1                | Model                       | Trust-aware consent representation                  | Transforms consent from a passive permission record into a structured and evaluable authorisation object.                                                                                         |
| RO2                | Controller and Model        | DID and VC verification                             | Establishes trustworthy participants while explicitly separating identity from authorisation authority.                                                                                           |
| RO3                | Controller                  | Verified multi-party threshold evaluation           | Establishes collective trust and prevents unilateral authorisation when multiple approvals are required.                                                                                          |
| RO4                | Controller and Model        | Policy, purpose, and data-scope evaluation          | Ensures that valid participants and sufficient approvals remain constrained by the authorised purpose and healthcare data scope.                                                                  |
| RO5                | Model and Controller        | Temporal validity and consent lifecycle enforcement | Ensures that authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. |
| RO6                | Model, View, and Controller | Formal security analysis and empirical              | Will provide formal assurance (next                                                                                                                                                               |



| Research Objective | Primary MVC Component | Core Mechanism | Expected Contribution                                                                                                                                                                                 |
|--------------------|-----------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                    |                       | validation     | stage) of the defined trust and authorisation properties and empirically evaluates whether the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions. |

environment in which these mechanisms can be instantiated and evaluated through representative healthcare data-sharing scenarios. The subsequent stage will extend the assurance of the architecture rather than its mechanisms. The consent Model already includes temporal validity, expiration, revocation, and controlled lifecycle transitions, as defined in Section 5.3 and realised in the implemented prototype described in Section 6.8. The Controller therefore already evaluates the corresponding temporal predicate  $V_T(C, t)$  and jurisdictional predicate  $V_L(C)$  within the authorisation decision, as expressed in Eq. (26) and enforced in the prototype. In addition, the complete decision model will be subjected to formal security analysis and broader empirical validation. Accordingly, the current stage architecture establishes the foundational security core of the research. The next stage will investigate whether this core can maintain trust dynamically over time beyond the lifecycle mechanisms already demonstrated in the prototype. It will also investigate whether the core can satisfy formally defined security properties and consistently enforce the complete trust-oriented authorisation model under representative and adversarial healthcare data-sharing conditions.

## 6 Proposed Solution

This chapter presents the proposed solution as six mechanisms, one for each research objective. Sections 6.1 to 6.6 define, for each objective, the formal condition, the workflow, the step-wise procedure and the corresponding algorithm. Each section also states which part of the mechanism is exercised by the current prototype and which part is reserved for the next stage. Section 6.7 relates the six algorithms to the research objectives. Section 6.8 presents the implementation and the live demonstration of the framework on the Ethereum Sepolia testnet. Throughout the chapter,  $C$  denotes the consent object,  $G$  the guardian set,  $N$  the approval threshold,  $D$  the authorised doctor,  $R$  an access request and  $t$  the evaluation time.

### 6.1 Trust-Centric Consent Model for RO1

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions access may be granted. The proposed consent object is represented as

$$C = (I, A, P, T, L, E) \quad (46)$$

where  $I$  represents patient and participant identity information,  $A$  represents authorisation requirements,  $P$  represents policy constraints,  $T$  represents the temporal validity window of the consent,  $L$  represents the jurisdiction in which the consent may be exercised, and  $E$  represents authorisation evidence.

The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit. The consent model therefore separates the specification of consent from the final access decision. A consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

#### 6.1.1 RO1 Consent Creation Workflow

The following workflow describes the creation of a trust-aware consent object. The process begins with a patient request and ends with a structured consent record that can be verified by subsequent authorisation services. The workflow first collects the patient identity and the intended healthcare participants. It then specifies the purpose and data scope of the consent. In the HALAH implementation, the patient interface allows the

patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent.

In the current interface the purpose is fixed to Treatment and is not selected by the patient. The purpose vocabulary check of Section 6.4.3 is therefore exercised by the automated tests rather than by the interface. Figure 10 shows the resulting consent-creation workflow.

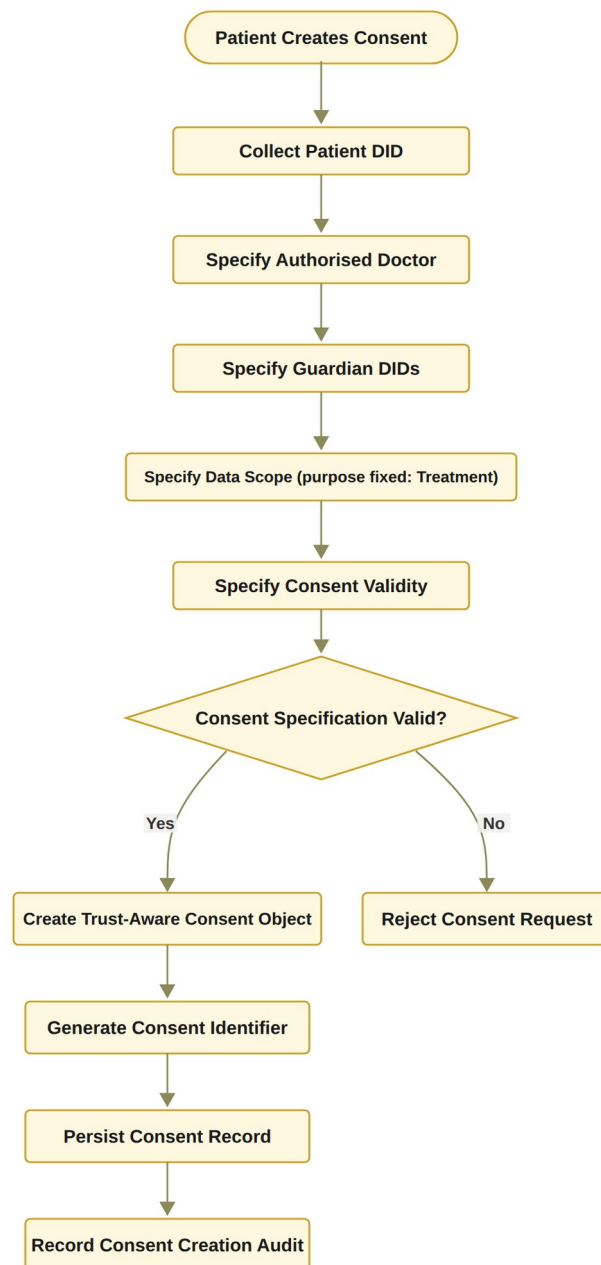


Figure 10: RO1 workflow for trust-centric consent creation

Figure 10 describes the behaviour of consent creation. Figure 11 presents the structure of the resulting consent object. It shows each of the six components of  $C = (I, A, P, T, L, E)$ , the content that each component holds

in the HALAH system, and the party that supplies it. The patient supplies the identity, authority, policy, temporal and jurisdictional components. The threshold  $N = |G|$  and the consent identifier  $id_C$  are generated by the system. The evidence component is accumulated by the audit layer, the guardians' signatures and the blockchain as the consent progresses.

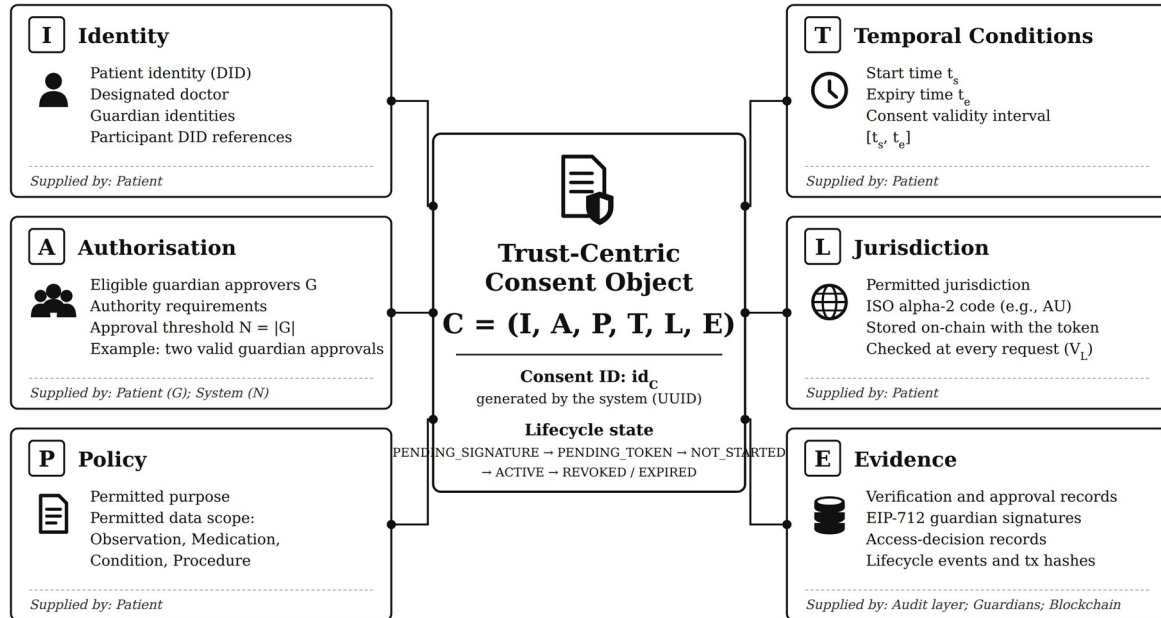


Figure 11: Six-component trust-centric consent model  $C = (I, A, P, T, L, E)$ , showing the content and the supplier of each component, the system-generated consent identifier, and the lifecycle state carried by the consent object.

The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. This process ensures that the consent object contains sufficient information for subsequent identity verification, multi-party authorisation, policy evaluation, and auditability.

The declared jurisdiction  $L$  is validated as a well-formed ISO alpha-2 territory code, AU in the demonstrated transactions, and is bound to the consent object at creation. This is important because the subsequent access decision is evaluated against it. Consequently, the construction sequence becomes  $I_p \rightarrow D \rightarrow G \rightarrow P_u \rightarrow S_C \rightarrow T \rightarrow L \rightarrow A \rightarrow id_C \rightarrow C \rightarrow E$ .

### 6.1.2 Procedure for Trust-Aware Consent Creation

The Trust-Aware Consent Creation procedure establishes a valid and auditable consent object by sequentially validating the participating entities, consent purpose, data scope, and temporal constraints before the consent is persisted. The procedure consists of the following steps. 1. Step 1 - Validate Patient Identity. The system first validates the patient's identity  $I_p$ . The identity is checked against the available identity and credential verification mechanisms to ensure that the consent request

originates from a recognised patient entity. If  $I_p$  cannot be successfully validated, the procedure terminates immediately and returns REJECT. 2. Step 2 – Validate the Authorised Doctor. The system validates the identity and authorisation status of the designated doctor  $D$ . This step determines whether the doctor is a recognised healthcare participant and whether the presented credentials are sufficient for participation in the requested consent relationship. An invalid or unauthorised doctor results in rejection of the consent request. 3. Step 3 – Validate Guardian or Proxy Participants. If a guardian or proxy is specified, the system validates the guardian set  $G$ . Each guardian is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. This step prevents an arbitrary third party from being treated as an authorised representative of the patient. 4. Step 4 – Validate the Intended Purpose. The intended data-use purpose  $P_u$  is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies. The purpose is subsequently bound to the consent object so that authorisation is not interpreted as unrestricted access to the patient’s healthcare information. 5. Step 5 – Validate the Data Scope. The requested data scope  $S_c$  is validated to determine precisely which healthcare resources may be accessed under the consent. The scope may represent specific resource categories, such as observations, medications, procedures, or other FHIR resources. This step establishes the principle of least privilege by ensuring that consent is associated with explicitly defined data resources rather than the patient’s entire healthcare record. 6. Step 6 – Validate the Consent Validity Interval. The system validates the temporal validity interval  $T = (t_s, t_e)$ , where  $t_s$  represents the consent start time and  $t_e$  represents the expiration time. The system verifies that the interval is logically valid by requiring  $t_e > t_s$ . If this condition is not satisfied, the consent request is rejected.

In the current prototype the identity validation of Steps 1 to 3 is structural. The patient DID is selected from the loaded record set, each guardian DID must be a well-formed DID before the consent is stored, and the doctor DID is checked for DID format only when the access decision is evaluated. The doctor is not independently authenticated at this stage, and credential-based verification of the presented identity is deferred to the production design.

Step 6 also validates the declared jurisdiction  $L$  as a well-formed ISO alpha-2 territory code and binds it to the consent object, as described in Section 6.1.1, so that the subsequent jurisdictional check  $V_L$  can be evaluated against it.

7. Step 7 – Define the Authorisation Requirement. After all input elements have been validated, the system defines the authorisation requirement  $A$ . This requirement specifies the conditions that must subsequently be satisfied before access can be granted. Depending on the system configuration,  $A$  may incorporate patient approval, guardian approval, doctor authority, role requirements, multi-party approval, scope

restrictions, purpose restrictions, and temporal constraints. 8. Step 8 - Generate a Unique Consent Identifier. The system generates a unique consent identifier  $id_C$ . The identifier is not supplied by any participant. It is generated by the Consent Service as a universally unique identifier (UUID) when the patient submits the consent. It is then displayed to the patient, who shares it with the designated guardians and the authorised doctor so that they can approve the consent or request access. Possession of the identifier alone grants no access, because every subsequent request is evaluated by the complete decision rule, and the on-chain token identifier is assigned separately by the smart contract only when the consent is activated. This identifier provides a persistent reference to the consent object and enables subsequent operations, including consent verification, access authorisation, modification, revocation, and audit. 9. Step 9 - Construct the Consent Object. The validated information is combined to construct the consent object  $C = (I, A, P, T, L, E)$ . In this object,  $I$  represents the verified identity information and  $A$  represents the authorisation requirements.  $P$  represents the consent purpose and associated permissions, and  $E$  represents the evidence associated with the consent decision. The resulting object therefore records the patient's preference together with the evidence required to support subsequent authorisation decisions. 10. Step 10 - Persist the Consent Object. The constructed consent object  $C$  is persisted in the consent-management infrastructure. The persistence mechanism provides a stable representation of the consent state that can subsequently be referenced by the access-control and authorisation components. 11. Step 11 - Record Consent Creation Evidence. Finally, the system records evidence associated with the creation event, including the consent identifier, participating entities, relevant timestamps, and the resulting consent state. This evidence provides an auditable record that can be used to reconstruct and verify the consent lifecycle. 12. Step 12 - Return the Consent Result. If all validation and construction operations are completed successfully, the system returns the newly created consent object  $C$ . If any mandatory validation fails during the process, the system terminates the procedure and returns REJECT. The overall procedure can therefore be represented as a sequential trust establishment process such that  $I_p \rightarrow D \rightarrow G \rightarrow P_u \rightarrow S_C \rightarrow T \rightarrow L \rightarrow A \rightarrow id_C \rightarrow C \rightarrow E$ . This sequence ensures that consent is created only after the relevant identity, authority, purpose, scope, and temporal constraints have been validated. Consequently, the resulting consent object is a structured authorisation artefact rather than a simple record of patient preference, and it provides the evidence required for subsequent healthcare data-access decisions.

---

**Algorithm 1** Trust-Aware Consent Creation

---

**Require:** Patient identity  $I_p$ , authorised doctor  $D$ , guardian set  $G$ , purpose  $P_u$ , data scope  $S_C$ , validity interval  $T$ , jurisdiction  $L$

**Ensure:** Consent object  $C$  or rejection

- 1: Validate  $I_p$
- 2: **if**  $I_p$  is invalid **then**

```

3: return REJECT
4: end if
5: Validate authorised doctor D
6: Validate guardian set G
7: Validate purpose  $P_u$ 
8: Validate data scope  $S_c$ 
9: Validate validity interval  $T = (t_s, t_e)$ 
10: if  $t_e \leq t_s$  then
11:   return REJECT
12: end if
13: Validate jurisdiction L; define authorisation requirement A
14: Generate consent identifier  $id_c$ 
15: Construct  $C = (I, A, P, T, L, E)$ 
16: Persist C
17: state  $\leftarrow$  PENDING_SIGNATURE  $\triangleright$  nothing is anchored on-chain until all
    guardians approve
18: Record consent creation evidence
19: return C

```

---

### 6.1.3 Algorithm 1: Trust-Aware Consent Creation

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. This distinction is important because the research treats consent as a structured policy-bound object rather than as a simple Boolean permission. The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I, RO3 evaluates the authorisation requirements contained in A, and RO4 evaluates the policy constraints contained in P. Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

## 6.2 Decentralised Identity and Authority Trust for RO2

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. The central principle of RO2 is

*Identity  $\neq$  Authorisation.* (47)

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute [20]. Neither mechanism should automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity verification condition can be expressed as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u), \quad (48)$$

where  $u$  is the requesting participant. The DID verification process establishes whether the identity reference is valid. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

### 6.2.1 RO2 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent. The output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

Figure 12 presents this workflow.

### 6.2.2 Procedure for DID and VC Identity and Authority Verification

The DID and VC Identity and Authority Verification procedure determines whether a participant possesses a valid decentralised identity and sufficient verifiable authority to participate in the consent-defined authorisation process. The procedure establishes a verifiable relationship between the participant  $u$ , the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object  $C$ . The procedure consists of the following steps. 1. Step 1 – Resolve the Participant's DID. The system first resolves the decentralised identifier (DID) associated with participant  $u$ . DID resolution retrieves the DID-related information required to establish the participant's decentralised identity and identify the corresponding DID document. If the DID cannot be successfully resolved, the verification process terminates and returns INVALID. 2. Step 2 – Verify the DID Document. After successful resolution, the system verifies the DID document and its associated identity information. The verification process determines whether the document is structurally valid and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted for subsequent credential verification. A failed DID verification results in an INVALID outcome.



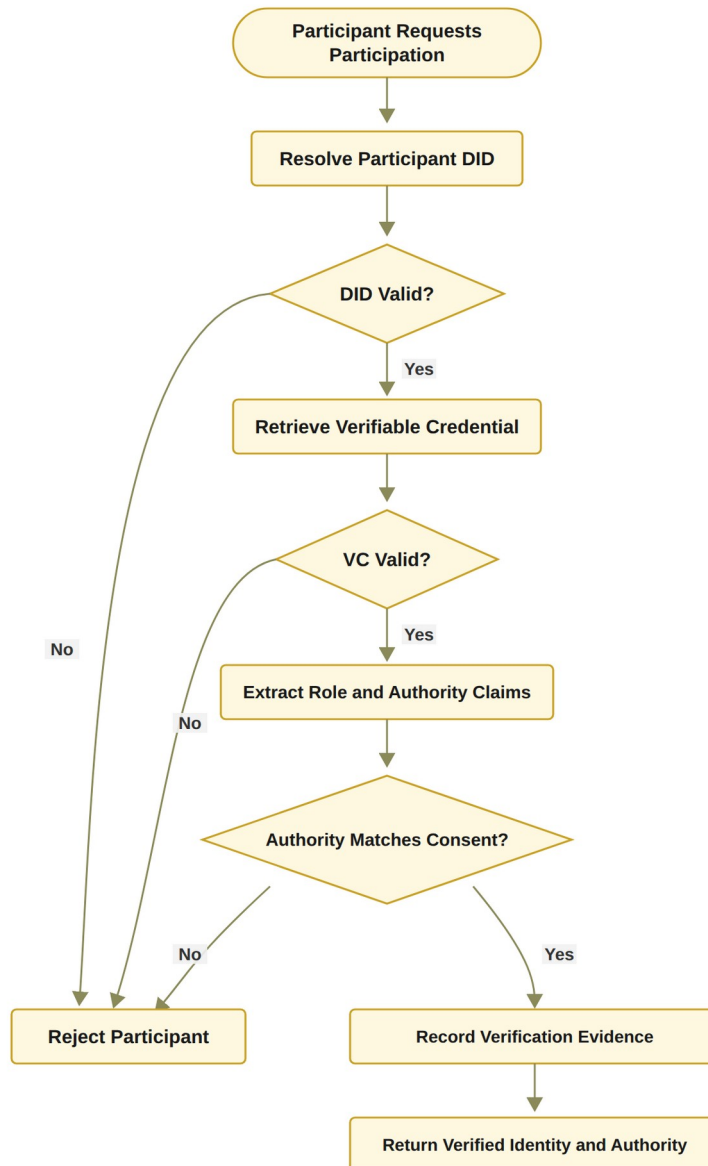


Figure 12: RO2 workflow for decentralised identity and authority verification

3. Step 3 – Retrieve the Participant’s Verifiable Credential. The system retrieves the verifiable credential (VC) associated with participant *u*. The VC provides machine-verifiable claims concerning the participant, such as professional role, organisational affiliation, or delegated authority. If an appropriate VC cannot be retrieved, the participant cannot establish the required authority and the verification process returns INVALID. 4. Step 4 – Verify the Verifiable Credential. In the target design the retrieved VC is cryptographically and semantically validated. The current prototype performs a structural check of the participant's DID string only. Full cryptographic validation is specified as the production behaviour. The system verifies the credential signature, issuer, subject, and validity conditions. In particular, the system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential

remains within its validity period. Formally, the credential can be considered valid only when  $VC_{\text{valid}} = \text{Sig}_{VC} \wedge \text{Issuer}_{\text{valid}} \wedge \text{Subject}_{\text{match}} \wedge \text{Time}_{\text{valid}}$ . If any of these conditions fails, the verification process returns INVALID. 5. Step 5 - Extract Role and Authority Claims. Once the VC has been successfully verified, the system extracts the relevant role and authority claims associated with participant  $u$ . Depending on the healthcare scenario, these claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims provide the evidence required for determining whether the participant satisfies the authority requirements of the consent object. 6. Step 6 - Compare Authority Claims with Consent Requirements. The extracted role and authority claims are compared against the authorisation requirements  $A$  specified in the consent object  $C$ . The purpose of this step is to ensure that possession of a valid identity or credential is not automatically interpreted as permission to access healthcare information. The authority verification condition can therefore be represented as  $\text{Authority}(u, C) = \text{Claims}(u) \models A_C$ , where  $\text{Claims}(u)$  denotes the verified claims associated with participant  $u$ , and  $A_C$  denotes the authority requirements defined by consent object  $C$ . If the participant's claims do not satisfy the required authority conditions, the system returns INVALID. 7. Step 7 - Establish Identity-Authority Binding. After the claims have satisfied the consent requirements, the system establishes the binding between the verified participant identity and the corresponding authority. This step ensures that the authority being exercised is associated with the same participant whose DID and VC have been successfully verified, thereby reducing the possibility of an unrelated credential being used to obtain access.

The condition  $VC_{\text{valid}}$  of Step 4 defines the target verification model rather than the behaviour presently exercised. The current prototype implements  $V_I(u)$  as a structural DID-format check and records its outcome in the audit ledger. Cryptographic validation of verifiable credentials against the four conditions above is specified here as the production behaviour. It is not yet exercised by the demonstration.

8. Step 8 - Record Identity and Authority Evidence. The system records the evidence generated during the verification process. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, verification timestamp, and the relationship between the verified claims and the consent requirements. This evidence provides an auditable basis for subsequent access-authorisation decisions. 9. Step 9 - Return the Verification Result. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns  $V_I(u) = \text{VALID}$ . Otherwise, the procedure terminates at the first failed mandatory verification condition and returns  $V_I(u) = \text{INVALID}$ . The overall verification process can therefore be represented as:  $\text{DID}_{\text{resolve}} \rightarrow \text{DID}_{\text{verify}} \rightarrow \text{VC}_{\text{retrieve}} \rightarrow \text{VC}_{\text{verify}} \rightarrow \text{Claims}_{\text{extract}} \rightarrow \text{Authority}_{\text{match}} \rightarrow \text{Evidence}_{\text{record}} \rightarrow V_I(u)$ . The procedure

establishes an important separation between identity verification and authority verification. A participant is not considered valid merely because a DID can be resolved or because a VC has a valid cryptographic signature. Instead, the participant must demonstrate that the verified credential claims satisfy the authority requirements associated with the specific consent object C. Consequently, the procedure can be interpreted as a two-layer verification mechanism  $\text{Identity}(u) \wedge \text{CredentialValidity}(u) \wedge \text{Authority}(u, C) \Rightarrow V_I(u) = \text{VALID}$ . This distinction is important for the proposed framework because a valid healthcare identity does not imply unrestricted access to healthcare data. DID and VC mechanisms provide trustworthy identity and attribute evidence, while the consent object provides the context against which those claims are evaluated. The resulting verification evidence can then be consumed by the subsequent policy, scope, and access-authorisation stages.

### 6.2.3 Algorithm 2: DID and VC Identity and Authority Verification

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance. This mechanism contributes to the trust-oriented framework by converting identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4.

---

#### Algorithm 2 DID and VC Identity and Authority Verification

---

**Require:** Participant  $u$ , consent object  $C$

**Ensure:** Verification result  $V_I(u)$

- 1: Resolve DID of  $u$
- 2: **if** DID resolution fails **then**
  - 3: **return** INVALID
- 4: **end if**
- 5: Verify DID document and associated identity information
- 6: **if** DID verification fails **then**
  - 7: **return** INVALID
- 8: **end if**
- 9: Retrieve VC associated with  $u$
- 10: **if** VC retrieval fails **then**
  - 11: **return** INVALID
- 12: **end if**
- 13: Verify VC signature, issuer, subject, and validity
- 14: **if** VC verification fails **then**
  - 15: **return** INVALID
- 16: **end if**
- 17: Extract role and authority claims from VC
- 18: **if** claims do not satisfy the authority requirements of  $C$  **then**
  - 19: **return** INVALID
- 20: **end if**

- 21: Record identity and authority verification evidence
  - 22: **return** VALID
- 

### 6.3 Trustworthy Multi-Party Authorisation for RO3

RO3 addresses RQ3 by developing a threshold-based multi-party authorisation mechanism. The objective is to ensure that sensitive healthcare data cannot be accessed through unilateral approval when the consent requires participation from multiple independently verified parties. Let  $A_v$  denote the set of valid approvals and let  $N$  denote the required authorisation threshold. The threshold condition is defined as

$$V_A(C) = \{ 1, |A_v| \geq N; 0, |A_v| < N \}. \quad (49)$$

The threshold mechanism establishes collective authorisation. It follows the threshold-committee principle used in decentralised identity systems [4, 33], but applies it to consent approval rather than to credential issuance. For example, a consent may require two valid guardian approvals. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold.

The N-of-N configuration was adopted for the prototype for two reasons. First, it is the most conservative instantiation of the threshold condition, because no designated guardian can be bypassed. Second, it allows the mechanism to be demonstrated without the quorum-selection and key-management questions that a general k-of-n threshold introduces. A configurable k-of-n threshold is a direct generalisation of the implemented mechanism. It is therefore left to future work.

#### 6.3.1 RO3 Multi-Party Authorisation Workflow

The workflow first identifies the participants required by the consent. Each participant must submit an approval that can be independently verified. Invalid approvals are rejected and must not contribute to the threshold count. Valid approvals are recorded and the current approval count is updated. The authorisation becomes active only when the number of valid approvals reaches the required threshold. In the HALAH implementation, the Guardian workflow verifies the guardian VC, appends the guardian DID to the consent signatures, and displays the current approval count relative to the threshold. When the threshold is reached, the implementation assigns an SBT identifier and records the corresponding minting event. The SBT should be interpreted as an activation or representation mechanism for the consent state rather than as the fundamental source of trust. The trust decision is established by the verification of participants and the satisfaction of the authorisation threshold. The blockchain or token layer provides persistence, traceability, and evidence of the resulting state.

In the HALAH implementation, the guardian's authority is evidenced by an EIP-712 typed-data signature. The signature is bound to the consent identifier, the guardian DID and the Sepolia chain identifier, and it is verified through off-chain signer recovery. The VC verification that precedes the signature is presently a DID-format check. In addition, the signing keys are derived deterministically from the guardian DIDs rather than held in wallets. It should be noted that this substitution is a limitation of the prototype. At access time the recovery is repeated for every recorded signature within the identity predicate  $V_I$ , whereas  $V_A$  counts the recorded approvals against  $N$  and checks the token identifier and the revocation flag.

Figure 13 presents the RO3 workflow.

### **6.3.2 Procedure for Threshold-Based Multi-Party Authorisation**

The Threshold-Based Multi-Party Authorisation procedure determines whether a consent-defined authorisation requirement has received sufficient valid approvals from the designated participants. Rather than relying on a single approval authority, the procedure requires a predefined number of eligible participants to independently provide valid approvals. This mechanism reduces reliance on a single decision-maker and provides an auditable basis for activating consent-related authorisation. 1. Step 1 – Retrieve the Required Participant Set. The system first retrieves the required participant set  $G$  associated with the consent object  $C$ . The set  $G$  defines which participants are eligible to contribute an approval to the authorisation process. Depending on the consent configuration,  $G$  may contain healthcare professionals, guardians, institutional representatives, or other authorised parties.

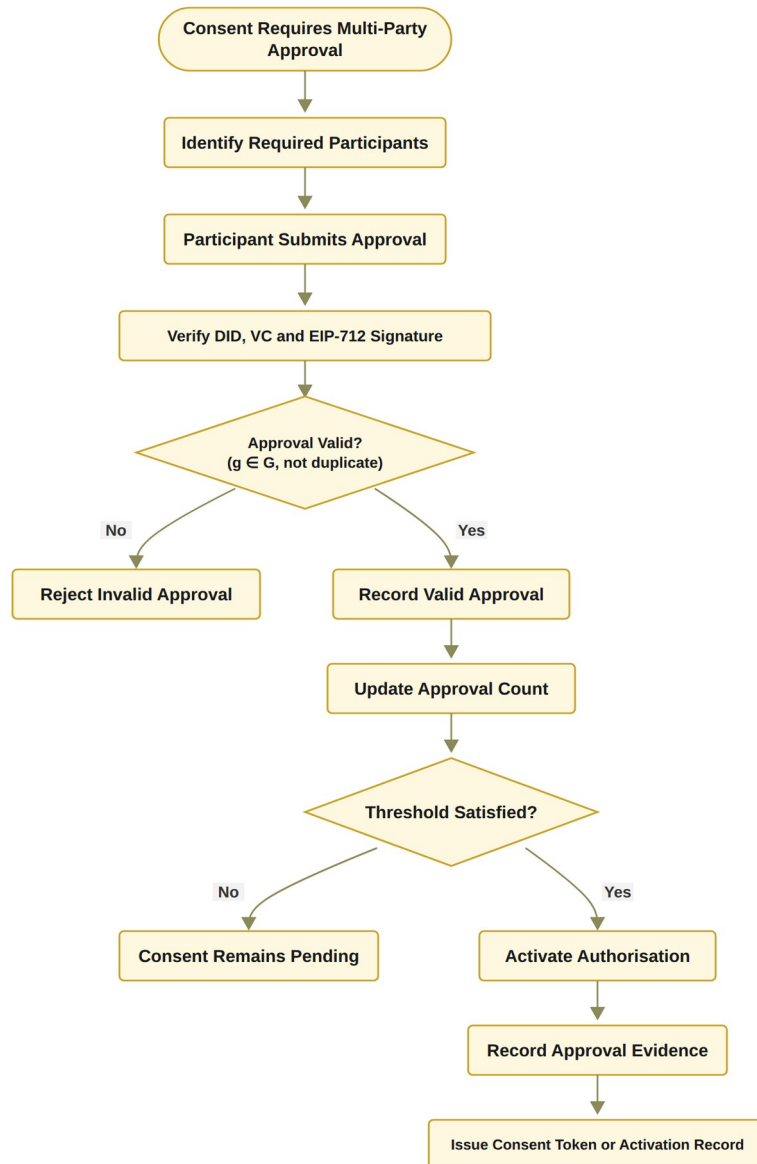


Figure 13: RO3 workflow for threshold-based multi-party authorisation

2. Step 2 – Define the Authorisation Threshold. The system obtains the threshold value  $N$ , which specifies the minimum number of valid and distinct approvals required to activate the authorisation. The threshold must satisfy  $1 \leq N \leq |G|$ . The threshold therefore determines how many eligible participants must independently approve the consent before the authorisation becomes active. 3. Step 3 – Receive a Participant Approval. A participant submits an approval  $a$  associated with consent object  $C$ . The approval is treated as a candidate authorisation contribution and is not considered valid until the identity and authority of the submitting participant have been verified. 4. Step 4 – Verify the Identity and Authority of the Approving Participant. The system verifies the identity and authority of the participant submitting  $a$ . The verification process may invoke the DID and VC verification procedure described in Algorithm 2. The system therefore determines whether the participant possesses a valid identity

and whether the associated authority claims satisfy the requirements of consent object C. If the verification fails, the approval is classified as invalid. The system records the invalid approval event and returns DENY for that approval attempt.

5. Step 5 – Verify Participant Eligibility. If the participant’s identity and authority are successfully verified, the system determines whether the participant belongs to the required participant set G. Formally,  $u \in G$ . If the participant is not a member of G, the approval cannot contribute to the threshold. The system records the event as an unauthorised approval attempt and returns DENY.

6. Step 6 – Check for Duplicate Approval. The system checks whether the participant has already approved consent object C. This prevents a single participant from submitting multiple approvals and artificially satisfying the threshold. Formally, no approval already contained in the valid approval set  $A_v$  may originate from participant u. If the participant has already submitted a valid approval, the system records a duplicate approval event and rejects the additional approval.

7. Step 7 – Record the Valid Approval. If the participant is both authorised and eligible, and no previous approval from that participant exists, the system records the approval a as valid. The corresponding participant is added to the valid approval set  $A_v$ . The approval set is therefore updated according to  $A_v \leftarrow A_v \cup \{a\}$ . Each valid approval becomes an independent piece of authorisation evidence associated with consent object C.

8. Step 8 – Evaluate the Approval Threshold. The system evaluates the number of valid approvals currently associated with the consent:  $|A_v| \geq N$ . This comparison determines whether the minimum number of required participants has been reached. It should be noted that only approvals that have passed the identity, authority, membership and duplicate checks are included in  $A_v$ .

9. Step 9 – Activate the Authorisation if the Threshold Is Satisfied. If  $|A_v| \geq N$ , the required threshold has been satisfied. The system activates the authorisation associated with consent object C. The activation indicates that the consent has obtained sufficient valid multi-party approval to proceed to the subsequent access-control or data-access stage.

10. Step 10 – Generate Activation Evidence. Following successful threshold satisfaction, the system generates activation or token evidence associated with the authorisation decision. The evidence may include the consent identifier, threshold value N, identities of the approving participants, approval timestamps, and the resulting authorisation state. This evidence provides a verifiable representation of how the authorisation was activated and which participants contributed to the decision.

11. Step 11 – Record the Threshold-Satisfied Event. The system records a threshold-satisfied event in the audit infrastructure. This event provides an immutable or otherwise tamper-evident record of the transition from a pending consent state to an active authorisation state.

12. Step 12 – Maintain Pending State if the Threshold Is Not Satisfied. If  $|A_v| < N$ , the consent does not yet satisfy the required multi-party authorisation condition. The system therefore maintains the consent in a PENDING state rather than activating access. The system records a threshold-pending event so that the current

authorisation state and the remaining approval requirement can be reconstructed during subsequent verification or audit.

13. Step 13 - Return the Authorisation Result. The final result is determined according to the threshold condition:  $\text{Authorisation}(C) = \{ \text{ACTIVATED}, |A_v| \geq N; \text{PENDING}, |A_v| < N \}$ . Invalid, unauthorised, or duplicate approval attempts are rejected and do not contribute to the valid approval count. The overall procedure can therefore be represented as:

$$G \rightarrow N \rightarrow a \rightarrow \text{Identity/Authority} \rightarrow \text{Eligibility} \rightarrow \text{Duplicate Check} \rightarrow A_v \rightarrow |A_v| \geq N \rightarrow \{ \text{ACTIVATED}; \text{PENDING} \} \quad (50)$$

The threshold condition can be expressed more explicitly as  $[\forall u_i \in A_v, \text{Identity}(u_i) \wedge \text{Authority}(u_i, C) \wedge (u_i \in G)] \wedge |A_v| \geq N \Rightarrow \text{Authorisation}(C) = \text{ACTIVATED}$ . This formulation is important because the threshold is not calculated from the number of submitted approvals alone. Instead, only valid, authorised, eligible, and non-duplicate approvals contribute to the threshold. Consequently, the procedure prevents a participant from satisfying the authorisation requirement merely by submitting multiple approvals or by presenting a valid identity without possessing the required authority. The procedure also introduces a clear distinction between approval and authorisation. An individual approval represents one participant's contribution to the decision, whereas authorisation is activated only when the collective evidence satisfies the predefined threshold. This provides a distributed decision mechanism in which no single participant necessarily has unilateral authority to activate the consent. From a trust perspective, the procedure can therefore be interpreted as

$$\text{Individual Trust Evidence} \rightarrow \text{Collective Approval Evidence} \rightarrow \text{Threshold Satisfaction} \rightarrow \text{Authorisation Activation} \quad (51)$$

### 6.3.3 Algorithm 3: Threshold-Based Multi-Party Authorisation

Algorithm 3 explicitly distinguishes between invalid, duplicate, and valid approvals. This distinction is important because simply counting submitted signatures could incorrectly treat unauthorised or repeated approvals as independent evidence. The algorithm also demonstrates why multi-party authorisation is a trust mechanism rather than merely a user-interface feature. The final decision depends on independently verified participants and a predefined collective requirement. Therefore, a single participant cannot unilaterally activate the consent when the threshold has not been satisfied. This mechanism complements the DID/VC verification procedure in Algorithm 2. Algorithm 2 establishes whether an individual participant possesses a valid identity and sufficient authority, whereas Algorithm 3 determines whether a sufficient number of independently verified participants have collectively satisfied the consent-defined authorisation requirement. The resulting activation evidence can subsequently be consumed by the policy and scope enforcement layer before healthcare data are released.



---

**Algorithm 3** Threshold-Based Multi-Party Authorisation

---

**Require:** Consent object  $C$  with identifier  $id_c$ , purpose  $P_u$ , interval  $(t_s, t_e)$  and jurisdiction  $L$ ; patient and requester addresses  $addr_p$ ,  $addr_r$ ; EIP-712 domain; approval  $a = (g, sig_a)$  submitted by guardian  $g$ ; threshold  $N = |G|$

**Ensure:** Authorisation result

- 1: Retrieve required participant set  $G$
  - 2:  $N \leftarrow |G|$
  - 3: Verify identity and authority of  $g$  (Algorithm 2; structural DID check in the prototype); **if** the verification fails **then** record the invalid approval and **return** DENY
  - 4:  $signer \leftarrow \text{RecoverEIP712}(\text{domain}, \{id_c, g, \text{APPROVE}\}, sig_a) \triangleright$  off-chain recovery
  - 5: **if**  $signer \neq \text{Addr}(g)$ , or the signature binds a different consent, guardian, or chain **then**
    - 6: Record invalid approval
    - 7: **return** DENY
  - 8: **end if**
  - 9: **if** participant is not in  $G$  **then**
    - 10: Record unauthorised approval attempt
    - 11: **return** DENY
  - 12: **end if**
  - 13: **if** participant has already approved  $C$  **then**
    - 14: Record duplicate approval
    - 15: **return** DENY
  - 16: **end if**
  - 17: Record  $signature\_data[g] \leftarrow (signer, sig_a)$
  - 18: Update valid approval set  $A_v$
  - 19: **if**  $|A_v| \geq N$  **then**
    - 20: Activate authorisation
    - 21: record a local token identifier; state  $\leftarrow$  ACTIVE once  $t_s$  has been reached
    - 22: submit  $\text{mintConsentV3}(addr_p, addr_r, P_u, t_s, t_e, L, \text{burnAuth})$  via the owner account  $\triangleright$  the contract stores  $\text{keccak256}(P_u)$ ; background job; reconciled on request from the guardian view
    - 23: on confirmation: replace the local token identifier with the on-chain token identifier
    - 24: Record threshold-satisfied event
    - 25: **return** ACTIVATED  $\triangleright$  activation is distinct from the access decision
  - 26: **else**
    - 27: Keep consent in pending state
    - 28: Record threshold-pending event
    - 29: **return** PENDING
  - 30: **end if**
- 

## 6.4 Policy- and Context-Aware Access Control for RO4

RO4 addresses RQ4 by developing a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is based on the observation that a valid identity and sufficient approval do not necessarily imply that every requested operation is permitted. A doctor

may be a legitimate participant and may possess a valid consent, but the requested data may exceed the authorised scope or the requested purpose may not match the purpose specified by the patient. Let  $S_C$  denote the data scope authorised by the consent and  $S_R$  denote the data scope requested by the participant. The scope condition is

$$V_S(C, R) = 1 \Leftrightarrow S_R \subseteq S_C. \quad (52)$$

The policy condition can therefore be expressed as

$$V_P(C, R) = V_U(C, R) \wedge V_S(C, R), \quad (53)$$

where  $V_U(C, R)$  represents purpose compatibility and  $V_S(C, R)$  represents data-scope compatibility. The complete authorisation decision enforced by the implemented system is, as stated in Equation (26),

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L \quad (54)$$

where the five verification functions are evaluated at every access request, and the resulting decision matrix is recorded in the audit ledger together with each GRANTED or DENIED outcome. In the prototype the matrix column  $V_P$  records the purpose check  $V_U$  only. The scope condition  $V_S$  is evaluated separately by the scope check of the doctor subsystem, and the final decision combines the matrix with that scope check and with the verified access proof.

#### 6.4.1 RO4 Policy-Aware Access Workflow

The workflow begins when a doctor submits a request for patient data. The system retrieves the relevant consent object and verifies the requesting participant. It then checks whether the required multi-party authorisation has been established. After the identity and authorisation conditions are satisfied, the system evaluates the requested purpose and data scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is contained within the authorised scope. The HALAH implementation provides a concrete basis for this objective. The Doctor interface retrieves a consent, evaluates its state, allows a requested scope to be selected from the consent scope, generates a proof, checks the requested scope, and invokes the authorisation function before returning data. Figure 14 presents this workflow. For example, if

$$S_C = \{Observation, Medication\}, \quad (55)$$

and

$$S_R = \{Observation, Medication, Procedure\}, \quad (56)$$

then

$$S_R \not\subseteq S_C, \quad (57)$$

and the request must be denied. This rule prevents a legitimate participant from obtaining data outside the patient's authorised scope.

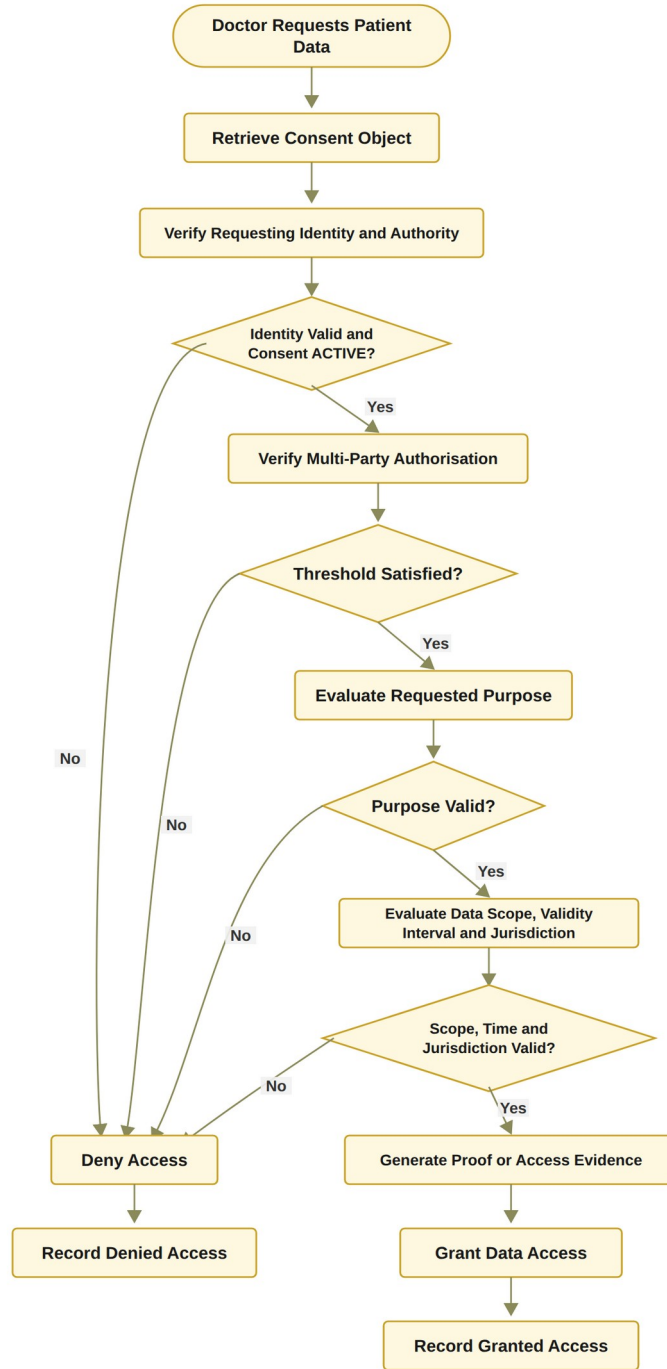


Figure 14: RO4 workflow for policy- and context-aware access control

#### 6.4.2 Algorithm 4: Policy-Aware Access Decision

---

##### Algorithm 4 Policy-Aware Access Decision

---

**Require:** Consent object  $C$ , access request  $R = (u, P_R, S_R, \text{Jur}(R))$ , requesting participant  $u$ , current time  $t$

**Ensure:** Access decision

- 1: Verify DID and VC of  $u$
- 2: **if** identity or authority verification fails **then**
- 3: Record denied decision
- 4: **return** DENY

```

5: end if
6: Evaluate consent state
7: if consent is not active then
8:   Record denied decision
9:   return DENY
10: end if
11: Verify multi-party authorisation
12: if threshold is not satisfied then
13:   Record denied decision
14:   return DENY
15: end if
16: Evaluate requested purpose
17: if purpose is incompatible with consent then
18:   Record denied decision
19:   return DENY
20: end if
21: Evaluate requested data scope
22: if  $S_R = \emptyset$  or  $S_R \not\subseteq S_C$  then
23:   Record denied decision
24:   return DENY
25: end if
26: if  $t < t_s$  or  $t > t_e$  then Record denied decision; return DENY end if
27: if  $Jur(R) \neq Jur(C)$  then Record denied decision; return DENY end if
28: Generate and verify a Groth16 proof that Poseidon(secret, expiry) equals the
   public commitment and that  $t \leq t_e$ ; record proof_mode = groth16
29: Retrieve authorised healthcare data
30: Record granted decision
31: return ALLOW

```

---

Algorithm 4 demonstrates that policy evaluation is performed after identity and multi-party authorisation verification but before data release. This ordering is important because it prevents the system from treating identity validity or collective approval as unrestricted permission.

The algorithm also establishes the connection between the proposed framework and the HALAH access-control implementation. The system must determine whether a consent exists, and it must also evaluate whether the current request satisfies the scope and purpose constraints of that consent. Both granted and denied requests should be recorded to support accountability and auditability.

### 6.4.3 Procedure for Policy-Aware Access Decision

The Policy-Aware Access Decision procedure determines whether a specific healthcare data-access request should be authorised. It does so by jointly evaluating the requesting participant's identity and authority, the current consent state, and the required multi-party authorisation condition. It also evaluates the intended purpose and the requested data scope. Rather than treating successful authentication as sufficient for access, the procedure evaluates the complete set of conditions defined by

the consent and applicable access-control policies. The procedure consists of the following steps. 1. Step 1 – Receive and Parse the Access Request. The system receives an access request  $R$  from requesting participant  $u$ . The request specifies the healthcare resources requested by the participant and the intended purpose of access. The requested data scope is denoted by  $S_R$ , while the purpose associated with the request is denoted by  $P_R$ . The access request can therefore be represented as  $R = (u, P_R, S_R, \text{Jur}(R))$ , where  $\text{Jur}(R)$  is the jurisdiction declared by the requester. The system associates  $R$  with the relevant consent object  $C$  before continuing with the authorisation process. 2. Step 2 – Verify the Requesting Participant’s DID and VC. The system verifies the DID and VC associated with participant  $u$ . This step invokes the identity and authority verification procedure defined in Algorithm 2. The system determines whether the participant possesses a valid decentralised identity and whether the associated verifiable credentials provide sufficient authority for the requested healthcare interaction. If identity or authority verification fails, the request is denied and the denial event is recorded. Formally,  $V_I(u) = \text{VALID}$  must hold before the request can proceed to the subsequent authorisation stages. 3. Step 3 – Evaluate the Current Consent State. After successful identity verification, the system evaluates the current state of consent object  $C$ . The system determines whether the consent is active and whether it remains within its defined validity period. In particular, the system verifies that the consent has not expired, been revoked, or otherwise transitioned into an inactive state. If  $\text{State}(C) \neq \text{ACTIVE}$ , the access request is denied and the decision is recorded.

4. Step 4 – Verify Multi-Party Authorisation. The system verifies whether the multi-party authorisation requirement associated with consent object  $C$  has been satisfied. The valid approval set  $A_v$  is evaluated against the required threshold  $N$ . The authorisation condition is expressed as  $|A_v| \geq N$ . If the threshold has not been satisfied, the consent cannot be used to authorise the requested access. The system therefore records a denied decision and returns DENY. 5. Step 5 – Evaluate the Requested Purpose. The system compares the purpose specified in the access request  $P_R$  with the purpose permitted by the consent object  $P_C$ . The purpose compatibility condition can be represented as  $P_R \models P_C$ , which means the requested purpose is required to satisfy the privacy constraint  $P_C$  before access can proceed. The evaluation is designed so that a request violating the privacy constraint is refused before any data are released. A formal proof of this property forms part of the next-stage security analysis. If the requested purpose is incompatible with the patient’s consent, the request is denied. This step prevents a participant from using otherwise valid credentials and consent to access healthcare information for a purpose that was not authorised by the patient. 6. Step 6 – Evaluate the Requested Data Scope. The system evaluates whether the requested data scope  $S_R$  is contained within the data scope authorised by the consent, denoted by  $S_C$ . The required containment relationship is  $S_R \subseteq S_C$ . If  $S_R \not\subseteq S_C$ , the requested

access exceeds the patient's authorised data scope. The system records a denied decision and returns DENY. This step is particularly important for fine-grained healthcare data access because authorisation to access one category of healthcare information does not imply authorisation to access all categories of the patient's record.

7. Step 7 - Evaluate the Complete Authorisation Policy. After the individual conditions have been successfully evaluated, the system performs the final policy evaluation. The decision is based on the conjunction of identity validity, active consent, sufficient multi-party approval, purpose compatibility, scope containment, temporal validity and jurisdictional match. The overall authorisation condition can be represented as  $\text{Authorised}(R, C, u) = V_I(u) \wedge \text{Active}(C) \wedge (|A_v| \geq N) \wedge \text{PurposeMatch}(P_R, P_C) \wedge \text{ScopeMatch}(S_R, S_C) \wedge (t_s \leq t \leq t_e) \wedge (\text{Jur}(R) = \text{Jur}(C))$ . Access can proceed only when all required conditions evaluate to true.

8. Step 8 - Generate or Verify Access Evidence. If the policy evaluation succeeds, the system generates or verifies the evidence supporting the access decision. The evidence may include the consent identifier, requesting participant DID, relevant VC claims, consent state, approval threshold, approving participants, requested purpose, requested scope, and decision timestamp. This evidence provides an auditable relationship between the access request and the conditions that justified the resulting authorisation.

9. Step 9 - Retrieve the Authorised Healthcare Data. Once the request has been successfully authorised, the system retrieves only the healthcare data satisfying the authorised scope  $S_R$ . The retrieval operation must enforce the same scope constraints that were evaluated during the policy decision. Thus,  $\text{Data}_{\text{returned}} \subseteq S_C$ . This prevents a mismatch between the policy decision and the actual data returned to the requester.

10. Step 10 - Record the Granted Decision. The system records the successful access-authorisation event. The recorded evidence may include the request identifier, consent identifier, requester identity, authorised purpose, authorised data scope, authorisation result, and relevant timestamp. The resulting event provides an auditable record of why and under which conditions access was granted.

11. Step 11 - Return the Final Access Decision. If all mandatory conditions have been satisfied, the system returns  $\text{AccessDecision} = \text{ALLOW}$ . If any mandatory condition fails during the evaluation process, the system records the corresponding denial evidence and returns  $\text{AccessDecision} = \text{DENY}$ . The overall decision process can therefore be represented as  $R \rightarrow \text{DID/VC} \rightarrow \text{Consent State} \rightarrow \text{Threshold} \rightarrow \text{Purpose} \rightarrow \text{Scope} \rightarrow \text{Time} \rightarrow \text{Jurisdiction} \rightarrow \text{Policy Eval.} \rightarrow \text{Evidence} \rightarrow \text{Data Retr.} \rightarrow \{ \text{ALLOW; DENY} \}$

As stated in Section 6.3, the implemented approval threshold is N-of-N with  $N = |G|$ , and the evaluated configuration is 2-of-2. Consequently, a configurable k-of-n threshold remains an item of future work rather than a property of the demonstrated prototype.

In the demonstrated prototype the doctor does not declare a separate request purpose. The purpose bound to the consent is checked against the supported purpose vocabulary (Treatment, Research and Emergency) and

is stored on-chain as `keccak256(purpose)`, so that  $V_P$  is presently evaluated over the consent purpose rather than over a requester-declared  $P_R$ . A formal proof that no execution path can violate the privacy policy is left to future work.

In the HALAH implementation, the access-evidence step (Step 8) is realised by generating and verifying a Groth16 zero-knowledge proof. The proof shows that the prover knows the secret and the expiry time behind a Poseidon commitment held in the application's consent record, and that the consent has not expired at time  $t$ . The proof mode is recorded with the decision in the audit ledger. Therefore, the proof constitutes the access evidence required by Algorithm 4 (line 28) before any data are retrieved.

It should be noted that the denial of lines 7 to 10 of Algorithm 4, for a consent that is not ACTIVE, is reported in the doctor interface but is not written to the audit ledger in the current prototype. Only requests evaluated against an ACTIVE consent produce the `STATE_CHECK` and `DATA_ACCESS` records, and the refusal that follows revocation is therefore evidenced by the interface (Figure 36) and by the automated tests rather than by a ledger row.

The final access decision can be formally expressed as  $\text{ALLOW} \iff \text{Identity} \wedge \text{Consent} \wedge \text{Authority} \wedge \text{Threshold} \wedge \text{Purpose} \wedge \text{Scope} \wedge \text{Time} \wedge \text{Jurisdiction} \wedge \text{Evidence}$  where the individual conditions are defined as follows. Identity, Consent, Authority and Threshold represent verified participant identity, active consent, sufficient authority and satisfied multi-party approval, respectively. Purpose, Scope, Time, Jurisdiction and Evidence represent compatible purpose, authorised data scope, temporal validity, jurisdictional match and sufficient decision evidence, respectively. This procedure establishes an important distinction between authentication, consent, and authorisation. A successfully authenticated participant is not automatically granted access. Instead, authentication provides identity evidence, consent provides patient-defined permission constraints, multi-party approval provides distributed authority evidence, and policy evaluation determines whether the particular request satisfies all applicable conditions. The procedure also implements the principle of least privilege through the explicit scope-containment condition that  $S_R \subseteq S_C$ . Consequently, even when a participant possesses a valid DID, a valid VC, and sufficient authority, the participant cannot retrieve healthcare resources outside the scope explicitly authorised by the consent. Similarly, a valid consent cannot be used for an incompatible purpose or before the required multi-party authorisation threshold has been reached. From an architectural perspective, Algorithm 4 therefore acts as the final policy-enforcement layer of the proposed authorisation lifecycle. Algorithm 1 establishes the consent constraints, Algorithm 2 establishes trustworthy identity and authority evidence, and Algorithm 3 establishes collective authorisation evidence. Algorithm 4 integrates these evidence sources with the specific access request and determines whether the requested

healthcare data can actually be released. The resulting end-to-end authorisation lifecycle can be summarised as

*Consent Creation → Identity Verification → Multi-Party Auth → Policy Decision*

In this context, healthcare data access is not a simple credential-based permission check. It is an evidence-based authorisation process in which identity, consent, authority, distributed approval, purpose, scope and audit evidence jointly determine the final access decision.

## 6.5 Temporal and Lifecycle Trust for RO5

RO5 addresses RQ5 and extends the foundational current-stage authorisation model with temporal validity and consent lifecycle controls. This objective was originally planned for the next stage (CA3). It has, however, been realised in the current prototype. The objective investigates how an authorisation remains trustworthy as time passes and as the consent state changes. The foundational model of Equation (37) evaluates identity, collective authorisation and policy compliance. RO5 extends this model by introducing temporal and lifecycle conditions, and the extended rule is the one enforced by the prototype. The temporal condition is defined as

$$V_T(C, t) = 1, t_s \leq t \leq t_e; 0, \text{ otherwise.} \quad (58)$$

The jurisdictional condition can be expressed as

$$V_L(C, R) = 1 \Leftrightarrow \text{Jur}(R) = \text{Jur}(C) \vee \text{Jur}(C) = \emptyset. \quad (59)$$

where  $\text{Jur}(\cdot)$  denotes the jurisdiction attribute, recorded on-chain as a two-letter ISO code. Lifecycle state and revocation are evaluated within  $V_A$  rather than within this predicate. In the decision rules that follow,  $V_L(C, R)$  is abbreviated to  $V_L(C)$  because the request  $R$  is understood. It should be noted that this check produced the demonstrated denial, in which a request declaring jurisdiction SA was refused against a consent issued for AU. The jurisdiction L is validated and bound at consent creation (Section 6.1.1). Therefore, the disjunct  $\text{Jur}(C) = \emptyset$  is not reached for any consent created through the current interface. In the demonstrated system the predicate reduces to strict equality, as the denial shown in Section 6.8.5 illustrates.

The extended authorisation decision is therefore

$$\text{Decision}(C, R, t) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (60)$$

The purpose of RO5 is not simply to add an expiry field. It is to ensure that the validity of a consent depends on both its temporal interval and its current lifecycle state. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied.



### 6.5.1 RO5 Temporal and Lifecycle Workflow

Temporal and lifecycle enforcement is implemented in the demonstrated prototype. In particular, the Consent Engine evaluates  $t_s \leq t \leq t_e$  at every access request. The deployed contract stores the notBefore and expiry fields and exposes the checkValid and checkValidAt functions. Revocation is executed both in the application state and as an on-chain revoke transaction confirmed in block 11,771,307. Figure 15 presents the RO5 workflow. It should be noted that the access decision evaluates  $V_T$  and  $V_L$  from the application record. The on-chain functions checkValid and checkValidAt are read by the independent verification tool rather than by the Consent Engine.

The implemented workflow evaluates the consent's temporal interval, lifecycle state, and revocation status before the system proceeds with the remaining authorisation conditions. This design ensures that a consent is not treated as permanently valid after it has expired or entered a state that no longer permits access.

### 6.5.2 Procedure for Temporal and Lifecycle Validation

The Temporal and Lifecycle Validation procedure determines whether a consent object remains temporally valid and whether the requested operation is permitted under its current lifecycle state. Unlike static authorisation checks, this procedure explicitly considers the temporal validity, revocation status, and state-transition rules of the consent object. It therefore ensures that a previously valid consent cannot be treated as permanently valid after expiration, revocation, or an unauthorised lifecycle transition.

1. Step 1 - Retrieve the Consent Validity Interval. The system retrieves the start time  $t_s$  and expiry time  $t_e$  associated with consent object C. These temporal attributes define the period during which the consent is potentially valid. The consent validity interval is represented as  $T_C = [t_s, t_e]$ . The system uses the current time  $t$  to determine whether the consent is currently within its defined validity period.
2. Step 2 - Validate the Current Time. The system compares the current time  $t$  with the consent validity interval. Temporal validity requires  $t_s \leq t \leq t_e$ . If  $t < t_s$  or  $t > t_e$ , the consent is considered temporally invalid. The system records the temporal invalidity evidence and returns INVALID. This step prevents a consent from being used before its effective start time or after its expiration time.
3. Step 3 - Retrieve the Current Lifecycle State. If the temporal condition is satisfied, the system retrieves the current lifecycle state of consent object C. Typical lifecycle states may include CREATED, PENDING, ACTIVE, SUSPENDED, REVOKED, and EXPIRED, depending on the system configuration. The current state is used to determine whether the requested operation can legally and logically be performed.
4. Step 4 - Validate State-Dependent Operations. The system evaluates whether the current lifecycle state permits the requested operation  $q$ . Different operations may be permitted only in specific lifecycle states. For example,

activation may require a consent to be in a pending state, while data access may require the consent to be active.

In the HALAH prototype the implemented lifecycle states are PENDING\_SIGNATURE, PENDING\_TOKEN, NOT\_STARTED, ACTIVE, EXPIRED and REVOKED. These six states realise the conceptual lifecycle of Equation (12). PENDING\_SIGNATURE and PENDING\_TOKEN correspond to the Verification and Approval stages, NOT\_STARTED and ACTIVE correspond to the Active stage before and within the validity interval, and EXPIRED and REVOKED correspond to the Expiration/Revocation stage.

The state transition condition can be represented as  $\text{State}(C) \models q$ . If the current state does not permit operation  $q$ , the system records an invalid lifecycle-state event and returns INVALID. 5. Step 5 - Check Revocation Status. The system explicitly checks whether consent object  $C$  has been revoked. Revocation represents a deliberate termination of the previously granted consent and must therefore override an otherwise valid temporal interval. Formally,  $\text{Revoked}(C) = \text{false}$  must hold for the consent to remain usable. If  $\text{Revoked}(C) = \text{true}$ , the system records revocation-based invalidity and returns INVALID. 6. Step 6 - Validate the Requested Lifecycle Transition. If the consent is temporally valid, in an appropriate lifecycle state, and has not been revoked, the system validates the requested transition  $q$ . The transition is evaluated against the predefined lifecycle-transition policy:  $\text{State}(C) \rightarrow^q \text{State}'(C)$ . The transition is valid only when  $q$  is explicitly permitted from the current state. If the transition is not permitted, the system records an unauthorised state-transition event and returns INVALID. 7. Step 7 - Establish Temporal and Lifecycle Consistency. After all individual checks have succeeded, the system establishes that the consent is simultaneously valid in terms of time, lifecycle state, revocation status, and requested transition. The overall lifecycle-validity condition can therefore be expressed as  $V_s(C, t, q) = \text{TimeValid}(C, t) \wedge \text{StateValid}(C, q) \wedge \neg \text{Revoked}(C) \wedge \text{TransitionValid}(C, q)$ . Only when all four conditions are satisfied can the consent proceed to the subsequent operation. 8. Step 8 - Record Temporal and Lifecycle Evidence. The system records evidence associated with the successful validation. The evidence may include the consent identifier, current timestamp, validity interval, current lifecycle state, revocation status, requested transition, and validation result. This evidence establishes an auditable relationship between the consent's lifecycle state and the operation performed at a particular point in time. It should be noted that the symbol  $V_s$  in this section denotes the lifecycle predicate  $V_s(C)$  of Eq. (13), extended here with the temporal condition  $V_t(C, t)$ . The implementation evaluates this predicate within  $V_A$ . It must not be confused with the data-scope predicate  $V_s(C, R)$  of Eq. (52). For this reason the lifecycle predicate is always written with three arguments,  $V_s(C, t, q)$ , in this section. It is distinct from the jurisdictional predicate  $V_l(C)$  of the decision rule, which is evaluated separately.

9. Step 9 - Return the Lifecycle Validation Result. If all temporal and lifecycle conditions are satisfied, the system returns  $V_s(C, t, q) = \text{VALID}$ . If any mandatory condition fails, the procedure returns  $V_s(C, t, q) = \text{INVALID}$ . The overall validation process can therefore be represented as  $C \rightarrow T_c \rightarrow t \rightarrow \text{State}(C) \rightarrow \text{Revocation} \rightarrow q \rightarrow \text{Lifecycle Validation} \rightarrow \text{Evidence} \rightarrow \{\text{VALID}; \text{INVALID}\}$ . The complete lifecycle-validity condition can be summarised as  $\text{VALID} \iff (t_s \leq t \leq t_e) \wedge \text{State}(C) \models q \wedge \neg \text{Revoked}(C) \wedge \text{TransitionPermitted}(q)$ . This procedure establishes that consent validity is not a static property. Instead, the validity of consent is a function of both time and lifecycle state that  $\text{Validity}(C) = f(t, \text{State}(C), \text{Revocation}(C))$ . Consequently, a consent that was valid at time  $t_1$  may become invalid at a later time  $t_2$  because it has expired, been revoked, suspended, or otherwise transitioned into a state that does not permit the requested operation. The explicit lifecycle validation also introduces an important distinction between consent existence and consent usability. The existence of a consent record in the system does not imply that the consent remains effective. Similarly, a consent that has successfully passed identity and authority verification may still be unusable if its validity period has expired or if it has subsequently been revoked. This temporal property can be represented as:  $\text{ConsentExists}(C) \neq \text{ConsentUsable}(C, t)$ . Instead,  $\text{ConsentUsable}(C, t) \Rightarrow \text{TimeValid}(C, t) \wedge \text{StateValid}(C) \wedge \neg \text{Revoked}(C)$ . The procedure therefore provides the lifecycle control required to connect the initial consent creation process with subsequent access decisions. Algorithm 1 establishes the consent object and its validity interval, Algorithm 2 verifies the identity and authority of participating entities, Algorithm 3 establishes multi-party approval, and Algorithm 4 evaluates the specific access request. Algorithm 5 complements these mechanisms by ensuring that the consent and its associated authorisation remain valid throughout their operational lifecycle. From the perspective of the overall HALAH architecture, the overall flow can therefore be summarised as  $\text{Consent} \rightarrow \text{Identity} \rightarrow \text{Authority} \rightarrow \text{Policy} \rightarrow \text{Temporal/Lifecycle Validation} \rightarrow \text{Access}$ .

The lifecycle validation mechanism can therefore be interpreted as a per-request validity layer. Validity is re-established at each evaluated access request and is recorded as a `STATE_CHECK` event in the audit ledger. It is not assumed to persist between requests.

Rather than treating authorisation as a one-time event, this approach enables the system to determine whether authorisation remains valid at the precise time an operation is requested. This is particularly important for dynamic consent environments [13, 24] in which permissions may expire, be revoked, suspended, renewed, or otherwise modified during the lifecycle of a healthcare data-sharing relationship.

### 6.5.3 Algorithm 5: Temporal and Lifecycle Validation

---

**Algorithm 5** Temporal and Lifecycle Validation

---

**Require:** Consent object  $C$ , current time  $t$ , requested transition  $q$

**Ensure:** Lifecycle validity result

- 1: Retrieve consent start time  $t_s$  and expiry time  $t_e$
  - 2: **if**  $t < t_s$  or  $t > t_e$  **then**
    - 3: Record temporal invalidity
    - 4: **return** INVALID
  - 5: **end if**
  - 6: Retrieve current lifecycle state of  $C$
  - 7: **if** current state does not permit the requested operation **then**
    - 8: Record invalid lifecycle state
    - 9: **return** INVALID
  - 10: **end if**
  - 11: Check whether  $C$  has been revoked
  - 12: **if**  $C$  is revoked **then**
    - 13: Record revocation-based invalidity
    - 14: **return** INVALID
  - 15: **end if**
  - 16: Validate requested transition  $q$
  - 17: **if** transition  $q$  is not permitted **then**
    - 18: Record unauthorised state transition
    - 19: **return** INVALID
  - 20: **end if**
  - 21: Record valid temporal and lifecycle evidence
  - 22: **return** VALID
- 

Algorithm 5 is implemented in the current prototype, with the exception of the transition check of lines 16 to 20. The lifecycle state is derived at each evaluation from the recorded signatures, the token identifier and the revocation flag, and revocation is accepted from any state that is not already REVOKED. Its checks are executed at every access request submitted against an active consent and recorded as STATE\_CHECK events in the audit ledger. Consequently, expiration and revocation already condition the demonstrated access decisions. They do not await a later implementation stage.

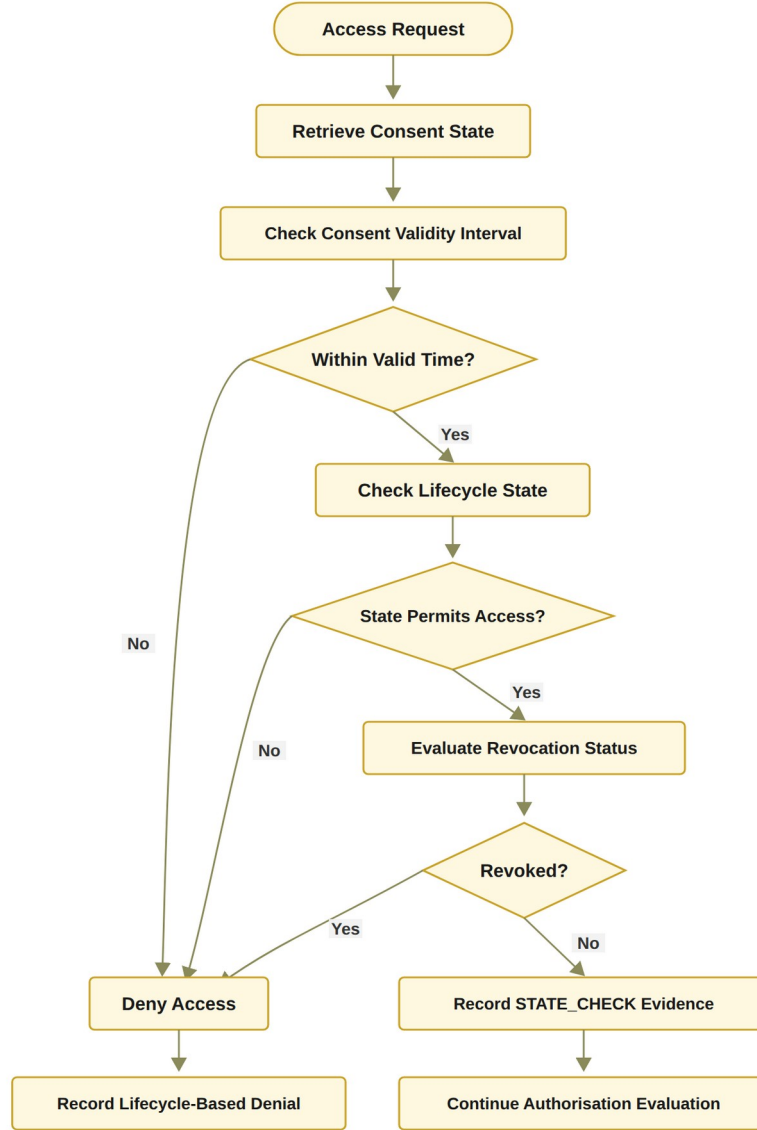


Figure 15: RO5 workflow for temporal and consent lifecycle trust

Algorithm 5 therefore ensures that consent validity in the demonstrated decision process is dynamic rather than permanent.

## 6.6 Formal Security Assurance and Empirical Validation for RO6

RO6 addresses RQ6 by formally analysing and empirically evaluating whether the proposed trust-oriented authorisation framework satisfies its defined security and authorisation properties. The objective combines two complementary forms of assurance. Formal security assurance specifies the conditions under which the authorisation mechanism should be considered secure and consistent. Empirical validation evaluates whether the implemented system behaves according to those conditions under representative healthcare data-sharing scenarios. The formal decision model is expressed in Equation (61) below.

The empirical half of this objective has been carried out on the demonstrated prototype, whereas formal proofs and model checking of the authorisation properties remain future work. Figure 16 presents the RO6 workflow for security assurance and empirical validation. Of the two forms of assurance, the empirical evaluation shown in the figure has been executed on the prototype, whereas the formal analysis of the decision rule remains planned. The empirical evidence consists of three parts, all of which are presented in Section 6.8. The first part is the 23 automated tests, which exercise per-dimension failures of the decision matrix, invalid EIP-712 guardian signatures, and tampered or expired proofs. The second part is the live demonstration on Sepolia, which includes the jurisdiction-based denial and the revocation followed by refusal. The third part is the independent re-verification of every recorded transaction against the chain.

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (61)$$

The soundness property that has been validated is  $Decision(C, R, t) = ALLOW \Rightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ . Equations (62) and (63) give the foundational three-predicate form of this property. In addition, each conjunct of the five-predicate rule is exercised by a dedicated per-dimension failure test, which confirms that access is denied when that predicate alone fails.

$$Decision(C, R) = ALLOW \Rightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (62)$$

This implication expresses the soundness requirement that every granted request must satisfy the identity, authorisation, and policy conditions. Conversely, if any mandatory condition is violated, the request must be denied:

$$\neg V_I(u) \vee \neg V_A(C) \vee \neg V_P(C, R) \Rightarrow Decision(C, R) = DENY. \quad (63)$$

### 6.6.1 RO6 Assurance and Validation Workflow

In particular, 23 automated tests cover per-dimension failures of the decision matrix, rejection of invalid EIP-712 signatures, and zero-knowledge tamper and expiry cases. The live demonstration includes a jurisdiction-based denial and a revocation followed by refusal. In addition, an independent verification tool re-checks every ledger transaction against Sepolia receipts and reports ALL CHECKS PASSED.

The validation process begins by defining the security and authorisation properties that the framework is expected to satisfy. These properties include identity validity, threshold correctness, policy compliance, denial of unauthorised requests, and consistency between the authorisation decision and the audit evidence. The HALAH prototype provides the implementation basis for this evaluation. The current system includes separate patient, guardian, doctor, and auditor interfaces. It also records consent creation, guardian approval, token minting, state checks, and data-access events.

### 6.6.2 Procedure for Formal and Empirical Authorisation Validation

The Formal and Empirical Authorisation Validation procedure evaluates whether the proposed framework  $F$  correctly implements the intended authorisation model under normal, invalid, and adversarial conditions. Rather than validating the framework only through successful

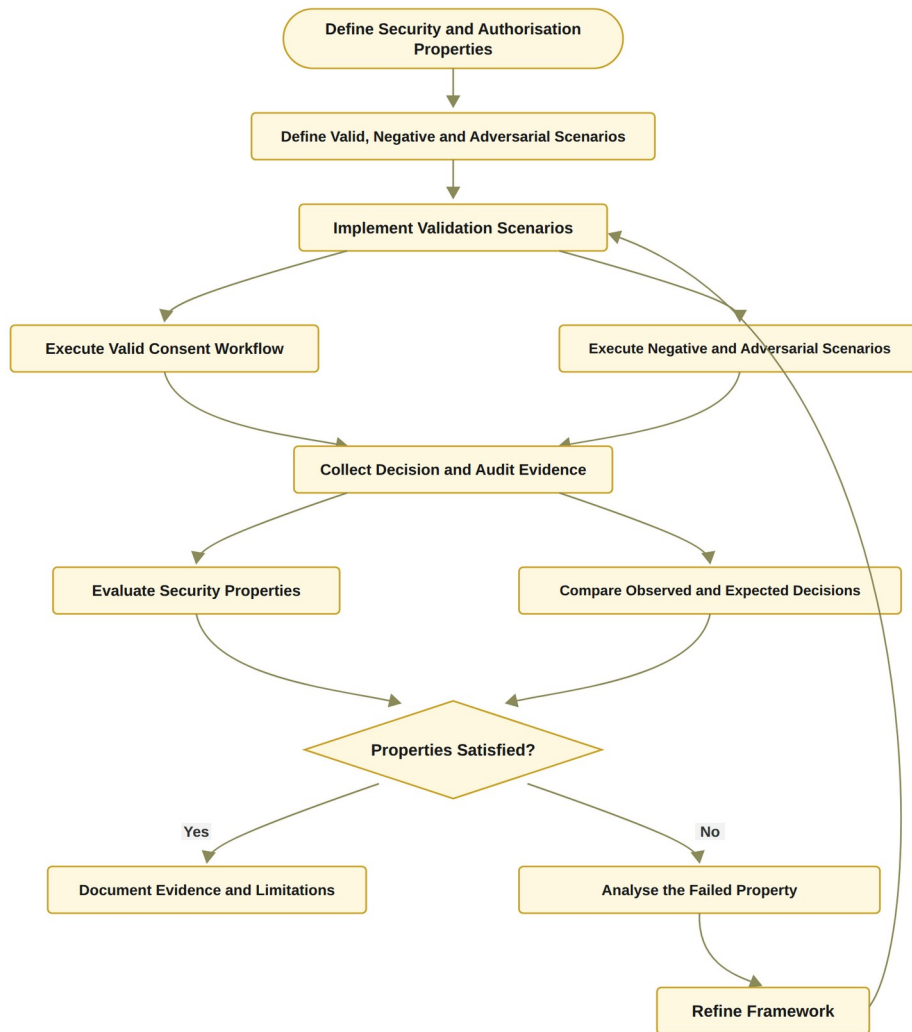


Figure 16: RO6 workflow for formal security assurance and empirical validation

execution cases, the procedure systematically evaluates both positive and negative behaviours and examines whether observed authorisation decisions are consistent with the formally defined security properties. The procedure therefore combines scenario-based empirical testing with property-oriented validation of authorisation correctness, denial behaviour, threshold enforcement, policy and scope compliance, and audit consistency. 1. Step 1 – Define the Expected Authorisation Properties. The first step is to define the security and authorisation properties  $P$  that the framework is expected to satisfy. These properties provide the formal evaluation criteria against which the observed system behaviour will

subsequently be compared. The properties may include authorisation soundness, correct denial of unauthorised requests, threshold correctness, policy compliance, scope enforcement, and audit consistency. Formally,  $P = \{P_{\text{sound}}, P_{\text{deny}}, P_{\text{threshold}}, P_{\text{policy}}, P_{\text{scope}}, P_{\text{audit}}\}$ . 2. Step 2 – Define Valid Scenarios. The system defines a set of valid scenarios  $S_{\text{valid}}$ , representing legitimate healthcare data-access workflows. These scenarios should contain valid patient identities, valid credentials, active consent, sufficient authority, satisfied multi-party approval, compatible purposes, and authorised data scopes. The purpose of these scenarios is to verify that legitimate requests are successfully authorised and that the framework does not incorrectly reject valid operations. 3. Step 3 – Define Negative Scenarios. The system defines a set of negative scenarios  $S_{\text{negative}}$ , representing requests that violate one or more authorisation conditions. Examples include invalid identities, expired consent, revoked consent, insufficient approval, unauthorised roles, incompatible purposes, and requests for data outside the consent scope. These scenarios test whether the framework correctly prevents access when an authorisation requirement is not satisfied. 4. Step 4 – Define Adversarial Scenarios. The system defines adversarial scenarios  $S_{\text{adv}}$ , representing attempts to circumvent or manipulate the authorisation process. Such scenarios may include replayed approvals, duplicate approvals, unauthorised participants attempting to satisfy a threshold, invalid or forged credentials, attempts to access data outside the authorised scope, and attempts to use a revoked or expired consent object. The adversarial test set is particularly important because it is not sufficient for a framework to show that legitimate requests succeed. The framework must also resist foreseeable attempts to bypass its security controls. 5. Step 5 – Construct the Complete Validation Scenario Set. The three scenario classes are combined into the complete validation set:  $S = S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}}$ .

Each scenario  $s \in S$  is associated with an expected authorisation outcome and the security properties that it is intended to evaluate. 6. Step 6 – Execute Each Scenario Using the Framework. The system executes each scenario  $s$  using the implemented framework  $F$ . During execution, the framework performs the corresponding consent, identity, authority, threshold, policy, scope, and lifecycle checks. The execution process is treated as an empirical observation of the implemented authorisation model that  $F(s) \rightarrow D_{\text{obs}}$ , where  $D_{\text{obs}}$  denotes the observed authorisation decision. 7. Step 7 – Collect the Observed Authorisation Decision. After each scenario has been executed, the system records the resulting authorisation decision. Depending on the operation, the observed result may be ALLOW, DENY, PENDING, or another explicitly defined lifecycle state. The observed decision is stored together with the corresponding scenario identifier to enable subsequent comparison with the expected outcome. 8. Step 8 – Collect Supporting Authorisation Evidence. In addition to the final decision, the system collects the evidence generated during the authorisation process. This evidence may include identity



verification results, VC validation results, participant approvals, threshold status, consent state, purpose evaluation, scope evaluation, timestamps, and audit records. The collected evidence can therefore be represented as  $E_s = \{E_I, E_A, E_C, E_T, E_P, E_S, E_L\}$ , where the individual components represent identity, authority, consent, threshold, policy, scope, and lifecycle evidence. 9. Step 9 - Compare Observed and Expected Decisions. The observed decision is compared with the expected decision defined for scenario  $s$ . Let  $D_{\text{exp}}(s)$  denote the expected decision and  $D_{\text{obs}}(s)$  denote the observed decision. The scenario passes when  $D_{\text{obs}}(s) = D_{\text{exp}}(s)$ . Otherwise, the scenario is classified as a validation failure.

10. Step 10 - Record the Scenario Result. The system records whether each scenario has passed or failed. For each failure, the corresponding condition, observed behaviour, expected behaviour, and supporting evidence are retained for subsequent analysis. This enables validation results to be traced from the final decision back to the individual authorisation conditions that produced that decision. 11. Step 11 - Evaluate Authorisation Soundness. The system evaluates the soundness property to determine whether every granted request satisfies the required authorisation conditions. Formally,  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow \text{Authorised}(s) = \text{TRUE}$ . A sound framework should not grant access when one or more mandatory authorisation conditions are violated. 12. Step 12 - Evaluate Denial Correctness. The system evaluates whether invalid or unauthorised requests are correctly denied. The denial property can be represented as  $\text{Authorised}(s) = \text{FALSE} \Rightarrow D_{\text{obs}}(s) \neq \text{ALLOW}$ . This evaluation is particularly important for negative and adversarial scenarios because successful operation under valid conditions alone cannot demonstrate that unauthorised access is reliably prevented. 13. Step 13 - Evaluate Threshold Correctness. The system evaluates whether multi-party authorisation is activated only when the required threshold condition is satisfied. The expected threshold property is  $\text{Authorisation}(C) = \text{ACTIVATED} \Rightarrow |A_v| \geq N$ . The evaluation should also verify that invalid, duplicate, or unauthorised approvals do not contribute to  $A_v$ . This ensures that the threshold cannot be artificially satisfied by repeated or illegitimate approval submissions. 14. Step 14 - Evaluate Policy and Scope Enforcement. The system evaluates whether every granted request satisfies the consent-defined policy and data-scope constraints. In particular, the scope enforcement property is  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow S_R \subseteq S_C$ .

The evaluation should verify that a participant cannot obtain healthcare resources outside the scope authorised by the patient's consent, even when the participant possesses a valid identity and authority credential. Purpose compatibility is evaluated similarly:  $D_{\text{obs}}(s) = \text{ALLOW} \Rightarrow P_R \models P_C$ . 15. Step 15 - Evaluate Audit Consistency. The system evaluates whether the recorded audit evidence is consistent with the actual authorisation decision and the underlying verification events. For an access event  $e$ , the audit record should provide sufficient evidence to establish a relationship between the request, requester, consent, policy evaluation, authorisation

result, and timestamp. Therefore,  $\text{Audit}(e) \models \text{Decision}(e)$ . An audit inconsistency occurs when the recorded evidence does not correspond to the actual system decision or when critical authorisation evidence is missing. 16. Step 16 - Analyse Failures and Limitations. Any failed scenario is analysed to determine the source and significance of the failure. The analysis distinguishes between implementation defects, policy-definition errors, integration problems, incomplete security controls, and limitations of the experimental environment. The purpose of this step is not to conceal unsuccessful cases but to determine whether observed failures represent violations of the intended security properties or limitations that should be addressed in future work. 17. Step 17 - Consolidate the Validation Results. Finally, the individual scenario results and property-level evaluations are consolidated into an overall validation result. The resulting evidence includes:  $V = \{R_{\text{scenario}}, R_{\text{sound}}, R_{\text{deny}}, R_{\text{threshold}}, R_{\text{policy}}, R_{\text{scope}}, R_{\text{audit}}\}$ . The framework is considered empirically consistent with the specified authorisation model when the observed decisions satisfy the expected outcomes across the defined validation scenarios and no critical security property is violated. The overall validation process can therefore be represented as

$$P \rightarrow S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}} \rightarrow F(s) \rightarrow D_{\text{obs}} \rightarrow E_s \rightarrow D_{\text{obs}} \stackrel{?}{=} D_{\text{exp}} \rightarrow \text{Property Evaluation} \rightarrow \text{Failure Analysis} \rightarrow \text{Validation Evidence}$$

The fundamental scenario-level validation criterion is  $\text{Pass}(s) \iff D_{\text{obs}}(s) = D_{\text{exp}}(s)$  while the framework-level validation can be expressed as:  $\text{Valid}(F) \Rightarrow P_{\text{sound}} \wedge P_{\text{deny}} \wedge P_{\text{threshold}} \wedge P_{\text{policy}} \wedge P_{\text{scope}} \wedge P_{\text{audit}}$ . This procedure establishes a distinction between functional correctness and security correctness. A system may successfully execute an access request and return data without necessarily demonstrating that the request should have been authorised. The proposed validation therefore does not treat successful execution as sufficient evidence of correctness. Instead, the observed decision must be consistent with the formally specified authorisation conditions. The use of three complementary scenario classes is particularly important. Valid scenarios establish that legitimate users can obtain authorised access, negative scenarios establish that invalid requests are correctly rejected, and adversarial scenarios examine whether security controls can resist deliberate attempts to circumvent the authorisation process. Together, these scenarios provide a more balanced evaluation of both the positive security property of granting legitimate access and the negative security property of preventing illegitimate access. The validation procedure also provides traceability between the final access decision and its supporting evidence. For each scenario, the decision can be interpreted as:  $\text{Decision}(s) = f(\text{Identity}, \text{Authority}, \text{Consent}, \text{Threshold}, \text{Purpose}, \text{Scope}, \text{Lifecycle}, \text{Evidence})$ . Consequently, validation does not merely determine whether the final output is ALLOW or DENY ; it also determines whether the underlying evidence is consistent with the decision. This is particularly important for a trust-aware framework because a correct decision without sufficient supporting evidence cannot provide strong

assurance regarding how the decision was reached. The relationship between the six algorithms can therefore be represented as Algorithm 1 : Create Consent Algorithm 2 : Verify Identity and Authority Algorithm 3 : Establish Multi-Party Authorisation Algorithm 4 : Evaluate Access Request Algorithm 5 : Validate Temporal and Lifecycle State Algorithm 6 : Validate the Complete Framework Algorithm 6 therefore operates at the highest level of the proposed methodology. Algorithms 1-5 define the operational authorisation lifecycle, whereas Algorithm 6 evaluates whether the complete lifecycle behaves according to its intended security properties. This creates a closed methodological loop Design → Implementation → Execution → Observation → Verification → Validation Therefore, the validation methodology provides empirical evidence that the proposed authorisation model can be enforced and tested in practice under legitimate, invalid and adversarial conditions, rather than remaining a conceptual definition only.

---

**Algorithm 6** Formal and Empirical Authorisation Validation

---

**Require:** Framework implementation  $F$ , validation scenarios  $S$ , security properties  $P$

**Ensure:** Validation evidence and evaluation results

- 1: Define expected authorisation properties  $P$
  - 2: Define valid scenarios  $S_{\text{valid}}$
  - 3: Define negative scenarios  $S_{\text{negative}}$
  - 4: Define adversarial scenarios  $S_{\text{adv}}$
  - 5: **for** each scenario  $s$  in  $S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}}$  **do**
    - 6: Execute  $s$  using framework  $F$
    - 7: Collect authorisation decision
    - 8: Collect identity, approval, policy, and audit evidence
    - 9: Compare observed decision with expected decision
    - 10: Record pass or failure result
  - 11: **end for**
  - 12: Evaluate soundness property
  - 13: Evaluate denial property
  - 14: Evaluate threshold correctness
  - 15: Evaluate policy-scope enforcement
  - 16: Evaluate audit consistency
  - 17: Analyse failures and limitations
  - 18: **return** Validation results
- 

### 6.6.3 Algorithm 6: Formal and Empirical Authorisation Validation

Algorithm 6 provides a structured method for evaluating the framework. It does not assume that successful execution of a consent workflow is sufficient evidence of security. Instead, it requires the system to demonstrate that invalid conditions produce appropriate denial decisions and that the recorded evidence is consistent with the decision. The formal and empirical components are complementary. Formal reasoning defines what the framework should guarantee, while empirical testing examines

whether the implementation satisfies those guarantees in representative operational scenarios. This combination is necessary because a system may be conceptually correct but incorrectly implemented, or may pass functional tests while failing under invalid or adversarial conditions.

## 6.7 Algorithms and the Research Objectives

The six algorithms correspond directly to the six research objectives and provide a progressive development structure for the proposed framework. Algorithm 1 establishes the consent representation, while Algorithm 2 verifies the identity and authority information contained in that representation. Algorithm 3 then establishes collective authorisation through independently verified approvals. Algorithm 4 evaluates whether a specific access request satisfies the consent policy before healthcare data are released. The final two algorithms extend this foundational mechanism. Algorithm 5 introduces temporal and lifecycle validity, while Algorithm 6 provides formal and empirical assurance of the complete framework. This structure reflects the staged research design. The current stage establishes the foundational authorisation mechanisms together with their dynamic validity. CA3 completes their formal security assurance and their practical evaluation.

security assurance and comprehensive practical evaluation. The overall trust-oriented authorisation process can therefore be summarised as Trustworthy Access with 1) Identity Trust, 2) Authority Trust, 3) Collective Authorisation, 4) Policy Compliance, 5) Temporal, Jurisdictional and Lifecycle Trust, and 6) Formal and Empirical Assurance of the complete decision. For the current stage implementation, the operational decision was originally based on the three-predicate rule of Equation (64), which the five-predicate rule of Equation (65) now supersedes in the implemented system.

$$Decision(C, R) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (64)$$

The extended rule, originally planned for CA3 and now enforced by the implemented system, incorporates temporal, jurisdictional and lifecycle conditions, as already stated in Equations (54), (60) and (61), such that

$$Decision(C, R, t) = ALLOW \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \quad (65)$$

Under Equation (65) access is granted only when all five predicates hold, revocation is evaluated within  $V_A$ , and every decision evaluated against an active consent, whether granted or denied, is logged together with the full decision matrix.

Algorithms 1, 3 and 4 are realised in the current prototype. Algorithm 5 is realised except for its transition check (lines 16 to 20). Algorithm 2 is realised in its structural form as a DID-format check without cryptographic VC validation. The empirical branch of Algorithm 6 has been executed against the prototype. Consequently, only the formal-assurance branch,

together with configurable k-of-n thresholds and authenticated requesters, remains for the next stage.

These equations demonstrate that trust is not provided by blockchain alone. Blockchain contributes integrity, tamper resistance, persistence, and auditability [2], [18]. DID and VC mechanisms contribute identity and authority evidence. Multi-party authorisation contributes collective decision-making. Policy evaluation contributes contextual compliance. Temporal and lifecycle controls contribute dynamic validity. The proposed framework integrates these mechanisms into a coherent authorisation process in which access is granted only when the required trust conditions are satisfied.

The remainder of this chapter moves from the formal design to its realisation. Section 6.8 presents the implemented HALAH system and its live demonstration on the Sepolia test network. In this way each algorithm introduced above can be traced to observable behaviour and to publicly verifiable on-chain transactions.

## 6.8 Implementation and Live Demonstration of the Proposed Solution

The HALAH implementation provides a role-based patient consent management environment that operationalises the proposed multi-party healthcare data-sharing framework. The subsystem is organised around four principal functions: patient consent creation, guardian cryptographic approval, authorised doctor data access, and independent audit of the consent lifecycle. Rather than treating consent as a single approval event, the implementation represents consent as a lifecycle in which a consent request is created, independently authorised by designated parties, and cryptographically activated on a public blockchain. The consent is then checked for validity at every request and is used to control access to specific electronic medical record (EMR) modules. EMR is the term used by the implementation for the electronic health record (EHR) components discussed in the earlier chapters.

The activation and revocation of a consent are not confined to the application. Instead, they are executed as real transactions on the **Ethereum Sepolia** test network. Consequently, the essential state changes of a consent can be verified by any third party on a public block explorer. The overall workflow implemented by the system is therefore consistent with the proposed authorisation model as

*Create Consent → Guardian Approval → Multi-signature Validation → On-chain Consent Activation  
→ Doctor Access → Consent Revocation → Independent Audit*

This sequence provides an end-to-end demonstration of how the conceptual consent model is translated into an operational healthcare data-sharing process. Each stage is documented below with a screenshot of the running system and, where the stage produces a blockchain transaction, with the corresponding transaction on Sepolia Etherscan.

This operational sequence realises the trust-oriented authorisation model developed in the preceding sections of this chapter. The consent object of Eq. (46), the identity and authority verification of Algorithm 2, the threshold-based multi-party authorisation of Algorithm 3 and the trust-predicate evaluation of Figure 8 are each exercised in this workflow. In addition, the resulting activation and revocation are anchored by real transactions on the Ethereum Sepolia test network. Consequently, the conceptual model and the running system can be verified against one another.

### 6.8.1 The HALAH System

The main HALAH subsystem presents itself as a Patient Consent Management Platform for History Access by Authorised Healthcare Providers. The subsystem provides a role-oriented environment in which different participants interact with the same consent lifecycle according to their respective authorisation responsibilities.

The implementation does not expose the underlying blockchain and cryptographic mechanisms as isolated technical components. Instead, these mechanisms are incorporated into the user workflow. Consequently, the subsystem presents the system from the perspective of the healthcare participants while the underlying implementation performs identity verification, consent-state checking, multi-party approval, cryptographic validation, on-chain anchoring and audit recording.

This design corresponds to the overall HALAH architecture, in which decentralised identifiers (DIDs) [20] provide identity pointers, the consent object defines the authorisation conditions, cryptographic signatures provide evidence of approval, and the blockchain-based ledger provides lifecycle traceability.

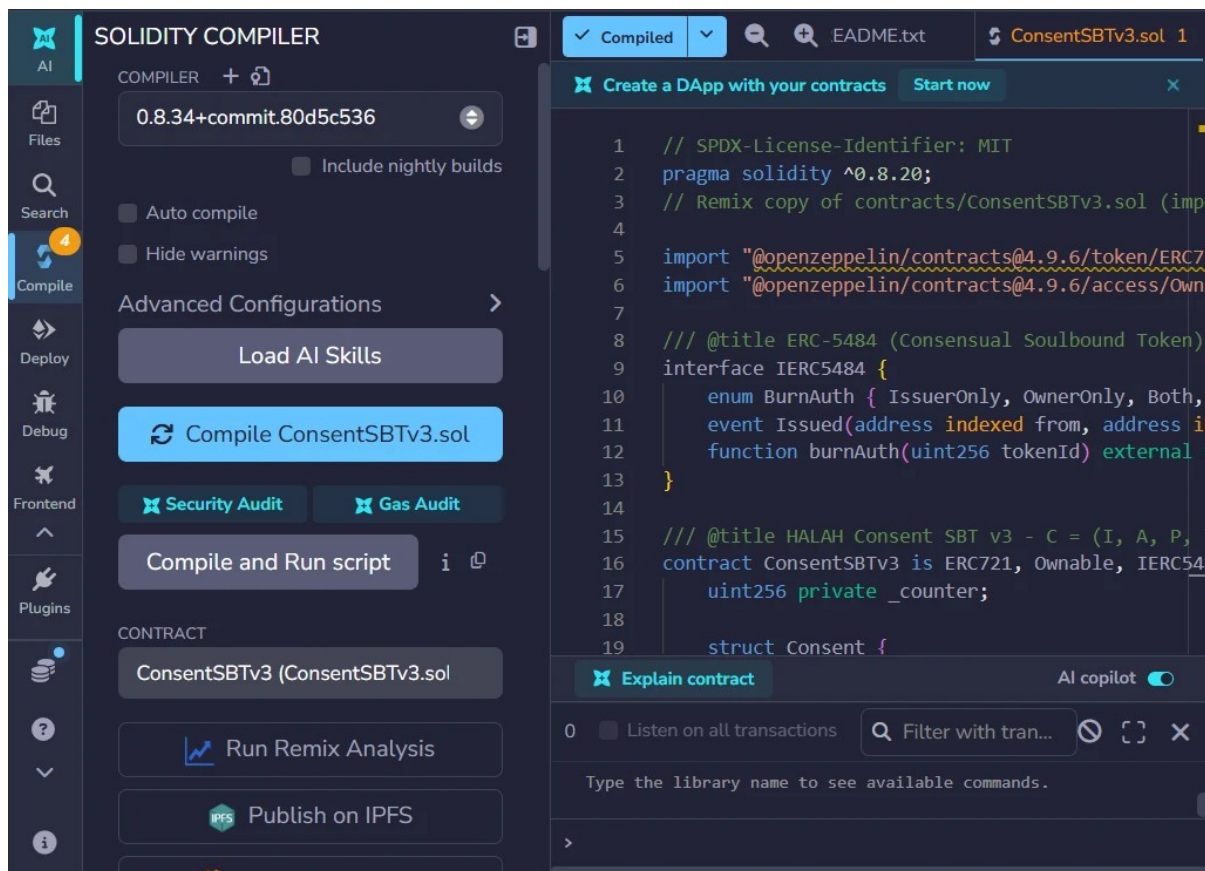


Figure 17: Compilation of ConsentSBTV3 in Remix: the compiler reports a successful compilation and the contract is selected for deployment.

As shown in Figure 17, the consent token contract, ConsentSBTV3, was first compiled in Remix without errors. The deployment record lists solc 0.8.34 with the optimiser enabled. The contract was then deployed to the Sepolia test network from the project test wallet through MetaMask. The contract implements a soulbound ERC-721 token, and transfers between accounts are blocked. Consequently, an activated consent can never be traded or moved. Burning is possible only through the ERC-5484 consensual-burn interface. Each token stores the pseudonymous patient and requester addresses, a hash of the purpose, the validity window, a two-letter jurisdiction code and a revocation flag. The contract stores the

purpose only as a keccak256 hash, and no medical content is written to the chain. It should be noted, however, that the plaintext purpose is passed as a parameter of the mint transaction and is therefore visible in the public transaction input. The EMR data remain in the application.

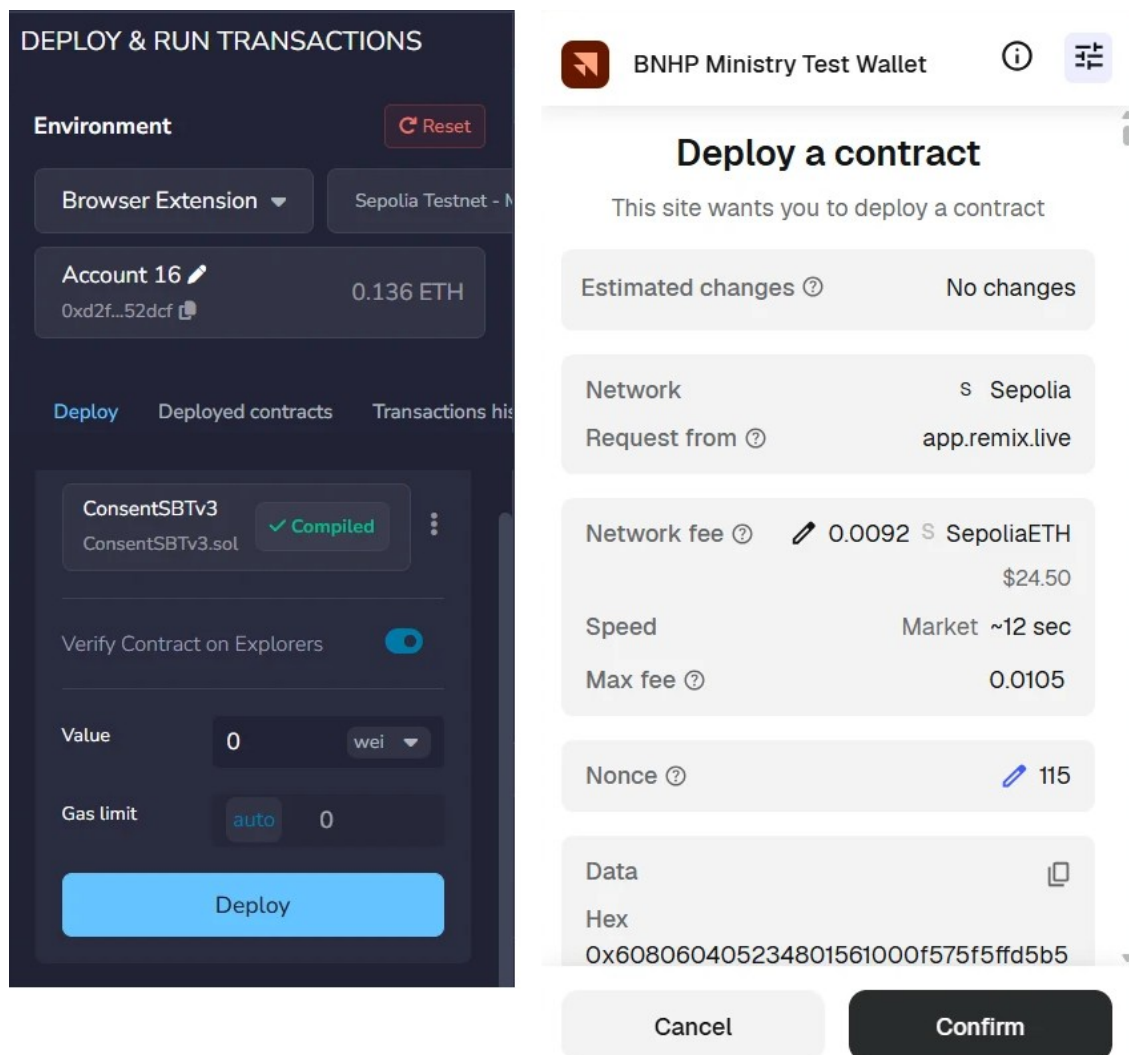


Figure 18: Deployment of ConsentSBTV3 from Remix through MetaMask on the Sepolia network.

As shown in Figure 18, the deployment is an ordinary Ethereum transaction that the wallet owner must explicitly confirm. The project test wallet, displayed as BNHP Ministry Test Wallet, shows the target network (Sepolia), the estimated network fee and the account nonce before the contract is created. This is important because it demonstrates that consent activation in HALAH ultimately rests on the same transaction-signing discipline as any other blockchain operation.



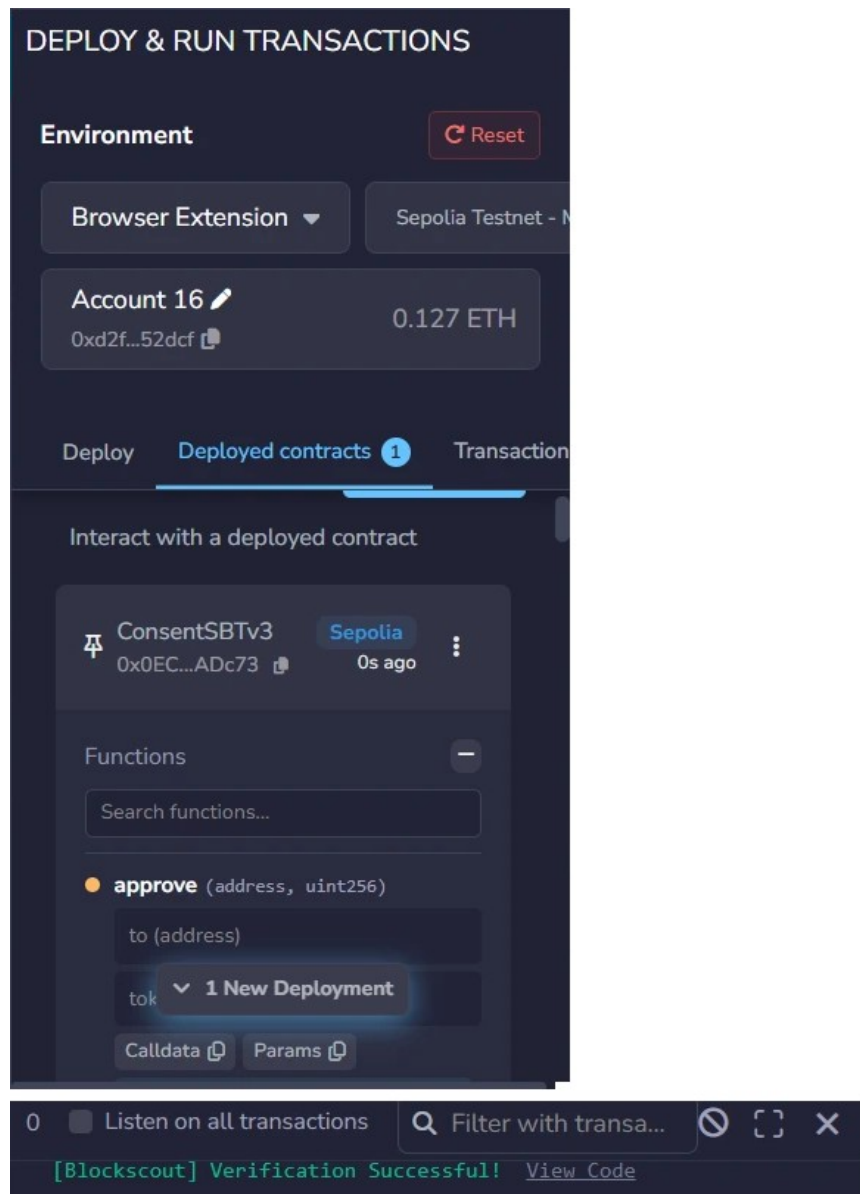


Figure 19: Remix after deployment: the contract appears under Deployed Contracts and the source verification service reports Verification Successful.

As shown in Figure 19, the deployed instance is listed in Remix under Deployed Contracts, and the source code was submitted for verification, which completed with Verification Successful. This is important because it ties the published bytecode on Sepolia to the Solidity source. Consequently, any party can confirm which rules the consent registry enforces.

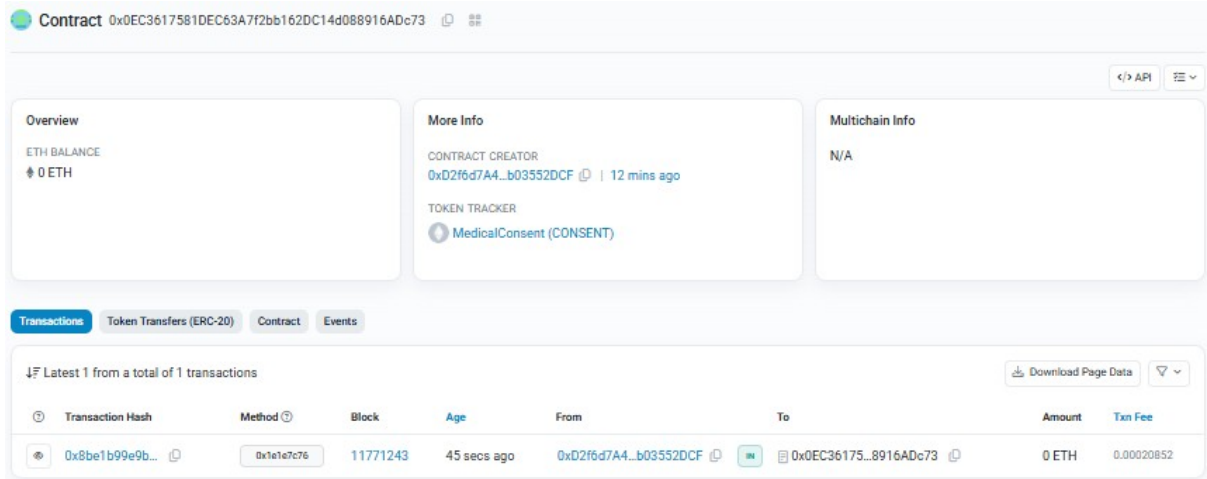


Figure 20: The deployed contract on Sepolia Etherscan, with the creator wallet, the MedicalConsent (CONSENT) token tracker and the first mint transaction.

As shown in Figure 20, the deployed contract is publicly listed at 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73 on Sepolia Etherscan, together with its creator wallet and the token tracker MedicalConsent (CONSENT). Consequently, the existence of the consent registry itself, and every activation or revocation recorded on it, can be inspected independently of the HALAH application.

### 6.8.2 Create Smart Consent Contract: Patient Subsystem

The first functional subsystem is the Create Smart Consent Contract module. This module represents the patient-side initiation of a consent transaction and corresponds directly to the construction of the proposed consent object.

The subsystem requires the patient to specify the Patient DID, Authorised Doctor DID, Data Access Scope, Designated Guardian DIDs, the Jurisdiction, and the temporal validity of the consent. These fields collectively operationalise the proposed consent representation:

$$C = (I, A, P, T, L, E)$$

where the identity of the patient is represented through a DID and the authorised actor is explicitly specified. The permitted data scope is constrained to selected EMR modules. The temporal fields define when the authorisation becomes valid and when it expires. The jurisdiction field constrains where the consent may be exercised. The evidence component E records the authorisation evidence, including whether the consent remains active or has been revoked.

The form fields therefore instantiate the consent object defined in Section 6.1. The demonstrated representation realises the six-component object  $C = (I, A, P, T, L, E)$  of Eq. (46) and Figure 11, in which the temporal validity window T, captured through the Start Time and Expiry Time fields, and the jurisdiction L are stored on-chain by the deployed ConsentSBTv3 contract and evaluated at every access decision.

### Create Smart Consent Contract

**Patient DID (Identity Pointer)**

**Designated Guardian DIDs (Comma Separated)**

**Authorised Doctor DID**

**Jurisdiction (VL)**

**Data Access Scope (EMR Modules)**

**Contract Temporal Validity**

**Start Time (YYYY-MM-DD HH:MM:SS)**

**Expiry Time (YYYY-MM-DD HH:MM:SS)**

Consent contract created and logged (off-chain).

```
[CONSENT CREATED - OFF-CHAIN]
• Consent ID: 04da25f5-b16f-4d9a-af39-a78f0a83b17f
• TxHash: OFF-CHAIN - anchoring happens after guardian 2/2 approval
• Block Number: pending
```

**My Consents**

→ did:hospital:001      PENDING\_SIGNATURE      0/2 sigs - token: -     

Figure 21: The patient subsystem after consent creation: four EMR modules, two designated guardians, jurisdiction AU, and the state PENDING\_SIGNATURE.

As shown in Figure 21, the Patient DID provides the identity pointer for the data subject, while the Authorised Doctor DID limits the intended healthcare recipient. This is important because the implementation does not represent consent as a general permission to access a patient's medical information. Instead, the authorisation is bound to a specific identity and therefore supports subject-specific and actor-specific access control.

The Data Access Scope is particularly important to the proposed framework. Instead of granting access to the complete EMR, the patient selects particular modules. In the demonstrated transaction all four modules (Observation, Medication, Condition and Procedure) were selected. This implements the principle of purpose- and scope-limited consent and corresponds to the P component of the consent object. In addition, the implementation validates the input before the consent is stored. A consent with an empty data scope is rejected, and every guardian entry must be a well-formed DID.

The Designated Guardian DIDs establish the additional parties required to participate in the authorisation process. Their presence in the consent-creation subsystem demonstrates that multi-party consent is incorporated at the point at which the consent contract is constructed rather than being added after authorisation.

Finally, the Start Time and Expiry Time implement temporal constraints on the consent, and the Jurisdiction field records the legal territory (AU in the

demonstrated transaction). Consequently, authorisation is not represented as a permanent or universal permission. Instead, the consent has a defined lifecycle and territory and can subsequently be evaluated by the Consent Engine according to both. At this point the consent exists only in the application ledger, in the state `PENDING_SIGNATURE`; nothing is written to the blockchain until the guardians have approved.

Two consent lifecycles appear in the demonstration and should be distinguished. The evaluated consent, `f050c29a`, was carried through the complete lifecycle. It was activated as token #1, it was granted access, it was refused access and it was finally revoked. All transaction evidence in this chapter follows this consent. The creation and approval stages of the evaluated consent were not captured before it was revoked, and a revoked consent cannot be returned to those states. Therefore, the screenshots of consent creation, guardian approval and granted access were captured from a second lifecycle with the same configuration. This second lifecycle used the same four-module scope, the same guardians, the same jurisdiction, the same purpose and the same doctor. It was executed for a different demonstration patient as consent `04da25f5`, which is anchored as token #2 in block 11,771,581. The two lifecycles were executed with the same code and the same contract.

From a system perspective, this module therefore corresponds primarily to **Consent Object Construction and Patient Initiation**.

### 6.8.3 Guardian Cryptographic Approval

The second part is the Guardian Cryptographic Approval. As shown in Figure 22, it operationalises the multi-party authorisation component of the proposed framework.

**Guardian Cryptographic Approval**

Enter Target Consent ID

04da25f5-b16f-4d9a-af39-a78f0a83b17f

Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a

Select Your Guardian DID Identity

did:parent:A

Sign Consent via VC

EIP-712 signature verified (signer 0x3Af549b0...). Multi-sig: 1/2

Figure 22: The guardian subsystem at the first approval: the EIP-712 signature of `did:parent:A` is verified and the multi-signature count is 1/2.

As shown in Figure 22, the first guardian (`did:parent:A`) approves the consent and the subsystem reports EIP-712 signature verified (signer `0x3Af549b0...`) with the multi-signature count 1/2. The consent remains pending, because the approval condition has not yet been satisfied. The second guardian then repeats the same procedure.



Figure 23: The guardian subsystem at the moment of the second approval: the EIP-712 signature is verified, the 2/2 threshold is reached, the SBT is minted in the local ledger and the Sepolia anchoring starts in the background.

As shown in Figure 23, the guardian first enters the target Consent ID. The system then retrieves the corresponding active transaction and displays the associated patient DID. The guardian then selects their own Guardian DID identity and approves the consent with an EIP-712 typed-data signature. The signature binds the approval to this specific consent, to this guardian and to this network (chainId 11155111). The system verifies each signature by recovering the signer address and comparing it with the address associated with that guardian DID. A signature produced for another consent, another guardian or another chain is rejected. In addition, the interface refuses a second signature from the same guardian.

Each approval is evaluated by the procedure formalised in Algorithm 3. In the implemented configuration the authorisation threshold is derived from the designated guardian set as  $N = |G|$ . Therefore, every listed guardian must produce a valid EIP-712 signature before activation. The demonstrated 2-of-2 approval is consequently an N-of-N case of the threshold condition of Eq. (49).

The subsystem subsequently reports:

EIP-712 signature verified (signer 0x39B12b87...). Multi-sig: 2/2

This is an important implementation-level demonstration because the consent is not activated merely because the patient created it. Instead, the system requires the predefined guardian approval condition to be satisfied. The guardian approval establishes the  $V_A$  conjunct of the logical authorisation rule that the implementation enforces at every subsequent access request:

$$ALLOW = VI \wedge VA \wedge VP \wedge VT \wedge VL$$

where identity verification, authorisation verification, purpose verification, temporal verification and jurisdictional verification must all be satisfied

before access can be granted. For the demonstrated two-guardian configuration, the approval process can also be represented as:

$$\sum_{g \in G} \text{Sign}(g, C) \geq |G| = 2$$

where G represents the designated guardians and every listed guardian must provide a valid signature for activation. Once the required signatures have been obtained, the subsystem displays SBT MINTED together with the Soulbound Token identifier, and a background job submits the mint transaction to Sepolia. While the background job is running, the subsystem reports the intermediate state explicitly.

The screenshot shows the 'Guardian Cryptographic Approval' interface. At the top, it says 'Enter Target Consent ID' with a text input field containing '04da25f5-b16f-4d9a-af39-a78f0a83b17f'. Below this, a blue box states 'Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a'. A green box indicates 'Threshold 2/2 reached but NOT anchored on Sepolia yet (token: SBT-LOCAL-04da25f5). Click below and wait ~30 s without touching anything.' There are two buttons: 'Sync from Sepolia (find existing mint)' and 'Anchor on Sepolia now (background)'. Below these, a blue box says 'Anchoring in progress - refresh in ~30 s.' The next section is 'Select Your Guardian DID Identity' with a dropdown menu showing 'did:parent:B'. A green button 'Sign Consent via VC' is present. At the bottom, a green box states 'This guardian has already signed this consent (one signature per guardian).'

Figure 24: The guardian subsystem while the mint transaction is pending: the 2/2 threshold is reached but not yet anchored, the anchoring runs in the background, and a repeated signature from the same guardian is refused.

As shown in Figure 24, the subsystem reports that the threshold has been reached but the consent is not yet anchored, offers a manual synchronisation with the chain, and refuses a second signature from the same guardian. This is important because the one-signature-per-guardian rule prevents a single guardian from satisfying the multi-signature threshold alone. When the guardian later re-enters the Consent ID, the subsystem reports Already anchored on Sepolia together with the on-chain token number (token #2 for the photographed lifecycle, token #1 for the evaluated consent).

The screenshot shows the 'Guardian Cryptographic Approval' interface after the background job has completed. The 'Enter Target Consent ID' field still contains '04da25f5-b16f-4d9a-af39-a78f0a83b17f'. The blue box still shows 'Found active transaction for Patient: did:patient:5f01f823-c8e8-9e40-c911-54b7b1ad843a'. The green box now states 'Already anchored on Sepolia - token #2'. The 'Select Your Guardian DID Identity' dropdown still shows 'did:parent:B'. The 'Sign Consent via VC' button is still present.

Figure 25: The guardian subsystem revisited after the background job has completed: 'Already anchored on Sepolia - token #2'.



As shown in Figure 25, the anchored state persists across sessions and navigation, because it is read back from the ledger rather than from the page. This provides a visible representation of the transition from a pending consent transaction to an activated, publicly recorded consent state. The SBT therefore functions in the implementation as a persistent cryptographic representation of the completed consent authorisation rather than as a transferable asset.

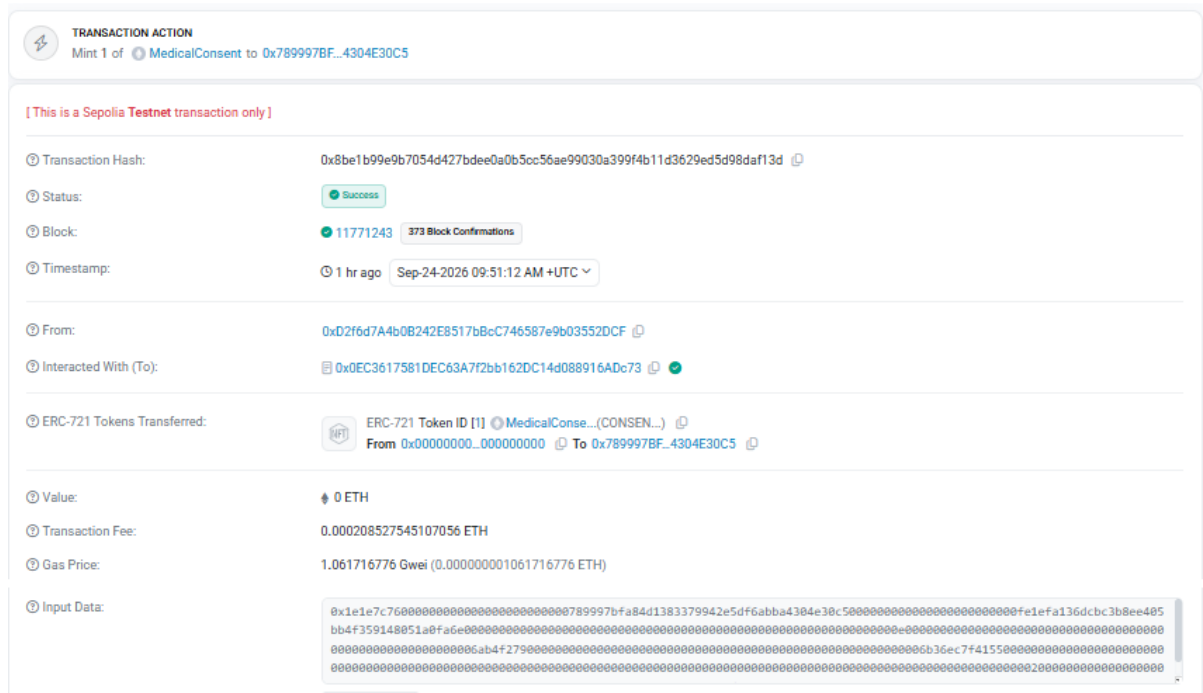


Figure 26: The anchoring transaction of the evaluated consent on Sepolia Etherscan: status Success, block 11,771,243, 'Mint 1 of MedicalConsent' to the pseudonymous patient address (function selector 0x1e1e7c76, mintConsentV3).

As shown in Figure 26, the anchoring of the evaluated consent (token #1) is an ordinary, publicly verifiable transaction. Etherscan reports the status Success, the block number 11,771,243 and the transaction fee. It also shows the transfer of one MedicalConsent token to the pseudonymous patient address derived from the patient DID. The transaction can be inspected on Sepolia Etherscan (mint transaction 0x8be1b99e...daf13d, listed in the verification links of Section 6.8.12). This provides an implementation-level demonstration that consent activation can be verified independently of the application.

The guardian subsystem consequently corresponds to **Multi-Party Approval, Cryptographic Verification and Consent Activation** in the proposed architecture.

#### 6.8.4 Secure Patient Data Access for the Doctor

The third module is the Secure Patient Data Access module and represents the healthcare-provider side of the authorisation process.

The doctor enters an authorised Consent ID, after which the system retrieves and displays the associated consent information. The subsystem shows the patient DID, Consent ID, purpose, and current consent state:

*State = ACTIVE*

This is important because the doctor does not directly access patient data based solely on possession of a Consent ID. The system first evaluates whether the underlying authorisation remains valid, and it does so for every component of the consent object. The decision matrix displayed to the doctor reports the outcome of each check individually.

The screenshot shows a web interface for a doctor's subsystem. At the top, there is a text input field labeled "Enter Authorised Consent ID" containing the value "f050c29a-3d92-4131-8605-63bcb1ff8d92". Below this is a section titled "Consent Information" with three cards: "Patient" showing "did:pat...", "Consent ID" showing "f050c2...", and "Purpose" showing "Treat...". Underneath is a dropdown menu for "Requester jurisdiction (VL check)" set to "AU". A "Decision matrix" table follows, with columns VI, VA, VP, VT, VL, and ALLOW, all showing "PASS". At the bottom, a green bar indicates "Consent State: ACTIVE".

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | PASS | PASS | PASS | PASS | PASS  |

Figure 27: The doctor subsystem with requester jurisdiction AU (the evaluated consent f050c29a, captured before its revocation): all five checks report PASS, ALLOW = PASS, and the consent state is ACTIVE.

As shown in Figure 27, the five checks VI (identity), VA (authorisation), VP (purpose), VT (time) and VL (jurisdiction) all report PASS, and consequently ALLOW = PASS. The subsystem then presents the Authorised Data Scope, showing that only the EMR modules specified in the original consent are available. In the demonstrated transaction, the authorised modules are:

*Scope = { Observation, Medication, Condition, Procedure }*

The five columns of the decision matrix are the operational form of the decision rule  $\text{Decision}(C, R, t) = \text{ALLOW} \iff \text{VI}(u) \wedge \text{VA}(C) \wedge \text{VP}(C, R) \wedge \text{VT}(C, t) \wedge \text{VL}(C)$ , which is the complete decision rule of Eq. (54) and Eq. (60), extending the three-predicate rule of Eq. (64) with the temporal and



jurisdictional verdicts. In the prototype every consent records a jurisdiction, so the jurisdiction predicate of Eq. (59) reduces to the condition that the requester's declared jurisdiction equals the jurisdiction recorded in the consent, which the jurisdiction-violation demonstration below confirms empirically.

Figure 28 shows the predicate evaluation flow of Figure 8 as it is enforced by the implemented Consent Engine.

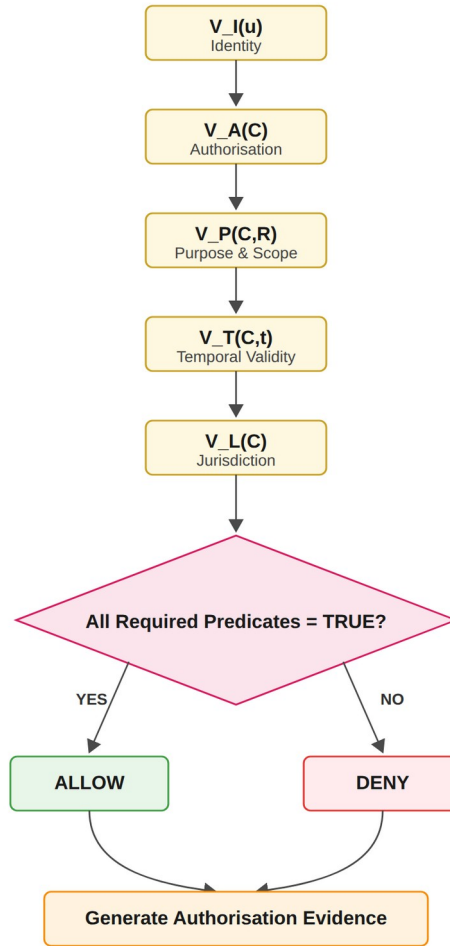


Figure 28: Trust Predicate Evaluation and Authorisation Decision Flow of Figure 8, as enforced by the implemented Consent Engine.

The doctor must subsequently select the modules to request; the request must be a non-empty subset of the authorised scope. The system displays the requested modules and performs cryptographic verification before granting access. In this version, the verification also generates and verifies a Groth16 zero-knowledge proof. The public inputs of the proof are a Poseidon commitment and the current time. The private witnesses are a secret and the expiry time. Because the prover and the verifier currently run on the same server, the proof demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee (see the limitations discussed at the end of this section). The audit ledger records the proof mode (groth16) with every access granted in the demonstrated

Patient

did:patient:5f01f...

Consent ID

04da25f5-b16f-4...

Purpose

Treatment

Requester jurisdiction (VL check)

AU

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

VI

VA

VP

VT

VL

ALLOW

PASS

PASS

PASS

PASS

PASS

PASS

Consent State: ACTIVE

Authorised Medical Records

▼ OBSERVATION

|     | DATE                 | PATIENT                              | ENCOUNTER                            | CATEGORY       | CODE    | DESCRIPTION                     | VALUE    | UNITS   |
|-----|----------------------|--------------------------------------|--------------------------------------|----------------|---------|---------------------------------|----------|---------|
| 238 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8302-2  | Body Height                     | 172.9    | cm      |
| 239 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 72514-3 | Pain severity - 0-10 verbal num | 0.0      | [score] |
| 240 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 29463-7 | Body Weight                     | 85.1     | kg      |
| 241 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 39156-5 | Body mass index (BMI) [Ratio]   | 28.5     | kg/m2   |
| 242 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8462-4  | Diastolic Blood Pressure        | 80.0     | mm[Hg]  |
| 243 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8480-6  | Systolic Blood Pressure         | 115.0    | mm[Hg]  |
| 244 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 8867-4  | Heart rate                      | 88.0     | /min    |
| 245 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | vital-signs    | 9279-1  | Respiratory rate                | 13.0     | /min    |
| 246 | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | social-history | 72166-2 | Tobacco smoking status          | Never sm | None    |
| 247 | 2016-08-12T03:15:24Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | survey         | 76501-6 | Within the last year have you b | No       | None    |

Download CSV

▼ MEDICATION

|    | START                | STOP                 | PATIENT                              | PAYER                               | ENCOUNTER                            | CODE    |
|----|----------------------|----------------------|--------------------------------------|-------------------------------------|--------------------------------------|---------|
| 10 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 1049504 |
| 11 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 245134  |
| 12 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 835603  |
| 13 | 2015-08-07T02:26:12Z | 2016-08-12T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-958e-92483fe3e582 | 1860491 |
| 14 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 1049504 |
| 15 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 245134  |
| 16 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 835603  |
| 17 | 2016-08-12T02:26:12Z | 2017-08-18T02:26:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | d31fcc3-1767-390d-966a-22a5156f4219 | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | 1860491 |

| CONDITION |            |         |                                      |                                      |                        |           |                                                   |
|-----------|------------|---------|--------------------------------------|--------------------------------------|------------------------|-----------|---------------------------------------------------|
|           | START      | STOP    | PATIENT                              | ENCOUNTER                            | SYSTEM                 | CODE      | DESCRIPTION                                       |
| 24        | 1977-03-16 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-3d12-6259d9e41d28 | http://snomed.info/sct | 40055000  | Chronic sinusitis (disorder)                      |
| 25        | 1987-07-17 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-5cb5-c909fa7070c  | http://snomed.info/sct | 224299000 | Received higher education (finding)               |
| 26        | 1993-01-01 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-a174-4b0d42609415 | http://snomed.info/sct | 162864005 | Body mass index 30+ - obesity (finding)           |
| 27        | 1993-12-20 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-e3e7-db542cc62f06 | http://snomed.info/sct | 428251008 | History of appendectomy (situation)               |
| 28        | 1995-05-10 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-b64e-6f71fd99cd0  | http://snomed.info/sct | 161744009 | Past pregnancy history of miscarriage (situation) |
| 29        | 1997-09-19 | 2016-01 | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-94a5-c564d96e7a37 | http://snomed.info/sct | 706893006 | Victim of intimate partner abuse (finding)        |
| 30        | 2005-04-23 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1340-b2438b25d99a | http://snomed.info/sct | 267020005 | History of tubal ligation (situation)             |
| 31        | 2014-02-02 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-fb96-afce40df3554 | http://snomed.info/sct | 82423001  | Chronic pain (finding)                            |
| 32        | 2014-02-02 | None    | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-fb96-afce40df3554 | http://snomed.info/sct | 278860009 | Chronic low back pain (finding)                   |
| 33        | 2014-08-01 | 2017-01 | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-ec33-e038d0a52a26 | http://snomed.info/sct | 160903007 | Full-time employment (finding)                    |

Download CSV

| PROCEDURE |                      |                      |                                      |                                      |                        |                 |               |
|-----------|----------------------|----------------------|--------------------------------------|--------------------------------------|------------------------|-----------------|---------------|
|           | START                | STOP                 | PATIENT                              | ENCOUNTER                            | SYSTEM                 | CODE            | DESCRIPTION   |
| 170       | 2016-08-12T02:26:12Z | 2016-08-12T02:41:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 430193006       | Medication    |
| 171       | 2016-08-12T02:26:12Z | 2016-08-12T03:15:24Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 710824005       | Assessment    |
| 172       | 2016-08-12T03:15:24Z | 2016-08-12T03:26:34Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 428211000124100 | Assessment    |
| 173       | 2016-08-12T03:26:34Z | 2016-08-12T03:48:35Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b18-d4c6bb1aa9c4 | http://snomed.info/sct | 763302001       | Assessment    |
| 174       | 2016-08-19T02:26:12Z | 2016-08-19T02:38:17Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-f486-ee6219a882da | http://snomed.info/sct | 76601001        | Intramuscular |
| 175       | 2016-11-18T02:26:12Z | 2016-11-18T02:43:39Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-c961-c9e35afa9c77 | http://snomed.info/sct | 76601001        | Intramuscular |
| 176       | 2017-02-17T02:26:12Z | 2017-02-17T02:37:40Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-f45f-17f268bac16c | http://snomed.info/sct | 76601001        | Intramuscular |
| 177       | 2017-05-19T02:26:12Z | 2017-05-19T02:37:14Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-1b5b-214bb8245e13 | http://snomed.info/sct | 76601001        | Intramuscular |
| 178       | 2017-08-18T02:26:12Z | 2017-08-18T02:41:12Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-eba1-0e85ddb2d8db | http://snomed.info/sct | 430193006       | Medication    |
| 179       | 2017-08-18T02:26:12Z | 2017-08-18T02:57:42Z | 5f01f823-c8e8-9e40-c911-54b7b1ad843a | 5f01f823-c8e8-9e40-eba1-0e85ddb2d8db | http://snomed.info/sct | 710824005       | Assessment    |

Figure 30: The remaining authorised modules of the same request: the Condition and Procedure records, with the Condition module's export control visible.

Figures 29 and 30 demonstrate the transition from consent verification to data-access authorisation. The checks are recorded in the audit ledger as STATE\_CHECK events, one for every evaluated access request. This distinction is central to the HALAH design. Consent and data access are not treated as identical events. Instead, the flow proceeds as follows:

*Consent → Verification → AccessDecision*

The doctor is therefore authorised only when the requested resources are consistent with the consent object and the consent remains active. The final Authorised Medical Records section presents the actual data modules available to the doctor. Because the subsystem separates the OBSERVATION, MEDICATION, CONDITION and PROCEDURE modules, it provides a direct visual demonstration of fine-grained EMR access control.

It should be noted that all medical records displayed in the demonstration are synthetic; no real patient data were used at any stage of the implementation or evaluation.

Thus, the doctor subsystem corresponds to **Consent-State Validation, Scope Enforcement and Authorised Data Access**.

### 6.8.5 Negative Demonstration: Jurisdiction Violation

The fourth part is the negative demonstration. This is important because a consent framework must be evaluated on whether it grants legitimate access and on whether it refuses illegitimate access. The same doctor therefore repeated the request for the evaluated consent while declaring the requester jurisdiction as SA, whereas the consent was issued for AU.

The screenshot shows a web interface for a doctor subsystem. At the top, there is a field labeled "Enter Authorised Consent ID" with the value "f050c29a-3d92-4131-8605-63bcb1ff8d92". Below this is a section titled "Consent Information" with three boxes: "Patient" with value "did:pat...", "Consent ID" with value "f050c2...", and "Purpose" with value "Treat...". Below these is a dropdown menu for "Requester jurisdiction (VL check)" with the value "SA". Below the dropdown is a table titled "Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL". The table has six columns: VI, VA, VP, VT, VL, and ALLOW. The rows show the results of the checks: VI is PASS, VA is PASS, VP is PASS, VT is PASS, VL is FAIL, and ALLOW is FAIL. At the bottom, there is a green bar with a green circle and the text "Consent State: ACTIVE".

| VI   | VA   | VP   | VT   | VL   | ALLOW |
|------|------|------|------|------|-------|
| PASS | PASS | PASS | PASS | FAIL | FAIL  |

Figure 31: The doctor subsystem with requester jurisdiction SA: VL reports FAIL and consequently ALLOW = FAIL, although the consent state remains ACTIVE.

As shown in Figure 31, the decision matrix immediately reports VL = FAIL and consequently ALLOW = FAIL, even though the consent itself is still ACTIVE, the guardian signatures remain valid and all other checks pass. This is important because it demonstrates that the access decision is taken over the complete consent tuple rather than over the consent state alone.

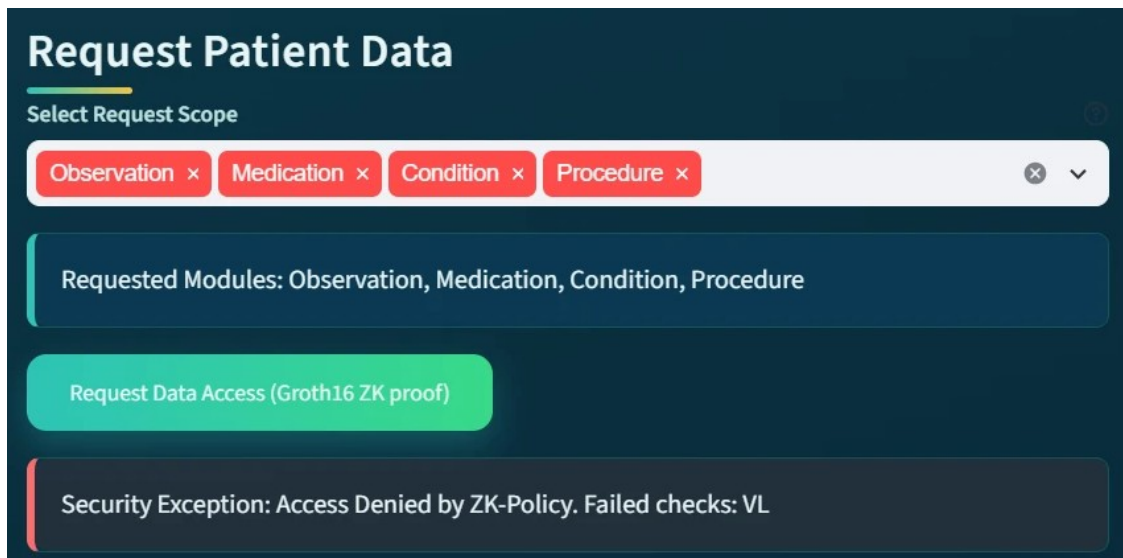


Figure 32: The refused request: 'Security Exception: Access Denied by ZK-Policy. Failed checks: VL'.

As shown in Figure 32, when the doctor submits the request, access is refused and the failed check is named explicitly. The corresponding audit-ledger entry records the result DENIED together with the complete decision matrix, so that the refusal is itself auditable. This is important because the jurisdiction check is included in the access decision rather than merely displayed.

This demonstration corresponds to **Jurisdictional Constraint Enforcement and Fail-Closed Access Control**.

### 6.8.6 Consent Revocation

The fifth module is the Consent Revocation module. This module operationalises the revocation dimension of the evidence component E of the consent object, which requires that a patient can withdraw consent and that the withdrawal takes effect for every subsequent request. In the patient's My Consents view, each consent is listed with its state, signature count and token. The patient then selects Revoke, after which the system updates the application state and submits a revoke transaction to the contract on Sepolia.



| My Consents                                             |                       |                                          |                         |
|---------------------------------------------------------|-----------------------|------------------------------------------|-------------------------|
| 2502632b... →<br>did:hospital:001                       | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| aca837a1... →<br>did:hospital:001                       | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| cd9a24bd... →<br>did:hospital:001                       | REVOKED               | 2/2 sigs - token: SBT-LOCAL-<br>cd9a24bd | REVOKED                 |
| 011bbb21... →<br>did:hospital:001                       | REVOKED               | 2/2 sigs - token: SBT-8                  | REVOKED                 |
| 0975c645... →<br>did:hospital:001                       | PENDING_SIGNA<br>TURE | 0/2 sigs - token: -                      | <button>Revoke</button> |
| f050c29a... →<br>did:hospital:001                       | ACTIVE                | 2/2 sigs - token: SBT-1                  | <button>Revoke</button> |
| Revoking on Sepolia - waiting for block confirmation... |                       |                                          |                         |

Figure 33: The patient subsystem during revocation: 'Revoking on Sepolia - waiting for block confirmation...'. As shown in Figure 33, the withdrawal is submitted as a blockchain transaction and the subsystem waits for the block confirmation before reporting the final state.

| My Consents                       |                       |                                          |                         |
|-----------------------------------|-----------------------|------------------------------------------|-------------------------|
| 2502632b... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| aca837a1... →<br>did:hospital:001 | REVOKED               | 0/2 sigs - token: -                      | REVOKED                 |
| cd9a24bd... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-LOCAL-<br>cd9a24bd | REVOKED                 |
| 011bbb21... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-8                  | REVOKED                 |
| 0975c645... →<br>did:hospital:001 | PENDING_SIGNA<br>TURE | 0/2 sigs - token: -                      | <button>Revoke</button> |
| f050c29a... →<br>did:hospital:001 | REVOKED               | 2/2 sigs - token: SBT-1                  | REVOKED                 |

Figure 34: The patient subsystem after revocation: the evaluated consent f050c29a is REVOKED with token #1 (displayed as SBT-1). The other rows are earlier trial consents.

As shown in Figure 34, the revoked consent is displayed as REVOKED together with its on-chain token number. The revocation was confirmed on Sepolia in block 11,771,307, and from that point the contract itself reports the token as no longer valid, so any verifier that reads the chain observes the withdrawal.

The demonstrated revocation completes the consent lifecycle anticipated by the temporal and lifecycle model of Section 6.5. The consent progresses through the controlled states `PENDING_SIGNATURE`, `ACTIVE` and `REVOKED` of the six-state lifecycle defined there. The `PENDING_TOKEN` state is passed within the same interaction, because a local token identifier is recorded as soon as the threshold is reached. The `EXPIRED` state is not reached in the demonstration. The `NOT_STARTED` state applies only while the current time precedes the start time of the consent and is left as soon as the start time is reached. The activating and revoking transitions are themselves verifiable Sepolia transactions, in blocks 11,771,243 and 11,771,307 respectively. Therefore, trust is not treated as permanently established at the moment a consent is created, which is the lifecycle-trust principle stated in Section 6.5.

Figure 35 summarises the implemented lifecycle and its anchored transitions.

It should be noted that the expiry path is not shown in the live demonstration. In this path the temporal predicate  $V_T$  fails once the current time exceeds  $t_e$  and the consent enters the `EXPIRED` state. This path is exercised by the automated tests reported in Section 6.8.9. A consent with a validity window long enough to be photographed cannot be allowed to expire within the demonstration period.

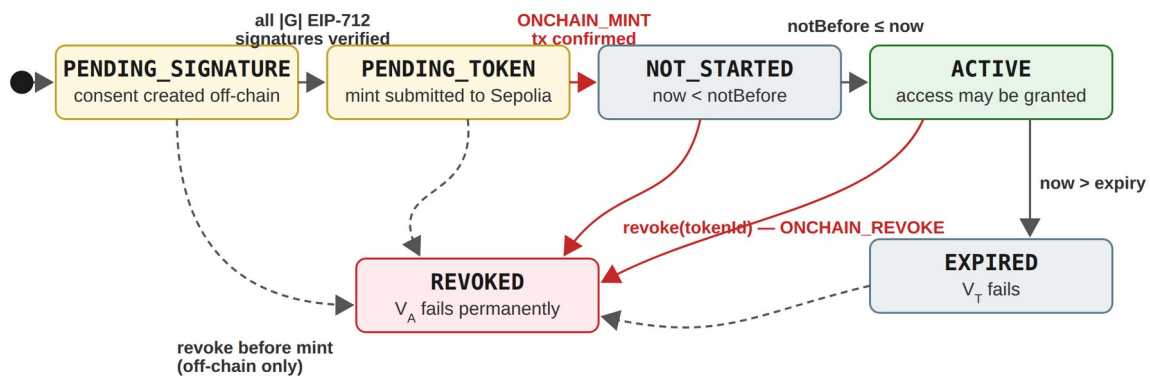


Figure 35: The implemented consent lifecycle: every consent progresses through controlled states, and the activating and revoking transitions are anchored as verifiable Sepolia transactions. Solid transitions are recorded in the audit ledger and the red transitions are anchored as Sepolia transactions; the dashed transitions show that revocation is accepted from any state that is not already REVOKED (Section 6.5.3), off-chain only before the mint.

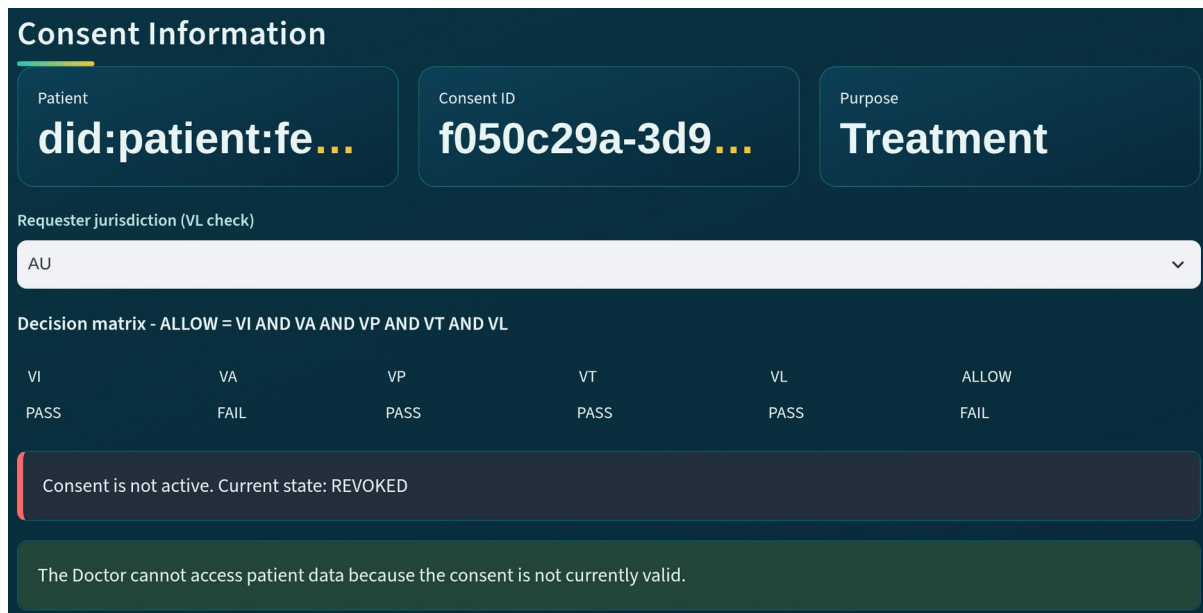


Figure 36: The doctor subsystem after revocation: VA reports FAIL and the consent is reported as 'not active. Current state: REVOKED'.

As shown in Figure 36, when the doctor subsequently enters the same Consent ID, the authorisation check VA fails and the subsystem reports that the consent is not active. Consequently, revocation is not merely a change of display. It removes the authorisation on which every later access decision depends.

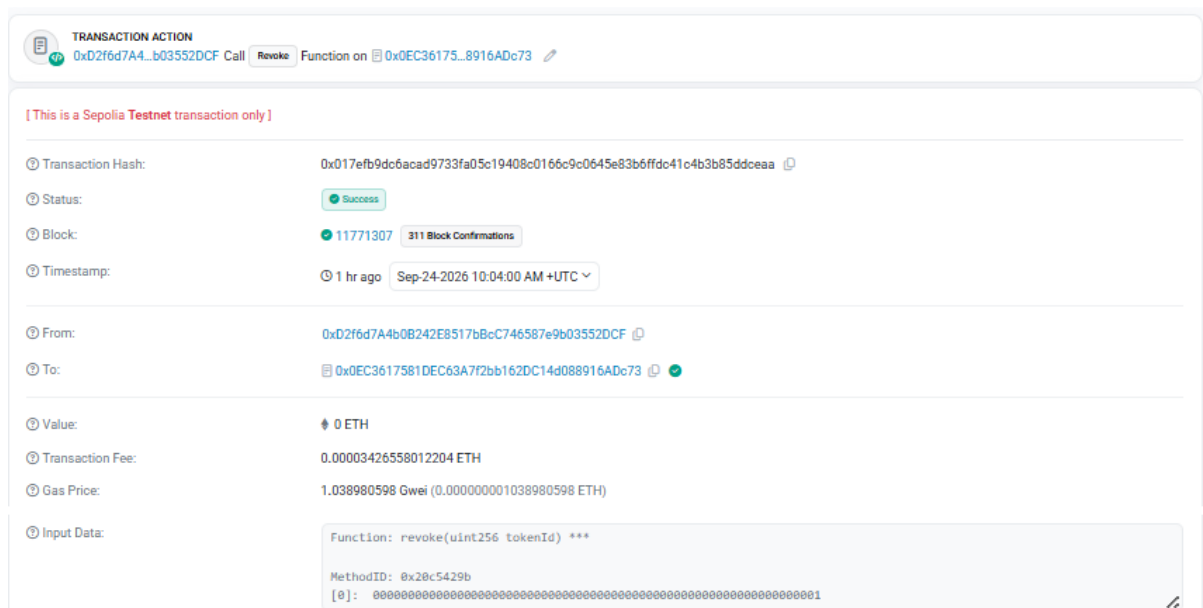


Figure 37: The revocation transaction on Sepolia Etherscan: status Success, block 11,771,307, decoded input 'Function: revoke(uint256 tokenId)' with tokenId = 1.

As shown in Figure 37, the revocation is again a publicly verifiable transaction, whose decoded input names the contract function revoke and the token identifier. The transaction can be inspected on Sepolia Etherscan (revoke transaction 0x017efb9d...dceaa, listed in the verification links of Section 6.8.12). The revocation subsystem therefore corresponds to **Enforcement State Management and Consent Withdrawal**.



### 6.8.7 Blockchain Audit and Consent Lifecycle for the Auditor

The sixth major module is the Blockchain Audit & Consent Lifecycle module. This subsystem provides an independent view of the complete consent process and corresponds to the auditability and accountability component of the HALAH framework.

|                                                                                                                                                                                                                                |                                                                                                                                                                                                                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p>2026-09-24T09:50:49.791935</p> <p>Actor: <code>did:patient:fe621c76-a591-b7be-5668-b77f00240d82</code></p> <p>Role: <code>Patient</code></p> <p>Action: <code>CREATE_CONSENT</code></p> <p>Result: <code>SUCCESS</code></p> | <p>2026-09-24T09:51:05.147730</p> <p>Actor: <code>did:parent:A</code></p> <p>Role: <code>Guardian</code></p> <p>Action: <code>SIGN_CONSENT</code></p> <p>Result: <code>SUCCESS</code></p>                                      |
| <p>2026-09-24T09:51:07.948663</p> <p>Actor: <code>did:parent:B</code></p> <p>Role: <code>Guardian</code></p> <p>Action: <code>SIGN_CONSENT</code></p> <p>Result: <code>SUCCESS</code></p>                                      | <p>2026-09-24T09:51:07.958682</p> <p>Actor: <code>Blockchain</code></p> <p>Role: <code>SmartContract</code></p> <p>Action: <code>MINT_SBT</code></p> <p>Result: <code>SUCCESS</code></p>                                       |
| <p>2026-09-24T09:51:12.812831</p> <p>Actor: <code>Blockchain</code></p> <p>Role: <code>SmartContract</code></p> <p>Action: <code>ONCHAIN_MINT</code></p> <p>Result: <code>SUCCESS</code></p>                                   | <p>2026-09-24T09:51:36.232885</p> <p>Actor: <code>System</code></p> <p>Role: <code>ConsentEngine</code></p> <p>Action: <code>STATE_CHECK</code></p> <p>Result: <code>ACTIVE</code></p>                                         |
| <p>2026-09-24T09:51:38.844118</p> <p>Actor: <code>did:hospital:001</code></p> <p>Role: <code>Doctor</code></p> <p>Action: <code>DATA_ACCESS</code></p> <p>Result: <code>GRANTED</code></p>                                     | <p>2026-09-24T09:51:39.310675</p> <p>Actor: <code>System</code></p> <p>Role: <code>ConsentEngine</code></p> <p>Action: <code>STATE_CHECK</code></p> <p>Result: <code>ACTIVE</code></p>                                         |
| <p>2026-09-24T09:51:41.159213</p> <p>Actor: <code>did:hospital:001</code></p> <p>Role: <code>Doctor</code></p> <p>Action: <code>DATA_ACCESS</code></p> <p>Result: <code>GRANTED</code></p>                                     | <p>2026-09-24T10:02:50.025638</p> <p>Actor: <code>System</code></p> <p>Role: <code>ConsentEngine</code></p> <p>Action: <code>STATE_CHECK</code></p> <p>Result: <code>ACTIVE</code></p>                                         |
| <p>2026-09-24T10:02:51.661961</p> <p>Actor: <code>did:hospital:001</code></p> <p>Role: <code>Doctor</code></p> <p>Action: <code>DATA_ACCESS</code></p> <p>Result: <code>DENIED</code></p>                                      | <p>2026-09-24T10:03:50.427292</p> <p>Actor: <code>did:patient:fe621c76-a591-b7be-5668-b77f00240d82</code></p> <p>Role: <code>Patient</code></p> <p>Action: <code>REVOKE_CONSENT</code></p> <p>Result: <code>SUCCESS</code></p> |
| <p>2026-09-24T10:04:00.807552</p> <p>Actor: <code>Blockchain</code></p> <p>Role: <code>SmartContract</code></p> <p>Action: <code>ONCHAIN_REVOKE</code></p> <p>Result: <code>SUCCESS</code></p>                                 |                                                                                                                                                                                                                                |

Figure 38: The Consent Lifecycle reconstruction for the evaluated consent f050c29a in the auditor subsystem: the thirteen recorded events in order, from CREATE\_CONSENT and the two guardian SIGN\_CONSENT events through MINT\_SBT and ONCHAIN\_MINT, the STATE\_CHECK and DATA\_ACCESS pairs (two granted, one denied on jurisdiction), to REVOKE\_CONSENT and ONCHAIN\_REVOKE.

As shown in Figure 38, the lifecycle view presents each event as a card with its timestamp, actor, role, action and result, so the chronological sequence of the authorisation process can be read directly.

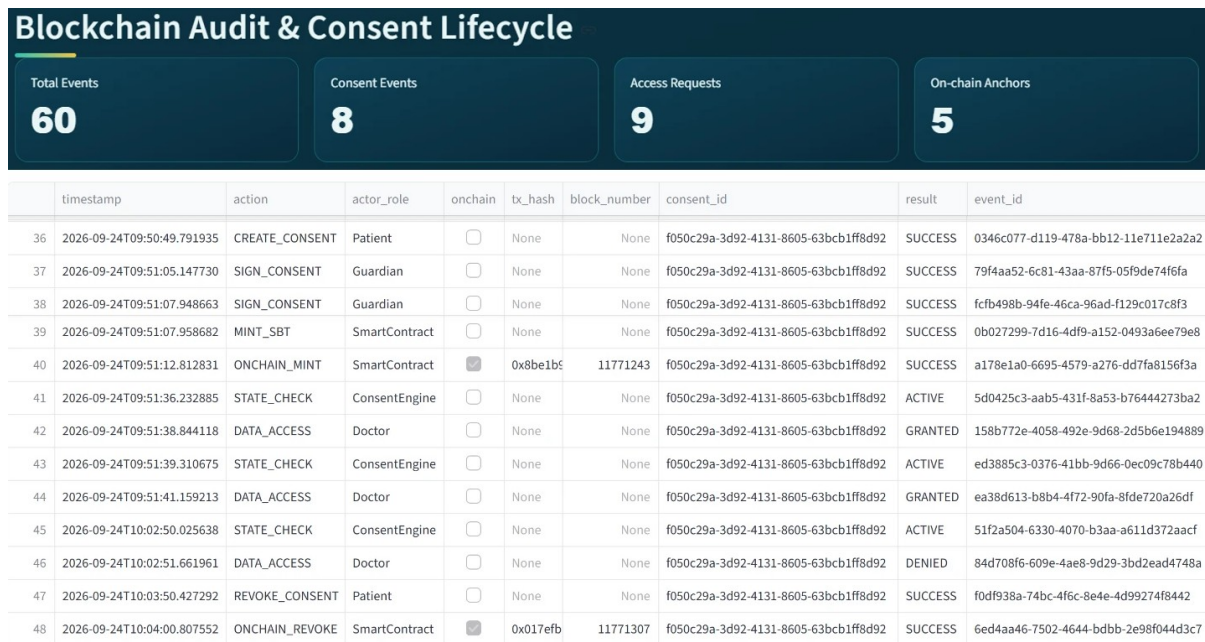


Figure 39: The auditor subsystem: the aggregate indicators of the exported ledger (60 events, 8 consent events, 9 access requests, 5 on-chain anchors) and the audit ledger rows 36 to 48 of the evaluated consent f050c29a, from CREATE\_CONSENT through ONCHAIN\_MINT (block 11,771,243), the granted and denied access requests and REVOKE\_CONSENT to ONCHAIN\_REVOKE (block 11,771,307).

As shown in Figure 39, the system first provides aggregate indicators including:

*Total Events = 60   Consent Events = 8   Access Requests = 9   On-chain Anchors = 5*

These indicators give the auditor an immediate overview of the recorded system activity and of how many events are anchored on the public chain. At the time of the capture the exported ledger held 60 events, of which five were anchored on Sepolia. The five anchors comprise the mint and revocation of the evaluated consent (token #1) and the mint of the photographed lifecycle (token #2). They also include the mint and revocation of an earlier trial consent on the previous contract. The nine access requests comprise the six granted and refused requests recorded across the two lifecycles together with three granted requests recorded for the earlier trial consents. In addition, the Consent Lifecycle section reconstructs the sequence of events associated with a particular consent. The reconstructed records include CREATE\_CONSENT performed by the patient, followed by SIGN\_CONSENT performed by each guardian, followed by MINT\_SBT and ONCHAIN\_MINT performed by the smart contract. In the figure the detailed table is scrolled to the on-chain events, whose rows carry the transaction hashes. The subsequent STATE\_CHECK system events demonstrate that the Consent Engine continuously evaluates the state of the authorisation. The doctor then generates DATA\_ACCESS with the result GRANTED, later DATA\_ACCESS with the result DENIED when the jurisdiction check fails, and finally the patient generates REVOKE\_CONSENT followed by ONCHAIN\_REVOKE performed by the smart contract.

This audit reconstruction, together with the independent verification of every recorded transaction against the public chain, constitutes the empirical component of the security-assurance objective RO6 of Section 6.6. Representative valid, invalid and adversarial scenarios have been executed against the running prototype, and the recorded evidence is consistent with the public chain. The formal component, that is, proofs and model checking of the stated properties, remains next-stage work.

This produces an explicit chain of evidence as

$$\begin{aligned} & Patient \rightarrow Guardian\_A \rightarrow Guardian\_B \rightarrow SmartContract(mint) \rightarrow ConsentEngine \rightarrow \\ & \quad Doctor(GRANTED) \\ & \rightarrow Doctor(DENIED) \rightarrow Patient(revoke) \rightarrow SmartContract(revoke) \end{aligned}$$

The audit subsystem therefore allows an auditor to reconstruct who accessed the data and why that access was permitted or refused. Each access event can be associated with the preceding consent creation, guardian approvals, on-chain activation and state checks, and with the decision matrix that was in force at that moment.

This corresponds to the proposed requirement for **traceability, accountability and non-repudiable consent evidence**.

### 6.8.8 Detailed Audit Records

The Detailed Audit Records component provides a lower-level view of the events represented in the lifecycle subsystem.

Where the lifecycle view is primarily designed to communicate the chronological sequence of the authorisation process, the detailed audit view provides the underlying event-level evidence. Each event can be associated with attributes such as actor, role, action, result, timestamp, consent context and, for on-chain events, the transaction hash and block number. As shown in Figure 39, the ONCHAIN\_MINT and ONCHAIN\_REVOKE rows carry the hashes of the two Sepolia transactions presented in Sections 6.8.3 and 6.8.6, so the ledger and the public chain describe the same events.

This separation is useful because different stakeholders require different levels of information. A clinician may only need to know that a consent is active and valid, whereas an auditor may need to establish precisely when an approval occurred, which identity performed it, and what authorisation decision followed.

The subsystem therefore implements the distinction between operational access information and forensic/audit information.

### 6.8.9 Complete Audit Ledger and Independent Verification

The Complete Blockchain Audit Ledger provides the most complete representation of the recorded consent history. This component demonstrates that the audit mechanism is not limited to successful data-

access events. Instead, the system records the broader lifecycle of the consent, including creation, signatures, state validation, smart-contract actions, refused requests and revocations. Consequently, the ledger provides the evidentiary foundation for evaluating several properties of the proposed framework:

*Accountability + Traceability + Integrity + Non-repudiation*

A ledger kept by the application could in principle contain fabricated entries. Consequently, the implementation provides an independent verification tool. The tool re-reads the ledger. For every event that carries a transaction hash, it fetches the corresponding receipt directly from Sepolia and checks that the transaction exists, succeeded, and was included in the recorded block. For every consent anchored on the current contract, it then reads the token back and compares the on-chain revocation state with the local state.

```
$ python3 -m tools.verify_poc
RPC https://ethereum-sepolia-rpc.publicnode.com | chainId 11155111 | head block 11820403
Contract 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73 | code 16273 bytes | owner 0xd2f6d7A4b0B242E8517bBcC746587e9b03552DCF

Audit ledger: 60 events, 5 with a tx_hash
[OK] ONCHAIN_MINT      0x5f9b2f14...6bc24994 block 11757272 (ledger 11757272) SUCCESS gas 156589 to 0xb0dA...4A6e7 (earlier deployment)
[OK] ONCHAIN_REVOKE   0x2adf73d8...06044048 block 11757344 (ledger 11757344) SUCCESS gas 46226 to 0xb0dA...4A6e7 (earlier deployment)
[OK] ONCHAIN_MINT      0x8be1b99e...98daf13d block 11771243 (ledger 11771243) SUCCESS gas 196406 to 0x0EC3...ADc73
[OK] ONCHAIN_REVOKE   0x017efb9d...85ddceaa block 11771307 (ledger 11771307) SUCCESS gas 32980 to 0x0EC3...ADc73
[OK] ONCHAIN_MINT      0x25ef5e2f...69d4c210 block 11771581 (ledger 11771581) SUCCESS gas 179306 to 0x0EC3...ADc73

Consent f050c29a-3d92-4131-8605-63bcb1ff8d92 -> token #1
ownerOf      0x789997BFa84D1383379942E5Df6ABba4304E30C5 == did_to_address(patient) True
requester     0xfE1efA136DChc3B8eE405bB4F359148051a0fA6e == did_to_address(doctor) True
purposeHash   0xff2a51e6eb5c67c2b1789c5fc8db6aaab2459d70d07eeac5c89f053cb18eb765 == keccak('Treatment') True
notBefore/expiry 1790243449 / 1798761599
jurisdiction  b'AU' revoked(on-chain) True burnAuth 2
checkValid     False
checkValidAt(AU) False checkValidAt(US) False
local ledger state revoked=True (matches chain: True)
Consent 04da25f5-b16f-4d9a-af39-a78f0a83b17f -> token #2
ownerOf      0x167D9770dE0c9E603DCb33e745DCf145adA3BD2F == did_to_address(patient) True
requester     0xfE1efA136DChc3B8eE405bB4F359148051a0fA6e == did_to_address(doctor) True
purposeHash   0xff2a51e6eb5c67c2b1789c5fc8db6aaab2459d70d07eeac5c89f053cb18eb765 == keccak('Treatment') True
notBefore/expiry 1790247349 / 1793491199
jurisdiction  b'AU' revoked(on-chain) False burnAuth 2
checkValid     True
checkValidAt(AU) True checkValidAt(US) False
local ledger state revoked=False (matches chain: True)

RESULT: ALL CHECKS PASSED
```

Figure 40: The independent verification tool re-executed against Sepolia after the second lifecycle: the five anchored transactions are found in their recorded blocks, the on-chain records of token #1 (revoked) and token #2 (valid for AU, rejected for US) match the local ledger, and the run ends with RESULT: ALL CHECKS PASSED.

As shown in Figure 40, the verification was re-executed after the second lifecycle and reports ALL CHECKS PASSED. Every recorded transaction was found on Sepolia in its recorded block. For both tokens on the current contract, the revocation state stored by the application matches the state stored by the contract. Accordingly, the demonstrated sequence shows that the doctor receives a GRANTED result only while the consent is in the ACTIVE state, and a DENIED or 'not active' result otherwise. This provides an implementation-level demonstration that access decisions are linked to the consent lifecycle rather than being independent application events, and that the recorded lifecycle is consistent with the public chain.

In addition to the live demonstration, the same decision logic is exercised by a suite of 23 automated tests covering per-dimension failures of the decision matrix, rejection of invalid EIP-712 guardian signatures and tampered or expired zero-knowledge proofs. The live Sepolia evidence and the automated tests together constitute the empirical validation reported in Section 7.6.

### 6.8.10 Correspondence Between the Subsystems and the Framework

The subsystems collectively implement the principal stages of the proposed framework.

Table 14 summarises the correspondence between the components of the framework and the subsystems of the implementation, and it consolidates the correspondences stated at the end of each of the preceding subsections.

**Table 14:** Correspondence between the HALAH framework components and the implemented subsystems

| HALAH Framework Component               | Implementation Subsystem                   | Main Function                                                                                 |
|-----------------------------------------|--------------------------------------------|-----------------------------------------------------------------------------------------------|
| Consent Object Construction             | Create Smart Consent Contract              | Defines patient, authorised doctor, data scope, guardians, jurisdiction and temporal validity |
| Identity & Authorisation                | Guardian Cryptographic Approval            | Verifies guardian identities and EIP-712 signatures                                           |
| Multi-party Consent                     | Guardian Cryptographic Approval            | Implements the 2-of-2 approval condition                                                      |
| Consent Activation                      | Guardian Cryptographic Approval            | Mints the SBT on Sepolia and marks the consent as fully activated                             |
| Consent-State Management                | Secure Patient Data Access                 | Checks whether the consent is ACTIVE                                                          |
| Scope Enforcement                       | Secure Patient Data Access                 | Restricts access to authorised EMR modules                                                    |
| Cryptographic Access Control            | Secure Patient Data Access                 | Verifies the request, including a Groth16 proof, before granting data                         |
| Jurisdictional Constraint (L)           | Secure Patient Data Access                 | Refuses requests whose declared jurisdiction differs from the consent                         |
| Healthcare Data Access                  | Secure Patient Data Access                 | Provides the authorised Observation, Medication, Condition and Procedure records              |
| Authorisation Evidence / Revocation (E) | My Consents (Patient)                      | Revokes the consent locally and on-chain                                                      |
| Lifecycle Traceability                  | Blockchain Audit & Consent Lifecycle       | Reconstructs the chronological consent process                                                |
| Accountability                          | Detailed Audit Records                     | Provides event-level evidence with transaction hashes                                         |
| Ledger Integrity                        | Complete Ledger + independent verification | Confirms the recorded history against Sepolia                                                 |

This mapping demonstrates that the implementation is not merely a collection of independent user-subsystem modules. Rather, the modules correspond to successive stages of the proposed authorisation protocol.

### 6.8.11 Overall System Demonstration

The subsystems collectively demonstrate an end-to-end implementation of the proposed HALAH authorisation workflow on a public blockchain. The patient first establishes the consent conditions through the Smart Consent Contract subsystem. The designated guardians then independently authenticate and provide the required cryptographic approvals. Once the multi-signature condition is satisfied, the consent is activated and represented by an SBT minted on Sepolia. The authorised doctor subsequently submits an access request, which is evaluated against the patient's identity, consent state, authorised data scope, temporal validity and jurisdiction. Only when these conditions are satisfied does the system provide access to the specified EMR modules. An out-of-jurisdiction request is refused and the failed check is named. The patient finally revokes the consent and the revocation is recorded on-chain. The complete sequence is then exposed through the auditor subsystem and re-verified independently against the chain.

*C → MS → SBT\_chain → StateCheck → AccessDecision → EMR → Revoke\_chain → Audit → Verify*

where C denotes consent creation, MS multi-signature approval, SBT\_chain on-chain consent activation, StateCheck lifecycle validation, AccessDecision authorisation enforcement over the full consent tuple, EMR authorised medical-record access, Revoke\_chain on-chain revocation, Audit immutable lifecycle recording, and Verify independent verification against Sepolia.

The demonstrated prototype makes several simplifications that are acceptable for a research demonstration but would require strengthening before deployment. The guardian signing keys are derived deterministically from the guardian DIDs so that the prototype can sign without wallets. In production, each guardian would sign the same typed data with a wallet-held key registered against their DID. The doctor's identity and jurisdiction are declared in the interface rather than authenticated. In addition, the Groth16 proof is generated and verified by the same server. Therefore, it currently demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee. These aspects define the immediate future work of the project.

In addition, this section reports functional evidence only. Transaction latency, gas cost and throughput have not been measured, and a systematic performance and overhead study is reserved for the next stage, as set out in Section 9.2.

It should be noted that, in the same way, the identity predicate  $V_1$  in the prototype performs identifier- and credential-format validation only;

cryptographic resolution of DIDs against a registry and authentication of the requester are reserved for the next stage, as stated in Section 7.2.

From a research-implementation perspective, the most significant feature of the presented subsystems is the continuity of the workflow. Consent specification, multi-party authorisation, public on-chain activation and revocation, access enforcement and independently verifiable audit evidence form one continuous process. The user subsystems provide a visible representation of this continuity. Consequently, the proposed HALAH model can be demonstrated as an operational authorisation workflow on a public network rather than only as a conceptual framework.

### **6.8.12 Verification Links**

Contract:

<https://sepolia.etherscan.io/address/0x0EC3617581DEC63A7f2bb162DC14d088916ADc73>

Consent activation (mint of token #1):  
<https://sepolia.etherscan.io/tx/0x8be1b99e9b7054d427bdee0a0b5cc56ae99030a399f4b11d3629ed5d98daf13d>

Consent activation (mint of token #2, photographed lifecycle):  
<https://sepolia.etherscan.io/tx/0x25ef5e2f0046735dcb01ff7b68875b760bdf88ad0fa3fedc9bfb910769d4c210>

Consent revocation (token #1):  
<https://sepolia.etherscan.io/tx/0x017efb9dc6acad9733fa05c19408c0166c9c0645e83b6ffdc41c4b3b85ddceaa>

Full audit-ledger export: evidence/sepolia\_audit\_ledger\_2026-09-24.csv;  
deployment and run record: evidence/sepolia\_deploy\_v3\_2026-09-24.txt  
preserved in the project evidence records.



## 7 Current Progress Status

### 7.1 Progress of RO1: Trust-Centric Consent Model

Status: Completed

RO1 has been completed at the conceptual and prototype-design level. The main contribution of RO1 is the transformation of consent from a static permission record into a structured authorisation object. Instead of storing only whether a patient has granted access, the consent object explicitly records the conditions that determine whether access should be permitted. The proposed representation, defined in Eq. (46), is

$$C = (I, A, P, T, L, E). \quad (66)$$

Identity information establishes the relevant participants. Authorisation requirements define who must approve the consent. Policy information specifies the purpose and permitted data scope. Temporal information defines the validity interval  $[t_s, t_e]$  within which the consent may be exercised, and the jurisdiction component records the legal territory in which access is permitted. Authorisation evidence records the information required to demonstrate how the consent decision was established. The model provides the foundation for the remaining objectives because the identity, multiparty approval, and policy mechanisms can all be evaluated against the same consent object. The current result demonstrates that consent can be represented as an evaluable authorisation object that, unlike the objects reported in the literature [71, 37, 44, 58, 66], carries the guardian set and threshold together with the purpose, data scope, validity interval, jurisdiction and lifecycle state. This provides a conceptual basis for dynamic access decisions and allows subsequent authorisation conditions to be evaluated consistently.

### 7.2 Progress of RO2: Decentralised Identity and Authority Trust

Status: Completed

RO2 has been completed at the conceptual and prototype level. The proposed framework explicitly separates identity authentication from authorisation authority, such that

$$\text{Identity} \neq \text{Authorisation}. \quad (67)$$

A decentralised identifier is used to establish the identity of a participant, while verifiable credentials provide evidence concerning the participant's role or authority. The identity verification condition is represented, as in Eq. (48), as

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u). \quad (68)$$

Successful identity verification therefore does not automatically grant access to healthcare information. Instead, identity and credential validity become trusted inputs to the subsequent authorisation process. The current implementation demonstrates the separation between participant



identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data.

It should be noted that the identity verification  $V_I$  in the current prototype performs identifier- and credential-format validation only. Cryptographic DID resolution against a registry and authentication of the requester are acknowledged limitations and are reserved for the next stage.

### 7.3 Progress of RO3: Trustworthy Multi-Party Authorisation

Status: Completed

RO3 has been completed at the conceptual and prototype level. The framework introduces threshold-based multi-party authorisation to prevent a single participant from unilaterally establishing sensitive healthcare data access. Let  $A_v$  represent the set of independently verified authorisation participants and  $N$  represent the required approval threshold. The authorisation condition, defined in Eq. (49), is

$$V_A(C) = 1, |A_v| \geq N; 0, |A_v| < N. \quad (69)$$

If the threshold is not satisfied,

$$|A_v| < N \Rightarrow \text{Decision}(C, R) = \text{DENY}. \quad (70)$$

This mechanism allows the framework to distinguish between insufficient and sufficient collective authorisation. The prototype demonstrates that a consent object remains unable to establish valid authorisation until the required number of independently verified participants has approved it. For example, where two approvals are required,

$$|A_v| = 2 \Rightarrow V_A(C) = 1, \quad (71)$$

whereas

$$|A_v| = 1 \Rightarrow V_A(C) = 0. \quad (72)$$

This provides preliminary evidence that the proposed framework can enforce collective rather than unilateral authorisation.

It should be noted that the implemented threshold is derived from the designated guardian set as  $N = |G|$ . Therefore, the prototype currently enforces an N-of-N instantiation of Eq. (69), and it has been evaluated in the 2-of-2 configuration. Configurable k-of-n thresholds are reserved for the next stage.

### 7.4 Progress of RO4: Policy- and Context-Aware Access Control

Status: Completed

RO4 represents the third layer of the foundational framework, beyond identity and multi-party approval. The objective is to ensure that an otherwise valid requester cannot access healthcare information outside

the purpose and data scope authorised by the consent. The proposed policy predicate is written, as in Eq. (36), as

$$V_P(C, R) = \text{Policy}(C, R). \quad (73)$$

where  $\text{Policy}(C, R)$  denotes the conjunction of the purpose check  $V_U(C, R)$  and the scope check  $V_S(C, R)$  defined in Eq. (53).

For example, if  $S_C = \{\text{Observation, Medication}\}$  and the requester asks for  $S_R = \{\text{Observation, Medication, Procedure}\}$ , the request exceeds the authorised scope. In this case  $V_P$  evaluates to 0 and the request is denied with  $V_P$  named as the failed check. This over-scope denial is exercised by the per-dimension failure tests described in Section 6.8.9. Section 6.8.4 shows the requested-subset rule enforced on the live system.

The policy predicate is evaluated as one term of the complete decision matrix  $V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ . Every denial names the failed checks explicitly in both the interface and the audit ledger. In addition, input validation on consent creation and access requests prevents malformed identifiers, scopes and jurisdictions from reaching the decision logic. Consequently, policy-aware access control is an enforced property of the running system rather than an expected outcome.

## 7.5 Progress of RO5: Temporal and Lifecycle Trust

Status: Largely Completed (temporal validity and on-chain revocation enforced; consent modification, delegation and guardian-set changes outstanding)

RO5 has moved from planned work to implemented capability. The consent validity interval  $[t_s, t_e]$  is now enforced by the temporal predicate  $V_T$  at every access request. The interval is additionally stored on-chain in the SBT as the `notBefore` and `expiry` fields, so that temporal validity can be verified independently of the application. The consent lifecycle is implemented as an explicit state machine comprising the states `PENDING_SIGNATURE`, `PENDING_TOKEN`, `NOT_STARTED`, `ACTIVE`, `EXPIRED` and `REVOKED`. Revocation is enforced end-to-end. The patient's withdrawal updates the application state and is confirmed as a revoke transaction on Sepolia in block 11,771,307. After that point the contract itself reports the token as invalid and subsequent access requests are denied. What remains for the next stage is therefore the dynamic and delegated dimension of lifecycle trust, such as consent modification, delegation and guardian-set changes, rather than temporal enforcement itself. The temporal predicate enforced at every access request is, as defined in Eq. (58),

$$V_T(C, t) = (t_s \leq t \leq t_e). \quad (74)$$

The next stage will extend the implemented lifecycle mechanism towards consent modification, delegation, and guardian-set changes, and will

formalise the state-transition model so that unauthorised lifecycle transitions can be excluded by construction.

## 7.6 Progress of RO6: Formal Security Assurance and Empirical Validation

Status: Partially Completed (scenario-based empirical validation complete; formal assurance and performance study outstanding)

RO6 is partially completed through the implementation and initial scenario-based validation of the HALAH prototype. The current prototype provides a practical environment for evaluating the trust-oriented authorisation model using synthetic healthcare records. The system represents patients and healthcare participants using decentralised identities and provides mechanisms for consent creation, participant verification, multi-party approval, and access-control evaluation. The decision rule enforced by the prototype at every access request is the rule of Eq. (65), written in piecewise form as

$$\text{Decision}(C, R, t) = \text{ALLOW}, V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C); \text{DENY}, \text{otherwise.} \quad (75)$$

At the current stage, the experimental evidence primarily demonstrates the consistency between the implemented consent, identity, policy, temporal, jurisdictional and multi-party authorisation mechanisms and their corresponding research questions.

or expired zero-knowledge proofs. Live validation on the Sepolia testnet includes a negative demonstration in which a request declaring jurisdiction SA is made against a consent issued for AU. The request is denied, with  $V_L$  named as the failed check. It also includes a revocation scenario in which the same consent, once revoked on-chain, is subsequently denied through  $V_A$ . Furthermore, an independent verification tool re-checks every ledger transaction hash against Sepolia receipts and reads each token back from the contract, reporting ALL CHECKS PASSED, and every granted access is accompanied by a real Groth16 proof generated and verified at request time. The implemented decision rule is therefore exactly Eq. (75). Formal security analysis and a systematic performance study remain for the next stage. It should be noted that the prover and the verifier currently run on the same server, so the proof demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee, as discussed in Section 6.8.11.

Policy-violation scenarios, temporal expiration, revocation and invalid lifecycle transitions have now been demonstrated empirically. Jurisdiction violation and revocation followed by denial were demonstrated in the live Sepolia deployment. Policy violation and temporal expiration were demonstrated in the automated test suite, and unauthorised lifecycle transitions remain to be examined in the next stage. The remaining work for the next stage is therefore considerably narrower. It consists of the formal definition and verification of the security properties, a systematic

performance and overhead study, and the removal of prototype limitations such as the N-of-N approval rule, the server-derived guardian keys and the unauthenticated requester role. Overall, RO1 to RO4 are completed at the conceptual and prototype level, RO5 is largely completed with its temporal and revocation controls enforced and anchored on-chain, and RO6 is partially completed through its empirical component. Therefore, the next stage of the research is defined by the formal component of RO6, the performance study and the dynamic lifecycle extensions of RO5, as set out in Chapter 9.

## 8 Publications Summary

The publication activities associated with this research are organised according to their current development status and their structural contribution to the thesis chapters and research questions.

It should be noted that no manuscript has been submitted at the time of writing. The first paper is intended for submission early in the next stage, so that it can present the consent model together with the deployed contract and its verified transaction evidence.

Table 15 summarises the planned research outputs, their target venues, their current status and their alignment with the research questions.

**Table 15:** Summary of Research Outputs and Publication Plan

| Research Output / Topic                                                                                                                                                                     | Target Venue                   | Current Status | Thesis Alignment                                                                                                                                                                                                              |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Trust-Centric Consent Framework: model architecture and multi-party authorisation policies                                                                                                  | Elsevier/IEEE                  | Almost Ready   | Core architectural contribution; addresses RQ1 to RQ4 (Sections 6.1 to 6.4).                                                                                                                                                  |
| HALAH Prototype & Validation: the decentralised implementation and the scenario-based validation are complete on the Sepolia public testnet; the performance evaluation remains outstanding | Systems / Security Conference  | In Progress    | Empirical validation platform; addresses implementation and validation; the paper's empirical section can now draw upon the deployed contract, the two minted tokens and the verified transaction trail as delivered evidence |
| Formal Security & Lifecycle Analysis: verification of temporal constraints and state transitions                                                                                            | Specialised Workshop / Journal | Planned        | Next stage research extension; addresses formal security assurance (Sections 6.5 and 6.6).                                                                                                                                    |

The publication strategy is aligned with the progression of the research. The current stage work establishes the conceptual and technical foundation, while the next stage work will strengthen the framework through formal analysis and comprehensive empirical validation.

## 9 Research Plan

The research plan is divided into two major stages, the current stage and the next stage.

### 9.1 Current Stage: Completed and Current Work

RO1 to RO4 have been implemented and validated in the HALAH prototype, and RO5 is largely complete. The delivered evidence includes the ConsentSBTV3 contract, deployed and source-verified on Sepolia at 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73. The evaluated consent was minted as token #1 in block 11,771,243 and revoked on-chain in block 11,771,307, and an independently reproduced lifecycle was minted as token #2 in block 11,771,581. Each transaction hash is recorded in the audit ledger and is publicly inspectable on Etherscan. The plan for the next stage therefore follows directly from the progress status reported in Chapter 7. The objectives marked as completed require no further conceptual development. The remaining work is defined by the formal component of RO6, the systematic performance and overhead study, and the identified prototype limitations. These limitations are the N-of-N approval rule, the server-derived guardian keys, the unauthenticated requester and the absence of cryptographic DID resolution.

The current stage focuses on establishing the foundational trust-oriented authorisation framework. The main activities are the development of the trust-centric consent model, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control. Temporal and lifecycle enforcement, originally planned for the next stage, has also been implemented in the current stage, as reported in Section 7.5.

### 9.2 Next Stage: Planned Work

Temporal and lifecycle trust was originally planned for the next stage and has been brought forward and implemented. Validity windows are enforced and anchored on-chain, revocation is effective at the contract level, and lifecycle transitions are governed by an explicit state machine. Consequently, the next stage concentrates on formal security assurance and on comprehensive empirical validation, including performance measurement. It also covers the dynamic consent governance extensions of RO5, which are consent modification, delegation and guardian-set changes.

The next stage will build upon the foundational trust-oriented authorisation framework established during the current stage and extend the research towards dynamic consent governance [13, 24], formal security assurance, and comprehensive empirical validation. The current stage focuses on establishing the core mechanisms required to construct a trustworthy authorisation decision. The next stage will investigate whether this trust can be maintained over time, formally justified, and reliably demonstrated in practical healthcare data-sharing scenarios.

The next stage activities are planned sequentially. The formal specification of the security properties will be undertaken first, since the empirical experiments are to be designed against those properties. The performance and adversarial evaluation will follow in the second half of the stage. The lifecycle extensions and integrated evaluation will be completed last, once the formal model is stable.

The first focus is formal security assurance. The current stage framework establishes the conceptual relationship between identity verification, collective authorisation, and policy enforcement. The next stage will investigate these relationships more rigorously by defining the security properties that the framework is expected to satisfy. The analysis will consider conditions such as invalid identities, insufficient authorisation, policy violations, expired consent, revoked consent, and unauthorised lifecycle transitions. The purpose of this work is not merely to demonstrate that the prototype works under normal conditions, but to establish explicit security properties and determine whether the proposed authorisation model provides the expected protection when relevant security conditions are violated.

The second focus is comprehensive empirical validation. The HALAH prototype provides the experimental environment for evaluating the proposed framework using synthetic healthcare data and representative multi-party consent scenarios. The next stage will extend the current prototype-based evaluation to include both successful and adversarial access requests. The experiments will examine whether the implementation consistently produces an ALLOW decision only when the required trust conditions are satisfied and produces a DENY decision when one or more required conditions are violated. Particular attention will be given to the relationship between the formal security model and the observed behaviour of the implemented system. The major next stage activities and their expected outcomes are summarised in Table 16.

The performance study will measure the gas cost of the mint and revoke transactions, the block-confirmation latency on Sepolia, the Groth16 proof generation and verification time, and the end-to-end decision latency per access request. In addition, it will report enforcement accuracy as the proportion of adversarial requests that are correctly denied.

The formal component will state two properties. The first is the soundness property  $\text{Decision}(C, R, t) = \text{ALLOW} \Rightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ . The second is the lifecycle invariant that no REVOKED or EXPIRED consent can re-enter the ACTIVE state. These properties will be verified by model checking of the state machine or by proof over the predicate definitions of Chapter 6. The evaluation criterion for this component is that every property is either verified or refuted by an explicit counterexample.

**Table 16:** Next Stage Research Activities, Methodological Focus, and Expected Outcomes

| Research Focus                                                 | Planned Activities                                                                                                                                                                                                                                                                                       | Expected Outcome                                                                                                                                              |
|----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Consent Modification, Delegation and Lifecycle Extensions      | Extend the implemented lifecycle mechanism to support consent modification, delegation and guardian-set changes, and formalise the state-transition model so that unauthorised transitions are excluded by construction. Evaluate access decisions under varying temporal and consent-state constraints. | A robust, dynamic consent management mechanism capable of validating whether an authorisation remains active at the precise point of access.                  |
| Formal Security Assurance (Properties & Verification)          | Formally define critical security properties and analyse system behaviour under adverse conditions, including invalid identities, insufficient multi-party approvals, policy violations, expired/revoked states, and illegal transitions.                                                                | A rigorous formal security model and verification proof establishing explicit security guarantees for the trust-oriented authorisation framework.             |
| Comprehensive Empirical Validation (HALAH Prototype Scenarios) | Scale and extend HALAH prototype experiments using representative positive and negative healthcare data-sharing scenarios. Measure and compare observed system runtime performance, overhead, and enforcement accuracy.                                                                                  | Empirical evidence and benchmark datasets demonstrating that the implementation consistently and efficiently enforces the proposed authorisation model.       |
| Integrated Framework Evaluation (Synthesis & End-to-End)       | Integrate temporal, lifecycle, formal verification, and empirical modules into a unified, cohesive framework. Evaluate cross-component interactions, scalability bottlenecks, and end-to-end feasibility in real-world settings.                                                                         | A fully integrated, validated trust-oriented authorisation framework providing secure, multi-party patient consent and decentralised healthcare data sharing. |

At the time of writing, the status of the activities in Table 16 is as follows. The temporal and lifecycle foundation of the first activity, Consent Modification, Delegation and Lifecycle Extensions, is largely completed. The on-chain notBefore and expiry fields are in place, the revoke transaction was confirmed in block 11,771,307, and the lifecycle is governed by an explicit state machine. The modification, delegation and guardian-set extensions themselves have not been started. Comprehensive Empirical Validation is partially delivered through the 23 automated tests, the live jurisdiction denial and revocation-then-denial on Sepolia, and the independent chain verification reporting ALL CHECKS PASSED. Performance and overhead measurement remains outstanding. Formal Security Assurance and the Integrated Framework Evaluation have not been started and constitute the next stage in full.



An important analytical objective of the next stage is to examine the relationship between the different forms of trust established throughout the framework. Temporal validity, for example, should not be treated as an independent access-control feature. Instead, it should act as an additional condition on an already established authorisation relationship. Similarly, revocation should invalidate a previously established consent rather than merely create a new record indicating that the consent has changed. This perspective allows the research to investigate trust as a dynamic property rather than as a one-time outcome of authentication or approval.

The complete authorisation model developed across the current stage and the next stage will therefore be evaluated as a conjunction of independently verifiable conditions. Conceptually, the final decision can be expressed as

$$Decision(C, R, t) = ALLOW \quad (76)$$

only when the identity and authority of the requester are valid, the required multi-party authorisation has been established, the requested operation satisfies the consent policy, and the consent remains valid according to its temporal and lifecycle state. If any required condition is violated, the framework should produce a denial decision and preserve sufficient evidence to explain the reason for that decision.

From a research perspective, this represents an important transition from static consent management to dynamic trustworthy authorisation. The objective is not to add a collection of independent security mechanisms, but to investigate how these mechanisms jointly contribute to the establishment, maintenance, and verification of trust throughout the consent lifecycle.

By the completion of the next stage, the research is expected to provide three complementary forms of contribution. First, the research will provide a conceptual Trust Computing model that explains how trustworthy multi-party consent can be established and maintained. Second, it will provide a technical implementation through the HALAH prototype demonstrating how the proposed trust conditions can be enforced in a decentralised healthcare environment. Third, it will provide formal and empirical evidence concerning the security and practical effectiveness of the proposed framework.

Consequently, the next stage will complete the transition from the foundational authorisation mechanisms established in the current stage to a dynamically managed, formally reasoned, and empirically validated trust-oriented authorisation framework. The final contribution will not be assessed simply by whether consent can be recorded or whether access can be granted. It will be assessed by whether the system can provide a defensible basis for determining why an access decision should be trusted. It must also determine when that trust should no longer apply.

## Appendix A — Traceability to the Implemented System

Table 17 summarises how each formal artefact of this report is realised in the implemented HALAH subsystem presented in Section 6.8, and which publicly verifiable evidence supports it.

**Table 17:** Traceability from the formal artefacts of this report to the implemented mechanisms and their on-chain evidence

| Research artefact                                                                      | Defined in         | Realised by (implementation)                                                                                                                                                                                        | Publicly verifiable evidence                                                                                       |
|----------------------------------------------------------------------------------------|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| RO1 / RQ1 — Consent object, Eq. (46), Algorithm 1                                      | §6.1               | Patient subsystem: consent creation; state PENDING_SIGNATURE                                                                                                                                                        | Consents f050c29a and 04da25f5 in the exported audit ledger                                                        |
| RO2 / RQ2 — DID and VC verification, Algorithm 2                                       | §6.2               | Guardian subsystem: EIP-712 typed-data signatures, off-chain signer recovery per guardian DID (VI itself performs identifier- and credential-format validation only; DID resolution is reserved for the next stage) | Verified signer 0x3Af549b0... recorded per SIGN_CONSENT event                                                      |
| RO3 / RQ3 — Threshold authorisation, Eq. (49), Algorithm 3                             | §6.3               | 2-of-2 ceremony with $N =  G $ ; SBT minted on threshold                                                                                                                                                            | Mint tx 0x8be1b99e... daf13d, block 11,771,243, token #1                                                           |
| RO4 / RQ4 — Policy predicate VP, Eqs. (52)–(53), Algorithm 4                           | §6.4               | Doctor subsystem: requested scope SR must be a non-empty subset of the authorised scope SC; purpose hash compared with the consent                                                                                  | STATE_CHECK and DATA_ACCESS events recording VP = PASS for the four-module scope of consents f050c29a and 04da25f5 |
| Decision rule and trust predicates, Eq. (54), Figure 8                                 | §5.1.2, §6.4, §6.6 | Doctor subsystem: five-verdict decision matrix, ALLOW / DENY with failed-check listing                                                                                                                              | GRANTED and DENIED DATA_ACCESS events; SA-jurisdiction denial                                                      |
| RO5 / RQ5 — Temporal and lifecycle trust, Eqs. (58)–(59), Algorithm 5                  | §6.5               | Six-state lifecycle with on-chain revocation (Section 6.8.6)                                                                                                                                                        | Revoke tx 0x017efb9d... dceaa, block 11,771,307                                                                    |
| RO6 / RQ6 — Empirical validation, Eq. (61), Algorithm 6 (formal component outstanding) | §6.6               | Auditor subsystem and the independent verifier re-checking every transaction receipt                                                                                                                                | 60-event ledger; RESULT: ALL CHECKS PASSED; token #2, block 11,771,581                                             |

## References

- [1] Abdullah Al Mamun, Sami Azam, and Clementine Gritti. Blockchain-based electronic health records management: A comprehensive review and future research direction. *IEEE Access*, 10:5768–5789, 2022.
- [2] J. Andrew, Deva Priya Isravel, K. Martin Sagayam, Bharat Bhushan, Yuichi Sei, and Jennifer Eunice. Blockchain for healthcare systems: Architecture, security challenges, trends and future directions. *Journal of Network and Computer Applications*, 215:103633, 2023.
- [3] Mohammad Salar Arbabi, Chhagan Lal, Narasimha Raghavan Veeraragavan, Dusica Marijan, Jan F. Nygård, and Roman Vitenberg. A survey on blockchain for healthcare: Challenges, benefits, and future directions. *IEEE Communications Surveys & Tutorials*, 25(1):386–424, 2023.
- [4] Haotian Deng, Jinwen Liang, Chuan Zhang, Ximeng Liu, Liehuang Zhu, and Song Guo. FutureDID: A fully decentralized identity system with multi-party verification. *IEEE Transactions on Computers*, 73(8):2051–2065, 2024.
- [5] Andrea Flamini, Giada Sciarretta, Mario Scuro, Amir Sharif, Alessandro Tomasi, and Silvio Ranise. On cryptographic mechanisms for the selective disclosure of verifiable credentials. *Journal of Information Security and Applications*, 83:103789, 2024.
- [6] Abdul Ghafoor, Iraklis Symeonidis, Anna Rydberg, Cecilia Lindahl, and Abdul Qadus Abbasi. Towards empowering stakeholders through decentralized trust and secure livestock data sharing. *Cryptography*, 9(3):52, 2025.
- [7] Pranto Kumar Ghosh, Arindom Chakraborty, Mehedi Hasan, Khalid Rashid, and Abdul Hasib Siddique. Blockchain application in healthcare systems: A review. *Systems*, 11(1):38, 2023.
- [8] Remy Hellstern, Daniel C. Park, Victoria Lemieux, and Guldana Salimjan. Leveraging blockchain-based archival solutions for sensitive documentation: A Xinjiang case study. *Digital Society*, 1(1):4, 2022.
- [9] Ateya Megahed Ibrahim, Hassanat Ramadan Abdel-Aziz, Heba Ali Hamed Mohamed, Donia Elsaid Fathi Zaghmir, Nadia Mohamed Ibrahim Wahba, Ghada A. Hassan, Mostafa Shaban, Mohammad El-Nablaway, Ohoud Naif Aldughmi, and Taghreed Hussien Aboelola. Balancing confidentiality and care coordination: challenges in patient privacy. *BMC Nursing*, 23(1):564, 2024.
- [10] Vitor Jesus and Harshvardhan J. Pandit. Consent receipts for a usable and auditable web of personal data. *IEEE Access*, 10:28545–28563, 2022.
- [11] Rong Jiang, Xue Chen, Yimin Yu, Ying Zhang, and Weiping Ding. Risk and UCON-based access control model for healthcare big data. *Journal of Big Data*, 10(1):104, 2023.

- [12] Katya Kaplow, Max Downey, Darren Stewart, Allan B. Massie, Jennifer D. Motter, Lauren Taylor, John Massarelli, Taylor Matalon, Carolyn Sidoti, Macey L. Levan, et al. Data professionals' attitudes on data privacy, sharing, and consent in healthcare and research. *Digital Health*, 10:20552076241290964, 2024.
- [13] Muhammad Irfan Khalid, Mansoor Ahmed, Markus Helfert, and Jungsuk Kim. Privacy-first paradigm for dynamic consent management systems: empowering data subjects through decentralized data controllers and privacy-preserving techniques. *Electronics*, 12(24):4973, 2023.
- [14] Alexander Kharlamov, Roland Hohmann, and Glenn Parry. Data sharing decisions: perceptions and intentions in healthcare. *Strategic Change*, 32(6):223–237, 2023.
- [15] Behnam Khayer, Siamak Mirzaei, Hooman Alavizadeh, and Ahmad Salehi Shahraki. Blockchain for secure IoT: A review of identity management, access control, and trust mechanisms. *IoT*, 6(4):65, 2025.
- [16] Chalima Dimitra Nassar Kyriakidou, Athanasia Maria Papathanasiou, and George C. Polyzos. Decentralized identity with applications to security and privacy for the internet of things. *Computer Networks and Communications*, 1(2):244–271, 2023.
- [17] Lanlan Li, Charles Z. Liu, Kejia Huang, Ruiyi Deng, Majed Abdullah Alrowaily, Mansoor Alghamdi, Ibrahim S. Alkhazi, and Malek Alrashidi. Trust-aware environmental state consensus for smart agriculture with TEE-enabled sensing and Byzantine-resilient blockchain coordination. *Sensors*, 26(14):4577, 2026.
- [18] Lanlan Li, Charles Z. Liu, and Sanjeeb Shrestha. Analytical entropy approach for measuring blockchain immutability and tamper-resilient trust. *Entropy*, 28(6):690, 2026.
- [19] Richard K. Lomotey, Sandra Kumi, and Ralph Deters. Data trusts as a service: Providing a platform for multi-party data sharing. *International Journal of Information Management Data Insights*, 2(1):100075, 2022.
- [20] Carlo Mazzocca, Abbas Acar, Selcuk Uluagac, Rebecca Montanari, Paolo Bellavista, and Mauro Conti. A survey on decentralized identifiers and verifiable credentials. *IEEE Communications Surveys & Tutorials*, 27:3641–3671, 2025.
- [21] Cindy Welzel, Max Ostermann, Hannah Louise Smith, Timo Minssen, Toralf Kirsten, and Stephen Gilbert. Enabling secure and self determined health data sharing and consent management. *npj Digital Medicine*, 8(1):560, 2025.
- [22] Roy McClelland and Colin M. Harper. Information privacy in healthcare: The vital role of informed consent. *European Journal of Health Law*, 30(4):469–480, 2023.

- [23] Jämes Ménétrey, Christian Göttel, Anum Khurshid, Marcelo Pasin, Pascal Felber, Valerio Schiavoni, and Shahid Raza. Attestation mechanisms for trusted execution environments demystified. In IFIP International Conference on Distributed Applications and Interoperable Systems, pages 95–113. Springer, 2022.
- [24] Minal R. Narkhede, Nilesh I. Wankhede, and Akanksha M. Kamble. Enhancing patient autonomy in data ownership: Privacy models and consent frameworks for healthcare. *Journal of Digital Health*, 4(1):1–23, 2025.
- [25] Aleena Nazir, Mubashir Husain Rehmani, Bernard Butler, and Donna O’Shea. Access control in healthcare IoT: A comprehensive survey. *Engineering Reports*, 8(4):e70766, 2026.
- [26] Thanh Linh Nguyen, Lam Nguyen, Thong Hoang, Dilum Bandara, Qin Wang, Qinghua Lu, Xiwei Xu, Liming Zhu, and Shiping Chen. Blockchain-empowered trustworthy data sharing: Fundamentals, applications, and challenges. *ACM Computing Surveys*, 57(8):1–36, 2025.
- [27] Rohini Poolat Parameswarath, Prosanta Gope, and Biplab Sikdar. User-empowered privacy-preserving authentication protocol for electric vehicle charging based on decentralized identity and verifiable credential. *ACM Transactions on Management Information Systems*, 13(4):1–21, 2022.
- [28] Ahmed M. Tawfik, Ayman Al-Ahwal, Adly S. Tag Eldien, and Hala H. Zayed. Blockchain-based access control and privacy preservation in healthcare: A comprehensive survey. *Cluster Computing*, 28(8):529, 2025.
- [29] Leonidas Theodorakopoulos, Alexandra Theodoropoulou, and Constantinos Halkiopoulos. Enhancing decentralized decision-making with big data and blockchain technology: A comprehensive review. *Applied Sciences*, 14(16):7007, 2024.
- [30] Mohammad Nawab Turan, Irshad Ahmed Hashimzai, and Mohammad Qaseem Qiam. A blockchain-based framework for secure and transparent environmental data sharing in smart cities: Enhancing trust, integrity, and interoperability in urban sustainability systems. *Nata Palemahan: Journal of Environmental Engineering Innovations*, 2(2):70–79, 2025.
- [31] Emily C. Webber, David Brick, James P. Scibilia, Peter Dehnel, Council on Clinical Information Technology, et al. Electronic communication of the health record and information with pediatric patients and their guardians. *Pediatrics*, 144(1):e20191359, 2019.
- [32] Hongjian Yin, Yiming Zhao, Lei Zhang, Baojun Qiao, Wenbo Chen, and Huaqing Wang. Attribute-based searchable encryption with decentralized key management for healthcare data sharing. *Journal of Systems Architecture*, 148:103081, 2024.

- [33] Jie Yin, Yang Xiao, Qian Chen, Xuefeng Liu, Qingqi Pei, Jianying Zhou, et al. DP-DID: A dynamic and proactive decentralized identity system. *IEEE Transactions on Information Forensics and Security*, 20:4999–5014, 2025.
- [34] Matthew J. Page, Joanne E. McKenzie, Patrick M. Bossuyt, Isabelle Boutron, Tammy C. Hoffmann, Cynthia D. Mulrow, et al. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. *BMJ*, 372:n71, 2021.
- [35] A. Abbasi, M. N. Humeidi, and Q. Wang. Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains. *IEEE Access*, 2026. doi:10.1109/ACCESS.2026.3677499
- [36] S. Akter and T. F. Sanam. A Blockchain Framework for Secure Healthcare Data Management Using Role-Based Access Control and Smart Contracts. 2025 International Conference on Electrical, Computer and Communication Engineering (ECCE), 2025. doi:10.1109/ECCE64574.2025.11013162
- [37] F. Albalwy, A. Brass, and A. Davies. A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study. *JMIR Medical Informatics*, 2021. doi:10.2196/27816
- [38] M. Al Amin, A. Altarawneh, and I. Ray. Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach. *Proceedings of the International Conference on Security and Cryptography*, 2023. doi:10.5220/0012090600003555
- [39] G. Bhalerao. Decentralized Cryptographic Governance for Cloud-Based Medical Record Infrastructure: A Distributed Ledger Framework for Cyber-Resilient Healthcare Data Sovereignty. 2026 2nd International Conference on Emerging and Intelligent Technologies and Systems (EITS), 2026. doi:10.1109/EITS70066.2026.11609600
- [40] S. Cao, L. Han, G. Liu, T. Zhang, X. Zhang, and X. Yang. A Privacy Set Intersection Protocol for Medical Data Security Sharing. 2025 IEEE International Conference on Big Data (BigData), 2025. doi:10.1109/BigData66926.2025.11402158
- [41] S. Chockalingam, S. Pirbhulal, and H. Abie. Improving Security and Privacy of Cognitive Digital Twins Through Dynamic Consent for Healthcare and Resilient Societies. *Lecture Notes in Computer Science*, 2026. doi:10.1007/978-3-032-12801-0\_20
- [42] J. A. Dhanraj, P. Dhongle, R. Tamilamuthan, M. Lakshmanan, N. Ashtankar, and S. R. Hole. Blockchain-Augmented Federated Learning for Secure and Healthcare Diagnosis from Distributed Electronic Health Records. 2026 1st International Conference on Emerging Trends in

Advancements and Applications of Computational Intelligence Techniques (ETAAct), 2026. doi:10.1109/ETAAct69135.2026.11541890

[43] K. Ekholm, A. Augustinsson, J. Sundström, C. Johansen, M. Storgärds, L. Ljöstad, et al. Implementing electronic informed consent in rare disease genomics. *Scientific Reports*, 2025. doi:10.1038/s41598-025-32740-1

[44] A. U. Eneh, L. A. C. Ahakonye, J. M. Lee, and D.-S. Kim. Demo: EdgeConsent: On-Chain Attribute-Based Access Control for Data Consent Management. 2026 IEEE International Conference on Blockchain and Cryptocurrency (ICBC), 2026. doi:10.1109/ICBC67748.2026.11575534

[45] J. C. Ferreira, R. Correia, L. Rosário, and A. Vila. Blockchain Integration for Trust and Consent Management in MCP-Enabled FHIR Systems. 2025 IEEE International Conference on Distributed Ledger Technologies (ICDLT), 2025. doi:10.1109/ICDLT66400.2025.11466653

[46] D. Ghosh, A.K. Das, S. Prajapat, and B. Sikdar. Blockchain-Enabled Hybrid Quantum-Safe Attribute-Based Access Control Scheme with Attribute Revocation Strategy for Smart Healthcare System. *Distributed Ledger Technologies: Research and Practice*, 2026. doi:10.1145/3827623

[47] J. Hagström, M. Hägglund, M. Holmroos, P. Lähteenmäki, and I. Hörhammer. Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland. *International Journal of Medical Informatics*, 2024. doi:10.1016/j.ijmedinf.2024.105465

[48] H. Gao, X. Wu, H. Huang, Q. Li, and Y. Xing. A Blockchain-Assisted Revocable and Efficient ABSE Scheme for Secure Medical Data Sharing. *ACM Transactions on the Web*, 20(1):1-29, 2026. doi:10.1145/3771992

[49] V. Jaiman and V. Urovi. A Consent Model for Blockchain-Based Health Data Sharing Platforms. *IEEE Access*, 2020. doi:10.1109/ACCESS.2020.3014565

[50] J. Zhao and Q. Su. A threshold traceable delegation authorization scheme for data sharing in healthcare. *Computers & Security*, 139:103686, 2024. doi:10.1016/j.cose.2023.103686

[51] H. Li, D. Li, G. Lv, N. Crespi, R. Minerva, W. Shao, et al. Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization. *IEEE Internet of Things Journal*, 2026. doi:10.1109/JIOT.2025.3633504

[52] J. Luo, P. Zeng, and X. Wang. Bilateral Privacy-Aware Proxy Re-Encryption With Traceability and Revocation for IoMT. *IEEE Internet of Things Journal*, 2025. doi:10.1109/JIOT.2025.3616987

[53] M. M. Madine, K. Salah, R. Jayaraman, I. Yaqoob, Y. Al-Hammadi, S. Ellahham, et al. Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records. *IEEE Access*, 2020. doi:10.1109/ACCESS.2020.3045048

- [54] V. Maruthi and K. Singh. Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain. *IEEE Transactions on Network and Service Management*, 2025. doi:10.1109/TNSM.2025.3602117
- [55] L. Mei, K. Huang, X. Li, H. Wang, and X. Zhang. Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT. *IEEE Internet of Things Journal*, 2026. doi:10.1109/JIOT.2026.3685269
- [56] M. Zhang, F. Shao, R. Zheng, M. Liu, and Z. Ji. An Efficient Encryption Scheme with Fully Hidden Access Policy for Medical Data. *Electronics*, 2023. doi:10.3390/electronics12132930
- [57] D.P. Panagoulas, A.I. Damian, C. Stamate, V. Toderian, P. Butusina, A. De Franceschi, et al. Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage. *Electronics*, 2026. doi:10.3390/electronics15143046
- [58] S. Phuyal, M. Bhandari, R. Bista, and J. C. Ferreira. Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR↔FHIR Translation. *IEEE Access*, 2026. doi:10.1109/ACCESS.2026.3661642
- [59] S. Phuyal, M. Bhandari, R. Bista, and J.C. Ferreira. A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data. *Blockchain in Healthcare Today*, 2026. doi:10.30953/bhty.v9.491
- [60] M.S. Prashanth, R. Karnati, M.S. Velpuru, and H. Venkateshwara Reddy. Enhancing Health Record Security and Privacy with Blockchain-Based Access Management. *Lecture Notes of the Institute for Computer Sciences, Social-Informatics and Telecommunications Engineering, LNICST*, 2024. doi:10.1007/978-3-031-66044-3\_13
- [61] A. Punia, P. Gulia, N.S. Gill, D. Kaushik, N. Alduaiji, P.K. Shukla, et al. An access control system for cloud-based healthcare systems driven by blockchain. *Journal of Cloud Computing*, 2025. doi:10.1186/s13677-025-00831-z
- [62] J. Qiao, N. Wang, J. Fu, L. Deng, J. Wang, and J. Liu. A Lightweight CP-ABE Scheme for EHR Over Cloud Based on Blockchain and Secure Multi-Party Computation. *Transactions on Emerging Telecommunications Technologies*, 2025. doi:10.1002/ett.70053
- [63] I. Román-Martínez, J. Calvillo-Arbizu, V. J. Mayor-Gallego, G. Madinabeitia-Luque, A. J. Estepa-Alonso, and R. M. Estepa-Alonso. Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing. *IEEE Access*, 2023. doi:10.1109/ACCESS.2023.3242605
- [64] Hema S., Goli Bulli Sai Reddy, and Shalini R. Patient Centric Cryptographic Protection of Cloud Electronic Health Records. 2026 6th



International Conference on Expert Clouds and Applications (ICOECA), 2026. doi:10.1109/ICOECA68095.2026.11485301

[65] N.M. Sawant and J. Gomes. A Decentralized Solution for Smarter and Safer Healthcare Systems with FabricMedChain. Iranian Journal of Science and Technology, Transactions of Electrical Engineering, 2026. doi:10.1007/s40998-025-00994-0

[66] M. Shanmugham and C. Senthilkumar. Blockchain Enabled Self-Sovereign Identity and Consent Framework for Secure Healthcare Data Access. 2026 3rd International Conference on Emerging Trends in Engineering and Medical Sciences (ICETEMS), 2026. doi:10.1109/ICETEMS66917.2026.11469586

[67] S. L. Soohoo, M. S. Keller, Y. Chen, D. Hu, S.-C. Huang, T.-T. Kuo, et al. Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems. JAMIA Open, 2026. doi:10.1093/jamiaopen/ooag111

[68] T. A. V. Y. Ranaweera, H. N. H. Hewage, H. K. D. W. M. C. B. Hapuhinna, K. L. K. T. Preethilal, A. Senarathne, and L. Ruggahakotuwa. Ensuring Electronic Health Record (EHR) Privacy using Zero Knowledge Proofs (ZKP) and Secure Encryption Schemes on Blockchain. 2023 5th International Conference on Advancements in Computing (ICAC), 2023. doi:10.1109/ICAC60630.2023.10417417

[69] K.-L. Tan, C.-H. Chi, and K.-Y. Lam. Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification. Wireless Networks, 2024. doi:10.1007/s11276-022-03114-6

[70] A. Teeda and Y.V. Subba Rao. A Patient-Centric Blockchain Based Electronic Health Records for Data Privacy and Confidentiality. Lecture Notes in Networks and Systems, 2026. doi:10.1007/978-3-032-08246-6\_15

[71] D. Tith, J.-S. Lee, H. Suzuki, W. M. A. B. Wijesundara, N. Taira, T. Obi, et al. Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology. Healthcare Informatics Research, 2020. doi:10.4258/hir.2020.26.4.265

[72] G. Tremper, T. Brenner, M. Ben Amor, T. Kussel, and M. Lablans. Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management. Patterns, 2026. doi:10.1016/j.patter.2025.101432

[73] C.-H. Tseng, Y.-H. Hsieh, H.-Y. Lin, and S.-M. Yuan. EMR-Chain: Decentralized Electronic Medical Record Exchange System. Technologies, 2025. doi:10.3390/technologies13100446

[74] J. Wagner, H. Schneiderheinze, M. Wurlitzer, O. Köckritz, N. Dittberner, M. Bialke, et al. Integration of Trusted Third Party Software into an EDC System for Data Protection-Compliant Identity Management, Consent Management and Pseudonymization in Medical Research Studies.

Studies in Health Technology and Informatics, 2024.  
doi:10.3233/SHTI240840

[75] Y. Wu, C. Liu, L. Sebald, P. Nguyen, and Y. Yesha. Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data. In Proceedings of the International Conference on Deep Learning, Big Data and Blockchain (DBB 2022), Lecture Notes in Networks and Systems, vol. 541, pages 3–14. Springer, 2023. doi:10.1007/978-3-031-16035-6\_1

[76] Z. Wu and D. Zhang. HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID. Computer Standards & Interfaces, 93:103967, 2025. doi:10.1016/j.csi.2024.103967

[77] G. Xu, C. Qi, W. Dong, L. Gong, S. Liu, S. Chen, et al. A Privacy-Preserving Medical Data Sharing Scheme Based on Blockchain. IEEE Journal of Biomedical and Health Informatics, 2023. doi:10.1109/JBHI.2022.3203577

[78] L. Zhang, H. Kan, and H. Huang. Patient-centered cross-enterprise document sharing and dynamic consent framework using consortium blockchain and ciphertext-policy attribute-based encryption. ACM International Conference Proceeding Series, 2022. doi:10.1145/3528416.3530228

[79] S. Phuyal, M. Bhandari, R. Bista, and J.C. Ferreira. HL7 FHIR consent for healthcare data sharing: challenges, opportunities and integrity implications. International Journal of Medical Informatics, 2026. doi:10.1016/j.ijmedinf.2026.106405

[80] S. Phuyal, M. Bhandari, R. Correia Bezerra, R. Bista, and J. C. Ferreira. Dynamic Consent for Secondary Use of Health Data: Challenges and Opportunities Under European Law. JMIR Medical Informatics, 2026. doi:10.2196/93348

[81] J. Vinnakota, T. Raheem, and G. Hossain. Secure AI-Driven eConsent Platforms: Enhancing Trust, Compliance, and Participation in Clinical Research. 2026 IEEE 2nd International Conference on Secure IoT, Assured and Trusted Computing (SATC), 2026. doi:10.1109/SATC69565.2026.11542223